ABSTRACT

Title of dissertation: REGULATE, RECOVER, REPEAT: MULTISTAKEHOLDER CONFLICT ANALYSIS FOR SOFTWARE CYBERSECURITY

Elliot Talbert-Goldstein, Doctor of Philosophy, 2026

Dissertation directed by: Professor Carolyn Seaman
University of Maryland, Baltimore County
Department of Information Systems
Empirical and Applied Software Engineering Lab (EASEL)

A secure cyberspace is required for all private and public enterprises to function properly, and for individuals to contribute to the commercial and democratic interests of society. The field of software engineering plays a critical role in ensuring this security. However, there are major conflicts that inhibit success, and there is a great need for cooperation to improve it. Software engineering professionals and researchers can observe the world around them, and use scientific methods to help create new tools and processes to address the security needs of users, governments, and software producers. However, no prior research investigates the systems of conflict and cooperation that ensure or inhibit software security among intergovernmental, national, subnational, industrial/commercial, and interpersonal actors. The interactions between these members of society govern the security of cyberspace. Research to support successful cooperation requires interdisciplinary study through fields including software engineering, conflict analysis, information systems, political science, cyber security, and management science. I will analyze cases of social

conflicts inherent to engineering software security to construct a novel grounded theory that illustrates the factors that contribute to conflict, the efforts to manage them, and the impacts on stakeholders. Using the results of this empirical analysis, stakeholders will better be able to cooperate and establish frameworks, methods, and tools to support the security needs of nations, enterprises, and people. Software engineering practitioners and researchers will be able to use the resulting theory to solve problems related to national security, corporate commercial interests, and individual human rights.

This research will use qualitative research methods to study existing cases and create a grounded theory of the impacts of conflict and collaboration on software security at a large scale. The goal is to apply this novel theory to identify opportunities to manage conflict, create cooperation, and build capacity for software security with stakeholders, partners, and allies, even when power is asymmetric. As software engineering professionals and researchers, we must be able to interpret and address conflict that could result in negative externalities to users, constituents, teams, companies, governments, and international organizations. Furthermore, we should be able to contribute to cooperation, and the healthy management of conflict, according to our needs and the needs of our stakeholders. For the software security professional, including engineers, regulators, researchers, and leaders, there is actionable knowledge derived from this dissertation that can be put to use to investigate both past and unfolding conflicts.

REGULATE, RECOVER, REPEAT: MULTISTAKEHOLDER CONFLICT ANALYSIS FOR SOFTWARE CYBERSECURITY

by

Elliot Talbert-Goldstein

Dissertation proposal submitted to the Faculty of the Graduate School of the
University of Maryland, Baltimore County in partial fulfillment
of the requirements for the degree of
Doctor of Philosophy
2026

Advisory Committee:
Professor Carolyn Seaman, Chair/Advisor
Professor Anita Komlodi
Professor Brian Polkinghorn
Professor Sreedevi Sampath
Professor Yaxing Yao

© Copyright by
Elliot Talbert-Goldstein
2026

Acknowledgments

I want to thank my wife, Susan, and family, Robin, Bruce, and Benjamin, for preparing me with the skills and knowledge I needed for this project, and the patience to see me through it. I want to thank my advisor, Carolyn Seaman, first for her commitment to generations of people through her admirable work, and second for supporting my effort to contribute something meaningful to our field. I also need to thank the interdisciplinary stakeholders that helped me along the way including friends, teachers and colleagues, especially Udi Sommer, Donald Snyder, Aaron Massey, Julie Gilless, Theresa Mabe, Dennise Cardona, Ted Murphree, as well as Rick Gershberg and the crew of *Momentous*. Thanks also to my committee for taking the time and energy to review and for your input along the way.

Table of Contents

Acknowledgements ii

1 Introduction 1

2 Background 6
- 2.1 Definitions of Conflict & Cooperation . . . 6
  - 2.1.1 Conflict . . . 6
  - 2.1.2 Cooperation . . . 8
- 2.2 Defining Software Security, Cybersecurity, Data Security, & Privacy . . . 10
- 2.3 Establishing Context: Enumerating the Stakeholders . . . 12
  - 2.3.1 Regulators . . . 12
  - 2.3.2 Software Producers . . . 14
  - 2.3.3 Users . . . 15
- 2.4 Existing Models, Methods, & Frameworks for Analysis . . . 16
  - 2.4.1 Conflict Analysis . . . 17
  - 2.4.2 Software Engineering Research . . . 18
  - 2.4.3 Management & Policy . . . 20
  - 2.4.4 Regulatory Compliance . . . 22
  - 2.4.5 International Relations . . . 23
  - 2.4.6 Theoretical Frameworks . . . 25

3 Methodology & Approach 28
- 3.1 Grounded Theory Approach . . . 29
  - 3.1.1 Basic Stage . . . 31
  - 3.1.2 Baseline Model . . . 33
    - Node Details . . . 35
  - 3.1.3 Advanced Stage Theory Development . . . 37
- 3.2 Case Selection . . . 40
- 3.3 Data Collection Protocol . . . 41
  - 3.3.1 Field Research . . . 41
  - 3.3.2 Secondary Data . . . 43

3.4 Threats to Validity . . . 45
3.4.1 Construct Validity . . . 46
3.4.2 Internal Validity . . . 47
3.4.3 External Validity . . . 49
3.4.4 Reliability . . . 50

4 Case Data and Analysis 51
4.1 Illuminate Education . . . 51
4.2 International Committee of the Red Cross . . . 54
4.3 Equifax . . . 57
4.4 CatalanGate . . . 60
4.5 Office of Personnel Management . . . 63

5 Grounded Theory 66
5.1 The Model . . . 67
5.1.1 Final Model . . . 68
5.1.2 Model Components . . . 71
5.2 The Theory: Regulate, Recover, Repeat . . . 77
5.3 Findings . . . 78
5.4 Finding 1: Regulatory Context Drives Compliance After Incidents . . . 79
5.4.1 Context & Environments . . . 79
Threat Environment . . . 80
Regulatory Environment . . . 80
5.4.2 Compliance Behaviors . . . 82
Antecedent Operating Compliance . . . 82
Response Compliance Behaviors . . . 83
5.4.3 Finding . . . 84
5.4.4 Testing the Theory . . . 84
5.5 Finding 2: Regulatory Operations Impact User Outcomes . . . 85
5.5.1 Stronger Regulatory Operational Environments . . . 86
5.5.2 Weaker Regulatory Operational Environment . . . 88
5.5.3 Impacts on User Outcomes . . . 88
Favorable User Remedies & High Regulator Costs . . . 89
Unfavorable Remedies & Low Regulator Costs . . . 89
5.5.4 Finding . . . 90
5.5.5 Testing the Theory . . . 90
5.6 Finding 3: Capacity Does Limit User Response, Remediation, and Recovery 91
5.6.1 Precursor Capacity . . . 91
Responses . . . 92
Finding . . . 92
5.6.2 Testing the Theory . . . 93
5.7 Finding 4: User Responses Impact Costs, but not Necessarily Remedies . . 94

5.7.1 Active Posturing & Compensating Response 94
Outcome Costs and Remedies 94
5.7.2 Note: Passive Posturing & Compensating Response 96
5.7.3 Finding 96
5.7.4 Testing the Theory 97
5.8 Finding 5: Correcting Activities and Their Outcomes 97
5.8.1 Favorable User Remedies 98
5.8.2 Less Favorable User Remedies 99
5.8.3 Transformation as an Outcome 100
5.8.4 Favorable User Remedies 101
5.8.5 Finding 102
5.8.6 Testing the Theory 102
5.9 Finding 6: Regulator Precursors were a Determinant of their Responses and Outcomes 103
5.9.1 Stricter Regimes and Strong Capacity 103
5.9.2 Weak Capacity and Somewhat Active Rulemaking 104
5.9.3 Finding 105
5.9.4 Testing the Theory 105

6 Discussion 106
6.1 RQ1: What are the types of conflicts that occur between stakeholders related to software security? 106
6.2 RQ2: What are the patterns of conflict management between software users, producers, and regulators in achieving software security? 108
6.3 RQ3: How can cooperation between these stakeholders be facilitated? . . . 111
6.4 Relationship to the Literature 114
6.5 Limitations 116
6.5.1 Case Selection 117
6.5.2 Methods 118
6.5.3 On Being WEIRD 121

7 Conclusion 123

A Illuminate Education Case Analysis 125
A.1 Introduction 125
A.2 Context 126
A.2.1 Regulatory Environment 127
A.2.2 Threat Environment 129
A.2.3 Operational Environment 130
A.3 Operations & Precursors 131
A.3.1 Software Producer 132
A.3.2 Regulators 134
A.3.3 Users 135

A.4 Incident & Impact . . . 136
A.5 Responding + Recovering . . . 137
A.5.1 Posturing . . . 138
A.5.2 Compensating . . . 139
A.5.3 Correcting . . . 141
A.5.4 Adhering & Complying . . . 143
A.6 Outcomes . . . 144
A.6.1 Costs . . . 144
A.6.2 Transformations . . . 145
A.6.3 Preservation . . . 146
A.6.4 Remedies . . . 147
A.7 Aftermath . . . 148
A.7.1 Enforcement Gaps . . . 148
A.7.2 New Methods of Cooperation . . . 148
A.7.3 Critical Characteristics . . . 149
A.8 Case Bibliography . . . 149

B ICRC Case Analysis 153
B.1 Introduction . . . 153
B.2 Cyber Social Context . . . 154
B.2.1 Software Producer . . . 154
B.2.2 Users . . . 158
B.2.3 Regulators . . . 160
B.3 Operating . . . 163
B.3.1 Users . . . 163
Deploying . . . 163
Securing . . . 164
Adherence/Compliance . . . 164
B.3.2 Software Producers . . . 164
Implementing . . . 165
Securing . . . 165
Adherence/Compliance . . . 165
B.3.3 Regulators . . . 166
B.4 Precursors . . . 167
B.4.1 Users . . . 168
Knowledge & Experience . . . 168
Business Change . . . 169
Adherence & Compliance . . . 169
Unaddressed Failures & Weaknesses . . . 170
B.4.2 Software Producers . . . 170
Knowledge & Experience . . . 170
Business Change . . . 171

Adherence & Compliance . . . 171
Unaddressed Failures & Weaknesses . . . 172
B.4.3 Regulators . . . 173
Regimes . . . 173
Knowledge/Information Products . . . 173
B.5 Incident/Adverse Event . . . 174
B.5.1 Regulators . . . 175
B.5.2 Users . . . 175
B.5.3 Producers . . . 176
B.6 Impacts . . . 176
B.6.1 Injuries & Harms . . . 176
Users . . . 177
Developers . . . 177
B.6.2 Regulators . . . 178
B.6.3 Observation . . . 178
B.7 Responding & Recovering . . . 178
B.7.1 Adherence & Compliance . . . 178
B.7.2 Posturing . . . 179
B.7.3 Correcting . . . 180
B.7.4 Compensating . . . 181
B.8 Outcomes . . . 181
B.8.1 Costs . . . 181
B.8.2 Transformations . . . 182
B.8.3 Preservation . . . 183
Users . . . 183
Developers . . . 184
Regulators . . . 184
B.9 Aftermath . . . 184
B.10 Case Bibliography . . . 185

C Equifax Case Analysis 188
C.1 Introduction . . . 188
C.2 Cyber Social Context . . . 189
C.2.1 Software Producer . . . 190
Operational Environment . . . 191
Threat Environment . . . 191
Regulatory Environment . . . 192
C.2.2 Users . . . 193
Operational Environment . . . 193
Threat Environment . . . 195
Regulatory Environment . . . 196
C.2.3 Regulators . . . 197

Regulatory Environment . . . 197
Threat Environment . . . 198
Operational Environment . . . 198
C.3 Operating & Precursors . . . 200
C.3.1 Software Producer . . . 200
C.3.2 Users . . . 203
Business Customers . . . 203
Consumer Users . . . 205
C.3.3 Regulators . . . 206
C.4 Incident & Impact . . . 209
C.4.1 Software Producer . . . 210
Incident . . . 210
Impact . . . 211
C.4.2 Users . . . 212
C.4.3 Regulators . . . 213
C.5 Responding & Recovering . . . 213
C.5.1 Software Producer . . . 214
C.5.2 Regulators . . . 216
Posturing . . . 216
Adhering & Complying . . . 219
Correcting . . . 219
Compensating . . . 221
C.5.3 Users . . . 221
C.6 Outcomes . . . 224
C.6.1 Software Producer . . . 224
Costs . . . 224
Transformations . . . 225
Preservation . . . 225
C.6.2 Regulators . . . 225
Remedies . . . 225
Costs . . . 226
Transformations . . . 226
Preservation . . . 227
C.6.3 Users . . . 227
Remedies . . . 227
Costs . . . 228
Transformations . . . 229
Preservation . . . 229
C.7 Aftermath . . . 230
C.8 Case Bibliography . . . 230

D CatalanGate Case Analysis 238

D.1 Introduction . . . 238
D.2 Cyber Social Context . . . 239
D.2.1 Users . . . 240
Operational Environment . . . 240
Regulatory Environment . . . 242
Threat Environment . . . 243
D.2.2 Regulators . . . 244
Regulatory Environment . . . 244
Operational Environment . . . 247
Threat Environment . . . 248
D.2.3 Software Producer . . . 248
Regulatory Environment . . . 248
Operational Environment . . . 249
Threat Environment . . . 249
D.3 Operating & Precursors . . . 250
D.3.1 Users . . . 250
The Surveilled and their Software . . . 251
Precipitating Changes . . . 252
D.3.2 Regulators . . . 253
European Regime . . . 253
The Surveillance Regime: Spanish Authorities . . . 254
D.3.3 Software Producer . . . 255
D.4 Incident & Impacts . . . 256
D.4.1 Users . . . 256
D.4.2 Regulators . . . 257
D.4.3 Software Producer . . . 258
D.5 Responding, Recovering, and Remediating . . . 258
D.5.1 Users . . . 259
D.5.2 Regulators . . . 260
European Regulators . . . 260
Spanish Regulators . . . 262
Other International Regulators . . . 264
D.5.3 Software Producer . . . 264
D.6 Outcomes . . . 265
D.6.1 Users . . . 266
D.6.2 Software Producers . . . 267
D.6.3 Regulators . . . 267
Spanish Regulators . . . 268
European Regulators . . . 268
Other International Regulators . . . 269
D.7 Aftermath . . . 270
D.7.1 Enforcement Gaps . . . 270

D.7.2 New Methods of Cooperation . . . 271
D.7.3 Critical Characteristics . . . 271
D.8 Case Bibliography . . . 272

E OPM Case Analysis 279
E.1 Introduction . . . 279
E.2 Cyber Social Context . . . 281
E.2.1 Software Producer . . . 281
Operational Environment . . . 281
Regulatory Environment . . . 283
Threat Environment . . . 285
E.2.2 Regulators . . . 286
Regulatory Environment . . . 286
Operational Environment . . . 287
Threat Environment . . . 288
E.2.3 Users . . . 288
Regulatory Environment . . . 288
Threat Environment . . . 289
Operational Environment . . . 289
E.3 Operating & Precursors . . . 290
E.3.1 Software Producer . . . 291
Human Resources in the Federal Government . . . 291
Unaddressed Failures and Weaknesses Part 1 . . . 294
Unaddressed Failures and Weaknesses Part 2 . . . 295
Compliance Behaviors . . . 296
E.3.2 Regulators . . . 296
E.3.3 Users . . . 298
E.4 Incident and Impacts . . . 299
E.4.1 The First Breach: 2014 . . . 299
E.4.2 The Second Breach: 2015 . . . 300
E.5 Response, Remediation, and Recovery . . . 301
E.5.1 Software Producer . . . 302
Security Through Procurement . . . 302
Problematic Posturing and Concerning Compliance . . . 303
“Failure to Cooperate” . . . 305
Compensating . . . 306
E.5.2 Regulators . . . 307
Federal Executive & Legislative Regulatory Response . . . 307
Judicial Involvement . . . 309
E.5.3 Users . . . 310
E.6 Outcomes . . . 311
E.6.1 Software Producer . . . 311

E.6.2 Regulators . . . 312
Executive & Legislative . . . 313
Judicial . . . 314
E.6.3 Users . . . 314
E.7 Aftermath . . . 315
E.7.1 . . . 316
E.7.2 Gaps in Enforcement Mechanisms . . . 316
E.7.3 New Methods of Cooperation . . . 316
E.7.4 Critical Characteristics . . . 317
E.8 Case Bibliography . . . 317

F Model Concept Definitions 325
F.1 Definition Format . . . 325
F.2 Cyber Social Context . . . 325
F.2.1 Environments overview . . . 326
Regulatory Environment . . . 326
Threat Environment . . . 326
Operational Environment . . . 326
F.2.2 User Environments . . . 327
Regulatory . . . 327
Threat . . . 327
Operational . . . 328
F.2.3 Software Producer Environments . . . 328
Regulatory . . . 328
Threat . . . 329
Operational . . . 330
F.2.4 Regulator Environments . . . 330
Regulatory . . . 330
Threat . . . 330
Operational . . . 331
F.3 Operating Behaviors . . . 331
F.3.1 User Net Effects . . . 332
Deploying . . . 332
Securing . . . 334
Influence . . . 335
Complying . . . 335
F.3.2 Software Producer Net Effects . . . 336
Implementing . . . 336
Securing . . . 337
Influence . . . 338
Complying . . . 338
F.3.3 Regulator Net Effects . . . 339

Rulemaking . . . 339
Enforcement . . . 340
Influence . . . 341
F.4 Precursor Conditions . . . 341
F.4.1 Users . . . 342
Capacity . . . 342
Business Change . . . 342
Compliance . . . 343
Unaddressed Failures & Weaknesses . . . 343
F.4.2 Software Producers . . . 344
Capacity . . . 344
Business Change . . . 345
Compliance . . . 345
Unaddressed Failures and Weaknesses . . . 346
F.4.3 Regulators . . . 346
Regimes . . . 347
Capacity . . . 347
F.5 Adverse Event/Incident . . . 348
F.5.1 Users . . . 349
Unauthorized Access of Data . . . 349
Injuries & Harms . . . 349
F.5.2 Software Producer . . . 349
Vulnerability Exploited . . . 349
Unauthorized Access to Data . . . 350
Ending the Incident . . . 350
Injuries & Harms . . . 351
F.5.3 Regulators . . . 351
Potentially Associated . . . 351
Observations . . . 352
F.6 Response, Remediation, and Recovery Action-Interactions . . . 352
F.6.1 User Behaviors . . . 353
Posturing . . . 353
Compensating . . . 354
Correcting . . . 354
Complying . . . 355
F.6.2 Software Producer Behaviors . . . 356
Posturing . . . 356
Compensating . . . 357
Correcting . . . 358
Complying . . . 358
F.6.3 Regulator Behaviors . . . 359
Posturing . . . 360

Compensating . . . 360
Correcting/Enforcing . . . 361
Complying . . . 361
F.7 Outcomes/Consequences . . . 362
F.7.1 Users . . . 363
Costs . . . 363
Transformations . . . 364
Remedies . . . 365
Preservation . . . 365
F.7.2 Software Producers . . . 366
Costs . . . 366
Transformations . . . 367
Remedies . . . 368
Preservation . . . 369
F.7.3 Regulators . . . 370
Costs . . . 370
Remedies . . . 371
Transformations . . . 372
Preservation . . . 373
F.7.4 Aftermath . . . 373
Gaps in Enforcement . . . 374
New Methods of Cooperation . . . 374
Perception of Critical Nature . . . 374

G Full Model 375

H Model-Case Matrix 378

I Interview Protocol 379
I.1 Software Data Privacy & Security Security Conflict Semi-Structured Interview Questions . . . 379

Bibliography 382

Chapter 1: Introduction

A secure cyberspace is required for all private and public enterprises to function properly, and for individuals to contribute to the commercial and democratic interests of society. The field of software engineering plays a critical role in ensuring this security. There are major conflicts that inhibit this security, and there is a great need for cooperation to improve it. Software security professionals and researchers can observe the world around them, and use scientific methods to help create new tools and processes to address the security needs of users, governments, and software producers. However, no prior research investigates the systems of conflict and cooperation that ensure or inhibit software security, amongst intergovernmental, national, subnational, industrial/commercial, and interpersonal actors. The interactions between these members of society govern the security of cyberspace. Research to support successful cooperation requires interdisciplinary study through fields including software engineering, conflict analysis, information systems, political science, cyber security, and management science.

The goal of this dissertation is to discover methods to analyze and act on conflict in intergroup situations where software security, data protection, and data privacy are concerned. I will analyze cases of social conflicts inherent to engineering software security to construct a novel grounded theory that illustrates the factors that contribute to conflict, the efforts to manage them, and the impacts on stakeholders. Using the results of this empirical analysis, stakeholders will better be able to cooperate and establish frameworks, methods, and tools to support the security needs of nations, enterprises, and people. Soft-

ware engineering (SWE) practitioners and researchers will be able to use this research to solve problems related to national security, corporate commercial interests, and individual human rights.

In order to reach these goals I will address the following research questions:

RQ1: What are the types of conflicts that occur between stakeholders related to software security?

RQ2: What are the patterns of conflict management between software users, producers, and regulators in achieving software security?

RQ3: How can cooperation between these stakeholders be facilitated?

The progression of these research questions matches the intended progression of the research. By choosing cases that can be coded to develop a theory in RQ1 and RQ2, I can identify the conflicts that end in cooperation and those that do not. By studying the differences between these cases, I will be able to address RQ3 in supporting the facilitation of more cooperative outcomes.

In any field conflict is a given. It is necessary, it is normal, and when addressed appropriately, it is healthy [158]. Unfortunately, conflicts can also be complex, intractable, and even "wicked" [80] leading to harms to individuals and societies [240]. Cooperation is the counterpart to conflict; it is both the ideal end result and a preventative measure. Of course, it is not always easy to leverage conflict and move towards cooperation. Social conflict that arises between stakeholders in cybersecurity, whether with a SWE team, agency, or regulator, can lead to less-secure software that violates rights or fails users. By inadequately involving groups of stakeholders in software development, these failures can contribute to broad conflicts in society.

As a software engineering practitioner and researcher, I intend for this research to be empirical and applied in the interest of data security and privacy practices implemented by

stakeholder groups including users, managers, software producers, firms, and governments. As practitioners, it behooves us to understand our place in the conflict and cooperation that exist between these stakeholder groups, because we never know how they could result in unexpected problems and externalities. As researchers, we can meaningfully contribute to the field to benefit stakeholders by advancing the knowledge and practice of engineering software, including organizational and global conflicts. Empirical research should observe the real world and provide valuable knowledge that can be applied to a domain. It can, however, be difficult to conduct and apply research that covers multiple domains and disparate groups of actors. Nevertheless, the field of conflict analysis does just this, and can be applied in multidisciplinary and interdisciplinary ways. My research will bring together different research areas, with a focus on the cybersecurity domain, in order to advance software security research and practice.

In practice, helping people and teams think through conflict and cooperation can be difficult, no matter the situation or scale. For example, during software projects, conflicts can be categorized as personal, task, and process conflicts, leading to faults, failures, and quality problems [158, 174, 309]. Or, in the broadest possible sense, societal conflicts like "wicked problems," typified by large-scale, complex issues, are difficult to address even by extremely capable, well-resourced organizations [80]. Even when we try interventions to manage conflicts, and create new tools to help solve problems, these can also lead to new issues that then need to be addressed. The immediate task of managing organizational conflict and considering negative externalities can be daunting, but taking into consideration the possible impacts on broader social issues is near impossible. Still, it is important that software engineers, professionals, and firms consider the broad context in which they operate. My goal is to give software professionals practical resources to use to consider how they approach their work with their immediate stakeholders, and with the world at large, to help ensure software security. My work should also provide researchers with empirical

data to contribute to further study of software engineering and security.

This research will use qualitative research methods to study existing cases and create a grounded theory of the impacts of conflict and collaboration on software security at micro and macro scales. The goal is to apply this novel theory to identify opportunities to manage conflict, create cooperation, and build capacity for software security with stakeholders, partners, and allies, even when there is asymmetric power. As software engineering professionals and researchers, we must be able to interpret and address conflict that could result in negative externalities to users, constituents, teams, companies, governments, and international organizations. Furthermore, we should be able to contribute to cooperation, and the healthy management of conflict, according to our needs and the needs of our stakeholders. For the software security professional, including engineers, regulators, researchers, and leaders, there should be actionable knowledge derived from this dissertation.

This research began with an extensive multidisciplinary literature review. Based on this literature, I was able to create a baseline model that was used to initiate the research by establishing the coding scheme. I used this preliminary coding scheme to retrospectively study existing cases by collecting data through field research including interviews with subject matter experts. I also collected secondary data such as software artifacts, legal documents, academic data sets, and journalistic sources. I used grounded theory methodologies to analyze the data, including multiple rounds of coding. The end result is a grounded theory of conflict and cooperation related to engineering software security.

This dissertation includes the Background (Chapter 2) using literature to provide key definitions (Sections 2.1 and 2.2), Establishing Context Across Multiple Levels of Society (2.3), and Existing Models, Methods, and Frameworks from relevant fields (2.4). Next, the Methodology & Approach (Chapter 3) section covers my Grounded Theory Approach, Data Collection, Data Analysis, and Threats to Validity. Overviews of the case analyses are included in Chapter 4, and the full versions are available as appendices. In Chapter 5

I describe the final model, as well as the theory and its major findings. Chapter 6 is the Discussion of my results, followed by my Conclusion.

Chapter 2: Background

The following background will cover the multidisciplinary concepts that will inform this research. This will include broad definitions of key terms, prerequisite concepts for studying broad social conflict in cyber security, and existing models in the relevant fields of study. These concepts helped construct the baseline model discussed in Chapter 3.

2.1 Definitions of Conflict & Cooperation

Foundational to this research are concepts of conflict and cooperation. These concepts, studied empirically, help coalesce the multiple disciplines so that they can be investigated harmoniously. Conflict and cooperation can mean different things in different contexts, so this research will focus on the study of social and intergroup conflict as it pertains to data security and privacy.

2.1.1 Conflict

A conflict exists when at least one party believes that their goals are incompatible with those of another party [53, 112]. Such incompatibility can be real or only perceived. The term social conflict focuses on aggregate groups of people, not individuals, and further restricts the definition to exclude "differences of opinion concerning facts and arguments over the interpretation of objective reality" [240]. The aim of this dissertation is to analyze cases of intergroup conflict regarding software security, data protection, and data privacy.

To meet this goal, I will incorporate aspects of social conflict described in foundational academic work and empirical studies of cyber conflict in software engineering.

When we use the term conflict in the software engineering domain, it invokes a lot of ideas and scenarios, all of which are important. At the lowest level is implementation conflict, for example when computing and information technology requirements are not reconciled with expressions for software design or functionality. This could be manifested and observed formally through testing, requirements documentation, knowledge representation, or from user feedback. At the intra-organizational level, team conflict can arise from task, process, or relationship disagreements [158] due to anything ranging from challenging workloads, to cross-cultural issues on global teams, to pair programming dialectics. Between organizations, enterprises may disagree on protocols and best practices to bring consumer and commercial products to market. Broadening to cyberspace, conflict can arise from crime, hackers, espionage, and warfare, with responses depending on the target and the relative scale of the conflict or attack. At the international level, nations can disagree on issues like technical protocols and legal regulations. For individuals, conflict can be with a software service they use or a government agency meant to protect their digital identity; it can be with another user on the web; it can be with a local business or a multinational conglomerate; individual employees can be in conflict with employers. Users' human rights, such as privacy, can even be compromised when security is not engineered effectively. Conflicts in software security can manifest at any one of these points, affecting any and all stakeholders, so they must be kept in consideration.

In software engineering research, we can critically study conflict in software engineering by investigating power dynamics and systemic or institutional problems that are exacerbated, and even created, through software production. Below are some examples of issues related to software business and engineering that intersect with civil and social issues, and may require critical study for resolution. Gender conflict is an issue in software

engineering, as women and gender minorities may suffer from under-representation and discrimination in the field, sometimes leading to software products that do not adequately serve the needs of people of all genders. Disruptive innovation, where a software producer aims to tear down an existing commercial model, creates conflict with existing enterprises, and can introduce new societal issues. For example, starting with Napster in 1999, companies like Spotify launched in 2006, and Hulu and Netflix in 2007 challenging the media industry's traditional structures to give people more control over their consumption of content. Algorithmic justice is a critical approach to challenging mathematical models that can result in disenfranchisement and alienation of people from individual liberties like property and privacy. In the realm of political conflict, software producers can contribute to, or fail to prevent, manipulation of people during times of political turmoil. These are issues in software development where the conditions leading to conflict are asymmetries of power, and the net result can lead to a lack of security.

Across different levels of society, individuals, enterprises, and governments can be embroiled in cyber conflict, from persistent low-level engagements up to explosive harm to critical infrastructure. Power imbalances between parties at each level can vary widely depending on the dispute at hand. Failure to address those inequities can lead to failures in meeting software security goals.

2.1.2 Cooperation

We can concurrently examine cooperation empirically in software security. Cooperation in software security could be considered to be achieved when the stakeholders believe that their privacy and data security needs are in alignment. At the software implementation stage, conflicts are reconciled between heterogeneous stakeholder requirements, although this can be difficult with market-driven requirements [173]. On teams, managers can man-

age conflicts effectively, which is healthy for team formation, and can lead to positive outcomes [158, 238]. In cyberspace we hope our government and private enterprises can protect us from threats and compensate us when issues arise. Nations, along with regulators and technical-legal experts, can implement best practices to create agreements on software interoperability and data privacy, such as via the World Wide Web and Europe's General Data Protection Regulation (GDPR). For individuals, software services can provide support for their customers, such as transaction dispute resolution, content moderation, or simply incorporating their feedback.

Applying cooperation in critical research approaches to software engineering can be a bit more bleeding edge, and requires creative approaches. Turning to the conflict examples presented in the previous section, one area that should not need to be particularly innovative is gender conflict: balancing the contributions of women and gender minorities in software engineering, and removing bias as an obstacle to their participation is not a new idea, though still needed. Ensuring their, and others', access to software, including usability and data privacy, also has room for improvement [19, 133]. With regard to cooperation and "disruption," it took the media industry some time to adapt to the user preference for quick and easy consumption of music and movies over the internet. While Napster initiated this broad conflict, more recently, major media conglomerates have also launched their own streaming services like Disney+, Paramount+, Peacock (NBC Universal), and others to meet the needs of consumers. Algorithmic justice advocates, like the Algorithmic Justice League, attempt to investigate issues [3] like those highlighted by Cathy O'Neill (author of *Weapons of Math Destruction* [230]) to buck historical racist and discriminatory economic practices to protect consumers. Groups like the Electronic Frontier Foundation (EFF) try to protect privacy in an age of regulatory capture and the overturning of *Roe v. Wade* [235]. Challenging monolithic social media, which can undermine democracy and contribute to abuses [143, 169], requires novel approaches and nuanced understanding of

how such complex firms operate and how threat actors take advantage of their software.

Demonstrating the outcomes of cooperation may be easier than showing the possible spectrum of conflict: it is easier to see that a puzzle is complete than it is to organize the pieces. Like the cover of the puzzle box, it is very helpful to have the end result right in front of you to help guide your decisions. My goal will be to provide a useful structure of applicable conflicts, and demonstrate some measures and examples of success, so that practitioners can apply them.

2.2 Defining Software Security, Cybersecurity, Data Security, & Privacy

Ultimately the scope of this study is narrowed to conflict and cooperation specifically as it relates to software security. This allows us to examine a field of inquiry that is rife with challenges and opportunities that need to be addressed, and begs for established methodologies to help resolve them. Below I will define some of the terms that get most often used in this research. While the definitions can be inductively constructed more thoroughly, the following brief explanations should serve to disambiguate them for the purposes of this research.

The IEEE defines software security as "engineering software so that it continues to function correctly under malicious attack" [200]. IEEE goes on to incorporate longitudinal aspects of "building security in" including security requirements engineering and designing for security. This definition focuses on the software producer as the key actor in ensuring that software is secure to protect its users. For the purposes of this research, this surface-level explanation does not need to include the extensive security principles and practices that exist in the business of software engineering.

Cybersecurity, defined by Stevens in [308] refers to "protecting and defending society and its essential information infrastructures, but also a way of prosecuting national and

international policies through information-technological means." By definition, cybersecurity comprises discord between actors such as users, software developers, threat actors, and even regulators who may have misaligned goals as to how to approach the matter. It is a space that requires constant vigilance to plan and execute collaboration. With this definition of cybersecurity in mind, in this research we can consider cyberspace as the physical and digital domains where conflict and cooperation may occur.

Data security is the practice of protecting data from malicious actions while keeping it exposed to those who have permissions to access it. The focus on confidentiality, integrity, and availability, (known as the CIA triad), is frequently used to describe the core concepts of data security. The CIA triad refers to prevention of unauthorized viewing of data, unauthorized modification of data, and unauthorized changing of permissions of authorized users [249].

Privacy refers to how people manage access to their personal information. Privacy management is "dynamic and multidimensional" which means that as situations and information change, people make different decisions about when and how to share their information [232]. While privacy decisions can be made in a variety of contexts [232, 263], our focus will be on privacy in the presence of software security.

To conclude these definitions, we can say that the focus of this research will be on the conflict and cooperation necessary in the practice of engineering software security, in order to broadly promote cybersecurity, which supports stakeholders' data security and privacy. While these concepts could be constructed with more nuance and depth, they are sufficient to support this research.

2.3 Establishing Context: Enumerating the Stakeholders

In this section, I will outline the context for studying cases of social conflict in cyberspace, specifically the groups of stakeholders pertinent to the cases I will analyze in this work. These groups of stakeholders are rooted in different levels of society, based on typical, comparative differences in power, where governments have the most power, enterprises have substantial power, and users have the least power. While somewhat prescriptive, these levels are not strict, and the interplay between stakeholders at each level, as well as their actual power in the real world, leaves this framework open for interpretation. Certainly, we can think of conflicts where individuals are strong and enterprises are weak, or where enterprises are strong and governments are weak. The following categorization of stakeholders is based on literature to structure my grounded theory study.

2.3.1 Regulators

Controlling the most power in most social conflicts are governments. National governments maintain a "monopoly on the legal use of force," according to Max Weber [306], and can therefore wield it in cyber conflict. International conflict can lead to some of the most detrimental consequences in cyberspace, such as through cyber warfare where human life can be affected [56]. Governments are also tasked with leading the development of policy, laws, regulations, and standards that protect their country's citizens and companies. The data security and privacy efforts of a national government have widespread impacts on the functioning of their society and economy.

Governments are the primary party responsible for laws and regulations that aim to protect society. In Western Democracies, executive, legislative, and judicial bodies all contribute to the way that technology is regulated, based on historical, national, and even international norms, customs, and customary law. Regulations in democracies are often

formulated in the "public interest," although they are not immune from interference [198]. In other countries, regulations may be developed by a centralized authority, like the Communist Party in China (via the National People's Congress [316]) or the monarchy of Saudi Arabia, and enacted through a variety of agencies, public-private companies, and methods of indirect control to achieve national goals. Policies and regulations developed by highly centralized regimes may employ "Paternalist" approaches to benefit the good of individuals, like maintaining social stability, preserving the central authority, and competing on the international stage [226]. Laws and regulations are also defined, depending on the country, by both statutory and case law, making both the development and interpretation often very complex. National leaders may disagree with one another on how technology should be governed, including issues like internet protocols and freedom of expression online. These disagreements manifest themselves as disputes and impact the operations and security of people, companies, and the governments themselves [43, 226].

Governments are also home to some very cooperative approaches to managing data privacy and security. Standards development organizations (SDOs), as well as nongovernmental industry regulators, bring together government officials, and industry experts, in venues for cooperation that have been incredibly successful. Examples include organizations like the International Telecommunication Union (ITU) which is a global governance body that predates the UN; the International Organization for Standardization (ISO) which brings together national standards organizations; and the UN Internet Governance Forum (IGF) [43, 140].

Critical infrastructure is also governed by national, regional, and local governments. Studies of cyber warfare and espionage highlight critical infrastructure as a serious threat surface that needs to be protected. These cyber and physical systems, if compromised, would have a "debilitating impact on ... physical or economic security or public health or safety" [219]. While critical infrastructure may be heavily reliant on enterprises, discussed

below, the responsibility for success and failure still lies with government agencies.

2.3.2 Software Producers

Software producers, including commercial, government, and nongovernmental organizations that create and use software, possess substantial power that can have drastic impacts on countries and individuals. It should be noted that some private companies can rival governments in their power, both economically and in force. Prominent monolithic software producers like Meta, Apple, Netflix, Alphabet, and Amazon, have the economic and human resources to challenge and influence governments for their own benefit. Companies in other industries, particularly extraction, like mining and petroleum, also utilize physical security resources to fight against violent combatants.

Enterprises are responsible for much of software production, delivering products for consumers, businesses, and government agencies. Enterprise software offers a wide threat surface for potential cyber attacks. Cyber crime often targets vulnerabilities in commercial software. Cyber warfighting also exploits these vulnerabilities to achieve military objectives.

Software-producing companies are not limited to just large software corporations, they also include non-governmental organizations (NGOs) like charities, universities, community groups, and hospitals, as well as international organizations like the Red Cross and UNHCR. They can also include government agencies that implement and deploy software for individual constituents and other government agencies. These organizations often handle very sensitive information and make use of commercially available software as well as tailor-made solutions.

Companies that create software must deal with normal organizational conflict, such as the issues defined by Jehn: task, process, and relationship [158]. Workers, namely software

engineers, may dispute with each other regarding tasks that must be completed, processes that enable their tasks (or other organizational behavior), and relationships with other colleagues. These conflicts can be healthy, but can also lead to unfavorable performance and unintended consequences.

Software producers must also comply with laws and regulations established by governments with jurisdiction over them. Those requirements can vary between national and local governments, by industry, by enforcement mechanisms, and are subject to change. This, along with other factors, make regulations difficult for a company to interpret [231].

2.3.3 Users

Users are the everyday people that interact with software. This could mean a non-paying customer, a business client, or an administrator. You and me. While our experience with software may be easy to share in conversation, the empirical study of our interactions is significantly more complex. Behavioral economics, cybersecurity pedagogy, human-centered computing, social psychology, and public health are all fields that endeavor to study how individuals interact with software security and data privacy. There are mixed results.

Users of software broadly understand the need to be concerned with data security and privacy [28]. However, the level of concern may vary, from wholly unconcerned to abject disquietude. Data collected about users that incorporate the most risk include education, health, and financial information. In the US, these data are regulated. In Europe, even more data collection and data processing practices are regulated [99]. Privacy is even enshrined as a human right [43]. Nevertheless, concerns and interests for privacy can vary between cultures, and may require different approaches depending on a user's cultural background [32]. In addition to cultural differences in perception of privacy, users' abilities to protect

their privacy and data vary by jurisdiction [43]. Moreover, data collected and processed by companies are subject to complex policies that users struggle to understand [17, 28, 43]. These complexities make it difficult for everyday people to protect their privacy and personal data.

From a power perspective, individual users are the weakest compared to enterprises and governments. Nevertheless, we still have influence. Users can contribute to software development by sending feedback to software producers. Individuals can similarly submit feedback to regulatory policy development through their elected officials and systems like Regulations.gov in the US, and Data Protection Authorities in Europe. In some cases, individual citizens can file suits against enterprises and organizations, although there are frequent legal obstacles. Organized groups of users also have impact on the development and governance of software. Advocacy organizations like the Access Now, Electronic Frontier Foundation (EFF), Future of Privacy Forum (FPF), and International Association of Privacy Professionals (IAPP), all represent the interests of users in a variety of issues related to software production.

2.4 Existing Models, Methods, & Frameworks for Analysis

My focus will be on categorizing actors, their conflicts, their cooperation, and outcomes for applied use by practitioners and academics with concerns in software security. In order to approach this, it is helpful to review existing models and structures that can help frame these concepts. Software security and software engineering ground my research, and in fields orthogonal to these, there are some methodological tools that may be useful. I have used, and will continue to use, grounded theory (GT) methods, which have been applied repeatedly in this field [141, 264] to bring together multiple fields of inquiry. For example, Straussian GT supplies the "conditional/consequential matrix" to explain both the context

surrounding the topic of study, and the conditions that give rise to the phenomenon being studied [167, 265]. The models, methods, and frameworks below come from multiple domains in order to create new tools for studying the real world. They help frame and construct the context for interdisciplinary study of conflict and cooperation in software security.

2.4.1 Conflict Analysis

Multidisciplinary conflict analysis tools can help provide insight into actors, behaviors, beliefs, underlying issues, interests, goals, etc that foment conflict. These models and frameworks have been applied in various situations, from interpersonal to international issues, and can be adapted for managing social conflict in software security. Practical models for analysis include timelines, stages of conflict, conflict mapping, and force-field analysis. These tools can help inform strategies to address conflict, influence policy, intervene directly, and address consequences, as well as evaluate the outcomes of the efforts [112].

Early work, like Coser's *The Functions of Social Conflict* helps ground the study of conflict in theoretical social science methods through a multi-part model that describes, at-scale, the characteristics and impacts of social conflict. This model includes broad categories of conflict and group boundaries, hostility and tensions in conflict relationships, conflict with in-groups, and conflict with out-groups [68]. Later work continues to develop, implement, and evaluate tools for conflict analysis and peacebuilding that can be applied at interpersonal, intergroup, and international levels of society [112]. Applied and scholarly work is conducted in nearly every industry and area of society, including all types of dispute resolution methods.

Pruitt and Kim synthesize studies of structural and systemic conflicts and show that they can arise from three levels, the issues themselves, the relationship between parties,

and broader social and structural systems. They also show that these social conflicts can have positive and negative outcomes. Positive outcomes include changes to unjust policies, discouragement of poorly formulated premature decisions, and the reconciliation of legitimate interests between parties. As discussed elsewhere in [68] and [158], conflict can also help with group solidarity and cohesion, when groups overcome issues within the group, and when they organize against competing groups. Negative outcomes of conflict can include physical and psychological harm, long-lasting trauma, and harmful effects on society [240].

Conflict analysis methodologies can be applied at the interpersonal, intergroup, organizational or intra-group, and international levels. They provide theoretical and practical tools to understand a variety of conflicts and bear application in the study of software security in order to improve outcomes for stakeholders.

2.4.2 Software Engineering Research

There are multiple approaches in the software engineering domain that could be applied to model conflict and cooperation in software security. For example, approaches to engineering security in the software development life cycle (SDLC) have grown as the need for software has grown. A systematic mapping study of 118 studies revealed six categories of 54 approaches to incorporating security across the SDLC [209]. In empirical research, ranking from most formal to least formal, models often take the form of ontologies, taxonomies, categorizations, and frameworks. These representations can be used to model the real world for computation and for requirements engineering. For example, a systematic literature review of models of legal requirements includes approaches like logic, knowledge representation, access control, and goal modeling [231]. These models can help software engineers identify conflicts between software capabilities and legal restrictions.

Software and its use is getting increasingly complex, as different applications often need to be interoperable with each other, including in personal and business settings. One concept for describing this interoperability, and its impact on quality and security, is the "value chain" which can help identify the risks of integrating multiple pieces of software together in creating a final product [39, 267]. Another concept is the "software ecosystem" which describes the interconnections of disparate software and how new software can be added by a single software producer or a third party, revealing security threats, among other things [134, 191, 267]. Studies of software ecosystems can help reveal issues that can lead to insecurity. Still a third concept for studying threats that arise from interoperability is the "software bill of materials" which is a "machine-readable inventory of software components and dependencies" and is used in software development in industries like healthcare, automotive, and energy [269].

To incorporate users in models, we need to look both at how they are viewed, and how they view software and cyberspace. Users can be viewed as consumers or citizens, groups or individuals, and sometimes as stakeholders [268]. Users might view software as "major technology companies" that can be regulated [299], necessary services, or disruptors that can improve their lives. Users' ability to consciously contribute to software engineering is limited [268]. Usable Security & Privacy (USP) and Privacy-by-Design (PBD) are some of the more prominent ways that users are incorporated as stakeholders in software security decision-making. USP presumes that security cannot be effective if all users cannot use software securely, whether they are administrators or non-technical [119]. PBD, introduced by Canadian data privacy official Ann Cavoukian, posits that "privacy cannot be assured solely by compliance with regulatory frameworks; rather, privacy assurance must ideally become an organization's default mode of operation" [47]. Complementary frameworks for modeling privacy threats include LINDDUN [82] and Privacy Impact Assessments [215]. All of these frameworks provide systematic tools for software producers to cooperate on

data privacy and security needs when developing software.

Software engineering research in which regulators, software producers, and users appear together is not common, so it is important to bring together concepts from a variety of research areas within the field. These studies help introduce some of the concepts that will be helpful in empirically studying the conflicts that occur between the disparate stakeholders responsible for, and that benefit from, software security.

2.4.3 Management & Policy

Managerial frameworks and models of conflict within software firms abound. From Agile to eXtreme programming, waterfall to Continuous Delivery, approaches to developing software are popular even outside of the field, including design thinking and "lower case 'a' agile." Within these business models are inter- and intra-organizational, as well as interpersonal, approaches to conflict management to help software teams overcome obstacles and meet goals [158, 174, 309]. Research combining these software development methodologies with software security needs is more limited. The field of requirements engineering offers models for managing conflict as it covers the end-to-end needs of eliciting requirements, operationalizing tasks, assigning responsibility, and verifying the results [297]. One model for fulfilling the requirements of set goals focuses on negotiation [243]. The elicitation, traceability, and verification of security requirements may necessitate complex technical-legal expertise, and tools exist to support the cooperation between engineers and legal teams.

For technical-legal practitioners, various structures can be used to create and interpret the law and have varying degrees of influence in the development of software. Solove's taxonomy offers an exhaustive structure that includes all the legal considerations for implementing privacy in software [263]. The Fair Information Processing Standards (FIPS)

are a major set of guidelines that have driven legislation and regulations. Originating with the OECD in the 1970s, "FIPs are a set of internationally recognized practices for addressing the privacy of information about individuals" [124]. Recent consanguineal regulations, like the GDPR, attempt to impose the practices set forth in FIPS on software producers. The development of FIPS led to later organizational assessment frameworks like ISO 27002 and NIST Special Publication 800 series. These frameworks can help enterprises measure their information security practices and make improvements. They can also be required practices for software that handles protected data for governments, healthcare, financial institutions, and more.

A model of "maturity" can help determine where a cyber program is succeeding and where it has room for improvement. The Cybersecurity Capacity Maturity Model for Nations (CMM) developed at the Oxford Martin School provides a "methodical framework designed to review a country's cybersecurity capacity" [2]. This nation-level approach covers many of the dimensions crucial to providing data privacy and security. It can be applied to national programs for evaluation and planning to evaluate and improve cybersecurity strategy and inform operations. By homing in on "maturity" across dozens of factors, government officials can set strategy and goals in cybersecurity. Further research from the Global Security Cyber Capacity Centre, which created the CMM, also reviews other related models [71].

Internet governance is an international arena of public policy that has widespread impacts on technology and society. Brown and Marsden break down internet governance and regulation into three competing approaches and two justifications to achieve economic, societal, and human rights benefits. They identify market-led self-regulation, state-led regulation, and multi-stakeholder coregulation as divergent approaches. These approaches are justified in two different ways, "those based on human rights ... and those based on economic efficiency" [43]. O'hara and Hall identify the public and private actors that actually

compete for how to govern the internet, particularly in the United States, European Union, Russia, and China [226].

Studies of the multistakeholder approaches to policy development incorporate the contributions of international organizations as well as nations to technical regulations [43, 132, 140, 226, 308]. Richard Hill, a practitioner and researcher, maps the governance bodies of the internet through a practical multi-stakeholder model. Agencies like the ITU, W3C, ICANN, and others often have overlapping or conflicting purposes that can be difficult to understand, and they issue requirements and recommendations that can be very complex [140]. Software producers, increasingly operating in the cloud, must incorporate global regulations, protocols, and practices into their work. Practitioners often also contribute to the development of those recommendations and standards, both as independent contributors and through their employers [246]. One global effort is the UN Secretary-General's Roadmap on Digital Cooperation, which is a set of recommendations for the international community regarding things like digital trust and security and improving "digital cooperation" [132].

Applied studies like those above, which describe or model the real world of public policy, can help software engineers understand the arcane international and national landscape of governance, and where their efforts are best used when trying to meet requirements from disparate stakeholders.

2.4.4 Regulatory Compliance

There is practicable research on software security compliance to structure both theoretical and applied analysis of cyber conflicts. Analysis of existing laws and policy recommendations provide important tools for analyzing breaches, including their precursors, impacts, and aftermaths with regard to all stakeholders.

Lauber and Böhme outline the characteristics of disclosure laws, specifically the types of reports, whom they are meant to address, the objectives of the laws, and their cost effects [180]. The characteristics include distinctions between the types of breaches that need to be disclosed: security and privacy. Additionally, the subjects of the disclosure distinguish between authorities and affected individuals. They also draw on a principal-agent theory of compliance, where the government acts as a principal to incentivize the software company as an agent.

Approaches to notification about data breaches are included in [253], which describes three existing models of informing about data security leaks and proposes a fourth model. These models take into account not only the laws that are in place, but also the role of the consumer in coordinating responses to data breaches. The three existing models describe the different types of notice that the breached company needs to address, based on the law. In each model, the software producer may be required to disclose the type of breach that occurred to affected users, and may need to share with third parties as well.

2.4.5 International Relations

The field of international relations (IR) has established methods and empirical studies that contribute to software security research. Foundational IR research methodologies like Foucault's "*dispositif*" and "genealogy" provide a valuable balance of formal and informal concepts to create practicable methodologies for empirical research [308]. Genealogy, introduced by Nietzsche and extended by Foucault, provides theoretical grounding for case study research [301], similar to the use of taxonomies and categorizations. Whiting constructs an IR interpretation of cybersecurity using the concept of *dispositif*, specifically investigating the impact of knowledge and power by governments and corporations on various types of cyber conflicts [308].

One applied IR model of cyberspace is Joseph Nye's "regime complex." Nye defines a regime as a set of norms and institutions, for example, internet technical standards, global intellectual property governance, and the alliances within the intelligence community. The regime complex expands on these arrangements, in cyberspace specifically, via their relationship with one another, and the model stresses the "importance of linkages of cyber to normative and regime structures" [214]. This is valuable to IR and cyber strategy, but has limited expressions in software engineering.

In the IR book *The Fifth Domain*, Richard Clark and Rob Knake discuss the roles of different levels of actors in securing cyberspace, although they do not put forth a formal model. They argue that it cannot be solely the role of the government to govern and protect cyberspace as it does land, sea, and air. Instead, different levels of actors must be included, including industry and individuals. However, this requires a degree of collaboration that has not been reached. They call for renewed thinking about "how the government should be interacting with the private sector to further erode the offense's remaining advantages" [56, p. 112]. Lucas Kello contributes a framework of cyber conflict in the international arena, defining disruptive forces that lead to technological revolution at a grand scale, including a re-ordering of the international order. The severity of these forces ranges from the introduction of new technology that changes national decisions, up to a "systems change" which can "challenge the traditional supremacy of states" [166].

In conflict analysis and international development, practical models are used to plan and evaluate aid, development, and capacity-building projects. The Logical Framework, or logframe, is the standard matrix used by the US Agency for International Development (USAID) for their programs [6]. This practical tool helps government agencies and non-governmental organizations structure their goals and actions in order to ensure the best outcomes for the beneficiaries of their programs, and measure success. Tools like this can help provide real-world examples of how conflict management plans are created and imple-

mented by both public and private actors. Similar tools are employed when using software in conflict and disaster zones [152].

Studies of and practical tools in international relations are important to studying cyber conflict due to the international nature of the field. Security threats and actors are not limited by geographical boundaries, and it is important to connect stakeholders across the globe in order to get a complete picture of opportunities for conflict and collaboration.

2.4.6 Theoretical Frameworks

A handful of theoretical frameworks can help with analysis across these different disciplines, incorporating the potential actors in a cyber conflict, and the interactions between them. A review of theoretical and empirical findings regarding data privacy issues covers a wide swathe of options [194] that are backed up by other studies. These concepts, including theories of justice, social contracts, and social exchange may be necessary to explain the dynamics of implementing software security. Frameworks from other fields like environmental policy, public health, and intersectionality can also support deeper investigation of the disparate aspects of software security conflicts.

Justice Theory offers two dimensions to investigate how parties perceive conflict and cooperation proceedings, procedural and distributive. Procedural justice means that the parties are satisfied with the dispute resolution process, regardless of the outcome. While they may not have received what they wanted, they perceive the process as fair. Distributive justice means that the parties are satisfied with the outcome, regardless of the process. When parties attempt to overcome a conflict, these theories of justice can help evaluate whether the parties will be able to move forward with cooperation [27, 194].

One framework posits that parties will evaluate their approach to managing the conflict based on various priorities, including their interests, rights, and power. Conflict manage-

ment based on interests is likely to bring parties together to solve problems mutually, and requires the least amount of resources. Rights-based approaches incorporate contracts, laws, and courts. Using power to resolve conflict involves coercion and pressure so that one party gets what they want. Rights- and power-based efforts require more resources to resolve and result in less satisfactory outcomes for the other parties [279]. The specifics of how these approaches are used vary by case, and negotiations often "cycle through" these strategies [187].

Social contract theory has been employed to study norms and expectations between organizations and consumers [194], as well as between corporations, citizens, and governments [37]. The concept has also been touted by Chris Inglis, the first National Cyber Director in the United States, a role that reports to the President. Inglis argues that a "new social contract for the digital age" will help support cooperation in cyberspace [151].

Social exchange theory explains the relationship of parties and their transactions, for example between marketers and consumers [194, 207]. In terms of data privacy, it explains what customers may be willing to give up in a transaction, for example money or their personal information. This has important implications for services that are offered for free to the customer, but where the company uses the customer's data to make a profit.

A theoretical framework that empirically contributes to the context of cybersecurity at the macro and micro level is the study of "cybersecurity capacity." Cybersecurity capacity refers to "individual's, organization's, or nation's resilience to security threats." In [83] Dutton et al study the importance of a country's wealth and size in relation to the scale and centrality of internet use, along with indicators of cybersecurity capacity to understand end user cybersecurity problems. This model incorporates quantitative measures of "managerial, technical, social, legal, policy, and regulatory initiatives" from multiple countries to determine the benefits of national cybersecurity capacity to protect end users from crime, terrorism, and warfare in the cyber domain [83].

Borrowing from environmental policy is the theoretical framework of "policy choice" which incorporates institutions, problems, and discourse as inputs for actors and their decisions, which results in a policy instrument to make a change [38]. This approach to understanding how regulations are created includes the concept of "distributional conflict" which explains why some groups may be opposed to particular policy changes based on their interests. Distributional conflict in software security might occur when e.g. software producers do not want to incur the costs of adding security to their products, users do not want to expend resources learning how to protect themselves, or regulators avoid contributing resources to enforcement.

The study of intersectionality provides a theoretical framework to help incorporate diverse populations that need to be included in public decision-making. In public health, using intersectionality, as well as critical race, feminist, and gender theories can benefit historically oppressed and marginalized populations [40]. Public health offers approaches to improving cybersecurity [258]. Additionally, the unique data privacy and security needs of marginalized groups have been distinguished from other populations [3, 133]. It is crucial to bring in the perspectives and needs of all populations, including "racial/ethnic minorities, LGBT people, low-income people, and those with disabilities" [40] to tackle cybersecurity problems.

Multiple theoretical frameworks may be necessary to describe different aspects of a case being studied [51, 265]. The theoretical frameworks described above informed my grounded theory research throughout the process, and there were others that I identified later as well. This short list covers some theories that were applicable in this multidisciplinary study.

Chapter 3: Methodology & Approach

This dissertation uses grounded theory and case study methods to investigate the characteristics of software security that are directly connected to social conflict and cooperation, in order to create theories that can be applied in the field and assist further research. I have taken the broad context of social conflict in software security and narrowed it down to data privacy and security disputes. According to Strauss and Corbin, "the distinction between micro and macro often made by researchers is an artificial one" [265, p. 162]. At scale, multiple disciplines like those described in Chapter 2, including software engineering, international relations, conflict management, and cybersecurity, can all contribute to software engineering practice and research, and they are necessary to answer the most complicated questions whether micro or macro. My research will address questions that need to be answered concurrently; engineers, users, regulators, and their organizations should be able to understand each other despite friction or anxiety.

This dissertation will develop a grounded theory on social conflicts that occur when software is put into practice in order to promote data privacy and security in cyberspace. It will contribute to software security by helping three critical stakeholder groups work together to mitigate unauthorized and inappropriate use of data through meaningful, practicable ideas.

3.1 Grounded Theory Approach

Grounded theory (GT) has been demonstrated as an effective research methodology in information systems and software engineering research [141, 195, 256]. GT is associated strongly with qualitative research and is frequently applied to case studies as the unit of analysis [51, 141, 195, 256, 265]. Its use in information systems research is considered to be "more advanced than in other fields" [195], and has yielded thorough and practicable guidance such as through Socio-Technical Grounded Theory (STGT) proposed by Rashina Hoda [141, 256].

Initially, I considered several different approaches to GT, such as Glaserian or constructivist, where rigidity is less necessary [167, 264]. However, given the interaction of heterogeneous disciplines necessary to conduct this research, it is helpful to have a more formalized guide to follow. Ultimately, the GT methodology, and the Straussian approach specifically, helps support my desired empirical and applied outcomes. Furthermore, many aspects of my approach, including using existing tools and structures, were also described by STGT [141].

While I did not specifically employ STGT, its description of grounded theory methods, including traditional approaches, provides a useful guide to evaluate both my methods and results. Based on Hoda's guidelines, my dissertation clearly demonstrates much of the "mature outcomes" described by STGT. Hoda's STGT also helps delineate a number of the factors most concerning to a novice doctoral research student, and disambiguates many of the concepts that are easily confused when using GT. For example, she details the "sweet spot" where GT is "most likely to succeed and indeed where it makes most sense to use," including human and social aspects focus; theory development; practice-based topics; complex and deep questions; primarily qualitative studies; and data collected through interviews and observations [141]. My methods, data, and results exemplify these charac-

teristics, supporting the validity of my research, and demonstrating why GT was an optimal approach.

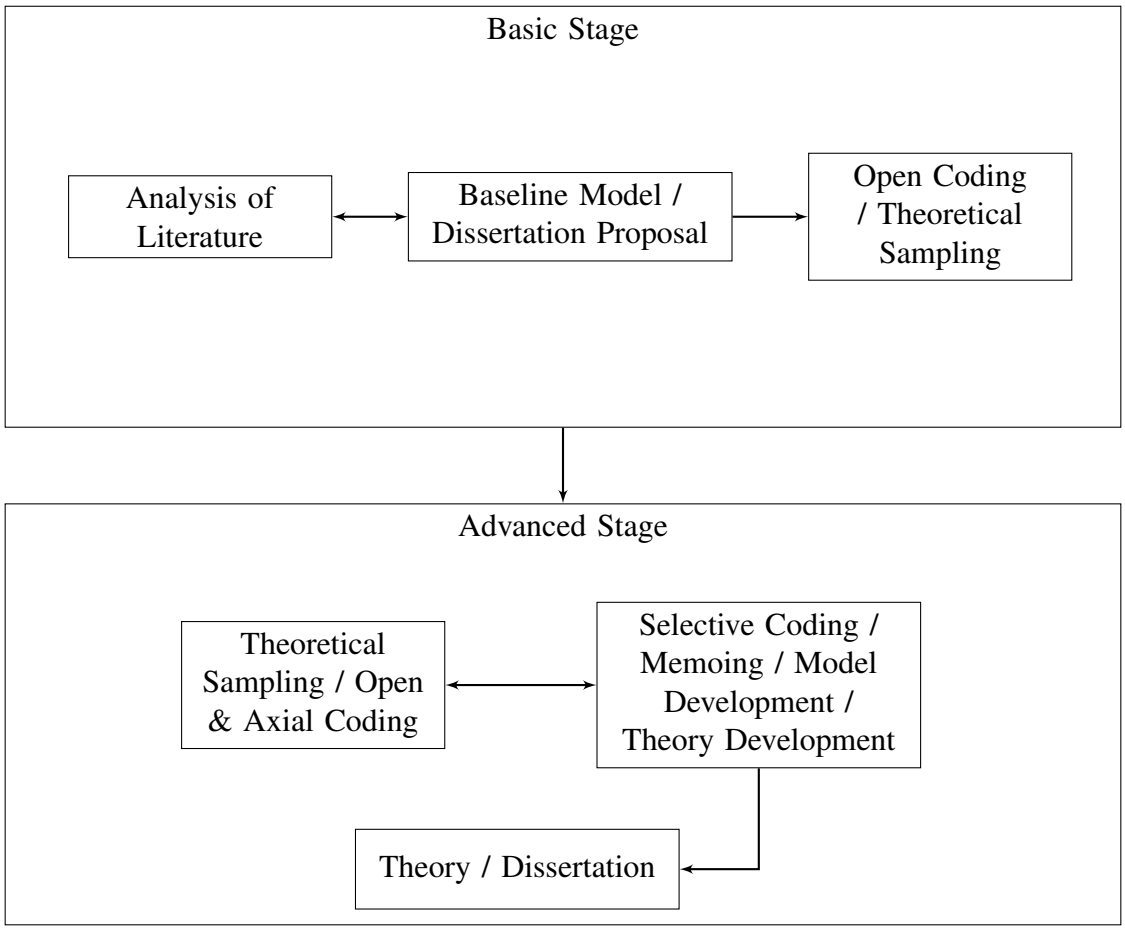

Figure 3.1: Method Steps Flowchart

The STGT method includes two key stages, with steps, procedures, and options for theory development, and progressively emerging outcomes of the theory [141]. In this section I will describe my methods as they align with this approach, as well as with GT more generally (also see Figure 3.1). The first stage is called the Basic Stage, and includes the standard GT steps of literature review, pilot data collection, and open coding. This stage resulted in the initial protocols for data selection, the baseline model, theoretical sampling and rounds of coding for the first few cases, and finally my dissertation proposal. During

the open coding phases of the first two or three cases, there were many new codes emerging. However, as each case was coded the coding scheme became more stable. The second stage is the Advanced Stage Theory Development, which included ongoing theoretical sampling, axial coding, selective or targeted coding, and reporting the theory. While I open coded each case, by the fourth case I was able to move quickly to axial and selective coding based on the maturing coding scheme, and rely on the model that was emerging from it. In the fifth and final case, I necessarily avoided changing the coding scheme, working directly from the existing model to analyze the case and confirm the effectiveness of the model and theory.

By relying on GT, it is straightforward, both ontologically and epistemologically, to identify modes of conflict and cooperation in software security at the micro and macro levels. The objective is not to create a litany of all possible conflicts and cooperation that can occur in this area. My goal is to create a theory that can be helpful for software engineering researchers, and could provide useful resources for software producers, and their user and regulatory counterparts as well.

3.1.1 Basic Stage

My initial steps included a literature review and background (Chapter 2), which demonstrated a gap in existing theory where I would conduct my research. My review of the literature covers sources and evidence that cut across the field of software security and can help support my novel research. Additionally, my analysis of these sources at this stage helped formulate the initial concepts to create my baseline model. The basic stage also includes the early rounds of theoretical sampling to select the first two-three cases, and the initial open coding of each new case.

Early on, I followed the initial phases of Straussian GT with some success, relying on

its procedural steps. I heavily relied on common approaches from the start of my research, including employing an abbreviated version of the so-called 6-C's to support coding: context, conditions, action-interaction (also called causes), and consequences [141, 265]. This methodology was particularly valuable when combining micro and macro issues, such as through the Conditional/Consequential Matrix [167, 265] for analyzing case studies.

Through the Straussian approach to developing the GT, I focused on "maximizing the similarities within and between concepts" [265, p. 141,155-6]. I started by connecting concepts through an introductory interdisciplinary investigation of the literature (see Chapter 2) that incorporates the most relevant fields of inquiry, including politics, software engineering, cybersecurity, organizational management, and conflict analysis. I also introduced my baseline model (see the next Section 3.1.2) based on the literature and background sources for studying the context of cases of social conflict that involve regulators, software producers, and users. This structured approach helped bound cases and ensure that they meet the research goals.

After defending my proposal, the next phase of the research was to select an initial set of cases and conduct open coding. The GT fundamentals provided a "collection approach" that helped structure the initial codes I used. For example, the pilot case I chose, Illuminate Education, incorporated the context and conditions I identified: a social conflict that concerns issues in data privacy & security, and includes software engineers, users, and regulators. In this case and the next, I analyzed the conflict and attempted to evaluate it using applicable theoretical frameworks. I evaluated the outcome based on how the stakeholders perceived it, and how it may have had an impact on the broader context. I was able to use descriptive and in vivo coding at this early stage to begin my analysis [51, 205].

My earliest steps in the basic stage, such as my interdisciplinary literature review and open coding, substantively supported my fieldwork later on. For example, the conditions for the conflict I described initially require a triad of actors (Figure 3.2), but those are simple

categories, and further coding was successful in identifying stakeholder-specific conditions in the first case analysis. Also, in the conflict management action-interaction following a breach, I observed a multitude of approaches, which I was later able to code for patterns. This resulted in an early iteration of the baseline model into a content-analytic summary table that included data from multiple cases [205]. In subsequent case analyses I occasionally returned to the earlier codes for fine tuning. Additionally, I used rigorous methods for data collection, discussed in Section 3.3, particularly when relying on secondary sources and extant literature to ensure it was credible [141, 195].

Based on this basic phase of analysis, I developed the initial model and codes for exploration, leading to the advanced stage later on.

3.1.2 Baseline Model

Based on the literature review and background, I created an initial model to frame and bound my pilot case analysis, and prepare for analysis of further real-world case studies. This model structured both the overarching context and narrowed issues for my inquiry. Based on my experience and research on asymmetric conflicts and software engineering, I was able to establish this model for early-stage case analysis to undergird the later phases of research to produce empirical results. Those results will contribute to the ability of stakeholders to navigate interactions between and among different levels of society. This model incorporates a broad understanding of social conflicts (the context), a narrower view of instances of disputes (the conditions), the approach to managing the conflict (action-interaction), the outcomes of the dispute (consequences), and the resulting impact those outcomes may have on the original context.

The initial model consisted of five nodes (Figure 3.2). The nodes were based on a GT coding family that includes the context, conditions, actions, and consequences of a sys-

tem being studied [265]. The first node introduces the main area of investigation for the research, representing the overarching context of possible cases that could be used in this study, and acts as a start/finish line. This context node represents the space of possible social conflict in the field of software security. The context comprises conflicts that exist between software producers, regulators, and users in trying to achieve data privacy and security goals. This abstract, global node is instantiated, through a conflict action such as a data breach, into the condition node. The condition node comprises the specific and necessary actors that are party to the conflict being analyzed and are engaged in a practical dispute: actual users, software-producing companies/organizations, and government regulatory bodies/agencies ,as well as an incident. The parties that provide the conditions for their conflict in the second node give way to the third node, an action-interaction event. The parties analyze the conflict, make a choice, and interact, leading to an outcome, or consequence. The stakeholders' action-interaction to manage the conflict connects to the consequence node. The consequence is the outcome of the approach to managing the conflict. Finally, the consequence of this conflict may lead to further impacts on the global context. The outcome of a particular dispute has a relationship with the broader social conflict in that it can have an impact on future, similar cases which can be evaluated.

The baseline model from the beginning seemed quite transferable. For example, as a model to describe cases, it is possible to swap out specific actors. More broadly, however, it may be possible to swap out different types of actors, particularly those in regulated environments. This means that instead of being limited to software producers, it could be possible to use telecommunications providers, the healthcare industry, or financial institutions. Instead of government regulators, it could be self-regulatory bodies. Instead of users, it could be constituents or customers. Subsequent versions of the model, following each phase of coding, will limit this broad applicability. Ultimately, the grounded theory will not be nearly as transferable outside the domain, and will be focused on software security

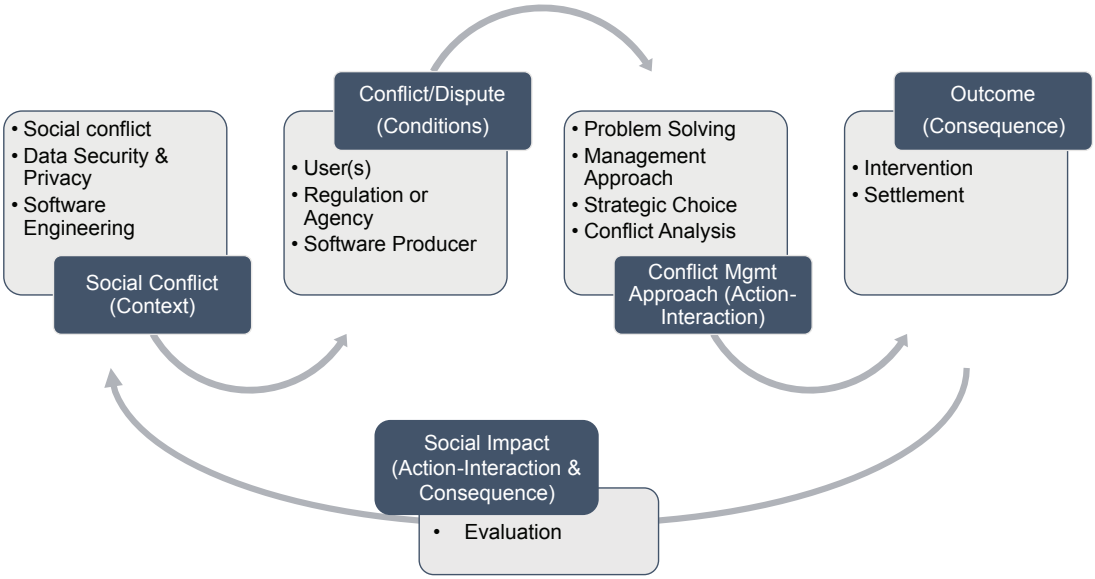

Figure 3.2: Baseline model created to conduct case studies

due to the cases being studied. However, if the cases are selected carefully, they can help ensure the theory is generalizable and externally valid to various cases in the field.

Node Details

The *context* represents the zone where the possible (or inevitable) conflict occurs between the triad of users, software producers, and regulators. For the purposes of this research, this space is limited to social conflict with regard to data security & privacy and software engineering. This context provides boundaries for possible case studies. It means that there must be a social conflict, as defined in Section 2.1.1, that arises from the field of data privacy and security, and implicates software engineers.

The *conditions* represent the realization of a prospective conflict between parties. By comparison, the conditions for cooperation would be that each stakeholder acts according

to their role and any rules set contractually, legally, normatively, etc. When one or more of the parties are under the impression that their goals are at odds with someone else's goals, there are the conditions for a conflict. My case studies will focus on when the conditions implicate all three parties and goals are not perceived to be aligned. Case studies must also result in an observable, real-world dispute. It is possible to use conflict analysis methods, such as conflict or stakeholder mapping, to analyze the conflict (see Section 2.4.1). Conflict analysis at this stage can help understand the underlying issues that led to the conflict, as well as impact the next phase, the approach to managing the conflict.

The *action-interaction* that bears studying is the approach to managing the conflict, and it connects the conditions for the conflict to the consequences. It may consist of both analysis and action by the parties, incorporating "strategic choice" [240] to determine the appropriate approach. See Sections 2.1, 2.4.1, and 2.4.6 for further information about approaches to managing conflict. Maybe the actors chose to file a complaint with the data protection authorities. Alternatively, they could have chosen to do nothing, or they may have had standing to sue the company directly, depending on the jurisdiction. They could also have attempted to settle out of court, such as by pursuing negotiations directly. What type of compensation they are seeking is also a matter to study.

The fourth node is the consequence, the outcome of the conflict management approach. Cooperation and collaboration are more likely to lead to a satisfactory outcome for all parties involved. Based on the interest-rights-power model, interest-based negotiations would yield better results for each party than resorting to rights- or power-based approaches [279]. It will be possible to evaluate the outcome for the stakeholders using theoretical frameworks like those discussed in Section 2.4.6. For example, Justice Theory would test whether the parties thought both the process and the outcome were fair [27, 57, 74].

The consequence (outcome) of a specific dispute may lead to yet another action-interaction, and another consequence: a social impact. This is shown on the fifth node, which connects

the consequence/outcome node back to the context in the first node. This refers to the fact that after a dispute is settled, it may change the global context for future disputes, such as through case law, new regulations, changes to behavior, etc. This is why we can consider the context node a "start/finish line," as a conflict has a starting context, and may eventually have an impact on that context.

The baseline model proved useful when approaching the pilot case, and quickly evolved to include new phases based on the empirical data and logical considerations when describing the processes and events that unfolded in each case. My goal was to choose cases that cover social conflict and have manifested an on-the-ground dispute. Going forward, using axial and selective coding methods, I expanded the baseline model, demonstrated the validity of the structure, generated categories and finally developed a theory.

The final model, described in Chapter 5, includes more substantive concepts that describe the behaviors and states of the stakeholders throughout multiple phases of the cases.

3.1.3 Advanced Stage Theory Development

The next step was the advanced stage of theory development and I continued to use Straussian approaches, which Hoda describes as a "structured mode of theory development" [141, 167, 265]. This emphasizes data collection and analysis in a structured way, including the use of existing tools and templates. Ultimately, five cases were chosen that demonstrated social conflict due to cybersecurity issues and software engineering in regulated environments.

This phase begins with axial coding on each case, after they had been open coded in basic stage analysis (See Figure 3.1 above). The results of my axial coding efforts include concepts both within and between the different actors and conflicts I investigated. My focus on "the complexity of the relationships between conditions, actions-interactions, and

consequences" [265] started to become a methodological differentiator compared to other research in the field, ultimately leading to novel knowledge. This includes generating new concepts about how the behaviors of stakeholders, both conflict and cooperation, are driven by regulatory policies, software engineering practices, and user privacy. The axial coding of each case, and between cases, helped refine the new concepts that I was identifying in each case. These codes substantially extended the baseline model, creating new phases beyond the initial five, and revealing systematic patterns of behaviors and relationships between the stakeholders.

Fundamental to the qualitative research was basic memo writing based on data collected from the mixed sources discussed in Section 3.3. My approach to coding at this stage included process and causation coding [205] to better categorize the behaviors and outcomes I observed. I also began exploring and explaining the case data using matrices to organize the parties, conflicts, approaches, and impacts over time. For example, the conditional/consequential matrix, effects matrices, and case dynamics matrices [205, 265]. Another effective approach, given the complexity of the cases, were causal network analyses, particularly within-case network analysis during the earlier stages of coding, and cross-case analysis later on. Compared to the initial case, the next cases were chosen to include different types of environments, actors, behaviors, and outcomes, which would improve the validity of the theory, and increase the applicability to more heterogeneous situations.

After axial coding, I moved to selective coding (also called targeted coding [141]) to fully develop the concepts necessary for a theory. Selective coding involved field memos and constant comparison to conduct cross-case analysis to develop the final model and theory. This included identifying patterns and subsuming lower-level codes while creating a coherent conclusion. Cross-case analysis at this stage started to include a thorough predictor-outcome-consequences matrix [205] that compared the event-states and behaviors of actors between cases. These methods helped support inductive and abductive rea-

soning that began to indicate theoretical saturation, a crucial step for theory integration [51, 141, 265]. The result of this phase was refinement of my model into a coherent tool that could be used practically to analyze case data, particularly for my fifth and final case.

Following the first four cases, theoretical saturation started to become apparent. The categories I had developed were no longer changing or benefiting substantially from new data. In particular, the predictor-outcome-consequence matrix showed patterns between contributing factors in different cases, despite differences in antecedent variables and outcomes. At this point, I was able to begin theory integration and prepare for the final case to validate the theory. It was clear at this stage that my research would integrate evidence from empirical case studies that reflect conflict and cooperation in software engineering, data privacy, and security to support a grounded theory.

The final-stage effort was a lightweight validation through analysis of a fifth and final existing case. The first four cases chosen to construct the theory during the coding phases can be considered a "training set." Then I used a fifth case as a "test" to validate the theory. This helps in evaluating the effectiveness and validity of the theory and demonstrates its maturity. Relying on the causal modeling I conducted during the first four cases, I was able to confirm that the multivariate predictors I identified clearly showed the causal mechanisms behind the outcomes [205] based on a clear "chain of evidence" from my qualitative data [245].

Throughout the process, I adhered to the GT methodology to focus the research and ensure the dissertation can be used as an artifact in future research and applied in real-world situations. Through these stages I have created a grounded theory that can be considered "mature" based on Hoda's evaluation criteria: novel, useful, parsimonious, and modifiable [141].

Future work could use the model to predict the outcomes of other real-world cases. The ideal situation for this would be to identify a burgeoning case, apply the theory, and

predict the outcome. A practicable tool in grounded theory is the causal prediction model, which could be built based on the predictor-outcome-consequence matrix I developed, the Model-Case Matrix (Appendix H). This prediction model may be useful for predicting future outcomes [205].

3.2 Case Selection

Cases were identified and prioritized based on a variety of variables, including grounded theory methods like theoretical sampling, case study best practices, and maximizing the validity and reliability of the final theory. Case studies in general can increase knowledge about groups, organizations, and social phenomena. In software engineering research this includes "development, operation, and maintenance of software" [245].

Using the baseline model as an a priori construct [85], I chose cases that covered the triad of actors that could be stakeholders in social conflict. It was not enough for the conflict to affect only two of the actors, for example, simply a regulation's impact on industry, or a user's complaint directly to a software producer. Additionally, it was not enough to review "within-level" conflicts, such as corporate espionage through hacking, or an intra-agency dispute about new privacy regulations. Lastly, the conflict should have resulted in an observable, multistakeholder dispute where parties interacted with each other and expressed their disagreement, including outcomes from their approaches to managing that conflict. I sought out salient examples of data privacy and security incidents that provided a substantial amount of data for collection from primary and secondary sources, including interviews and archival data [245].

Taken together, the cases were chosen to support a diverse data set for cross-case analysis, which can help "[achieve] maximum variance along relevant dimensions" as an exploratory process for theory development [245, 257]. The total number of selected cases is

small, which means that they are not likely to be representative of all possible categories. However, there is wide diversity in the cases in their causes and their outcomes, which is valuable for supporting validity, discussed in Section 3.4.

3.3 Data Collection Protocol

After each case was selected, I performed multiple phases of qualitative research, including field research, as well as locating secondary (extant) data sources for desk research. Field research included interviews with subject matter experts. Secondary data collection included locating and evaluating existing quantitative and qualitative data. Ultimately, I selected five cases to analyze, each of which consisted of dozens of extant sources including journalistic, legislative, judicial, organizational materials, public statements, testimony, released internal materials, and more. I also attempted to conduct at least one interview with subject matter experts for each case, resulting in 3 interviews each pertaining to one case, and 2 interviews pertaining to a fourth case. One case did not yield any interviews, unfortunately. These sources of real-world data, as well as other academic repositories, can be incorporated as both primary and secondary data for case studies.

3.3.1 Field Research

Field research comprised interviews with stakeholder subject matter experts (SMEs) that were familiar with each case, including software engineers, legislative and regulatory practitioners, governance professionals, and user advocates. In order to interview these SMEs, I reached out to existing contacts, and made new connections with people connected directly or indirectly to the cases. These contacts come from industry work experience, past professors and instructors, as well as from networking outreach, such as at public conferences and meetings, and cold emails.

Once cases were selected, I identified stakeholders who were party to the conflict, or other SMEs who could speak to the specific cases based on their explicit experience. I conducted semi-structured interviews with subjects to ensure that I collected specific data about the case, as well as their experience, while leaving opportunities for open-ended discussions to get details that I may not have identified from other sources [245]. Based on my interview guide, the semi-structured interviews included background information about the interviewee, knowledge of and familiarity with the specific case being studied, and their experience with the software production, regulation, or use within the case. The interview guide included 26 questions, which included options based on the role of the participant, and were organized based on the timeline of the cases (See Appendix I). In order to be as flexible as possible for the interviewee, and to support recording, the interviews were conducted virtually, lasting approximately 60 minutes. Follow-up interviews were not necessary. While there was no need for sensitive information to be shared for the study, there are two areas of concern that need to be addressed. First, if an interviewee is party to a case, then their personal or private stories may be sensitive. Second is protected information, such as company secrets or classified information. In order to protect the interviewees and/or their employers, I received Institutional Review Board (IRB) approval to conduct the interviews, secured all data as required, and received consent forms from every participant.

In total, I interviewed five subject matter experts about four of the cases. I was unable to identify an expert to be interviewed about the Equifax case, and I found two to speak about the ICRC case. The Equifax case, which was widely known and widely studied, had such rigorous secondary data that it was straightforward to document the details of the case. In particular, a Congressional investigation report that included multiple rounds of testimony and the release of internal documents, thorough reporting by advocacy groups due to the high-profile nature of the case, and the numerous court documents from litigation. However, finding an expert to speak about the details of the case was difficult, and many

individuals who are experts in the field felt limited in how much they could say because of how long ago the incident occurred. The ICRC case involved two subjects because of some of the confusing internal approaches to software development. Details on the use of software by humanitarian organizations were limited, as were the unique features provided by the ICRC for its beneficiaries. Furthermore, the regulatory environment was very complex, given the international nature of the organization, and the specialized use of the software. However, SMEs familiar with the case were very interested in speaking about it in order to help promote humanitarian data privacy.

3.3.2 Secondary Data

Collection of secondary data, also known as extant texts, archival data, or third degree sources, was critical for analyzing the cases [51, 245, 305]. This data is comprised of software artifacts, legal documents, corporate and organizational reports, and journalistic sources from across society. For case study research, this data is crucial to complement data collected from interviews to support validity through "triangulation" [245]. I used methods described in Watkins [305] and Charmaz [51] to select and evaluate the secondary sources. Watkins' 2022 book, *Secondary Data in Mixed Methods Research*, details a variety of methods for evaluation and incorporation in multiple research approaches, including inductive investigation [305]. Charmaz is a grounded theory researcher and provides multiple practical approaches for including extant texts in GT research [51]. These selection and evaluation processes include multiple considerations and questions, for example: what was the purpose of the original research, who collected it originally, what is the context in which the data was created, who was the original intended audience, and whether my variables match those from the original study. By documenting and following these processes for evaluation, I was able to assess both the quality and appropriateness of each secondary

source. Evaluating quality helped make sure the data was reliable and credible, and appropriateness helped ensure that it was applicable to each case specifically, and my research more broadly. Once these sources were evaluated for quality and deemed appropriate for use, I incorporated them as I did primary data. Given the plethora of this secondary data, I referred to it constantly throughout the case studies.

As I conducted each case study, I relied heavily on secondary data. I evaluated each source as it was incorporated into the research, and regularly documented concerns or mitigating factors when they needed to be addressed. To evaluate the secondary data, I first considered the type of data it was, e.g. a software artifact, legal document, academic publication, journalism, company report, etc. These types would be assessed both for their benefits and their limitations. For example, a legal document may not provide technical details to accurately describe software implementation. A journalistic source may have a bias towards a particular policy approach. A company report may be skewed to show an issue in better light. A research publication may be limited in its applicability to my research questions.

In addition to the source of the data, I also evaluated the specific narrative, content, or underlying data to ensure that it was credible and applicable to each case. For example, legal documents were evaluated based on the politics of the legislature or court. Journalistic sources were evaluated for media bias and through their popularity and stated mission. Corporate reports were evaluated for their company or organization's interests. Scholarly research was evaluated for quality based, for example, on how many times it had been cited and its publication's impact factor.

To give a specific example, in the Illuminate Education case, I found articles in high school newspapers that included opinions and statements from students, teachers, and administrators who were affected by the breach. These were valuable to get actual reactions from a variety of affected users whom it would have been impractical to find and interview.

However, the articles were limited in their understanding of the pertinent regulations, and the technical aspects of the data breach. Additionally, I had to take into account some editorializing by the authors, but the quotes from fellow students and school staff (such as a school principal) were reliable. I was also able to find multiple high school news articles that expressed similar sentiments and behaviors, which, taken together, supported the validity of that set of data through triangulation.

Using secondary data sources helped provide independent sources compared to primary data, and even the weaknesses were used to frame my arguments [51]. For example, a secondary source that was seen to be particularly biased was used to show the perspective of the stakeholder it represents, such as a company or regulator. I incorporated these outside sources to scrutinize, not corroborate, my evidence. Secondary data of questionable quality or appropriateness were occasionally included, with the concerns highlighted. I also used the assessment process to help me choose cases that had more high-quality secondary data available. For example, when looking into a possible case, if there were few reliable external sources about the issue, I chose not to proceed. In the infrequent situation where two sources had discrepancies in the facts of a case, I resolved the discrepancy by relying on the higher quality source, or by disregarding the data if it was not important for analysis. Ultimately, I extensively used reliable secondary qualitative data by incorporating into the design and planning of the research, as well as for case analysis and inductive reasoning.

3.4 Threats to Validity

In order to maximize the quality of the research, I will use the four tests of construct validity, internal validity, external validity, and reliability [245, 315]. Below I explain how my methods satisfy the requirements of these tests starting at the design phase, and throughout the research process.

3.4.1 Construct Validity

Construct validity refers to how my methods address the questions I intend to answer. In order to support construct validity, my research was comprised of qualitative case studies that incorporated multiple sources of evidence. Qualitative sources include primary interviews from SMEs knowledgeable about the cases. Secondary data was collected from reputable journalists, recognized industry organizations, official legal documents including government-led investigations, corporate reports from companies involved in the cases, and more. The variety and quantity of these sources provides ample triangulation for valid data on the causes and impacts of the conflicts in the cases [245].

One threat to construct validity is the interdisciplinary foundation of the research. For example, different fields may use different terms to explain the same phenomena. This issue arose early on, for example, simply in defining the term "conflict," so it was necessary to be careful to clarify the terms used both during analysis and in the final results for the reader. Additionally, there were differences in constructing and articulating ideas from these different fields. This also occurred early on in the research when describing models from different domains like political science and software engineering. In these cases, where possible, I defined terminology that is consistent with the software engineering literature to try to keep concepts coherent.

Another related threat to construct validity was my lack of familiarity with some of the complex concepts in the cases, particularly legal approaches, and occasionally software engineering. I am not a lawyer or jurist, and I am not qualified to assess the legal theory behind legislative and judicial actions or outcomes. In the engineering approaches to cybersecurity, I am not experienced enough to say whether some methods of prevention or remediation were appropriate. This threatens construct validity because it means that it is possible that I misunderstood or misinterpreted key causes and outcomes in cases. I

mitigated this threat in two ways. First, I relied on expert explanations of these details, from both primary and secondary data. The public nature of these cases meant that I was typically able to find nontechnical explanations of what happened and use them as data, or have an SME participant explain it to me, and incorporate the explanations in the theory when applicable. Second, I was often able to abstract the very technical behaviors of both lawyers and engineers. In a sense, it did not always matter what narrow action these stakeholders took. It was important to document some of these actions, but it was the broader approach, as well as the logic behind it (the 'why'), that was more important for theory development. The result is that an expert reviewing any individual case analysis that uses my theory would be able to dive deeper into the technical approaches for their own purposes if they choose, and the overarching theory remains valid.

I also addressed construct validity by ensuring that each case was bounded by similar inputs and outputs. I chose cases that included a cybersecurity breach, that resulted in unauthorized access to data about individuals who had some regulatory protection, and resulted in actions taken by stakeholders to the breach to remediate or recover from it. The stakeholders necessarily included a company that implemented and/or deployed software, users whose data was accessed without appropriate permission, and regulators that had influence over the situation. All of these things had to have a sufficient amount of publicly available information for analysis. The result is that the cases focus on examples of social conflict, as opposed to e.g. cyber warfare, or cyber crime, where these criteria may not be applicable, and would have resulted in different theoretical outcomes.

3.4.2 Internal Validity

Internal validity concerns the extent to which I am able to represent my results as causal relations. To improve internal validity, when selecting each case I considered the data

breach, its precursors, the dispute that manifested, the approaches to resolving the dispute, the outcomes for the parties, and the consequences of the broader conflict. This logic model, showing a chain of cause-effect relationships, was established early in my baseline model, and was valuable in assessing the internal validity of each case study. During the analysis phases, I attempted to improve validity by matching patterns within and between cases, including deeper analysis of explanation building and logic models. Matching patterns within the cases in order to understand cause-effect relationships was important to the case studies and helped assure their validity.

I also attempted to improve internal validity by countering my assumptions with rival theories [315]. This included constant comparison between the emerging findings and additional literature [85, 141, 265]. I also attempted to select cases that appeared to contradict the results of previous case studies in order to exercise the evolving theory. For example, I included cases in the US and Europe, as well as issues arising from different regulatory regimes within those jurisdictions, and different types of companies that were breached. The emerging data from the cases helped expand the theory until I reached theoretical saturation, at which point I moved to the final case to test the theory. The result was that the broader research, including the additional literature and the new cases, continued to support my findings, indicating strong internal validity.

Another threat to internal validity was my use of secondary data and the potential biases from those sources that could muddy the final theory. To control for this, I assessed my data sources for potential biases, as discussed in Section 3.3.2, and made sure that my codes were not evaluative, nor assigned judgment to the behaviors and outcomes I observed [205]. In my case analyses, for example, I made sure to include descriptions of secondary data sources that clarified their potential biases. My close adherence to this objective approach yielded practical holistic and causation codes early on, and pattern codes later [205].

3.4.3 External Validity

External validity concerns the possibility of generalizing my findings, and how valuable they are to other people outside the research. There are two major efforts to maximize the external validity of the research. First is the use of multiple cases. The use of qualitative case studies is not based on statistically representative samples, instead, I carefully selected cases that border on revelatory on their own, with characteristics that are common to a wide variety of possible issues. The cases that I chose are representative of the common cybersecurity mantra about data breaches: it is not a matter of *if* a software will be breached, it is a matter of *when*. As such, I selected cases where the overall context was typical, including the data breach itself, the affected companies, the regulatory environment, and the user base, as well as the antecedent and outcome behaviors. These cases are typical such that other, similar stakeholders in the world could look any case and say "this could happen to me." At the same time, I analyzed the unique characteristics of the cases to develop the theory, but organized them to be "sufficiently abstract to cover the range of empirical situations" [51]. The result is a theory with rich and deep categories that can be useful for analyzing a wide variety of similar cases in the future, including their causes and outcomes.

The second effort to maximize external validity is the use of grounded theory. The grounded theory that I developed as a result of the case studies is widely generalizable because of my adherence to the best practices of the methodology [315]. For example, through constant comparison and integrating existing literature into the emerging theory, I also ensured that my data tied to existing phenomena, even if they were not already associated with each other [85]. The theory is also modifiable, that is, it can expand based on new evidence when it is applied in the future [141].

Limited cases are being studied, so future research could continue to develop the theory by adding additional cases, or relying on other research approaches. My final-stage,

lightweight validation test case (described above in Section 3.3) also helped characterize the level of saturation achieved, which will be useful to future researchers.

3.4.4 Reliability

Reliability is related to the ability to reproduce my research, and how it depends on my individual approach to get the results. I maintain a satisfactory level of reliability by adhering to the research best practices of qualitative research in empirical software engineering while studying cases that have a large amount of publicly available data. Reliability can be demonstrated through the concepts of rigor and credibility [141, 265]. With respect to rigor, I maintained detailed repositories and citations for the secondary data that I collected, and the interviews I conducted were with subject matter experts that can be easily reproduced with similarly experienced individuals. In terms of credibility, I have demonstrated evidence of clear understanding and application of the GT methodology throughout this dissertation. The entire process has been thoroughly documented and full details are available, which means that another researcher should be able to follow similar steps using the data that I have collected and come to the same conclusions.

Chapter 4: Case Data and Analysis

Based on the methods described in Chapter 3, I began with an initial pilot case study (Illuminate Education), followed by analysis of three cases where I developed a grounded theory and model of conflict and cooperation in cybersecurity, regulatory compliance, and software engineering. Finally, I selected a fifth case study (OPM) as a lightweight test case to evaluate whether the model and theory held up without revision. Below I provide a synopsis for each of the case studies I conducted, including key details and concepts that supported theory development. The synposes below were created in part using NotebookLM, a Google AI tool that used only my full case analyses as data sources, along with my editing, review, and additions. The full case analyses, including their respective citations, are in the Appendices.

4.1 Illuminate Education

Illuminate Education is a software provider for education institutions and districts, including primary and secondary schools around the US, counting millions of students as their users, in addition to teachers, administrators, and parents. Among their clients were the two largest public school districts in the country, Los Angeles and New York City, as well as districts in Colorado, Connecticut, Oklahoma, and more. These districts and schools, as well as their superior state and federal jurisdictions, employ privacy and data security privacy policies that regulate Illuminate Education as a software producer in this

field. These policies focus on protected classes of people, including students and minors. Illuminate Education's popular software services, such as PupilPath, were used for things like tracking grades and attendance, and included PII about the students and teachers. In January 2022, Illuminate Education suffered an outage to their services, which was later revealed to be related to a data breach. According to the New York Times, there was unauthorized access between December 28, 2021 and January 8, 2022. Ultimately, it was revealed that the records for at least 3 million students, across 605 districts, were accessed and possibly exfiltrated. After the breach, multiple lawsuits were filed by the parents of affected students against Illuminate Education in multiple jurisdictions, including federal court. These lawsuits included allegations of identity theft, future identity theft, and harms associated with loss of privacy. However, the cases were ultimately dismissed after reaching federal court. Contracts were also canceled with the company, and they suffered negative attention and criticism in the media and in the education technology industry. In 2025, a coalition of state regulators pursued action against the company, resulting in fines and ongoing oversight into their cybersecurity practices. Edtech remains a lucrative space for businesses, and a target for cyberattacks, with all stakeholders working to protect their interests.

Selection Criteria: This case was chosen because the primary users were students/ minors (a protected class), along with parents, teachers, and school administrators. Education technology operates in a regulated environment at the local, state, and federal levels, as well as by third-party industry regulators, due to their use of the protected PII of students and minors. However, at the time I chose this case, there had been limited action in enforcing these regulations, only a dismissed lawsuit against the company, and this ostensible failure seemed worthy of investigation. Years later, in 2025, after I had finished analyzing the case, new regulatory action introduced new data, and forced me to re-analyze the case. This yielded crucial results and made this an even more important case.

Context: Regulations relevant to the education technology sector focus on protecting students as a vulnerable and protected class. Federally, the foundational law is the Family Educational Rights and Privacy Act (FERPA) of 1974, although statutory and case law have limited its enforcement, often finding that individuals lack the right to sue in court for violations (a private right of action). Due to the perceived inadequacy of federal laws like FERPA and the Children's Online Privacy Protection Act (COPPA), some state and local jurisdictions developed their own regulations, including California, Connecticut, and New York, and even the New York City Department of Education (NYC DOE). Additionally, the industry developed a self-regulatory framework, the Student Privacy Pledge, which, although voluntary, is designed to be legally enforceable by regulators like the FTC and State Attorneys General.

Antecedent Behavior: Students and school staff used the software (like PupilPath) for daily tasks such as grading and scheduling. Illuminate Education was in a period of growth at this time, merging with other companies and getting private equity investment. High-level users, specifically school districts (e.g., NYC DOE), procured the software and enforced stringent contractual requirements, such as mandating the encryption of student data at rest. Despite these requirements, the records of at least 3 million students were compromised, and the company was alleged to not follow the best practice of having their data encrypted while at rest.

Response, Remediation, and Recovery: Parents of affected students actively pursued compensation by filing multiple class action lawsuits in federal court, alleging harms such as identity theft and loss of privacy. However, these lawsuits were dismissed. Some users had the services cut off entirely when contracts were canceled with Illuminate Education, such as in New York City, where the the NYC DOE (a customer of Illuminate Education) terminated their agreements. This forced schools in that district to undertake correcting behaviors, such as finding and deploying new software solutions (including using ad hoc tools

like Google or Microsoft services). State and federal agencies also pursued enforcement actions against Illuminate, culminating in a settlement agreement and mandated security practices. The company also deliberately restricted information about the incident, making only a few public statements, and actively getting court documents sealed.

Outcome: Despite the users' efforts and the consolidation of their lawsuits, the federal court dismissed the class action complaints, adhering to the precedent that limits individuals' ability to sue for compensation under federal education law. Simultaneously, client users like the NYC DOE adhered to the terms of their contracts and severed the relationship with Illuminate Education, while other clients continued working with the company. Nearly four years later, in December 2025, the FTC filed a complaint against Illuminate Education forcing the company to comply with new data security practices. Additionally, Attorneys General for three states settled with Illuminate for $5.1 million, including civil penalties, although that is not slated to go to affected users.

4.2 International Committee of the Red Cross

The International Committee of the Red Cross (ICRC) is not a typical software producer, but it does create software solutions for a variety of users to achieve its mission. Its users are comprised of a heterogeneous mix of international organizations, field staff, and end-users, all of whom depend on the software for critical and even life-saving operations. The end-users, called beneficiaries, are of particular importance, and they are the people that benefit from the services provided by the ICRC in highly sensitive situations like violent conflict and environmental disaster. With their iconic Red Cross emblem, the ICRC provides a variety of services to their beneficiaries, including reconnecting families who have been separated, which they have done for over 150 years. Today, this means implementing and deploying software through their Restoring Family Links (RFL) pro-

gram, which is deployed by field staff worldwide. The regulatory regimes that apply to the ICRC and its users are manifold, including disparate national requirements in the countries where they work, and international agreements like the Geneva Convention, as well as strict internal regulations.

In 2021, a breach compromised information of about 515,000 beneficiaries of the RFL program. These end users are a particularly vulnerable population, and malicious use of their data could lead to direct harm. Additionally, their privacy, diverse situations, and diffuse locations disrupt their ability to recover from the breach, such as through legal action. The regulatory bodies that are tasked with controlling and remediating the breach are also spread out among multiple jurisdictions, making it hard for anyone to act. The ICRC, as the software producer, had to act in the best interests of their mission, which takes into account their future operations and the well-being of their users, particularly, the beneficiaries. The users in the ICRC case fall into two categories: the beneficiaries (end users) and the National Societies (deployment users). The focus here is primarily on the beneficiaries.

Selection Criteria: This was the first international case that I selected, and it was very complex for multiple reasons. First, the ICRC is not a typical software producer, and their technology was used for marginalized communities in extremely critical situations. The ICRC was very open about the incident, providing valuable data for observation. Additionally, there are a variety of regimes that govern their organization and technology, such as the Geneva Conventions, and their relationships are very complex. The complexity of the relationships between the ICRC as a software producer, the various regimes that regulated the use of their software, and the vulnerability of the end-users made this an important case to examine. Overall, this case demonstrated the critical nature of data privacy and security in a unique and challenging way. Furthermore, I came across the case through a subject matter expert, and connected with others, who could provide key internal details beyond

the publicly available information.

Context: The regulatory regimes governing the ICRC are multifaceted, stemming primarily from international humanitarian law and internal self-regulation. The highest legal basis for ICRC's operations are the Geneva Conventions (dating back to 1864 and revised in 1949, with later Additional Protocols), which establish international laws for the humanitarian treatment of conflict and disaster victims, extending protections to their data security and privacy. Furthermore, the ICRC created and adheres to its own stringent internal regulations, such as the ICRC Rules on Personal Data Protection (2015) and the Code of Conduct on Data Protection (2015), designed to ensure its mandate is carried out consistent with internationally recognized standards. These self-regulatory artifacts were developed to maintain the organization's principles of impartiality, independence, and neutrality while operating across multiple jurisdictions and their disparate national requirements.

Antecedent Behavior: The affected beneficiaries, 515,000 victims of armed conflict or disaster, are a particularly vulnerable population who entrusted their sensitive demographic and biographic data to the Restoring Family Links (RFL) program to receive critical humanitarian assistance and protection. They used the software for services like video calling and secure messaging to reconnect with separated family members. However, they would have had the least connection with the software producer and regulators.

The ICRC was seen to be taking a very strict approach to cybersecurity policies and technical controls. However, the breach exploited a known vulnerability in their unpatched software for about 60 days after it was first identified publicly.

Response, Remediation, and Recovery: The diffuse location and vulnerable nature of the beneficiaries disrupted their ability to pursue legal action or compensation. Consequently, the Red Cross Movement often acted as their advocate, making public statements condemning the attackers (although they did not attribute the attack to any actor, as is typical of their focus on neutrality). There is no evidence of compensation being sought by the

end-users or mandated by external regulators. The ICRC was very open about the incident, publishing documentation and even holding an open conference to discuss data privacy in the humanitarian space. They worked with many stakeholders to create new internal regulations to help prevent future cybersecurity issues.

Outcome: The primary cost to beneficiaries was the risk of future harm due to the compromise of highly personal data (health, location, family details). Users may be disinclined to work with the ICRC in the future due to heightened awareness of risks. Some users likely sought to preserve their support by continuing with ICRC, while others may have disengaged to protect their future safety. The organization continues to implement this software and its partners deploy it worldwide, growing their user base since the incident. New controls and policies were implemented afterwards.

4.3 Equifax

Equifax is a US-based credit reporting agency (CRA), one of three in what is called the Consumer Reporting Agency System. The role of a CRA is to collect consumer data that can be used by businesses, such as employers and creditors, as well as government agencies, in their operations. There is a robust regulatory environment surrounding the CRA system, including oversight and enforcement from agencies like the Securities and Exchange Commission (SEC) and FTC, as well as others. The CRA system has a very large role in American society, pulling in data on every consumer in the country, such as their habits and purchases, aggregating them and providing the data to a variety of business customers. In 2017 an attacker accessed and stole the data of 145.5 million consumers in the US, and more in Canada and the UK. There were immediate responses from all stakeholders, including regulatory action, business customer behavior, and, eventually, monetary compensation from Equifax to affected individuals. The scale of the breach, the regulatory

environment in which it occurred, and the aftereffects were widely discussed in the media, academia, and the general public.

The users included passive consumers (nearly every adult in the US) and active business customers (companies and government agencies).

Selection Criteria: This was a major case when it occurred in 2017, demonstrating to the public the vulnerability of their data, and the scale at which it was being collected by data processors, which many people were not aware. In fact, this challenged the definition of a "user," given that many people did not directly, or knowingly, interact with their software. Additionally, Equifax was a highly-regulated organization with strict security and reporting requirements that should have prevented such a massive incident. The conflict was investigated thoroughly by multiple government entities, providing valuable data about Equifax's behaviors before and after the incident, including internal documents and conversations, and testimony from leaders. The public response was also quite broad, adding more resources to understand the impacts of the incident. The enforcement actions after the incident were also sweeping, leading to massive fines and payouts to affected users following major court decisions that set new precedent.

Context: The regulatory regime for CRAs in the US developed over decades in response to concerns regarding the consolidation of sensitive consumer data. Key foundational laws include the Fair Credit Reporting Act (FCRA) of 1970, which was enacted specifically to address the modernizing credit reporting system and requires CRAs to adopt "reasonable procedures" for confidentiality. Subsequent federal laws like the Gramm-Leach-Bliley Act (GLBA) (1999) and the Fair and Accurate Transactions Act (FACT) of 2003 added protections for preventing and correcting identity theft. This body of law, along with corresponding international guidelines and case law established through consistent enforcement actions by agencies like the FTC and Consumer Financial Protection Bureau (CFPB), forms the complex and highly active regime governing CRAs.

Antecedent Behaviors: Passive consumers automatically supplied vast amounts of sensitive financial and personally identifiable information to Equifax through everyday transactions without the ability to opt out. This PII, including names, Social Security numbers, and dates of birth, was compromised for over 145 million consumers. Business customers (including government agencies) actively deployed Equifax's software to inform critical decisions e.g., lending, employment screening. These business users were required to contribute their own customer data back to Equifax in a "give-to-get" scheme. Meanwhile, Equifax suffered from a number of unaddressed vulnerabilities that led to their systems being compromised for 76 days before they were able to identify and remove the threat. The system exploited was a federally mandated customer complaint portal, which had a user-facing website and was connected through complex code to software dating back to the 1970s.

Response, Remediation, and Recovery: Consumers were notified starting in September 2017 and immediately sought remediation by using the ad hoc website created by Equifax (which later suffered from other vulnerabilities) to check if they were affected and enroll in credit monitoring services offered by the company. Consumers engaged in posturing by submitting public comments to regulatory bodies like the FTC and CFPB, advocating for legal corrections and compensation. Crucially, users successfully filed and won a class action lawsuit against Equifax (over $380 million), which was tied together with a separate FTC suit, resulting in legal precedent that regulates the industry.

Outcome: Consumers received significant remedies, including cash payments (up to $125 per filer, and more reimbursement for proven costs) and identity theft protection services from a settlement fund. Equifax executives were required to testify in Congress multiple times about the incident and underwent rigorous investigation and enforcement actions. Business customers that were major clients responded by launching their own investigations, performing security assessments, and modifying contracts to mitigate future

risk. The regulatory landscape, including litigation outcomes, were shaped for the future as a result of this case.

4.4 CatalanGate

In 2022, a political scandal erupted when reports detailed the hacking of prominent people from Catalonia, specifically through their use of the popular mobile/instant messaging software WhatsApp. Catalonia is an autonomous region within Spain, and, in conflict with the interests of the Spanish government, has sought independence throughout modern history. The people affected by the hack include elected officials, political leaders, and activists that were involved in the Catalan independence movement, as well as people associated with them, all of whom were users of WhatsApp. Much of the hacking occurred around the time of the independence referendum in 2017. CatalanGate was part of a broader conflict regarding the use of commercial spyware, in particular one called Pegasus. The scandal implicated a variety of stakeholders, across multiple jurisdictions, in a changing environment. The affected users were Catalan people, who are citizens of Spain, and protected by the recently applied General Data Protection Regulation (GDPR) of the supranational European Union. The software exploited was the popular WhatsApp, developed by an American company with massive reach in Europe, purchased by Facebook in 2014, and now part of the parent conglomerate Meta. Responses to the scandal include multilevel EU enforcement, including a large investigation by a dedicated body, the PEGA Committee and US court decisions in 2025.

The users in the CatalanGate scandal were primarily elected officials, political leaders, activists, and journalists involved in the Catalan independence movement, along with their associated friends and family. The breach of their WhatsApp accounts was found to be perpetrated by the Spanish government for national security purposes.

Selection Criteria: This case was selected because of its setting in Europe, and putative connection to GDPR, which is among the most mature data privacy regulations in the world. Additionally, it involved consumer software, WhatsApp, which I had not investigated previously. The incident was widely covered in the media, and resulted in in-depth investigations by the European government and advocacy organizations, resulting in rich data. Furthermore, the affected users were important figures that were targeted more narrowly than in prior cases. Ultimately, this case became even more valuable because of the complex nature of the European regulations that were implicated. The incident revealed major shortcomings in GDPR, which led to limited enforcement, and pushed regulators to establish new protections. The involvement of Meta, an American company, and its litigation also added valuable data for analysis. Lastly, I studied this case only as it unfolded in Spain, although the full extent of the Pegasus spyware and data privacy disputes occurred in multiple EU member countries, providing a valuable boundary for investigating a broader phenomenon.

Context: The relevant regulatory framework in Europe, particularly the General Data Protection Regulation (GDPR), was developed based on a long history of legal protections for data privacy within EU member states. The expansion and passage of GDPR were driven by key societal changes, including the general growth of the internet and monolithic companies like Facebook and Google, as well as crucial Court of Justice of the European Union (CJEU) decisions like the 2015 *Schrems I* case concerning the transfer of EU data to the US. However, there is a perceived gap in privacy protections when it comes to member states using spyware technology for security. Meanwhile, within Spain, the right to privacy is constitutionally protected under the 1978 Spanish Constitution, although this right can be suspended for national security reasons, provided there is judicial participation and parliamentary control.

Antecedent Behaviors: These users were utilizing WhatsApp ubiquitously for both

personal and official/business communications. Their involvement in political operations, such as the independence referendum in 2017 and subsequent political events (e.g., elections, appointments), made their data highly valuable to potential attackers. The attacks compromised their mobile devices, effectively turning them into sensors for surreptitious surveillance, exposing private information beyond just in-app messages.

Response, Remediation, and Recovery: After the breaches were revealed, targeted users demonstrated significant activism and legal efforts. They engaged in posturing by making public statements to journalists and networking with activist organizations like Citizen Lab and Amnesty International. At the national level, they filed as many as nine complaints in Spanish courts and pursued investigations through the independent Spanish Ombudsman's office. At the international level, affected users participated directly in the European Parliament's PEGA Committee hearings and investigations in an attempt to amend the governing regime. Furthermore, user concerns regarding human rights led to the very rare support of advocacy organizations for Meta in their lawsuit against the spyware creator, NSO Group. This was also successful and novel litigation that set new precedent.

Outcome: In the European regime, the publicity of the scandal led to aggressive investigative activities by the European Parliament, which established the PEGA Committee, resulting in a formal report and non-binding recommendations adopted in 2023. New EU regulations like the Cyber Resilience Act (CRA) and the Media Freedom Act (EMFA), as well as the Pall Mall Process outside of the EU itself, were later introduced to set cybersecurity requirements and add protections against spyware use, but stopped short of restricting state-sponsored spyware deployment. Spanish regulatory authorities largely preserved the existing regime, meaning the users are still seeking meaningful remedies.

4.5 Office of Personnel Management

The United States Office of Personnel Management (OPM) is the primary human resources agency and personnel policy manager for the federal government. Between 2014 and 2015, the OPM suffered from a series of cybersecurity failures that amounted to one of the largest data leaks in US government history. The vulnerability exploits compromised sensitive data for government employees, including information that could be threatening to national security. The exfiltrated data contained personally identifiable information (PII) from over 21 million government employees, including personnel files, detailed information from background security investigations required for security clearances, and biometric fingerprint data. As a government agency, the OPM is highly regulated, particularly by the Federal Information Security Modernization Act (FISMA), and the data it was responsible for was also highly protected.

Breaches in 2014 were identified, but security teams were unable to identify the full extent of the exploits, which led to them persisting through 2015, resulting in a second overall data breach. In response to the incidents there was comprehensive regulatory enforcement, including by the US House of Representatives and federal agencies, as well as a successful class action lawsuit against OPM and its vendor, KeyPoint. OPM provided credit data monitoring for affected victims and reformed their cybersecurity efforts as a result of the incident.

Selection Criteria: This case was selected because it was so high profile, and involved a government software producer that was highly regulated. This case is also distinguished by its dual incidents, which offers two stages of antecedent factors, those that led up to the first breach, and the (failed) responses to it, which then become the precursors that led to the second breach. The investigation by Congress also revealed a wealth of information for analysis, including internal documents, testimony, and conversations from cybersecurity

personnel working on the incidents. Furthermore, the volatility of the data that was compromised demonstrates the critical nature of data security and privacy, and the cooperation required to maintain it.

Context: The context of the OPM breach is characterized by a complex intersection of government operations, high-stakes national security data, and an evolving regulatory regime. OPM managed the Personnel Investigations Processing System (PIPS) on behalf of deployment users, including over 100 federal agencies, for background checks, security clearance data, and more. The end-users were the millions of federal employees and contractors whose data was stored in this system. OPM was governed by the Federal Information Security Modernization Act (FISMA) and overseen by internal watchdogs like the Office of the Inspector General (OIG) and external bodies like Congress and the Office of Management and Budget. Since 2005, federal agencies had been targeted by Advanced Persistent Threats (APTs), which are sophisticated, state-sponsored hackers. OPM was a "prime target" due to the immense value of its centralized PII.

Antecedent Behaviors: Following the Intelligence Reform and Terrorism Prevention Act of 2004 (IRTPA), OPM assumed the responsibility for processing 95% of the government's background investigations. This created a massive backlog, leading leadership to prioritize the speed of processing over the quality of cybersecurity. Much of the data was stored on an antiquated mainframe environment (PIPS) that lacked modern security controls. Furthermore, OPM was cited as one of the weakest agencies in implementing Personal Identity Verification (PIV) cards; as of 2015, only one percent of staff were required to use them. Despite repeated warnings from the OIG starting in 2005, OPM leadership failed to prioritize security. A 2013 audit released just as new Director Katherine Archuleta and CIO Donna Seymour were onboarded revealed security controls that had never even been tested.

Response, Remediation, and Recovery: The response was marked by intense friction

between OPM leadership and regulators. OPM attempted to modernize its architecture but faced bureaucratic hurdles, leading to a second round of breaches after the first had been identified. The House Oversight Committee launched a scathing investigation, accusing OPM leadership of making "misleading statements" regarding the breaches. This eventually led to the resignations of the Director and CIO. Labor unions (AFGE and NTEU) filed a class action lawsuit, which was initially dismissed but overturned on appeal. OPM eventually settled for $63 million in damages for victims.

Outcome: These breaches put cybersecurity in the federal government, and nationwide, in focus. The Obama administration launched a 30-Day Cybersecurity Sprint in June 2015, mandating that agencies immediately implement multifactor authentication and patch critical vulnerabilities. Background investigations were moved from OPM to the Defense Counterintelligence and Security Agency (DCSA) in 2019. Furthermore, the Cybersecurity and Infrastructure Security Agency (CISA) was granted new power to issue Binding Operational Directives to enforce standards across the government. OPM has spent over $725 million on identity theft protection services for victims. For users, the breach created long-term risks for those involved in national security, as their intimate personal histories are now in the hands of a foreign power.

Chapter 5: Grounded Theory

Through multiple rounds of coding and analysis of the case data, I developed a grounded theory of multistakeholder conflict and cooperation in software cybersecurity. Concepts emerged from analysis of within- and between-case data, and were revised through multiple rounds of coding. The theory development process culminated in a lightweight test of the theory through the fifth case analysis. The behaviors and outcomes in each case are described through a model that was developed to support the theory development.

First I will introduce the final working model, which was iterated through the basic and advanced stages of theory development. The model is similar to a predictor-outcome-consequence matrix as described in [205]. The model includes antecedent variables, outcomes, and consequences that can be used to explain, not just describe, patterns in each case. Furthermore, this model can be used to replicate my approach and support my findings, as well as in future research. The model and theory can be applied to similar cases in data privacy and security to support analysis in fields including cybersecurity, conflict analysis, political science, and business. Researchers investigating real-world cases in these areas can use the grounded theory to understand the behaviors of key stakeholders in their research, scope areas of analysis, and account for outcomes they observe. They will have reliable descriptors for behaviors and outcomes for all different stakeholders involved in their cases.

Next, I will introduce the theory and its key findings. Whereas the model frames the data, the theory and findings include analysis that can be used to explain the patterns of

behaviors by the stakeholders, and their outcomes. The findings include the relationships within each case, and how they are related, or not, to the other cases. Ultimately, the theory explains systems associated with engineering software security to improve data privacy, based on the involvement of various stakeholders.

5.1 The Model

I started with a baseline model, presented in the dissertation proposal (Figure 3.2 and earlier in this document, Section **??**), based on preliminary research to help structure the case studies. This was instrumental in identifying and describing multistakeholder conflict in the early stages of my research. However, the baseline model quickly became insufficient to describe the full complexity of even the pilot case. Immediately, new concepts emerged, and the model expanded to include additional phases both before and after the data breach. Across the first four cases I was able to code the data and evolve the model to describe the circumstances and relationships between stakeholders before and after data privacy breaches. In the fifth case, I attempted to use the model without modifications to ensure that it could be applied to future cases. This test case was successful, as the model held up to scrutiny and served as a useful tool to interpret the final case despite choosing the test case to deliberately challenge the model in specific ways. In particular, I attempted to find a case that would stress the GT due to its unique inputs, including the complexity of the incident and its stakeholders, as well as the outcomes, which were somewhat unique.

Anecdotally, the bigger test of the theory was not the final lightweight test case, but instead came when new developments in the pilot case (Illuminate Education) occurred in 2025, nearly five years after the incident occurred and three years after I had conducted my case analysis. This did not challenge the overall model, nor the theory, but impacted cross-case analysis and revealed important behaviors.

5.1.1 Final Model

The final model has seven phases, made up of states, behaviors, and an incident, along with the three groups of stakeholders: users, software producers, and regulators. The phases align with the Grounded Theory coding family known as the six C's: Causes, Context, Conditions, Covariances, Contingencies, and Consequences [141, 265]. The model phases and the coding family are designed to describe the interrelationships between stakeholders, including both how they influence the incident, and how they respond. Ultimately, the model is a functional tool for practitioners and researchers to describe and analyze cybersecurity incidents over time with a focus on the relationships between key stakeholders to the incident. It is a novel contribution to scholarship about conflict and cooperation in cybersecurity and software that can be used in conjunction with other theories, models, and frameworks.

This model is unique from other models and frameworks, such as those referenced in Section 2.4. Software engineering and cybersecurity frameworks typically focus on implementation procedures within an organization, especially technical processes. For example, the popular NIST and SANS frameworks define cycles of behavior before, during, and after incidents for technical and non-technical personnel within an organization. However, they do not include concepts for understanding the other stakeholders in the incident, the relationships between them, nor the behaviors before and after an incident. Policy and international relations models typically describe the broader landscape of cybersecurity, including different stakeholders. However, they typically do not provide concepts for describing stakeholders at different levels of society (such as individuals, companies, and governments), nor their interactions both before and after an incident. My new model provides the concepts necessary to scaffold the investigation of data privacy and security in conjunction with other models and frameworks. It can be used by technical, legal, and lay

stakeholders in practice, as well as for scholarly research.

The final model was expanded from the baseline model and includes additional phases and concepts based on empirical case data. The baseline model was developed primarily based on concepts from the literature, my general knowledge about privacy disputes, and grounded theory concepts. When this was applied to the case data, concepts quickly grew, introducing new concepts that encompassed the behaviors and states of each group of stakeholders, including individual activities, inputs, outputs, and net effects. Codes for the different behaviors and outcomes continued to evolve through the multiple phases of coding. As the model evolved, I used the most current version to analyze the case studies, resulting in some differences in codes in each case analysis, which are included in the appendices. For example, in the baseline model, the "Conflict/Dispute Node" encompassed the Conditions for the conflict. However, it became clear that there were a variety of Conditions that presaged the dispute in the cases, and so the Conditions expanded to include both a "Behavior" phase and a "State" phase, which describe both the actions and outcomes taken by stakeholders prior to the conflict, and which are the Conditions to it. This Behavior-State relationship was also added after the incident, within the Action-Interaction group of codes, to describe the interactions between the stakeholders. The groups of codes within each phase also evolved, subsuming earlier concepts and were deliberately aligned to demonstrate the parallels between the stakeholder groups, in spite of their differences. The Adverse Event/Incident phase also went through multiple transformations, eventually becoming a single inflection point around which the other phases coalesce.

Following the third case study, the model was in a sufficiently mature state, and to begin more advanced cross-case analysis, I introduced value scales to the observed behaviors and states. This meant that in each case, in each phase, and for each set of behaviors and outcomes, I assigned a score such as weak or strong, lenient or strict, passive or active, unfavorable or favorable, etc. These values provided useful data to analyze patterns of

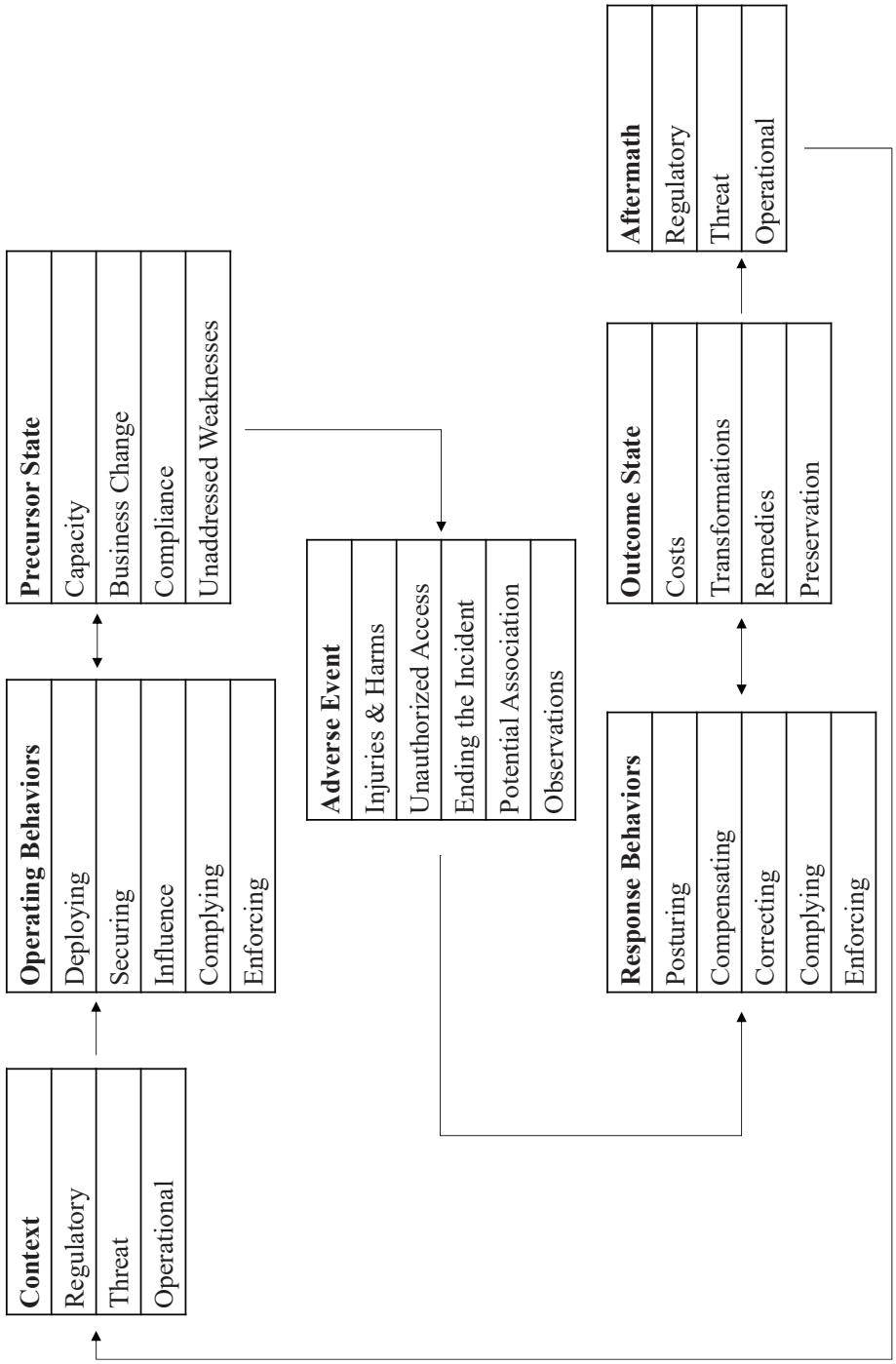

Figure 5.1: Final model behaviors, phases, and states.

behaviors and outcomes between cases and within them. Beyond verbal descriptions, I was now able to evaluate the relative effort behind a given behavior and its relative impact on outcomes. By assessing antecedent characteristics such as a "Strict Regime" or "High Capacity" I was able to account for consequences like "Favorable Remedies" and "High Costs." For the dissertation, I only assigned values for the overall stakeholder group, not for individual actors within it, such as national versus state regulators, although this would be a logical next step. Additionally, using these values took a small step towards quantifying some of the concepts in my work. However, these values could be applied more extensively for more detailed quantitative analysis in future work.

After the fourth case, including all aspects of the model, I was able to test it on the fifth and final, test case. The final case warranted no substantial revisions to the model, and I was readily able to fill in the data I collected. I then continued to analyze the cross-case data using the model, including the value scales, and developed the findings in Section 5.3. Below I will provide an overview of the structure and components of the final model. An overview of the phases, behaviors, and states is shown in Figure 5.1 The full model is available in Appendix G.

5.1.2 Model Components

Below is an overview of the major components of the model, including definitions of the key concepts. The full list of definitions is available in Appendix F.

Phases The model is made up of two types of phases, behaviors and states, that connect to each other. Behaviors result in states, and states influence behaviors. There are three antecedent phases before the incident: the context state, operating behaviors, and precursor state. Following the incident, there are three consequence phases: the response behaviors, outcome state, and the aftermath. The incident is an inflection point that occurs due to

the antecedent operations and precursors and instigates the responses and outcomes. The context and aftermath act as a start/finish line for each case, where the aftermath may have impacts on the context going forward. The incident is typically perpetrated by a malicious party who is not included as a stakeholder. This has important implications in the model and theory, but the general premise is that there is no continuing relationship with the attacker. Additionally, while the attacker is responsible for introducing the incident, the conflict and cooperation between the stakeholders is the observable area of my inquiry, including what happened between the parties before and after.

Each phase (except for the context) is comprised of net effects that are the results of activities, inputs, and outputs from the stakeholders. The context consists of different environments. In each phase, the net effects and environments are closely related between the stakeholders, and frequently overlap. The overlaps and connections between these net effects demonstrate the interconnectedness of the actions and interests for each stakeholder group. The result is a practical model of conflict and cooperation for multistakeholder data privacy and security. The model is sufficiently broad to allow for future concepts to be extended, but narrow enough to meaningfully describe the system. The phases include behaviors and states that are observable in different cases.

Context The context is the state that exists between software producers, regulators, and users in trying to achieve data privacy and security goals (see Figure 5.1). The concept is based on the grounded theory concept of context, which bounds the case being studied, and represents the zone where the possible (or inevitable) conflict occurs between the triad of users, software producers, and regulators. For the purposes of this research, this space is limited to social conflict with regard to data security & privacy and software engineering.

After a dispute is settled, it may change the global context for future disputes, such as through case law, new regulations, changes to behavior, etc. This is why we can consider

	Context	Operating	Precursors
Users	Regulatory Threat Operational	Deploying Securing Influence Complying	Capacity Business Change Compliance Unaddressed Failures
Software Producers	Regulatory Threat Operational	Implementing Securing Influence Complying	Capacity Business Change Compliance Unaddressed Failures
Regulators	Regulatory Threat Operational	Rulemaking Enforcement Investigation Influence	Regimes Capacity

Table 5.1: Antecedent Conditions: Context, Operating Behaviors, and Precursor States.

the context node a "start/finish line," as a conflict has a starting context, and may eventually have an impact on that context.

The context is comprised of three environments for each stakeholder: regulatory, threat, and operational. These environments are interrelated but have different inputs, outputs, dimensions, and meanings for each stakeholder. The overall context sets the stage for the conditions, actions-interactions, and consequences throughout the case being analyzed.

Operating Behaviors The operating behaviors are the real-world actions taken by the stakeholders preceding the conflict that occurs as a result of a data breach. This phase is the first that establishes the conditions described by GT, and these behaviors yield a precursor state. The operating behaviors follow logically from the context, and describe the various activities taken by stakeholders, which are categorized into a limited set of net effects. Net effects comprise the goals and organizational processes that each stakeholder has in interacting with each other, whether that means using software, creating software, or regulating software.

For users and software producers, the operating behaviors are deploying or implement-

ing, securing, influencing, and adhering/complying. For regulators, they are rulemaking, enforcing, and influencing. Because the operating behaviors are all action-oriented, they can all be evaluated by how active the stakeholder is in that behavior, either active or passive.

Precursor State The precursors comprise the state that stakeholders find themselves in as conditions to a dispute. The precursor state is the outcome of the operating behaviors, and in some ways are an abstract description and in others are a more concrete explanation of the antecedent conditions. Ultimately, they describe the state of affairs that are exploited by malicious actors and which will be under scrutiny after the data breach. There is not a direct timeline from operating behaviors to precursors and stakeholders may cycle between these two phases. For example, business change (a precursor state) may result from deployment activities (operating), which could affect their capacity (precursor).

Adverse Event/Incident The incident is the first step of the action-interaction phase, and represents the behaviors undertaken by the stakeholders as the incident unfolds. The incidents being studied are data breaches caused by malicious actors exploiting a vulnerability and gaining unauthorized access to user data through software producer systems. Activities are almost entirely limited to the software producer during the incident itself, although users are directly affected, and regulators are implicated.

Responding, Recovering, & Remediating Behaviors The behaviors that the stakeholders take after the incident occurs are included in a phase called responding, remediating, and recovering (RRR). For ease, I typically refer to this as the Responding phase, although the other components, remediating and recovering, are also important, and the behaviors contribute to those strategies. The options the stakeholders have at this phase are predicated on the operating and precursors before the incident, as well as the nature of the incident

	Responding	Outcome	Aftermath
Users	Posturing Compensating Correcting Complying	Costs Transformations Remedies Preservation	Regulatory Threat Operational
Software Producers	Posturing Compensating Correcting Complying	Costs Transformations Preservation Remedies	Regulatory Threat Operational
Regulators	Posturing Compensating Correcting/Enforcing Complying	Costs Remedies Transformations Preservation	Regulatory Threat Operational

Table 5.2: Interactions & Consequences.

itself. The range of possible actions, and what actually occur, vary widely and have very different results. There are examples of conflict and cooperation in this phase, and patterns emerge that can change the context for future, similar incidents, or ensure that things stay the same.

The categories of behaviors (the net effects) taken by all stakeholders in the RRR phase are all the same: posturing, compensating, correcting, and complying. The net effects are organized to share the same terms for each stakeholder, showing that they pursue a similar set of goals, although they can have different consequences. Each individual net effect can support response, remediation, and/or recovery efforts, which is why the entire phase uses those three terms, but there is no single net effect that uses any one of them. This is a very active phase, with many intertwining actions, and overlapping efforts.

This cohesive approach holds true when the goals between stakeholders are mutually beneficial, and when they are at odds with each other. The matching categories demonstrate the way that goals between stakeholders can be aligned following a data breach. However, even when interests are opposing, stakeholders are still seeking different goals within the same categories of activities. For example, while all three stakeholders might go to court,

the way they get there, and their intentions for doing so, are not usually the same.

These activities are what grounded theory describes as covariances, as these are the actions and interactions that vary together between the stakeholders, sometimes causally. Stakeholders' actions cycle back and forth as the conflict unfolds, and their behaviors are determined not just by the antecedent conditions, but also by the behaviors of the other stakeholders.

Outcome State The outcomes and consequences are the practical results of the behaviors in the previous phase. Similar to the RRR phase, the possible outcomes are organized into a set of categories that are the same for each stakeholder: costs, transformations, preservation, and remedies. While the individual outcomes within these categories vary for each stakeholder, the categories themselves remain the same, and can represent both the aligned and disparate outcomes for the stakeholders. For example, in determining remedies, the stakeholders might negotiate together (such as in a court settlement) to get the best remedies for themselves, while reducing their own costs.

The consequences are typically focused within the given case they are describing, but those with a larger scope can result in broader changes to the context going forward, which is described in the next phase.

The outcomes have a rich covariance with each other, and with the previous phase. It is difficult to disambiguate many of the outcomes, both for each stakeholder and between stakeholders. For example, costs and remedies are connected, but may not vary directly, as higher costs could mean better remedies, but not necessarily. These correlations and causations have important implications for observing the relationship between the parties, including their cooperation and conflict.

From a theoretical standpoint, by including the same categories for each stakeholder, even when there was little or no data in some cases, it left the door open for future cases

to introduce that data. By creating interconnected categories in advance, it was feasible to assume that future cases could fill in those gaps, instead of limiting the model to what had only been observed.

Aftermath The aftermath describes the changes to the context for similar cases going forward. This means that the case had observable impacts on the regulatory, threat, and operational environments for all stakeholders. Not all cases resulted in an observable aftermath, meaning that not all cases were so critical that they changed the way future cases would be addressed. However, those that did result in such drastic aftermath phases included three observable phenomenon: there were gaps in enforcement mechanisms that were addressed, there were novel approaches to cooperation that had not occurred before, and there was a perceived critical nature of the issues involved in the case. Taken together, these characteristics led to long-term changes to the contexts (regulatory, operational, and threat) of future data security and privacy cases.

5.2 The Theory: Regulate, Recover, Repeat

The theory, *Regulate, Recover, Repeat*, describes the cyclical nature of software cybersecurity, and the roles that people play in that system. In a sense, I am elevating the popular aphorism about data breaches "it's not a matter of *if* a software will be breached, it's a matter of *when*" into an empirically sound theory, and incorporating the different ways that stakeholders address this dilemma. When thinking about cybersecurity, all stakeholders participate in regulation to prepare for an incident, and in recovery after it occurs. Then everyone does it all over again.

Each stakeholder, whether a user, a software producer, a regulator, or someone else, participates in different ways, and the outcomes of their efforts vary. Meanwhile, they may

not be thinking strategically about what the other stakeholders are doing or how they will respond. When the inevitable next incident strikes, sometimes there are new resources in place after the preceding ones, sometimes not. Those resources include technical controls and regulations, but they can also be shared interests and cooperation, or at least a better understanding of the other parties involved. In order to improve cybersecurity, these people must be able to observe and understand each other's behaviors.

Furthermore, there are few resources for holistically explaining the multistakeholder systems of cybersecurity efforts. But such resources can help improve the commercial interests of businesses and consumers, as well as democracy and the public interest. At any point, someone can pick up the model that I have developed and start analyzing cybersecurity incidents to look for strengths, weaknesses, opportunities, and threats across all the stakeholders that are involved. Ideally, they can identify mutual interests between the stakeholders, and capitalize on them to improve data privacy and security.

Below I will further elaborate the theory based on its findings. This includes major themes incorporating the model and between-case conditions and actions that emerged that logically explain the consequences [205].

5.3 Findings

To fully construct the theory, I reduced each case into its component parts within the model. This meant creating 1-3 sentence breakdowns of the behaviors and states based on the full case analysis. I then applied values to each behavior and state based on the value scales described earlier. The result was the Model-Case Matrix, also known as a "predictor-outcome-consequence" matrix, as described by Miles, Huberman, and Saldaña [205]. The full matrix has 275 components, which were color coded for their values for easier pattern recognition. I compared the different values within and between cases in the first four cases

to develop the initial findings. I then coded and applied values to the fifth lightweight test case, and compared the results to the findings.

The full Model-Case Matrix is available in Appendix H, and the specific components have been reduced into tables within each finding.

5.4 Finding 1: Regulatory Context Drives Compliance After Incidents

The first finding relates to the Context Environments for the Software Producers and the Regulators in each case. In all five cases, the Threat Environment for Software Producers has been rated as either Risky or Somewhat Risky. This aligns with the nature of the cases I have selected, given that they all suffered high profile data breaches. While Software Producers typically attempted to adhere to the rules, there were lapses in their Operations that led to the breaches. However, after the incident, their relative Complying Behaviors were clearly linked to the factors before it: limitations in the Enforcement or Complying prior to the incident indicated that they would also be less compliant afterwards.

5.4.1 Context & Environments

There is a chicken-and-egg relationship between the Threat Environments and Regulatory Environments. Specifically, the Threat Environments for Software Producers were all rated as Risky or Somewhat Risky. Additionally, the corresponding Regulatory Environment for Regulators, which describes the strictness of the regime in place, were rated as Strict or Somewhat Strict. This reflects a real-world relationship between the regulatory bodies and the software producers where the sensitive data being collected is understood to be at risk for harm to users, and requires regulatory involvement.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
SW Producers Threat Env	R-	R	R	R	R
SW Producers Regulatory Env	N	S	S	S	S
Regulator Regulatory Env	S-	S	S	S-	S-

Table 5.3: Antecedent Context Values for Finding 1. S = Strict, S- = Somewhat Strict, N = Neither Strict Nor Lenient. R = Risky.

Threat Environment

ICRC was rated as Risky for its Threat Environment particularly because of its highly variable threat surface: it operates in multiple countries, each with different technical needs, different regimes governing their use, and different potential attackers. Equifax was rated as Risky because it is such a high value target, and nefarious actors are known to be pursuing advanced tactics to compromise the data. Illuminate Education is considered only Somewhat Risky because the software producer had a slightly more limited threat surface, focusing only on education software, which would have had some valuable personal information, but not as much as the Red Cross or Equifax which deal with particularly sensitive data. WhatsApp (in CatalanGate) can be seen as risky because, while they were familiar with a variety of threats and regularly released security updates, they had such a massive user base that they were probably constantly under threat.

Regulatory Environment

There were similarities between the cases with Risky Threat Environments for Software Producers, and the Regulatory Context in which they operate. Both the Software Producers' Regulatory Environment and the Regulators' Regulatory Environment are considered to be Strict in the ICRC, Equifax, and CatalanGate cases. This means that the Software Producers closely adhered to their regulations, and Regulators strictly enforced them.

The Software Producers' Regulatory Environment is shaped by the regime that governs

them, and how it imposes on their business practices. In a sense, this is about how they interpret the regime created by regulatory stakeholders. In three cases, they were taking strict interpretations: ICRC had multiple national and international regimes to adhere to, and strict endogenous regulations; Equifax complied with a rigorous legal regime that protects the data it collects and stores about US consumers; WhatsApp was highly regulated in Europe, where the breach occurred, under the General Data Protection Regulation (GDPR). In these cases, failure to comply would severely affect their operations. Illuminate Education had a slightly less strict Regulatory Environment, given that there were/are less clear requirements for them to protect their data, and it is more likely that their customers (educational institutions) were responsible for data protection. However, this also depended on the jurisdiction where they operated.

The Regulator's Regulatory Environment is primarily comprised of the regime that emerges from the legal history, court rulings, legislation, national and local governments, etc. In the ICRC case the Strict regime emerges from multiple national and international governing bodies, which provided strict guards on actions, and pre-emptively forced compliance by the Red Cross' software implementation team. For Equifax, the Strict regime emerges from multiple federal agencies with broad mandates and robust enforcement methods, as well as strong protections for the data of consumer Users whose data is being collected. For Illuminate Education, the Somewhat Strict regime emerges from some national and state agencies that have varying enforcement abilities. For CatalanGate, the Somewhat Strict regime rating comes from the fact that while the EU had strict privacy and data security regulations in place, those requirements were mainly focused on consumer technology, and were very limited with regard to spyware. Additionally, Spanish authorities also had a Somewhat Strict regime in place, because although it was rigorous in its requirements for the use of spyware, such as ex ante and ex post documentation of decisions, it still mostly supported the use of spyware by their government.

5.4.2 Compliance Behaviors

Prior to the incident, the ICRC, Equifax, and WhatsApp were active in their Compliance Behaviors (although Equifax suffered some crucial lapses, which affected their actual Compliance State). Additionally, they were rated as High in their Compliance Behaviors in their Responses to the Incident. However, Illuminate Education was comparatively less Active and less Strict in its Compliance before and after the incident. This appears to reinforce the impact of the strict Regulatory Environments in which the companies operate.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
SW Producers Complying Before	N	A	A	A	P
SW Producers Complying After	N	H	H	H	L-

Table 5.4: Antecedent Conditions Finding 1. A = Active, P = Passive. H = High, N = Neither High Nor Low, L- = Somewhat Low.

Antecedent Operating Compliance

ICRC was considered Active in its Compliance operations because it must adhere to a uniquely complex regime designed for catastrophic situations which includes protecting user data, among many other concerns. They have a robust internal bureaucracy for creating and implementing their own policies, guidance, and rules. This was arduously documented. They also deployed software to be compliant with the non-functional, regulatory requirements of their users.

Equifax's Active Compliance was driven by the US government's strict regulations to protect consumer interests, including data collected by Equifax and its competitors. The financial industry and the credit reporting industry also have some self-regulatory bodies to protect their businesses by protecting consumers. As quickly as Equifax began to use computing for business in the 1970s, they also had to implement and maintain software

solutions to comply with regulations, in particular, a dispute resolution platform to respond to consumer complaints. This dispute resolution system is where the breach eventually occurred, decades later, and where they failed to adhere to required security measures. It stands to reason that they inadequately secured this capability given that it did not drive revenue for the company and instead was a cost-center. However, generally speaking, Equifax is active in its Compliance activities.

WhatsApp's parent company Meta was one of the main focuses of the development and implementation of the GDPR protections in Europe (e.g. the Schrems I and II lawsuits) [176] forcing their Active Compliance operations. They were under strict scrutiny, and in order to continue doing business in Europe, they were required to comply, unlike possibly smaller companies which may have been able to fly under the radar.

Illuminate Education would have had to implement technical solutions to comply with the regimes in the various jurisdictions in which they operated, for example, the "strict data agreement" with the NYC DOE. They also voluntarily signed onto the Student Privacy Pledge, an industry self-regulatory body. However, the enforcement capabilities of those bodies varied and Illuminate did not require as strict adherence compared to the other cases. Therefore, their Compliance operations were only rated as Neither Passive Nor Active.

Response Compliance Behaviors

Following the data breaches in each case, the Response Behaviors by software producers aligned with their Operating Behaviors: Red Cross, Equifax, and WhatsApp were highly compliant, and Illuminate was moderate (Neither High nor Low Compliance).

ICRC adhered to its regulations and best practices in this phase, addressing the issues of their Users and remediating the issue as quickly as possible, and eventually supplementing their policies with new security measures. Equifax's adherence activities were extremely

intense, beginning with testimony before congress, working with a government delegated third-party to remediate the issue, reporting on their remediation efforts, and later abiding by court rulings to provide compensation to affected users. WhatsApp were rigorous in their compliance efforts so they could work with regulators to prevent the future threat of the use of spyware against their technology, such as through the court system, as well as with privacy organizations that shared their interest in combating spyware through regime change.

On the other hand, Illuminate had very few required compliance behaviors, save those that were enforceable by their contracts (the NYC DOE for example canceled their agreements with the company). Courts ultimately dismissed complaints against them from Users. However, four years later, they were penalized by state-level regulators and forced to pay fines, as well as submit to new security compliance measures overseen by both state and federal regulators.

5.4.3 Finding

More risky threat environments (e.g. in the ICRC, Whatsapp, and Equifax cases) led to stricter Threat and Regulatory Environments (for both Software Producers and Regulators), which in turn resulted in a system where Software Producers were required to engage in more active compliance and adherence behaviors both before and after the breach.

5.4.4 Testing the Theory

The OPM case, which I used as my test case, is mostly in line with this finding, when considering some key details. Similar to the other cases, there was a Risky Threat Environment for the Software Producer, and a Somewhat Strict Regulator Regulatory Environment to try to mitigate that risk. However, unlike the other cases, the OPM as Software Producer

was Passive in Complying before the Incident, in spite of the Somewhat Strict Regime. This differs from the other cases, but for a very specific reason: For years, government had established cybersecurity guidance and rules for government agencies. This also included mandatory roles within agencies, including CIOs and IGs which also supported a relatively stringent regime. However, this oversight did not translate directly into enforcement abilities, leaving a gap just wide enough to allow OPM to shirk its compliance activities.

Furthermore, the OPM case demonstrates another aspect to this finding. OPM was evaluated to be Passive in Complying before the incident, and Somewhat Low in Complying after. This relationship between the antecedent and outcome Complying Behaviors match the finding to some degree, given that the behaviors were aligned across the conflict timeline, as was demonstrated in the other cases.

5.5 Finding 2: Regulatory Operations Impact User Outcomes

The Operational Context for Regulators sets the stage for their Operating Activities and Precursors. This also had impacts on the Remedies for Users after the incident. A Strong Operational Environment means that Regulators are effective in areas like rulemaking, enforcement, and influence, resulting in Strict regimes and Strong Capacity. In the Equifax breach case study, this Strong Environment exists, and there was a Somewhat Strong Environment in CatalanGate. In the other two cases, Illuminate Education and ICRC, the Regulator's Operational Environments were Somewhat Weak. The Operational Environment for Regulators has a clear impact on their Behaviors after the incident, as well as on the Outcomes of the Incident for Users, including better Remedies for Users when Regulators were more effective.

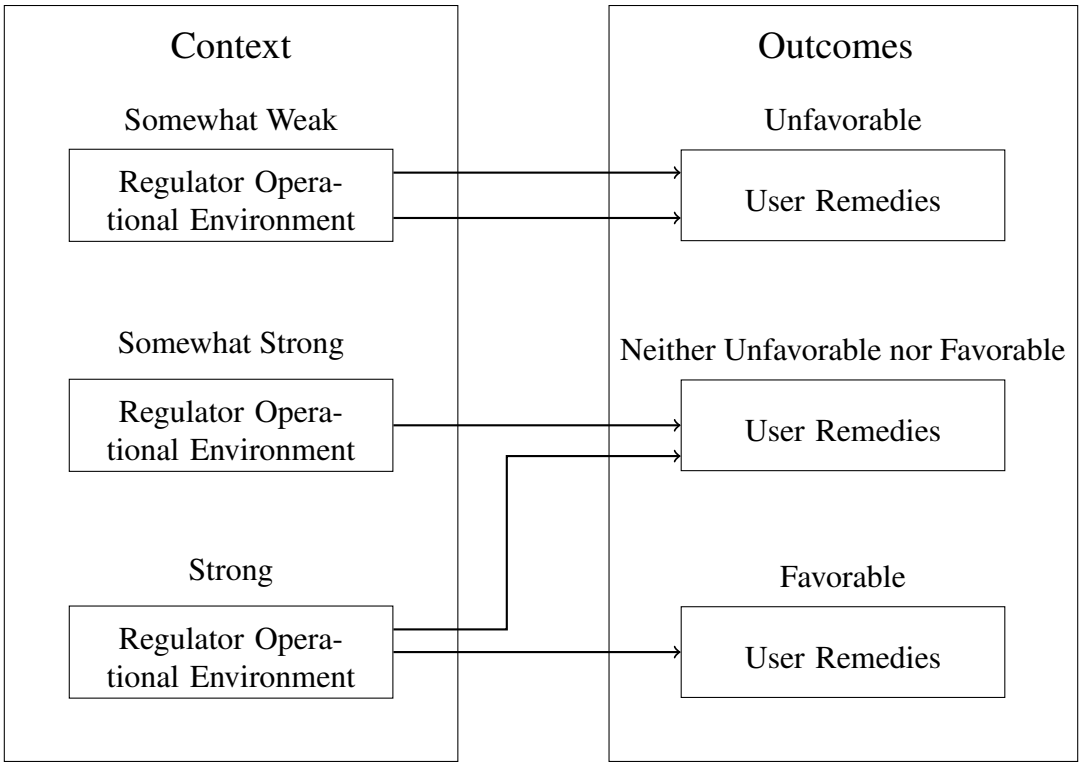

Figure 5.2: Context Impact on User Outcomes

5.5.1 Stronger Regulatory Operational Environments

In the Equifax case, the Regulatory stakeholders have strong operational abilities such as balancing business interests with data security restrictions, enforcement methods, and an effective hierarchy of agencies (limited gaps or overlaps in jurisdiction). Many enforcement methods are regularly employed, and can balance business interests with consumer protections. The political climate of the last 50+ years has frequently favored protecting consumer interests in the financial space. This is true for various regimes including the US, Canada, and the UK.

This Environment yields Active Behaviors including rulemaking, enforcement, investigation, and influence. Strict rules regulating the credit reporting industry rose as quickly as the industry itself did, stemming from case and statutory law, with the input of politicians,

consumers, advocacy groups, industry groups, lawyers, and judges. Rules continued to evolve, adapting to societal changes, with updates in likely every decade since 1970. Enforcement practices were commensurate with rulemaking, agencies (especially the FTC) and courts take action against Equifax and other credit agencies for violations frequently. Investigation is used both before enforcement action and after and CRAs like Equifax are under constant scrutiny by elected officials, agency bureaucrats, and advocacy organizations. The actions of the various regulators stand out as strong influence to encourage Equifax to adhere to rules, signaling their intentions, and shaping the regime. Successful enforcement actions promote the interests of regulatory agencies by publicly showcasing their abilities, and bringing in revenue in the form of fines.

These Operating Behaviors yield Strict Regimes, and Strong Capacity. The Regime that governs Equifax is robust, well-defined, and frequently employed against software producers. The FTC was active in enforcing cybersecurity, privacy, and other regulations against Equifax and similar companies prior to the incident. It had resources, experience, authority, knowledge, support, and funding to pursue violators.

Because there are some Outcomes of the Strong Environment that are not consistent with the Outcomes of the Weak Regulatory Environment, there are some corollaries we can establish by contrasting them.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
Regulator Operational Env	W-	W-	S	S-	S
Regulator Costs	N	N	H	H	H
User Remedies	U	U	F	N	N

Table 5.5: Regulator Operational Environment and User Remedies. W = Weak, W- = Somewhat Weak, S = Strong, S- = Somewhat Strong. H = High, N = Neither Low Nor High. U = Unfavorable, N = Neither Unfavorable Nor Favorable, F = Favorable.

5.5.2 Weaker Regulatory Operational Environment

In the Illuminate Education and ICRC cases, the Operational Environment for the Regulators is considered to be Somewhat Weak. This is true even though the Regulatory Environment for the Regulators is actually seen to be Strict or Somewhat Strict. The distinction lies in the Enforcement Behaviors of regulatory agencies, and their Capacity. They may be able to make rules (i.e. a Strict Regulatory Environment), but they have a hard time enforcing them, or using them to push for favorable outcomes for the people they are supposed to protect (i.e. a Somewhat Weak Operational Environment).

The impact of the Weaker Regulatory Operational Environment is that Enforcement is Somewhat Passive. For Illuminate Education, the regulations appear to provide various responsible agencies with a variety of enforcement mechanisms should a conflict occur, however they do not seem to have been used for data breaches in education technology. For ICRC, Enforcement methods against ICRC and its National Societies are limited. If they upset their host countries or other actors, they may not be allowed to operate. If they lose the trust of their beneficiaries, they may cease to be users. But there do not seem to be any prior cases regarding data breaches where this occurred. For both cases, the Capacity of Regulatory agencies to enforce data privacy and security rules is extremely limited; there is little, if any, documentation of dedicated resources prior to these cases. However, this changed in 2025 when state regulators formed a new partnership to pursue violations of state-level data privacy regulations, including in edtech, and specifically against Illuminate Education.

5.5.3 Impacts on User Outcomes

Within the two cases with Weak Regulatory Operational Environments, there are related Outcomes that contrast with more Strong Environments. Additionally, the Outcomes in the

Equifax case are notable compared to other cases with Strong Environments, and the data from this case can be compared to others to provide reasonable predictions for other, similar cases.

Favorable User Remedies & High Regulator Costs

The most clear correlations in Outcomes are in the User Remedies and the Regulator Costs. For the Equifax case, with a Strong Regulatory Context, the Remedies for Users can be seen as Favorable. Users received compensation from the court settlement, typically up to $125, with protection for up to $20k if there were additional, direct harms. Users also received free privacy monitoring services. At the same time, the Regulators poured immense resources into regulatory actions including ongoing investigation and multifaceted enforcement from multiple agencies, including the legislative and judicial branches in the US, and regulatory bodies in Canada and the UK. These Outcomes seem to flow directly from the Strong Operational Environment.

Unfavorable Remedies & Low Regulator Costs

On the contrary, for Illuminate Education and ICRC, the Remedies for Users were both Unfavorable: no compensation was collected in either case. Simultaneously, costs to Regulators were moderate (Neither Low nor High). Some resources were spent by state regulators to investigate Illuminate, but no major costs were incurred for enforcement or remediation. The Red Cross Movement spent limited resources on remediating the incident and establishing new processes. Once again, there is a clear correlation between the antecedent context and the consequences.

Note: Impact of User Posturing or Compensating Behaviors Between the two cases with Unfavorable Remedies, contrasting methods were employed by Users in Posturing and Compensating, demonstrating that these methods likely did not have an impact on the Outcomes.

In Illuminate Education, parents of affected students were Active in Compensating Behaviors by suing in court. This happened multiple times and eventually all the cases were consolidated into a class action, which ultimately failed. Affected users were also Active in Posturing by speaking out publicly, connecting with advocacy groups who also made statements. At the other end of the spectrum, ICRC Users were completely passive, partly by nature of their situation. They took no action to Compensate nor Posture. Regardless of either extreme in Behavior, the resulting Remedies for Users was the same: none. This helps confirm that Favorable Remedies for Users are highly connected to the Regulatory Operational Context that precedes the data breach, not the actions of the Users.

5.5.4 Finding

The data indicates a correlation between the Context surrounding the cases before the incident and the Outcomes for the people affected by it. A Strong Environment for Regulator Operations, including capacity, enforcement, and investigation directly correlated to positive remedies for Users. Inversely, a Somewhat Weak Environment led to unfavorable outcomes for users. This correlation held despite differences in User activities, such as Compensating and Posturing behaviors, leading to the conclusion that User efforts alone have little effect on User outcomes.

5.5.5 Testing the Theory

The OPM case supports this finding, given that the Strong Regulator Operational En-

vironment led to High Costs to the Regulators after the Incident, and moderately favorable outcomes for Users afterwards.

5.6 Finding 3: Capacity Does Limit User Response, Remediation, and Recovery

The Capacity of Users before an incident describes their abilities to help secure their data, as well as the resources they have available to respond to data breaches if and when they occur. The data indicates that this antecedent Capacity was not usually an indicator of whether or not Users used Posturing as a Response, meaning they were able to raise their concerns in some cases, even when they had limited resources at the outset of the incident. Additionally, they were able to pursue Compensating behaviors after the incident to try and receive some remedies for their harms.

5.6.1 Precursor Capacity

Prior to the breaches in Illuminate Education, Equifax, and CatalanGate, end users were only loosely affiliated, and are seen to have moderate Capacity (or Low, in the case of Equifax) to support data security with their respective software, and protect themselves before and after breaches. In the ICRC case, Users also had limited Capacity, but the case is so different from the others, it is difficult to find a connection between the Response efforts.

The User Capacity in the CatalanGate case stems from Operating Influence Behavior by activist organizations, who were very active in their field, creating opportunity for regime change in the future.

Responses

Despite the limited Capacity of end Users before the Incidents in Illuminate, and Equifax, the Responses afterward were Active. In each of these cases, Users were Active in their Posturing and Compensating efforts in particular. Affected users spoke out publicly about the breach. They connected with legal teams for lawsuits, and advocates for support, who also made statements. Parents of affected students also sued Illuminate in court for compensation, and unsuccessfully attempted to find legal grounds to sue. Equifax users were successful in their legal efforts after a large campaign.

However, in CatalanGate, there was an active network of advocacy organizations that worked together to protect high risk targets for spyware, and this resulted in a uniquely Active Correcting Response in an effort to change the regulations in place. So, while Users were less Active in pursuing compensation in the courts, their activist representatives were diligent in attempting to create new protections for the future.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
User Capacity	N	L-	L	N	N
User Posturing	A	P	A	A	A
User Compensating	A	P	A	A-	A
User Correcting	A-	A-	P	A	P
User Complying	P-	P	P-	N	–

Table 5.6: Finding 3: User Capacity and Responses. N = Neither Low Nor High, L = Low, L- = Somewhat Low. A = Active, A- = Somewhat Active, P = Passive, P- = Somewhat Passive. N = Neither Passive Nor Active. - = No Data Available

Finding

This indicates that Precursor Capacity is not a determinant of Users ability to speak out publicly about an incident that affects them, nor seek meaningful compensation. Following a breach, Users are able to find resources to help them pursue remediation. For example,

in the Equifax case, while there are many consumer advocacy groups, the generic nature of their work coupled with the massive number of affected users did not add any Capacity prior to the incident. However, they were able to pursue an historic lawsuit against the company with legal support and in conjunction with regulatory enforcement. In regard to the Illuminate Education breach, the end users, who were primarily made up of students, had little capacity to address their security or protect their interests after a breach. However, the subject matter expert interviewed indicated that it was likely the parents of affected students in wealthy areas that were able to pursue legal action, particularly those who had legal training themselves.

Note: The only confounding factor to this finding was the ICRC case, in which end users had limited Capacity similar to the other cases, but they did not pursue Compensation or make any observable Posturing efforts. The unique nature of this case, which involved highly vulnerable populations in critical situations, such as disaster and conflict, makes it an outlier in this Finding. Their experiences, along with their diffuse geographic locations, made them even more limited in their ability to respond. Furthermore, the ICRC provides humanitarian services that they may have wanted to continue using, without other options, despite the incident.

5.6.2 Testing the Theory

The OPM case supports this finding, as it was very similar to the other cases. Prior to the breaches, OPM, as in Illuminate Education and CatalanGate, end users were only loosely affiliated, and are seen to have moderate Capacity to support data security. The Responses afterward were similarly Active, as Users were Active in their Posturing and Compensating efforts in particular.

5.7 Finding 4: User Responses Impact Costs, but not Necessarily Remedies

Finding 4 concerns the drivers and impacts of User Responses to the breaches, specifically Posturing and Compensating. Posturing and Compensating behaviors had only one clear impact, an increase in Costs to Users. However, those efforts did not necessarily improve Remedies.

5.7.1 Active Posturing & Compensating Response

In the Illuminate Education and Equifax cases, Users' Response to the Breach is seen as Active for both Posturing and Compensating. The Behaviors in each of these cases at this stage resemble each other quite a lot. The cohorts of Users suffered from privacy violations by American organizations in industries that are perceived to be regulated because of the sensitive, and high risk nature of the data. After the breach, in these cases, Users formed networks with advocacy groups and lawyers, made public statements, and filed lawsuits against the software producers. All sets of complaints were consolidated into class action lawsuits in national courts. However, the Remedies varied widely between each case.

In CatalanGate, by comparison, the Posturing was Active, but the Compensating was only Somewhat Active. This is demonstrated by a lack of major lawsuits by the affected users, which changed the Outcomes for users in that case.

Outcome Costs and Remedies

In Illuminate and Equifax, Users hired lawyers to represent them in court, which incurred Costs to them. In consumer class action lawsuits it is most likely that the lawyers incurred the costs without the Users paying anything. So, while affected Users did not in-

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
User Posturing	A	P	A	A	A
User Compensating	A	P	A	A-	A
User Costs	U	N	U-	U	U-
User Remedies	U	U	F	N	N

Table 5.7: Finding 4: User Responses and Outcomes. A = Active, A- = Somewhat Active, P = Passive, P- = Somewhat Passive. U = Unfavorable, U- = Somewhat Unfavorable N = Neither Unfavorable Nor Favorable, F = Favorable

cur much monetary costs, they did spend time and energy pursuing the case. Only the legal teams that formed a network with the User group that took on substantial Costs to pursue Compensation for their clients, and ultimately themselves.

In Illuminate Ed, the lawyers representing the Users incurred Costs, but received no Compensation for their work. This means that both the Users and their legal representation would have spent greatly but not received favorable compensation for their efforts.

For winning the Equifax case, lawyers in that suit collected around $80 million in fees, which came out of the total settlement for the affected users in the US. So, while the Compensation for affected Users in the Equifax breach received a Favorable compensation, they still had Somewhat Unfavorable Costs to get it. Additionally, while Users filed in court in the Equifax case, FTC regulators also filed suits against Equifax, and won that suit as well. In principle, Equifax did not pay twice as much for losing twice, but both losing decisions reinforced each other. One could ask the question of whether it was worth it for the Users to incur their own costs if the regulators were going to win is an open question. If lawyers representing the class action did not receive fees for winning, then an additional $80 million may have been available to affected Users. Per Finding 5.5, if there is a clear path to regulatory enforcement, Users may want to ask themselves this question before pursuing legal action. However, it is reasonable to assume that the regulators may not have been able to pursue effective Compensation for consumers, and lawyers representing the lawsuit would have insight into whether a consumer class action lawsuit could possibly

result in better Remedies for affected Users. This can also vary by jurisdiction, but is similar in Canada and US, although different in the UK.

In CatalanGate, Responses by advocacy groups were focused on Correcting Activities to amend the regime going forward. The result is that the Remedies for Users were Neither Favorable Nor Unfavorable, because going forward they may enjoy better protections, but not at this point. The costs for users were also considered High because many of them suffered direct harms, professional and personal, from the breaches.

5.7.2 Note: Passive Posturing & Compensating Response

In the ICRC case, Users were Passive in their Posturing and Compensating responses. In essence, there does not appear to be any action taken. In particular, there were no efforts by Users to Compensate themselves for the breach. Furthermore, the Red Cross Movement, including the internal customers of the software, made few public statements that could be seen as Posturing. This is largely because of their need to stay neutral in international conflict, condemning a presumed actor could impact their ability to support their beneficiaries in the future.

So, while the Remedies in the ICRC breach are seen as Unfavorable, the Costs were mitigated by not expending resources on Posturing and Compensating. Only the Costs associated with the direct impacts of the Incident are present.

5.7.3 Finding

The idea that, when Users expend resources, they can be successful at getting Compensation, is not necessarily true. Spending resources in an attempt to receive Compensation for the data breach was a losing endeavor for the end Users in the Illuminate Education breach, even after new action by regulators years later, demonstrating that there must be

careful consideration before pursuing action. Furthermore, this finding reinforces the factors in Finding 2, that Regulatory Operations have a more measurable impact on User Outcomes, rather than User Response Behaviors.

5.7.4 Testing the Theory

In OPM, this finding was supported. The users were represented by their unions, who would have been responsible for the costs associated with litigation. Furthermore, this type of protective action is what unions are supposed to do with their funds, so the direct costs to consumers were minimal, aside from their already-committed dues. However, because we also measure Costs to include the harms done as a result of the breach, the OPM users were at higher risk to abuse of their data, because of things like security background information, so their Costs were evaluated to be Somewhat Unfavorable. Additionally, despite efforts by unions to improve the Outcomes for Users, they still did not receive Favorable or even Somewhat Favorable Remedies.

5.8 Finding 5: Correcting Activities and Their Outcomes

Correcting activities in response to incidents were carried out by all stakeholders in most cases, but the most impactful efforts were those by Regulators and Software Producers. For User Remedies, the best outcome was achieved when both Regulators and Software Producers were Active in their Correcting Behaviors (synonymous with Enforcing for Regulators), specifically in the Equifax case. However, this relationship was not a sufficient condition for the best Remedies for Users. When Software Producers and Regulators were more Active, but there were not great outcomes for Users, this typically correlated with High Transformations.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
SW Producer Correcting	P-	A	A	A	N
Regulator Correcting	A	A-	A	A	A
Regulator Remedies	U	N	U-	U	U-
User Remedies	U	U	F	N	N

Table 5.8: Finding 5: Regulator Correcting/Enforcing and User Outcomes. A = Active, A- = Somewhat Active, P = Passive, P- = Somewhat Passive, N = Neither Passive Nor Active. U = Unfavorable, U- = Somewhat Unfavorable N = Neither Unfavorable Nor Favorable, F = Favorable

5.8.1 Favorable User Remedies

Correcting Behaviors were often undertaken by both regulators and software producers. Regulators in particular were always typically Active or Somewhat Active in some way. In the Equifax case, both the Software Producer and Regulators were Active in their Correcting Activities, leading to optimal results. Equifax undertook much of this activity on its own volition, but some was also mandated by Regulators. These behaviors are also connected to Finding 2, and here there is a connection between the Behaviors after the Incident, in addition to the Context before it.

In response to the breach of Equifax, multiple regulatory agencies took multiple actions, resulting in Regulator Remedies that are considered to be Strong. Enforcement actions (Remedies) included investigation, fines, mandated compensation, ongoing monitoring, and engaging with networks to achieve these goals. The company itself had to restore software, change business processes (including firing staff), and dedicate massive resources to making fixes. They also worked with an external cybersecurity company that reported to the Regulators. This also had the Outcome of Unfavorable Costs for Equifax, which paid dearly for all of these Activities, and ultimately in the settlement with affected Users.

In the Equifax case, Active Correcting Activities by both the Regulators and Software Producer led to Strong Remedies enforced by Regulators. This in turn yielded the only

case with Favorable Remedies for Users. Users received compensation from the court settlement, typically up to $125, with protection for up to $20k. They also received free privacy monitoring services. Regulators also fined the company, resulting in revenue for themselves.

5.8.2 Less Favorable User Remedies

In Illuminate Education, Regulators took very few Correcting Actions against the company, despite state Regulators becoming heavily involved. The result was that Users had Unfavorable Remedies. In CatalanGate, while the Software Producer and Regulators were Active in Correcting Activities, they did not take action in favor of Users, resulting in less Favorable Outcomes for them. In the OPM case, Regulators were Active in Correcting Activities, but once again, the Software Producer was not, and ultimately Users received less Favorable Outcomes than in Equifax. It is worth noting that there was a successful lawsuit against OPM, but Users did not receive the same level of payout as in Equifax.

In Illuminate Education, government regulators initially took very few Corrective or Enforcement actions in response to the Incident. At the national level there was little activity, but some school districts (like NYC) did enforce the terms of contracts with customers by canceling contracts. An industry association also removed the company from its program. Simultaneously, Illuminate Education took little action after the incident, remaining silent publicly, sealing court documents, and making no public effort to resolve issues with the affected Users. However, in 2025, a new partnership of state regulators pursued Correcting activities against Illuminate Education in a novel effort to enforce privacy regulations, eventually fining them $5.1 million. Regardless of this regulatory action, Court Regulators did not find in favor of the Users in the class action lawsuit against Illuminate Education, saving the company from paying millions of dollars in Compensation. Further-

more, the fines levied by the state Regulators were not part of any Remedies paid to Users. Altogether, this reflects Unfavorable Compensation for Users.

The ICRC case in this finding is somewhat of an outlier. As the end users had little Capacity to seek any form of Remedies, and because there was no direct involvement by Government Regulators in particular, the User Outcomes were Unfavorable. Although the ICRC as Software Producer and internal Regulators were Active and Somewhat Active, respectively, this did not translate into Remedies specifically for their end Users.

In the CatalanGate case, Regulators and Software Producers were active, but mainly in an effort to solve problems they saw in the regulations. For WhatsApp, that meant seeking Compensation from NSO Group in US Courts. For European Regulators, this meant investigating NSO Group, then pursuing new regulations to protect Users going forward. Within Spain, the Court Regulators have not been sympathetic to the lawsuits of the Users, finding that the breaches were justified legally. This has resulted in less than Favorable Remedies for Users.

5.8.3 Transformation as an Outcome

Transformations describe changes such as new processes, networks, or policy changes that arise following an incident. These can be limited to the stakeholders in the case, but some Transformations extend beyond the case itself and set new precedent for future conflicts. In the three cases above, there were Regulator Correcting Behaviors that were considered Active. In these cases, instead of better outcomes for Users, there was a higher degree of Transformations observed. Whereas in the Equifax case, Remedies for Users were the best, but there was little Transformation.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
Regulator Enforcing	A	A-	A	A	A
Regulator Transformation	H	L-	L	H-	H-
Regulator Preservation	N	H-	H	H-	H-

Table 5.9: Finding 5: Regulator Correcting and Transformation Outcomes. A = Active, A- = Somewhat Active, P = Passive, P- = Somewhat Passive, N = Neither Passive Nor Active. H = High, H- = Somewhat High, L = Low, L- = Somewhat Low, N = Neither Low Nor High

5.8.4 Favorable User Remedies

A novel approach to Correcting Behaviors by Regulators in the Illuminate Education case resulted in important Transformations to the regime, although it did not have drastic benefits for Users. Specifically, a new partnership was formed between multiple state Attorneys General to pursue legal action for data privacy violations, and Illuminate Education was their first target. This new state-level enforcement sets the stage for new approaches to regulatory enforcement going forward, as the Regulators determined they did not have the right tools to enforce data privacy protections for students and children. However, the federal enforcement changed little, and at the national level, the regime would be characterized by Somewhat High Preservation for Regulators, meaning that the national regime remained predominantly intact.

In the Equifax case, Active Correcting Activities by Regulators had a unique correlation with the Transformations and Preservation of their Operations following the Incident. The Outcome was that no major Transformations occurred, and there was High Preservation. Due to the effectiveness of the existing regime, Regulators preserved their mandate, showing that it is effective and can respond to issues without major changes. In essence, they demonstrated that future cybersecurity Incidents would be handled in the same way. This could be connected to the fact that millions of consumers were able to claim compensation, and major fines were levied.

In the CatalanGate case, Regulators, as well as the other stakeholders, worked aggressively on Correcting Activities that were focused on reforming regulations. These Response activities ultimately led to Transformations for Regulators, including new laws that protect these Users going forward, such as the EMFA and ECRA.

5.8.5 Finding

Correcting Activities had different Outcomes. When both Software Producers and Regulators took more Corrective actions, Users benefited through better Remedies, such as in Equifax. When Regulators were Active in Correcting, there was also the opportunity for Transformation, particularly when there was a perceived gap in the regime, such as in Illuminate Education, CatalanGate, and OPM.

5.8.6 Testing the Theory

The OPM case supported this finding. In the test case, Regulators were Active in Correcting Behavior, including enforcement actions and finding in favor of the plaintiffs in their lawsuit against OPM. However, the Outcomes for Users are considered Neither Unfavorable Nor Favorable because the amount of money they received as a result of the suit, and the number of people who were able to make claims, was extremely limited.

With regard to the Transformation Outcomes, following the OPM data breach, Regulators heavily reformed cybersecurity regulations for federal agencies, moved the Software Producer responsibility out of OPM's hand, and forced a change in leadership at the agency. While Regulators had attempted to improve cybersecurity efforts in government and nationwide previously, the OPM breach revealed shortcomings that needed to be addressed. These were major Transformations both in the regime, and for the Software Producer itself.

5.9 Finding 6: Regulator Precursors were a Determinant of their Responses and Outcomes

The strength of the Capacity of the Regulators, and the strength of the Regime before each Incident directly correlated with the Complying Response Behavior as well as the Remedy Outcomes after each Incident. However, some level of Preservation was a common Outcome for Regulators across all Capacities and Regimes.

Stakeholder / Case	Illuminate	ICRC	Equifax	CatalanGate	OPM
Regulator Capacity	W	N	S	S	S-
Regulator Complying	A-	N	A	A	A
Regulator Remedies	N	N	S	S	S

Table 5.10: Finding 6: Regulator Capacity and Outcomes. W = Weak, N = Neither Weak Nor Strong, S = Strong. A = Active, A- = Somewhat Active. S = Strong, N = Neither Weak Nor Strong.

5.9.1 Stricter Regimes and Strong Capacity

In the Equifax case, Regulator Capacity was Strong, as the FTC was active in enforcing regulations against Equifax and similar companies. It had resources, experience, authority, knowledge, support, and funding to pursue violators. Additionally, the regime was Strict, well-defined, and frequently employed against software producers similar to Equifax. This resulted in various agencies Complying with their mandates in taking actions: pursuing compensation, conducting investigations, making legal decisions. Remedies included enforcement actions like investigation, fines, mandated compensation, ongoing monitoring, and engaging with networks to enforce the Strict Regime. Ultimately, Regulators Preserved their mandate, showing that it is effective and can respond to issues governed by the regime.

In CatalanGate, the European and Spanish governments had Strong Capacity to handle data privacy and security incidents concerning consumer companies like WhatsApp,

and had demonstrated their abilities regularly. However, the Regimes can only be considered Somewhat Strict because of the limited rules for incidents resulting from the use of spyware. In Spain particularly, the Regime favored the government agencies responsible for deploying spyware in situations concerning national security. Compliance Responses by Regulators were very active, including thorough investigations by both EU and Spanish authorities. The Preservation Outcomes for this case are only considered Somewhat High because there were calls for regulatory change, and some new regulations have made progress in transforming the Regime, including the Pall Mall Process and the European Media Freedom Act. However, these are not rigorous Transformations to the existing regimes, but stepwise additions to protections, and the existing Regime remains largely unchanged.

5.9.2 Weak Capacity and Somewhat Active Rulemaking

In the Illuminate Education case, the emergent Regime was more Lenient than Strict in enforcing student data privacy regulations prior to the incident, especially against third-party Software Producers. Although they appear to have strict regulations in place for students, regulators actually had limited Capacity to enforce the law in data breach situations. As a result, in Response to the Incident, Regulators initially followed the Lenient regime that was in place, canceling agreements in some jurisdictions, but taking little further action, and not upholding the claims of the User plaintiffs in court. Illuminate Education was not governed as strictly as the education bodies it served would be if they had instead been breached. However, new precedent was set when state level regulators introduced new methods of enforcement against companies that violate data privacy regulations, increasing their Capacity going forward. This is likely due to the Somewhat Active Rulemaking Operations prior to the incident, which paved the way for Somewhat High Transformation and improved Remedies for the Regulators themselves.

5.9.3 Finding

This comparison between the antecedent characteristics of Regulators helps to demonstrate the usefulness of the model in describing their behaviors after the incident, as well as some of the results. Less effective Regulators, typified by Lenient Regimes and Weak Capacity, limited their ability to protect users that suffered a data breach. However, when coupled with more Active Rulemaking Behaviors, and a compelling interest to protect critical data, such as that of students, Regulators were able to Transform the Regulations, and set new precedent. Meanwhile, Stricter Regimes and Stronger Capacity meant the Regulators could take more action immediately after an incident, and this demonstrated their effectiveness, which also allowed them to Preserve the extant regulatory situation.

5.9.4 Testing the Theory

The OPM test case supports this finding, with Strong Capacity before, and Active Complying and strong Remedies after. In the OPM case, for years, the US government had established cybersecurity guidance and rules for government agencies, as well as providing resources to support such efforts. They also required the existence of CIOs and IGs within agencies, which supported Regulatory Capacity, and supported a more Strict regime. Furthermore, the government had enormous capacity to address potential cybersecurity failures and to ensure compliance by their agencies. However, some enforcement capacity, which was added later through CISA, was lacking at the time of the OPM breaches. After the breach, Regulator Remedies included a strong incentive to address the issues that led to the breach, mainly by improving security standards, but also in providing remedies to victims. Additionally, Regulation and enforcement were improved, and new precedence was set in dealing with these issues, demonstrating some Transformation. But overall, the roles of Regulators and the rules stayed the same, with some new enhancements.

Chapter 6: Discussion

The objective of the grounded theory was to answer three research questions, reiterated below. The theory and model can be applied to a variety of situations in data privacy and security, and by any stakeholder. I will discuss the "when" and "how" of these applications in this section, as well as further implications for my results, including relationship to the literature and limitations.

RQ1: What are the types of conflicts that occur between stakeholders related to software security?

RQ2: What are the patterns of conflict management between software users, producers, and regulators in achieving software security?

RQ3: How can cooperation between these stakeholders be facilitated?

6.1 RQ1: What are the types of conflicts that occur between stakeholders related to software security?

As described in the introduction, and my proposal, there are a lot of conflicts that can occur between stakeholders related to software security. In this dissertation, I have focused on social conflict in the area of data privacy and security in software engineering.

Through empirical analysis of real-world cases, I investigated the conflict and cooperation that occurs between stakeholders before and after a cybersecurity incident.

An incident itself presents a conflict that helps set the conditions for cases to be studied. In each case, a software producer suffered unauthorized access to data that they were expected to secure. They were expected to secure this data by their users and by regulators. In these incidents, the software producers, users, and regulators are stakeholders, and because they have interests that do not align with unauthorized access to the data, they are in conflict. The composition of the stakeholders, as well as their interests, responsibilities, rights, and powers vary by case. This is also true for their relationships, approaches to addressing the conflict, and the results of their efforts. However, there are patterns in these characteristics and behaviors, and I have described them in my grounded theory.

The software producers in these cases provide various services for their users, which include business customers, free users, people in need, passive participants, and others. Ultimately, the software producers were entrusted with the data they collected from their users, no matter how they interacted with the software. This trust was codified and enforced by regulators who established binding and nonbinding requirements to secure the data being collected, and protect the people who used the software. These regulations, rules, requirements, and laws were developed over time, based on the changing nature of technology and society. Regulators took into account the interests of the software producers and the users to create these requirements. Users and software producers rely on these requirements for their protection, and to understand what their rights and responsibilities are when it comes to data privacy and security. When a cybersecurity incident occurs, all of these parties are stakeholders to the incident, and they are in need of conflict management to address the problems that arise, and find solutions.

The software producers and users can both suffer harms because of cybersecurity incidents. Users can have financial issues, human security problems, and emotional distress,

among other things. Software producers can suffer from reputational harm, loss of revenue, fines, and negative impacts on employees. My model demonstrates that while software producers, users, and regulators may be in conflict due to the risk and realization of cyber incidents, they also have some aligned interests in finding the best outcomes to solve these problems.

6.2 RQ2: What are the patterns of conflict management between software users, producers, and regulators in achieving software security?

Through my model and theory, I have described the patterns of behaviors and their outcomes by stakeholders when attempting to manage conflicts in software security.

One component of my analysis is the matter of time. "Time is everywhere in cybersecurity research" according to Tim Stevens [72]. I have described the antecedent conditions and the consequences of cybersecurity conflicts over time. Furthermore, my theory incorporates a cyclical approach to time, given that cybersecurity incidents occur again, and again, and again. One key observation that resulted from my research is how much time can expend before key behaviors occur when addressing data breaches. In my pilot case study, which occurred in early 2021, major regulatory enforcement did not occur until late in 2025. For followers of regulatory compliance, this timeline is seen as nominal, but for investigating real-world cases, this can put a strain on the research process.

There was a consistent pattern of litigation in all cases except for one. This rights-based effort for conflict management may seem like an obvious response, but it presents some important factors for discussion. First, the overwhelming use of lawsuits after data privacy incidents demonstrates a crucial method for affected users to get compensation, but also to try to punish companies for failures. Furthermore, regulators also contribute to litigation against companies for cybersecurity failures. Successful lawsuits in these cases can lead to

modest cash payments to users, but taken together, and along with fines, they can be costly for the software producers. More broadly, it demonstrates that there may not be other methods for users to manage data privacy and security conflicts with software companies, such as through interest-based negotiation. That being said, it is clearly impractical to bring thousands or even millions of users to the negotiating table, which is precisely why class action lawsuits exist. It is also why regulators have a role in suing software producers for violations.

Another consistent behavior was the offer of identity theft and credit monitoring services by the software producers after the breach. While they frequently provided this prior to any litigation, it was also often included in settlement agreements. Contrary to the rights-based approach of litigation, the monitoring service offer represents some interest-based approaches to managing the dispute. By providing these tools the software producer acknowledges that the data breach could have an effect on affected users, particularly through financial crimes, and identity theft/credit monitoring can help meet their needs.

Another set of patterns described explicitly in the model are the posturing efforts undertaken by all stakeholders. Users connected with legal representatives, data privacy advocates, and other civil society organizations to speak publicly about the harms they suffered, and to support their interests in getting compensated. Regulators released statements, worked with cybersecurity experts, implemented nonbinding rules, and threatened legal actions to support enforcement. Software producers also made public statements, although they also postured by limiting publicly available information. These efforts seem like a natural response to managing data privacy conflicts, although their effectiveness varied in each case. Regardless of the outcomes in the cases, the more posturing activities that were undertaken, the higher the costs were, because it takes resources to make these efforts. A noteworthy example of this was Illuminate Education's approach to posturing through concealment. Specifically, they sealed court documents, which would have added extra costs

and (potentially substantial) work for their legal team.

The data, specifically Findings 2,4, and 5, showed that behaviors that led to the best outcomes for the users over the course of a case were strict regulatory regimes prior to an incident, as well as active enforcement activities by regulators and active compliance activities by the software producers after the incident. This was demonstrated primarily in the Equifax case, when users received the largest compensation package out of all the cases I analyzed. Further analysis of other data privacy litigation that resulted in compensation for users, such as those in [109, 175], which include analysis of dozens of such lawsuits.

The other notable patterns were those that led to important changes for future cases, cases that had an observable Aftermath phase (Section 5.1.2) resulting from key transformations to regulations, as shown in Finding 5. In these cases, the unique combination of novel approaches to cooperation, the identification of gaps in enforcement mechanisms, and a shared perception of the critical nature of the data that was compromised led to changes in the regulatory, threat, and operational environments for stakeholders going forward. When stakeholders were able to capitalize on these trends, they were able to work together to improve data security and privacy to meet their mutual interests. This has positive impacts on commerce, security, and well-being for all parties involved. This is a key insight from my research, that for lasting impacts to occur from a single case, there must be new methods of cooperation. This occurred in three cases, and, taken together with other factors, led to crucial impacts on data privacy and security. These examples were unique in each case, and did not always include all the stakeholders.

As a caveat, the other two factors connected to disruptive aftermaths, gaps in enforcement methods and a perception of the critical nature of the compromised data, are not always discernible or actionable while a case is unfolding. For example, one group may think that the compromised data may be critical, but others may not. Or, stakeholders may not be able to pursue new methods of enforcement for a variety of reasons. Regardless, un-

derstanding that the combination of these three factors might lead to critical changes to data privacy and security protections is important for stakeholders so that they can seek them out when possible to make change, and retrospectively observe them so they understand how the change came about.

6.3 RQ3: How can cooperation between these stakeholders be facilitated?

The theory and model I have developed may be useful in facilitating cooperation between stakeholders before and after data breaches. As a model of the system of behaviors and outcomes in cybersecurity breaches, practitioners and researchers can better identify their options to achieve the best outcomes. They can do this both before and after incidents occur. In particular, the four categories of behaviors undertaken by all stakeholders following an incident are posturing, compensating, correcting, and complying. These categories are parallel for each stakeholder because they reflect the shared concerns that each has after a cybersecurity incident. While their actual behaviors within those categories differ based on their roles and their interests, this symmetry still demonstrates opportunities for cooperation. Given that the theory of regulate, recover, repeat is cyclical in nature, these responses are also preludes to future conflicts.

Prior to an incident, stakeholders can use the model to analyze their current status, as well as look at existing cases in similar contexts to determine what they are doing that could set them up for success or failure if and when a breach occurs. In Finding 3, I described the ways that users in particular can build their own capacity in advance of data breaches. Some aspects of this are already occurring, such as the lawyers at the software producer being familiar with the regime in place. Another example is that stakeholders should be aware of the advocacy organizations that represent the users in the industry they are in, and have open lines of communication with them.

After an incident, stakeholders can use the model to look at what the net effects may be of any of their behaviors and those of the other stakeholders. The model is especially practical in this area as the behaviors and outcomes for each stakeholder are in nearly identical categories. This makes it easy for any stakeholder to understand the relationship between their actions and the others'. As described in Finding 5, it is possible for stakeholders to consider the transformations resulting from the incident to determine whether broader changes are possible, or necessary.

One area where cooperation can be facilitated is improving the capacity of all stakeholders to address data privacy and security. In the model, each stakeholder has a certain level of capacity, based on a variety of factors. Capacity is also documented as a characteristic that can improve cybersecurity in other research [2, 83]. Capacity is frequently driven not by any one stakeholder, but by relationships with other parties that help improve their capacity. For example, users are often represented by advocacy groups that provide training and resources, among other things. For software producers and regulators, this capacity is often supported by external cybersecurity vendors, including technical and legal experts. It is likely that these different expert resources have some connections to each other, such as through industry conferences, but facilitating open relationships between them and their clients could help improve outcomes. For example, in the Equifax case, one of the advocacy organizations was US PIRG, which represents consumers in a variety of ways. Equifax and federal regulators had a relationship with cybersecurity company Mandiant to help reinforce their cybersecurity. Together, organizations like organizations could help build capacity for all stakeholders. Privacy advocacy groups likely maintain such connections with cybersecurity firms, but there also may be more adversarial relationships between actors, such as privacy advocates and large software companies, when they do not perceive their interests to be in alignment. By coordinating their efforts, they may be able to improve security through a united front, and seeking new solutions. This

was demonstrated in the CatalanGate case, when privacy advocates cooperated with Meta on the lawsuit against NSO Group. While normally that relationship is strained, the novel cooperation helped improve outcomes.

One way to support this type of coordination could be through conferences. Disparate stakeholders, even those who feel uninitiated in cybersecurity, can still find opportunities to develop coagency in these settings. James Shires describes cybersecurity conferences as "ritualized activities" that can help create "expert community across international boundaries despite significant political and social differences" [259]. Finding new ways for stakeholders to cooperate could be instrumental in supporting data privacy and security. Shires goes on to say that "cybersecurity expertise should not be thought of as a gap to be closed, because the requirements for successful performance grow together with the widening of the domain." As the threat to users, software producers, and regulators continues to be a problem, there must be new modes of cooperation to support their mutual interests.

Another example of the cooperation appears in research on collective action for remediating data privacy breaches. Wu, Edwards, and Das developed a concept using "Find-Fix-Verify" to help coordinate demands among disparate users that were affected by data breaches and other "privacy-violating institutional experiences" [313]. In their research, they used this process to "[simplify] the complex task of asynchronously distilling a unified set of demands from a distributed collective" using two of the same cases in this dissertation, Equifax and OPM. The results were somewhat vague lists of demands, but the authors noted that this could be improved by incorporating experts to help "steward" the process [313].

In Section 2.1.2, I described cooperation as akin to a puzzle box, where looking at a jumble of pieces was not always enough to see the possible outcome. Instead, we rely on the final picture to help us assemble the pieces into a whole. Facilitating cooperation in cybersecurity is much the same, and the results of my research are designed to provide

such a picture to stakeholders. While the patterns of conflict management discussed above regarding RQ2 are likely to be well known, the methods of facilitating cooperation in RQ3 are not. Now, stakeholders involved in data privacy and security have a clearer picture of what cooperation can look like in the field and for future research.

6.4 Relationship to the Literature

My grounded theory and my model were built from the empirical evidence that I observed. However, there are many models in cybersecurity, conflict analysis, international relations, and other fields that are related to my results. Many of these were included in the introduction, and I will include some of them again here. The final model does not preclude the use of other models in analyzing real-world scenarios. In fact, many align very well, and can be used in conjunction with each other for both research and applied purposes. As I discussed in my methodology (Section 3.4) I used "constant comparison" to challenge my emergent findings with other theories and additional literature [85, 141, 265].

The best example is the NIST Cybersecurity Framework (CSF), which "provides guidance to industry, government agencies, and other organizations to manage cybersecurity risks" [211]. This artifact, and its earlier versions, is a highly regarded resource that is freely available to organizations to support their cybersecurity. If my model did not mesh with an important model like the CSF, that would raise some concerns about the validity and applicability of my research. The CSF fits perfectly into the operating, and response, recovery, and remediation phases of my model, particularly for the software producers, who are likely to use the CSF, or something very similar, to inform their cybersecurity practices. However, the CSF is not designed to explain the relationship between the software producer and other stakeholders as a system. Additionally, it is not practical for an outside observer to use the CSF to investigate the broader conflicts that arise from a data

breach over time.

Another model that integrates well is the "interests, rights, power" framework [279] that can be used to describe the different approaches that stakeholders took in addressing the conflicts. While there are various examples of these different approaches across the cases, I will select a few that best represent the framework. The interest-based approach to negotiating describes a process where the parties highlight their concerns and underlying needs to manage a conflict. This approach is represented by Equifax, and other software producers, when they provide credit monitoring services free of charge to their affected users. This effort aligns with the interests of all the stakeholders: it provides a remedy for users whose data was compromised, it demonstrates the software producers' interest in minimizing the harm to their users, it could help reduce penalties by regulators, and it meets regulatory interests by demonstrating a sort of deference by the company for a potential violation. However, as with many interest-based approaches, this was often not enough to resolve the dispute. The rights-based approaches are clear cut; the litigation efforts by the stakeholders in most of the cases are examples of the rights-based approach. In those cases where lawsuits were filed, and where the software producers did not settle outright, each stakeholder demonstrated that they thought they would prevail on a legal basis. Both the interest- and rights-based approaches clearly fit into the compensation, correcting, and complying behaviors after the incident in my model. The power-based approach was mostly apparent in some of the posturing behaviors. One example of this is in the Equifax case when members of Congress proposed legislation to penalize the company for the breach. As described in the case study, many of these bills did not go very far, and were clearly meant to coerce Equifax to take some action.

One model that I used early on to help describe the cases that had impactful aftermaths was Kello's Virtual Weapon [166]. In particular, his description of "systemic disruption" in which there has been a major disturbance that "disrupts the conduct of units" such as

governments and software companies, including impacts on "rules, norms, and principals" between non-state actors due to cyber attacks. The elements of his model aptly described the critical nature of the outcomes in the Illuminate Education, CatalanGate, and OPM cases, which resulted in disruptions to rules and norms.

While investigating the multiple roles of regulators as stakeholders, my research was complemented by analysis of multistakeholder governance from Marsden [193]. He describes the relationships between governmental and nongovernmental regulators in data privacy and security, including self-regulation by industry groups, co-regulation through an independent party with government support, and statutory regulation by government regulators. This spectrum, which was based on prior research, supported my empirical description of the different regulators involved in each case. This research helped reinforce, for example, my useful yet confusing model component, "Regulator Regulatory Context." In fact, he describes an equally perplexing example of "regulated self-regulation" which helps demonstrate how confusing this particular schema really is.

Throughout the constant comparison and grounded theory processes there were many other models that I examined in light of my emerging findings which aligned well, and at a minimum had no major contradictions. Many of these were included in the Background (Section 2), and in the dissertation proposal. There were others that I investigated later as well. These included Stakeholder Theory [115, 208], Privacy-by-Design [47], usable security and privacy [119], a taxonomy of cyber-harms [18], social contracts and privacy [194], and cybersecurity economics [114].

6.5 Limitations

Below I will address the major limitations of my research. As an interdisciplinary, qualitative study, analyzing real-world cases, there were many opportunities to pursue, but

that had to be skipped due to limited resources. I hope to take advantage of the data and the grounded theory in future research to address some of these areas of interest.

6.5.1 Case Selection

The first limitation was in my selection of cases to analyze. I focused entirely on data privacy and security conflicts, which provided a practical bound for a dissertation. However, selection of other types of cases may have resulted in a different, but also valid, grounded theory. Alternatively, choosing a wider variety of cases could have improved external validity.

The first example is avoiding analysis of militarized data breaches from the perspective of intelligence, espionage, or warfare. The use of cyberspace for warfighting operations is important and has broader impacts on social conflict, as attacks on critical infrastructure, for example, have resounding effects for everyday people, not just militaries and not just in warzones. Some of my cases did include issues of security and physical conflict, such as the ICRC and CatalanGate cases. However, expanding my data to include the laws of war as regulations would have been a drastic and impractical jump. Additionally, it may have been difficult to get reliable data for analysis.

Another type of case that I avoided categorically was ransomware. While ransomware cases are typical of data privacy breaches, my attention was continuously brought to major cases where data was known to be compromised, resulting in more direct impacts to users beyond service interruptions. While there are examples of ransoms not being paid, [298], this primarily results in the loss of data with no backups, not exfiltration and potential privacy violations. Furthermore, introducing ransomware would have also implicated the attackers as stakeholders, adding complexity to the research that was outside the scope of my initial proposal. This might have included concepts around criminology and negotiation

that would have been difficult to pursue. However, incorporating ransomware cases would also be an obvious area to test the theory going forward. Crucially, the impact on all stakeholders does seem to fit into my grounded theory, for example, the correcting behaviors in the model, which describe e.g. addressing the loss of services or data after an attack. Insofar as data privacy and security impacts commerce, the consequences for businesses and governments that suffer ransomware attacks, and their constituent users, would be a logical area to pursue further research using my theory and model. An obvious example would be the dynamics between all stakeholders when determining how to approach resolving the issues caused by the ransomware, such as negotiating with the attackers, which seem quite different from recovering from data privacy violations.

6.5.2 Methods

There were two methodological limitations that could impact the theory, but that also provide space for future research. These do not limit validity (e.g. construct or internal validity) in any major way, but further investigation could help support the results, and would provide valuable knowledge for analyzing these cases, and demonstrate how the theory could be applied in the future. The first concerns data collection about the attackers, and technical details about their attacks. The second limitation is in regard to the use of the value scales to quantify the behaviors in each phase of a case.

First, I omitted details about the hackers and technical details about the breach from the theory and model. This was an explicit decision which allowed me to stay focused on the primary stakeholders I outlined in the proposal, and especially their behaviors and interactions. The advantage is that the theory can be agnostic to different types of breaches going forward, such as ransomware discussed above. Instead of analyzing the who, what, and why of the actors behind the breaches, which could be anyone at any time, I was able

to investigate the people and organizations that suffer from these attacks, how they prepare, and how they recover from them. Understanding the motives of hackers, while important, would not have yielded valuable data for these stakeholders, since there is little they can do to address them. Furthermore, gathering data on these motives would be impractical, given that these are deliberately surreptitious attackers, and even simple attribution can be near impossible at times. Technical details about the attacks were included in the case analyses, and these can be important for understanding the unaddressed failures and weaknesses that preempted the attacks. However, technical cybersecurity models, like NIST CSF, and others, have more practical tools for addressing these issues. Instead, the theory focuses on the broader precursors that led to these failures, and their impacts. Furthermore, the outcomes of these breaches in each case were often quite similar, regardless of the technical characteristics: there was unauthorized access to data, which resulted in the privacy of users being violated. This congruency is captured by the theory.

After analyzing the cases, I introduced value scales to provide a limited quantitative measure of the behaviors of each stakeholder at each phase of a case. For example, a Regulator may have been "Strict" or "Lenient" in Enforcement activities, or the Compensation for Users could have been "Unfavorable" or "Favorable." The primary limitation with this is that I only applied it generally to a high level grouping of the stakeholders, and not to other groups or individuals within the hierarchy. For example, Federal Regulators may have been "Strict" while State Regulators may have been "Neither Lenient Nor Strict" resulting in an overall value of "Somewhat Strict." Or, Business Customer Users may have had "Somewhat Favorable" Compensation while end users may have had "Somewhat Unfavorable" compensation. This resulted in some less accurate quantification of the behaviors and outcomes in the cases. However, adding this level of granularity would have roughly tripled the number of data points in each case, making it impractical to analyze as a sole researcher. Additionally, in the many cases where there were not differences among different

levels of stakeholders, differentiating among them would have added unnecessary noise. I accounted for the issue in two ways. First, I prioritized the qualitative data that I collected to develop the theory, and did not overly rely on the values; the description of what happened always took precedence. Additionally, when using the values for my analysis, I still analyzed the more granular characteristics, such as individual behaviors, to make sure my results were reliable. Furthermore, I did not use these values for any additional quantitative analysis, although future statistical applications would be a valuable area to pursue.

In reality, the stakeholders included in the model (users, regulators, software producers) are groups of stakeholders in the case, not just standalone actors. It is practical to group them together at a high level early on, and more useful to break them down further when analyzing a given case. Frequently, this breakdown results in a hierarchy of different stakeholders within each group. It is not always practical to ascertain a clear, distinct value for where they sit in the hierarchy, but there is often some logical inference about where they sit compared to others in their group, and compared to other stakeholder groups in terms of relative power. Analyzing the different stakeholders within each group in terms of a hierarchy is extremely useful for understanding the conflict and cooperation within the case. This structure could be useful in future research.

Another limitation of this value scale, and the overall qualitative approach, is in the area of costs for stakeholders in each case. It would be great to have detailed quantitative monetary values for analysis. However, it is not always feasible to get reliable information about how much was spent on cybersecurity before or after each case, how much an incident cost a company, how much regulators spent on enforcement, or the legal fees for lawsuits. There are, for example, calculators to estimate the cost of a data breach, such as one from At-Bay, which I used and referred to in the full case studies. But they can have different results, and may not include all factors. There was occasionally publicly reported data, such as from government investigations, mandated financial reports, and court docu-

ments, and I was able to observe general expenditures. However, even when I could collect this information, the cases were so different that comparing dollar-for-dollar costs was not useful. Furthermore, even without publicly reported information, I was still able to infer costs. For example, large investigations with major reports and staff, such as the PEGA Committee in CatalanGate, can reasonably be assumed to have been quite costly. As such, it was more reliable to provide my own values for cost data, leading to broad scores like "low" and "high" which could be easily verified, and made it possible to compare between dissimilar cases.

6.5.3 On Being WEIRD

One obvious limitation is the setting for my data, which is predominantly WEIRD: Western, Educated, Industrialized, Rich, and Democratic, a known issue in security and privacy research, and beyond [72, 137]. The reality is that the data I aimed to analyze, including company reports, government investigations, and other publicly available artifacts, are primarily "based in the West" which was a primary factor in my "focus on a limited number of Western countries where research-enabling data is easier to access" [72]. Furthermore, choosing cases among other "rising cyber powers (e.g. India, Brazil, or South Korea)," [72] would have also required a substantial burden in my research. Understanding the regulatory regimes and business practices in the US and Europe was already a major challenge, despite my familiarity with them, and ready access to resources, including subject matter experts. Attempting to analyze the intricacies of cases in other countries would have been insurmountable for a dissertation.

However, there is a critical approach to my research that supports validity regardless of the WEIRD limitations. The goal of my dissertation is to "challenge, transform, and empower" and directly addresses the "current distribution of power" in society [273]. Be-

cause of this, my grounded theory can contribute to knowledge production that is not simply Western- or state-centric, as it has been designed to address "cybersecurity as a lived experience" and incorporates the way various stakeholders interact [72]. Future research can use the theory and model to elucidate issues in other countries and among marginalized populations, not just in the environments included in my case selection. Furthermore, my use of grounded theory methods also provides a foundation for growth to improve the data to address a wider space of multistakeholder cybersecurity.

Lastly, I will point out that I attempted to include more global data through the ICRC case, which had affected users spread across the world. However, I will concede that the data in that case did not contribute substantially to future research in non-Western scenarios.

Chapter 7: Conclusion

This research uses grounded theory and case studies to investigate the relationships between stakeholders in data privacy and security, including software producers, regulators, and users. By examining five real-world cases of conflict between these groups, caused by a data breach, the results include a grounded theory and model of cybersecurity conflict and cooperation behaviors and outcomes. The theory and model can be used by practitioners and researchers to investigate past, present, and future cases to understand the systems of software security.

The objective of my dissertation was to create practical framework for understanding the systems of actors and actions in data privacy and security. My goal was to help make it easier for a broad spectrum of software security practitioners and researchers to understand cybersecurity conflicts both in the past and as they unfold. This can include engineers, regulators, academics, leaders, business people, and lay users. To do this, I investigated five different systems and preeminent conflicts that occurred within them. I analyzed these five cases, including their stakeholders, behaviors, antecedents, and outcomes, for the similarities and differences between them to develop a comprehensive model and theory. Now these tools can be applied by software security professionals, broadly defined, to interpret and improve outcomes.

Future research can use my data and results in a variety of ways. Expanding on the quantitative characteristics of stakeholder's behaviors could help redefine expectations when they pursue a particular course of action. For example, when comparing the cost of

building cybersecurity capacity with the risks of litigation in their particular industry. Another area of investigation would be testing the model with professionals in the field. This could include bringing together a heterogeneous group of technical, legal, and management professionals in a controlled setting, introducing them to the model, and seeing how they would use it to collaborate in a hypothetical scenario. Lastly, researchers can use the model in further cybersecurity research to situate their data and ensure they have covered all factors that might affect their results.

I was able to conduct such extensive research on these cases in large part due to the availability of reliable information from civil society and government actors. Given the applied and critical nature of the research, it is my hope that these same actors will use my data and results in their efforts to improve data privacy and security for their constituents. They have new, actionable insights on complex relationships, including empirical data on how cooperation between stakeholders can support their work. At times, this may even involve reshaping power dynamics to support people who may be disproportionately affected by data breaches. While businesses are not always as forthcoming with the details of their cybersecurity tribulations, in these cases, there was still valuable data from them, whether it was voluntary or mandated. Regardless, they too can use my results to support their software security efforts, no matter what field they are in. Ultimately, I hope that all these stakeholders can work together using my results as a collaborative resource to improve cybersecurity outcomes.

Appendix A: Illuminate Education Case Analysis

A.1 Introduction

Choosing cases of cyber conflict where stakeholders must include regulators and regulated stakeholders leads to an easily available choice of students and young people. Minors are a protected class of people worldwide. Their participation in society is typically controlled based on their age, with rights and responsibilities being afforded at different ages for things like voting, driving motor vehicles, agreeing to contracts, consuming alcohol, or joining the military. The education technology industry is highly regulated at the federal, state, and local levels due to the sensitive nature of their users, who are frequently minors, and considered a protected class. Given that today, education heavily relies on computers and software, a cyber security dispute that includes students as a stakeholder is ripe for study because of protections like these and the complexities they introduce for software producers.

Illuminate Education is a software provider for education institutions and districts, including primary and secondary schools around the country, counting millions of students as their users, in addition to teachers, administrators, and parents. Among their clients are the two largest public school districts in the country, Los Angeles and New York City, as well as districts in Colorado, Connecticut, Oklahoma, and more. These districts and schools, as well as their superior state and federal jurisdictions, employ privacy and data security privacy policies that regulate Illuminate Education as a software producer in this

field, which focuses on a protected class of people. Their popular software, such as PupilPath, is used "extensively to communicate with parents and check grades for each student" [12]. In January 2022, Illuminate Education suffered an outage to their services, which was later revealed to be related to a data breach. According to the New York Times, there was unauthorized access between December 28, 2021 and January 8, 2022. Ultimately, it was revealed that the records for at least 3 million students, across 605 districts, were accessed and possibly exfiltrated [23]. After the breach, multiple lawsuits were filed by the parents of affected students against Illuminate Education in multiple jurisdictions, including federal court. These lawsuits included allegations of identity theft and future identity theft, harms associated with loss of privacy. However, the cases were ultimately dismissed. Contracts were also canceled with the company, and they suffered negative attention and criticism in the media and in the education technology industry. Edtech remains a lucrative space for businesses, and a target for cyberattacks, with all stakeholders working to protect their interests.

A.2 Context

School districts, individual schools, teachers, and students rely on software for daily school needs. Teaching, grading, scheduling, and administering all rely on software. Their use of software needs to comply with regulations to protect students' data under national and local laws. Like any other software, education software is a target for hackers, but student data also has special legal protections. Meeting those legal requirements, and a failure to do so, adds complexities that may not appear in other industries. Illuminate Education is a software producer that serves the education market in a variety of jurisdictions.

A.2.1 Regulatory Environment

In the US, student data can fall under multiple overlapping and changing regulations and jurisdictions that govern privacy and data security. Together, regardless of their complexity, these regulations, rules, laws, guidance, and other agreements form a regime that encompasses the regulatory requirements of a software producer. In the US, a student's data is protected federally (nationally) by the Family Educational Rights and Privacy Act (FERPA). States and other local jurisdictions protect student data through regulation as well, adding to the patchwork of regulations that software companies must adhere to. While student data protections have been enshrined in law, the enforcement of those protections is complicated. In the case of a violation of the law, individuals may not have a private right of action, this means that they cannot necessarily sue an educational institution for that violation. Instead, they may need to file a complaint with a regulatory authority, such as the Department of Education, in order to enforce the rules. Violations of these rules may also implicate other agencies, such as the Department of Justice (DOJ) or the Federal Trade Commission (FTC), if there is a commercial issue caused by the violation.

Due to the sensitive nature of this industry, there is also self-regulation in place, for example the Student Privacy Pledge, which incorporates voluntary participation to help protect student privacy. Commitment to the pledge can be legally enforceable, as the FTC and state Attorneys General "have legal authority to ensure they keep their promises" [11]. However, as of 2022, this agreement has not led to any legal enforcement [17].

Student data is protected by regimes formed at the national and local levels. The regimes are established and enforced by agencies with various jurisdictions and expertise. For example, federal agencies that enforce regulations include the FTC, which is also responsible for other regulatory spaces, although the Department of Education is responsible for other education-related issues. However, local departments of education may

have enforcement authority within their jurisdiction. These agencies also possess different tools for enforcement and observation based on their mandates and jurisdictions. They also have processes for creating new rules and regulations to respond to changes in the industry, threats, and violations.

Software producers in the education space are familiar with the rules and regulations that protect student data and engineer their software to comply with these requirements. They provide technical specifications to their clients to demonstrate these technical controls and practices. This dedication to the regulated arena means that they have familiarity with the types of vulnerabilities that occur within it. If a software producer wants to enter this market, having only dealt with other industries, they will need to learn the regime requirements necessary to meet the needs of their new clients. These companies may also need to comply with requirements that are unique to different jurisdictions when they sell their products and services and cooperate with clients that have varying levels of requirements.

Regulators in the education technology space include local, state, and federal government bodies, as well as non-governmental organizations that aim to protect students from a variety of harms, including privacy and data security. Their jurisdictions are not limited to cybersecurity issues, however, and can include concerns like school quality, food, transportation, safety, accessibility, and more. They may be subject to changing political climates by elected officials and economic problems that face their governments. These issues can affect their ability and their methods in observing and enforcing cybersecurity issues for their constituents and jurisdictions. One of the primary sets of rules in place is the Federal Education Rights and Privacy Act of 1974 (FERPA). However, the mandate for federal enforcement of FERPA rules is extremely limited: Few court cases have been prosecuted, and the results of those related to privacy have been "unsuccessful," even deciding that individual students do not have the right to enforce FERPA regulations through

lawsuits [4, 7, 9]. Additionally, FERPA and other student privacy regulations are seen as "inadequate" and even been "weakened" over time [4, 7]. Similarly, the Children's Online Privacy Protection Act (COPPA), meant to protect children's data as a vulnerable population, is seen as "weakly enforced and generally ineffective" [28]. Furthermore, none of these laws seem to regulate a third-party software company that handles student data. State-level regulations and their enforcement mechanisms are variable. The New York City Department of Education, for example, has established New York State Education Law 2-d and Chancellor's Regulation A-820, which *inter alia* regulate the collection and use of student data by schools and third-parties, requires data privacy training for staff, and creates a "Parent's Bill of Rights" [26]. It is feasible, nor possible, to create a full record of the regulations that constitute the regulatory environment. Instead, the aggregated rules created from statutory and case law and self-regulation are considered to comprise an abstract emergent regime that influences the regulatory environment.

A.2.2 Threat Environment

Threat actors are constantly changing the ways that they attempt to compromise software, exploiting new vulnerabilities, attempting new social engineering tactics, etc. Users are also implementing heterogeneous practices that can introduce new vulnerabilities. Software producers must be able to control for this variable threat surface in their engineering.

The education space is rife with breaches and creates a particularly complex problem. Since 2005, US schools have suffered nearly 2,700 breaches and 32 million records [3, 5]. Teachers and schools have limited budgets and are constantly trying to offer students compelling curricula, and so are frequently looking for new tools. With hundreds or thousands of end users, trying multitudes of software tools to meet their needs, F001 contends that education may have the largest threat surface of any industry [3]. Teachers, students, and

administrators may be deploying software that meets their needs but introduces new vulnerabilities. For example, a teacher may employ a web-based tool that collects the data of its student users.

Students represent a protected class of citizen, and grade school students are also typically minors, which means they are concurrently protected. From a cybersecurity standpoint, their data is especially valuable, as it can be years before they find out that their data has been compromised, giving hackers more time to use the data for nefarious purposes [21].

Students are not the only end users of the software; teachers, school administrators, and school district staff are all responsible for procuring and implementing the software and participate in its day-to-day use. This staff includes information technology professionals who are responsible for cybersecurity. All of these users can introduce heterogeneous practices not necessarily foreseen by the software producer or cybersecurity professionals. These heterogeneous practices may introduce new vulnerabilities that compromise the data security and privacy of all users, in particular, the protected students.

When it comes to protecting against threats to student privacy and data security, regulators' experience will vary, and their ability to guide and regulate the deployment of software will also be based on their familiarity with cybersecurity vulnerabilities in this field. They must be prepared to help prevent, respond to, and support recovery from cybersecurity issues. Based on this experience there are established regulations that aim to support cybersecurity for the student and education population.

A.2.3 Operational Environment

According to the New York Times, Illuminate Education claims to support more than 17 million students in 5,200 school districts in the US [15]. It supplies multiple applications

for these schools and their constituents, including grade and attendance monitoring, as well as other classroom tools.

Software producers that implement software in this industry must be ready to comply with the multitude of overlapping requirements of their clients, defend against the vulnerabilities endemic to this industry, and meet their clients' needs at an affordable price to stay commercially viable. New features, changing threats, and complex regulations all add to the cost of implementing software. However,

Regulatory bodies, whether they are governmental or non-governmental, must be prepared to support the compliance efforts of their constituents, which include both the users and the software producers. This means that they provide rules and regulations that protect their constituents but don't encumber software producers such that they cannot do business. They must observe and enforce compliance with the law within the boundaries set by their elected officials' policies, judges' decisions and within their budget and capacity. In education privacy and data security, these inputs and outputs to regulatory operations can vary widely in their scope and effectiveness. For example, the NYC Department of Education may have more resources to help prevent regulatory violations compared to a small school district in Oklahoma that uses the same software. Additionally, as discussed in section 1.1., the federal government has limited operational ability to enforce protections for students; Case and statutory law do not support active enforcement methods for violations of federal regulations (Daggett, 2008).

A.3 Operations & Precursors

Below are the general practices and specific activities undertaken by each stakeholder leading up to the incident. The net effects of these practices and activities are driven by their outputs, which also serve as inputs to the incident that occurred.

A.3.1 Software Producer

Illuminate Education is a privately owned software company that provides software to school districts and individual schools. The software producer, using knowledge and expertise about their clients and this industry, would create and improve products to meet their business goals. Prior to the breach, and to this day, the company's applications are used by students, teachers, and administrators and contain protected information about students. The company itself had to secure its software, including preparing for, defending against, and preventing cyber attacks to maintain a commercially viable product and comply with regulations. Securing software is an ongoing process which can require the producer to develop patches for their clients so they can update deployed software to protect against new and changing threats. The implementation of these patches, including the creation by the company and the dissemination to their clients, is considered a mandatory practice in software engineering. There are other evolving best practices that software producers must implement to maintain security which are supported by a massive industry that provide consulting, guidance, and additional technical tools.

Illuminate Education was founded in 2009 and developed edtech software. In 2018 and 2019 it merged with or acquired another six companies, including well-known firms like FastBridge and IO Education [6, 29]. IOeducation is the company that originally developed PupilPath, and was itself the result of mergers and acquisitions of four other companies between 2015 and 2017 [22]. To manage this growth and meet the needs of its customers, Illuminate Education had to extend its disparate software products, such as by creating a single sign-on capability, and "create a consistent interface and user experience across those tools." This period of growth also included layoffs, estimated at about 50 people in the 600-person organization, in 2019 [29]. As of 2025, however, the login area of the Illuminate Education website still provides separate links to its various applications, including IO

Education, FastBridge, and others [14]. While there was no specific disclosure, PupilPath and other IO Education products were the most referenced software solutions in use by the affected customers, and were the only ones referenced later in court documents.

In providing the software to their clients, Illuminate had to comply with national and local regimes to secure its unique implementation, including preparing, defending, and preventing against cyber attacks that might compromise data, including the protected student data. However, their commercial viability and legal liability in complying with regulations varied by client need and jurisdiction. For example, in regard to commercial viability, if Illuminate offers a less expensive product than a competitor, a client may be more willing to forego cybersecurity requirements to save costs. Additionally, regarding legal liability, adherence, and compliance depending on the regime under which they were operating, the school district or school may be responsible or liable for regulatory compliance, not the software producer.

In this case, Illuminate Education provided their software PupilPath, among others, to schools and school districts across the country. This includes large districts like New York and Los Angeles which have established local regulatory regimes that govern the procurement and implementation of software within their jurisdiction. To win the business of these clients, Illuminate Education would have had to agree to comply with the rules set forth by the regime under which they were operating. Each contract would have constituted its own regime unique to the agreement with the client and the requirements of the multiple levels of jurisdictions. Illuminate Education also participated in industry self-regulation, specifically, the Student Privacy Pledge. The Student Privacy Pledge is a program administered by two software industry organizations, the Future of Privacy Forum (FPF) and the Software & Information Industry Association (SIIA) to "safeguard student privacy regarding the collection, maintenance, and use of student personal information."

Unfortunately, in this case, the software provider's operations led to unaddressed fail-

ures & weaknesses that compromised the data privacy and security of its clients. Despite their attempts at adherence/compliance, as well as their knowledge and expertise, they left vulnerabilities open for a breach. According to publicly available information, the breach was not caused by any vulnerabilities introduced by the users. The vulnerability that was exploited has not been explicitly verified by Illuminate, but all media coverage and legal complaints point to an operational security failure exposed by the software producer. There is some evidence that the vulnerability that was exploited was specifically identified as a requirement by the NYC Department of Education: encrypting student information while the data was at rest [12].

A.3.2 Regulators

Regulatory bodies, including government agencies and self-regulatory organizations, would also be performing their duties. Depending on the context, this could include creating new rules, monitoring stakeholders, enforcing rules, and working with stakeholders towards these capacities.

The agencies charged with the development and enforcement of these regulations also have their own dynamics in achieving their goals. Local (including state and sub-state governments in the US) and national entities have different roles and responsibilities in governing the implementation and deployment of software. Among the users and software producers there are people tasked with ensuring that the software adheres to regulations, so they can be seen to be higher up in the hierarchy of user stakeholders because there are fewer of them, they have more responsibility, and they may not be as closely connected as those responsible for implementing and deploying the software.

An example of a regime that governed Illuminate Education's software development, implementation, and deployment, is with the NYC DOE. In 2020 the company "signed a

strict data agreement with the [New York City] district requiring the company to safeguard student data and promptly notify district officials in the event of a data breach" [27]. Concurrently, Illuminate and its client the NYC DOE, signed onto the independent industry guidance program, the Student Privacy Pledge, along with other companies and school districts [11, 27]. This is also concurrent with any other rules established by the city and state of New York, as well as the US federal government. Ultimately, the combination of these requirements from each entity formed a unique regime that Illuminate had to comply with. The NYC DOE offers a particularly useful example because it appears publicly to have the strictest requirements on their edtech providers, but not all jurisdictions had the same requirements in place, based on publicly available documents.

An example of a self-regulatory body is the Student Privacy Pledge, which "is a public and legally enforceable statement by edtech companies to safeguard student privacy" [11]. The pledge has hundreds of voluntary participants, and has a few regulatory impacts. First, in order to join, participants must comply with the rules of the organization, which means they may alter their processes to best practices when before they may have not. Because different jurisdictions have different requirements, this means that signatory companies may also be adhering to common, but not ubiquitous regulations. Lastly, the pledge also allows other regulatory authorities, like the FTC and state AGs to ensure that signatories comply through enforcement [11].

A.3.3 Users

In deploying this software, and others, the users (including districts, schools, teachers, and students) would have gained knowledge and expertise with the software. During the life of the software they also would have needed to apply patches to protect against new and changing cybersecurity threats. These changes, when possible, should have been

documented for users to implement properly. Additionally, when these changes fell under regulatory regimes, should be documented for adherence and compliance.

The sale, procurement, and deployment of this software would require the involved participation of various people from both the school district who procured the software, and the software producer who provided it. They would have gone through countless conversations and steps to tailor the software to meet the needs of the school district's various users. In procuring and implementing the software, clients also had to comply with national and local regimes to secure its unique implementation, including preparing, defending, and preventing against cyber attacks that might compromise their data, including the protected student data.

All these actions, which were undertaken by the stakeholders, would be documented in artifacts. Procuring the software required signed agreements, between the software producer and user. Regulations were coded in law by agencies. Deployment for day-to-day operations would be documented. Logs would be created through regular use of the software. These artifacts can be made available for both daily use, and future forensic analysis should some conflict occur.

A.4 Incident & Impact

Between December 28, 2021 and January 8, 2022 Illuminate Education suffered a breach that targeted the data of as many as 3 million student users. The compromised data included personally identifiable, biological, and demographic information. The breach exploited a vulnerability that has not been disclosed by the software company. At least one journalistic source indicates that Illuminate "did not encrypt student information while the data was at rest" (The Record, 2022). Encrypting stored data, also known as data at rest, is known as a cybersecurity best practice, and was also mandated by their NYC Department

of Education client [12].

The incident began on December 28, 2021, when a malicious actor gained unauthorized access to Illuminate's data. Illuminate detected and identified the unauthorized access, and by January 8, 2022, they had contained and/or eradicated it. During this time, they also removed access to the software for at least 10 days. They began alerting users of the incident starting March 25, and continued to disclose information until July 29, 2022.

Both the software producer and users suffered injuries and harms as net effects of the incident. The direct cost to Illuminate Education resulting from the breach is estimated at $22-30 million [1, 25]. At the same time, the users lost their ability to use the software in some cases, and so had to use resources to find new solutions. Additionally, their personal data was compromised and can be used by nefarious actors, which could incur future harms and costs.

Illuminate, as a best practice and as required by their obligating regimes, would have had to notify users and regulators of the breach. This is a non-trivial process which would have required multiple people and offices within the organization, such as the cybersecurity team, legal counsel, public relations, and executive officers. The timeline for notifying users also varies by jurisdiction, and while notifications were sent out, some users complained that they were not notified in a timely manner [18]. Following the formal notification of the breach, regulatory bodies would begin their investigation [12]. Based on public information, this included the NYC DOE and other school districts, although few other regulatory bodies made their investigation public.

A.5 Responding + Recovering

In response to the incident, the stakeholders to the conflict sought to respond and recover to the incident. They pursued strategies that might be achieved through various prac-

tices. While the end goals and specific tactics may have varied between the users, software producer, and regulators, they still followed a limited set of approaches. Specifically, there are four strategies that they pursued through various practices: posturing, compensating, correcting, and adhering/complying.

In pursuing the following strategies, each stakeholder had to make specialized decisions based on the variegated regimes that governed the conflict, and their individual needs in this context. There were intricate legal efforts that cannot be interpreted in this research. Additionally, there were choices that involved the input of multiple people from human resources, public relations, legal, IT, teams, that would have been formed totally internally and with many intricacies. The strategies would also have to take into account their relationships with the other stakeholders. Instead of trying to document the dynamics of these strategies in detail, I'm describing these practices abstractly as constructing a multistakeholder response. Each party, to achieve their best interests, would work with their networks to examine the regimes that have influence and assemble a legal vehicle that offered them the best opportunity to meet their goals, in the jurisdiction(s) where they would be most likely to succeed. They would use the below strategies together to construct a multistakeholder response.

A.5.1 Posturing

All stakeholders postured to protect their interests. The most prominent posturing was making public statements. Users, including end users like students and teachers, school administrators, and school districts, as well as user representatives like advocacy groups and elected officials issued statements through internal channels and through the media [12, 27]. The software producer, Illuminate Education, made limited public statements [8, 13], presumably to protect their interests by limiting exposure, but must have spoken directly with

their clients. Even their lack of public statements can be seen as posturing, as the company wanted to keep details hidden. Regulatory agencies, including local and national governments also issued statements about the attack. While the FTC did not respond directly to the Illuminate Education breach, they did issue an official statement and a Consumer Alert about education technology shortly after the breach was made public [2, 10, 17]. However, the NYC Mayor made more direct statements condemning the incident and the company's alleged failures [12].

Further posturing occurred when the parties formed and managed networks with other external stakeholders that had an interest in the conflict. This could include forming new networks, reinforcing existing ones, or even distancing themselves from stakeholders that posed a threat. On all sides lawyers and legal experts were consulted. The parties may have had internal legal counsel, but they also sought outside support. Parents of students began retaining lawyers to pursue legal action and Illuminate Education worked with a separate law firm to represent them in court [16, 18, 31]. Industry experts were also part of this network, providing valuable knowledge to the different parties, for example the K12 Security Information Exchange, a nonprofit focused on supporting cybersecurity in education technology.

The regulatory bodies would have also sought knowledge and expertise from outside parties to inform areas where they may not have enough in-house resources and gauge public interest. This might include collecting comments or amicus briefs and would have helped support their other strategies.

A.5.2 Compensating

All parties pursued compensation that was in their best interests. Users tried to maximize their compensation, while the software producer sought to reduce their costs to com-

pensate users. Illuminate may have also sought monetary compensation if they had cybersecurity insurance. Regulators contributed to decisions on compensation for the affected parties, including the users and software producers. Regulators, including local and national government branches, pursued compensation according to their mandated responsibilities and jurisdiction on behalf of their constituents.

An example of the constructed response for compensation, multiple class action lawsuits were filed by parents of the student users in multiple courts [16, 18, 31]. In the courts, because the case involved so many different jurisdictions, the parties had to evaluate their options, consolidate their arguments, and prove that they were owed compensation. They also worked with other parties and stakeholders to best achieve their goals. Eventually, they consolidated those lawsuits into a single filing, a process that required the input of the courts and the defendant, Illuminate Education. In the end, the court decided that the class did not have standing to sue: the response they constructed did not protect them such that they could receive compensation due to restrictions arising from the regime that governed their rights. Instead, the software producer's constructed response protected them from compensating the student users in court. In this situation, the regulatory stakeholder was the court, which ultimately made the decision.

The schools and districts that had formal agreements with Illuminate Education likely followed the terms of the agreements to seek redress. Compensation also would have included any terms that Illuminate Education and its clients agreed to when they signed their agreement. This could include the opportunity for the clients to opt-out of the agreement, and might also include reports or data that describe the incident so the clients can review it. No compensation for these harms has been disclosed publicly. It is possible that some clients may not have sought compensation.

A.5.3 Correcting

Each party had its own approach to the strategy of correcting the precursors and impacts of the incident. This means recovering from the event itself, as well as ensuring it doesn't happen again. Correcting is a separate strategy from compensating, in that it seeks to directly address the root causes and the negative impacts of the incident, so that operations can continue. Correcting therefore includes the immediate responses to remediate the issue and restore the compromised software, and business process changes that need to be made to prevent the incident from happening again. In this case, the software producer took their software offline for at least 10 days [13], but the broader business process changes are not known. It was alleged that Illuminate Education did not encrypt their data as required in their agreements. For users, correcting might also include changes to business processes including reinforcing future agreements with other software producers and resolving problems that may have occurred due to the incident, such as a loss of access to the software. In this case, the user clients claim that Illuminate Education did not follow specific requirements regarding encryption, so another change to business processes might not be relevant for prevention.

For end users, including teachers and students, and even school administrators, correction included a very different practice from those discussed thus far. To correct for the disruption caused by the breach, end users who were required to desist from using the software (such as in NY), had to find new software solutions to meet their day-to-day needs. Far from seeking compensation in the courts, these users had to resolve software problems that were previously solved by Illuminate Education. Students, teachers, and administrators needed to continue to operate including managing grades and assignments without the PupilPath software. In spite of the breach, the users had interests that would have gone unaddressed without some software in place. These users deployed new soft-

ware solutions, including creating new applications and procuring new solutions in order to meet their needs. This required the participation of higher-level constituents involved in the procurement processes including school districts and individual school administrators. In some cases, they would have implemented ad hoc solutions using readily available tools like those offered by Google or Microsoft. These ad hoc solutions might have compromised quality, meaning they weren't as capable at delivering the needs of the users, and even might have further compromised security if they weren't properly managed.

Regulatory stakeholders, including national and local government agencies and courts, also participated in correcting. These bodies seek correction by remediation of the impacts of the incident and helping to prevent such events from occurring in the future. However, they must take into account the interests of all the stakeholders. If they overcorrect, they may negatively impact the industry by dissuading future business. If they undercorrect, then they may not adequately protect the victims of the event. In either case, they may also set precedence for future action that has negative consequences. As such, the regulatory interventions must positively influence the software producer to comply with the rules without deterring them from conducting their business, while protecting the interests of the users so that they are protected from harms.

Initially, there were only two examples of regulatory correction in this case. The NYC DOE cut off all contracts, which led to other issues for the end users, but also set a precedent for the future. Also, the Student Privacy Pledge removed Illuminate from their program. However, in 2025, regulators announced punitive measures against Illuminate Education for the data breaches. Illuminate came to two separate settlement agreements, one with the FTC at the federal level, and another with a coalition of three state Attorneys General, New York, Connecticut, and California. The FTC settlement agreement included mandated security measures that would be enforced to ensure that Illuminate is in compliance [24]. The settlement with the states included similar security measures as well as a $5.1 million

penalty, to be distributed between the states [30]. The joint enforcement between the states was likely the first action by a recently formed Coalition of Privacy Regulators, created to enforce state-level regulations for privacy violations [20].

A.5.4 Adhering & Complying

Each stakeholder attempted to recover from the incident through adherence to and compliance with existing regimes.

The software producer was required to alert its customers in a set amount of time about the breach and some details about its effects. However, the rules about the notification and the details that needed to be included varied by jurisdiction, and failure to comply strictly with the rules is not necessarily going to warrant an enforcement action by the regulators. The breach consisted of a few days of unauthorized access by attackers to the software producers' data, which included the student data. In response, the timeliness, method, and information contained in the disclosure by the company would have been the subject of decisions based on a few factors: the various regime requirements under which it operated, their understanding of the incident, their capabilities or resources, and their evaluation of what would be best for the company itself. Ultimately, the disclosure would reflect their intentions toward adherence to the spirit of the regime, and their compliance with the written rules of the regime. The software producer disclosed the breach by notifying users starting March 25, 2022 through July 29, 2022 [18, 27]. The network of users that filed the lawsuit argued that these notifications were not timely as required.

The users that were responsible for managing the relationship with the software producer also would also approach their response to the breach based on the rules of their respective regimes and the contracted agreements they had with Illuminate Education. In New York, they were able to terminate their business relationship. Other districts did not

terminate business, and that could include limitations in their agreements and the laws surrounding their negotiations.

Regulatory response would have been managed by the offices with jurisdiction to respond to the issue. Their job is to ensure compliance with the law. However, they also have adherence and compliance strategies based on the interests of their appointed or elected officials, their resources, the capabilities of the team, and the strategic bureaucratic interests of the office, all of which factor into their constructed multistakeholder response. For example, the judge responsible for the lawsuit filed against Illuminate Education determined, based on law and precedent, that the case had to be dismissed.

A.6 Outcomes

The strategies and practices of the stakeholders to this conflict resulted in identifiable outcomes described in this section. These outcomes are comprised of outputs of their response and recovery practices, and also serve as inputs to the broader aftermath of the conflict.

A.6.1 Costs

For the users, one of the most visible costs resulting from the response to the breach was the need for new software solutions. In the New York jurisdiction, and possibly others, the severing of the relationship with Illuminate Education left gaps in the day-to-day operations of the users. This meant that users, with varying roles, had to seek out replacements to meet their needs. This ranged from implementing free software to developing new custom solutions, all of which have their own risks and costs associated with them. Free software may make their money by collecting the data of the users, leading to further privacy concerns. Creating a new solution requires capital and human resource investments. This

includes time to develop the software and train users. In the meantime, the users are unable to adequately meet their needs, in this case issues like grading, viewing grades, managing student data, and more.

The most obvious cost to the users is that their data is now at risk of future harms. The personal data that was compromised can be used for cybercrime, which could lead to a variety of issues to those users affected.

All of the stakeholders incurred legal costs in this case. The users sued the company paid lawyers, the regulators used human resources to investigate and remedy it, and the company suffered reputational damage and lost contracts, as well as legal costs responding to the suits and investigations.

Based on the NetDiligence Data Breach Cost Calculator, the cost to the software producer is about $22 million. This includes costs associated with incident investigation, crisis management, regulatory fines & penalties, and lawsuits.

A.6.2 Transformations

The users of the Illuminate Education software implemented new software and adjusted their business practices. Higher level users likely addressed the requirements in their contracts to make more strict demands of their suppliers to prevent incidents like this from occurring in the future. All of these users are likely to have undergone further cybersecurity training to help with prevention as well.

The software producer, Illuminate Education, has been quiet about the event, so there is no data as to any transformation in their business processes. However, they were acquired by a private equity firm, Renaissance Learning, in August 2022, just 7 months after the breach [19].

In New York, new rules and requirements were adopted by the primary regulatory body,

Department of Education. The self-regulatory Student Privacy Pledge also transformed their enforcement approaches by removing a participant for the first time. Typically, they seek to encourage compliance with their rules [11], so removal is not an ideal response, it is better to punish signatories, but keep them within the fold. In this case, however, Illuminate Education was removed from the agreement.

In 2025, a group of state regulators joined together in a novel effort to pursue privacy regulation, and the first action they announced was a $5.1 million settlement with Illuminate Education [30]. While this transformation took multiple years, the impact is broad, as it demonstrates the intense interest of state regulators in enforcing privacy laws. Crucially, the creation of the Consortium of Privacy Regulators occurred in 2025, years after the Illuminate data breach. At this point, that network formation might not even have registered as posturing for this particular case. However, by settling with Illuminate as their first (or one of their first) actions, they made a significant transformation to the enforcement approaches for privacy violations due to data breaches.

Courts at the national and state level did not make any transformations, instead they held to the precedent that individuals did not have a right of action to pursue compensation. Federal regulators in the FTC did come to a settlement agreement with Illuminate Education in 2025, but this represents standard operating procedure for consumer protection, not a transformation.

A.6.3 Preservation

The most apparent example of preservation in this case comes from the federal courts, which dismissed the class action lawsuit against Illuminate Education. The class action was the result of multiple lawsuits which were consolidated into a single complaint. However, the federal court decision to dismiss the complaint, based on their adherence with the

existing laws, upheld the status quo making no changes to the regime.

The Student Privacy Pledge also sought to preserve their status as a self-regulatory body by removing the company. While in the past they have sought to encourage adherence, in this case they made a novel decision to remove the violating party [17].

There has also not been any public notice of action taken by some schools or school districts, indicating that they may have preserved their contracts with Illuminate Education in spite of the breach. This means that the users would also not have to make any changes to their operations.

A.6.4 Remedies

For the regulators, the efforts took time, but eventually resulted in penalties for the company. In the education jurisdictions, as we have seen, some regulatory bodies like the NYDOE canceled contracts with Illuminate Education, enforcing their contract rights. The Student Privacy Pledge removed the company from their agreement as an enforcement action. Later, in 2025, some of those states also punished Illuminate, resulting in them paying $5.1 million to New York, Connecticut, and California for violations of their privacy laws. The same year, the FTC also settled with the company, mandating cybersecurity upgrades.

Users and their advocates sought remediation through monetary compensation via the courts. More specifically, the parents of students filed lawsuits against Illuminate Education. They did not get any monetary compensation through this effort.

The courts, mainly the federal court, decided not to offer any remedy to the parties that sued.

A.7 Aftermath

Upon initial observation of this case, I did not identify any long-lasting impacts on the context for future cases in the aftermath. However, when the state regulators pursued enforcement action in 2025, this changed. For there to be an aftermath that substantively changes the context of future, similar cases, there are three factors that are met. Gaps in enforcement mechanisms, new methods of cooperation, and critical characteristics of the incident.

A.7.1 Enforcement Gaps

In the Illuminate Education case, the class action lawsuit against the company failed. After 4 years, the federal government had taken no action, and it appeared as if they did not have the legal authority to pursue enforcement against a provider of education technology, because it was ultimately the school or school district that was subject to the regime. Eventually, in 2025, a group of state regulators formed a new entity specifically to enforce violations of state-level data privacy regulations. Their first action was to sue Illuminate Education, which resulted in a fine of $5.1 million. This new coalition changes the regulatory and operational context of similar cases, as there are new enforcement mechanisms against companies that violate state data privacy regulations.

A.7.2 New Methods of Cooperation

In the Illuminate Education case, there were multiple attempts at cooperation as a result of the breach. The most prominent and common example was the class action lawsuit, which brought together a variety of users (and their parents), lawyers, and privacy advocates. However, the class action lawsuit was unsuccessful in remediating or remedying the

incident. The new method of cooperation was the creation of the Consortium of Privacy Regulators, formed by state regulators. While this approach to regulatory enforcement is not new, it was new for the field of data privacy and security regulation. This changes the operational and regulatory environments for regulators and software producers in particular, as they have changes to rules and compliance efforts going forward.

A.7.3 Critical Characteristics

In the Illuminate Education case, the affected users were students and children, which resonated strongly with the stakeholders. When the state-level enforcement came through, the common sentiment was that more needed to be done to ensure privacy protections for kids. This is demonstrated by the fact that upon forming the new coalition to enforce privacy regulations, their first action was against Illuminate Education.

A.8 Case Bibliography

Bibliography

[1] At bay cost estimate. At Bay Cyber Risk Calculator. Cyber Risk Calculators document.

[2] Policy statement of the federal trade commission on education technology and the children's online privacy protection act. Technical report, Federal Trade Commission, May 2022.

[3] Interview with participant f001, October 2023.

[4] Susan G. Archambault. Student privacy in the digital age. *Brigham Young University Education and Law Journal*, 2021(1):1–49, 2021.

[5] Sam Cook. Us schools leaked 32 million records in 2,691 data breaches. *Comparitech*, April 2023.

[6] Crunchbase. Illuminate education - crunchbase company profile, 2025.

[7] Lynn M. Daggett. Ferpa in the twenty-first century: Failure to effectively regulate privacy for all students. *Catholic University Law Review*, 58(1):59–114, 2008.

[8] Michael Elsen-Rooney. Nyc schools ban online gradebook following security breach. *New York Daily News*, June 2022.

[9] Jody Feder. The family educational rights and privacy act (ferpa): A legal overview. Technical report, Congressional Research Service, November 2013.

[10] Federal Trade Commission. Is your kid using education technology?, 2022.

[11] Future of Privacy Forum. Student privacy pledge bolsters legal requirements, September 2020.

[12] Jonathan Greig. Nyc officials call for investigation after data of 820,000 students compromised in hack. *The Record*, March 2022.

[13] Jonathan Greig. Nyc school platform outage complicating covid-19 tracing efforts. *ZDNet*, January 2022.

[14] Illuminate Education. Log in - illuminate education, 2025. Webpage.

[15] Illuminate Education. Our story, 2025. Webpage.

[16] Kaplan Fox & Kilsheimer LLP and Kantrowitz, Goldhamer & Graifman, P.C. Consolidated class action complaint. United States District Court, Central District of California, October 2022.

[17] Mark Keierleber. Ftc targets ed tech companies that 'illegally surveil children'. *The 74*, 2022.

[18] Anastasiya Kisil. Class action complaint. United States District Court, Central District of California.

[19] Kristal Kuykendall. Renaissance acquires illuminate education. *THE Journal*, August 2022.

[20] Alex LaCasse. Us consortium of privacy regulators discuss enforcement priorities, collaboration. *IAPP*, October 2025.

[21] Doug Levin. The state of k-12 cybersecurity: Year in review, 2022. Presentation to NPE.

[22] LLR Partners. Io education. Portfolio Companies Profile.

[23] Anna Merod. Class action data breach lawsuit against illuminate dismissed. *K-12 Dive*, 2023.

[24] Anna Merod. Illuminate education reaches settlement with ftc over 2021 data breach. *K-12 Dive*, January 2025.

[25] NetDiligence. Netdiligence mini data breach cost calculator.

[26] New York City Department of Education. Data privacy and security policies, 2025.

[27] Natasha Singer. A cyberattack illuminates the shaky state of student privacy. *The New York Times*, July 2022.

[28] Diana S. Skowronski. Coppa and educational technologies: The need for additional online privacy protections for students. *Georgia State University Law Review*, 38, 2022.

[29] Emily Tate Sullivan. Illuminate education's buying spree comes at a price, including layoffs. *EdSurge*, July 2019.

[30] Troutman Pepper Locke. Key takeaways from $5.1m settlement with education technology company. *Regulatory Oversight*, 2026.

[31] Central District of California United States District Court. Order regarding motion to dismiss (excerpt). Case No. 8:22-cv-1164.

Appendix B: ICRC Case Analysis

B.1 Introduction

The breach of the International Committee of the Red Cross (ICRC) is a highly complex case, including the preceding factors and the aftereffects. The organization is not a typical software producer, but does create software solutions for a variety of users to achieve its mission. Its users are comprised of a heterogeneous mix of international organizations, field staff, and end users, all of whom depend on the software for critical and even life-saving operations. The end users, called beneficiaries, are of particular importance, and they are the people that benefit from the services provided by the ICRC in disaster situations like violent conflict and environmental disaster. With their iconic Red Cross emblem, the ICRC provides a variety of services to their beneficiaries, including reconnecting families who have been separated, which they have done for over 150 years. Today, this means implementing and deploying software through their Restoring Family Links (RFL) program, which is deployed by field staff worldwide. The regulatory regimes that apply to the ICRC and its users are manifold, including disparate national requirements in the countries where they work, and international agreements like the Geneva Convention.

In 2021, a breach compromised information about 515,000 beneficiaries of the RFL program. These end users are a particularly vulnerable population, and malicious use of their data could lead to direct harm. Additionally, their privacy, diverse situations, and diffuse locations disrupt their ability to recover from the breach, such as through legal action.

The regulatory bodies that are tasked with controlling and remediating the breach are also spread out among multiple jurisdictions, making it hard for anyone to act. The ICRC, as the software producer, had to act in the best interests of their mission, which takes into account their future operations and the wellbeing of their users, particularly, the beneficiaries. Ultimately, the state of data protection and privacy as it relates to humanitarian aid is challenged.

B.2 Cyber Social Context

The broad context that sets the stage for the cyber incident that occurred is made up of three environments: **regulatory, threat, and operational**. There are inputs to- and outputs from each of these environments that relate to each stakeholder. Inputs to the context come from the industry and regulations that have been set previously, and the outputs inform each stakeholder's processes. The regulatory environment is comprised of the various rules and regulations across the jurisdictions where users & producers that operate collectively form a regime that the stakeholders operate under. The operational environment is made up of the day-to-day operations that the stakeholder undertakes using the software to meet their needs. The threat environment is made up of the risk of an incident, the stakeholder's abilities in securing their operations, and more.

B.2.1 Software Producer

The ICRC, which was founded in 1863, has developed internal software solutions to support its operations, specifically their "mandate and mission" to ensure "protect the lives and dignity of victims of armed conflict and other situations of violence and to provide them with assistance.", as well as things like natural disasters, as a "neutral and indepdendent organization" [13]. One of the programs of the ICRC is called Restoring Family Links,

“Restoring Family Links (RFL) is a general term used to describe a broad range of activities carried out by the [Red Cross] Movement to prevent family separation, restore and maintain contact between family members, and ascertain the fate and whereabouts of missing people. RFL activities include enabling the exchange of family news; tracing missing family members; identifying, registering and following up unaccompanied and separated vulnerable children and others; and arranging family reunification” [13]. They have been doing this work since 1870 through their Central Tracing Agency (CTA) and with the support of the various bodies of the Red Cross Movement partners (described below) work together to support reconnecting families that have been separated.

Given the delicacy of the needs of its end users, the ICRC must adhere to a high standard of protection and security of the data, otherwise they may not be able to meet their goals and protect the victims who are beneficiaries of their services. To that effect, they have been recognized for their state-of-the-art security practices [1, 19]. To operate, the ICRC relies on funding from a variety of sources, including governments, “supranational organizations”, and public and private donors. As with any charity, should they fail to achieve their mission, those funding sources may hold back, and the organization would not be sustainable or their operations viable. The ICRC is also not a single, standalone organization. In fact, it is made up of multiple organizations, namely the Red Cross National Societies which operate in individual countries, and the International Federation of the Red Cross, which administers the different bodies. Together, they are collectively called the Red Cross and Red Crescent Movement. In terms of the software, the ICRC provides the National Societies with the tools they need to conduct operations in their host countries. For RFL, the Movement has implemented and deployed a software ecosystem for beneficiaries to find and contact family if they have been separated.

The threat environment that the ICRC is concerned with for its software is not widely studied. Given the vulnerability of the end users, nefarious actors include the broadest

spectrum of adversaries, including states, criminals, and hacktivists. States may seek to compromise the data of beneficiaries to gain leverage in a conflict or subjugate people they see as enemies. Criminals may try to exploit the data for financial gain. Hacktivists might try to achieve political agendas with the data of people who are engaged with the ICRC. Because the software is being implemented by various National Societies in various situations, the ICRC must control for a variable threat surface that changes with the circumstances where the software is being used. To deal with this, their data privacy and security teams have developed knowledge, skills, and practices specific to their needs, resulting in familiarity with vulnerabilities that are internal to their domain. The ICRC has been recognized for their expertise in cybersecurity, demonstrating a familiarity with the cyber threats endemic to their field that is valuable to protecting their users [1, 19].

Part of implementing their software operations, and responding to the threat environment, is fitting within the regulatory spaces that govern them. The ICRC and the Movement partners are bound, at the highest level, by the Geneva Conventions, first adopted in 1864 and revised multiple times until 1949, and the additional Protocols amended later. The Conventions and Protocols establish international laws for humanitarian treatment during violent conflict. The ICRC is headquartered in Geneva, Switzerland, and must comply with the regulations of that country as well. The National Societies, which implement the software, must comply with the regulatory regimes in their host countries [6, 14]. In addition to complying with rules that are heterogeneous between each National Society, the host countries may be friendly or hostile towards these operations, complicating privacy and security efforts. The ICRC also identifies multiple other legal instruments & guidance when processing data for RFL, including various international charters, treaties, and conventions [6]. Internal controls are quite stringent, for example National Societies are meant to perform a data protection impact assessment "Where processing is likely to present specific risks to the rights and freedoms of data subjects"[6].

The beneficiaries of the aid may also have their own predispositions to their use of the software, as well as technical obstacles like language barriers, alphabets, and devices.

ICRC Developers (Implementation)

Centrally, the ICRC develops the software, and they create solutions to meet the needs of their National Societies and beneficiaries RFL goals. They have permissions based on their needs to access the data, implement changes, and coordinate with other stakeholders. Hierarchically, they sit towards the top, because they interact with the other users, and the leadership responsible for the organization. Ultimately, they must answer to authorities for their successes and failures. They will also be able to support the implementation and use of the software by the National Society and beneficiaries. Additionally, in this case, the technical teams responsible for implementation may also be the producers of the software, which means they have an unmediated link to software changes.

As the technical experts implementing the software, they are also the closest to understanding the regulatory regimes that govern its use. As issues arise from the other users, they must be able to address questions and conflicts so that they stay in compliance with the regimes in place. There are also technical challenges in complying with multiple regulations; data must be stored, transmitted, and secured in various ways depending on the country. They may face legal challenges with their host country in order to meet their mandate while complying with the regime in place.

Regarding threats, they must be externally familiar with the vulnerabilities consequential to their operations. External familiarity requires developers to be prepared for threat actors' unique ability to exploit users through their acquaintance with user practices in this specific circumstance, such as a domain, country, culture, or language. This means that there is a variable threat surface because of the disparate ways that users use software, creating new vulnerabilities that can be exploited. Threats can be created by practices that are not controlled for, and these need to be communicated to the software producers. Soft-

ware developers are also internally familiar with their own systems, and can make security decisions based on their experience with their software.

B.2.2 Users

There are different types of users that deploy the ICRC software, which could be grouped based on their use cases, permissions, and hierarchically. The users include the National Societies that deploy the software in the field and the end users who are beneficiaries of the RFL program. The field workers are users that deploy the software, and are also closely connected to the software developers because of their relationship to the ICRC. However, the field staff are users who deploy the software in the field and are not responsible for the development of the software. The end users are what the Red Cross Movement, and other organizations, call beneficiaries, because they benefit from the aid provided. These end users use the software to reconnect with their families by providing their biographical information and are then able to send messages and get updates on their situation [13].

National Societies (Deployment)

The National Societies' software use case includes their operations within the host countries, managing the humanitarian aid they deliver to the victims of armed conflicts and other disasters. They deploy the software provided by the ICRC to meet their mission, connecting families who have been separated. In the hierarchy of stakeholders, they are in the middle, possibly able to relay feedback and questions to the developers, but unable to fully control the software and its requirements. They interact with the end users more directly. This means that their permissions may not include the ability to change the software, like the central developers, but they may have access to the critical data about the populations they are trying to protect. They may be able to access aggregated reports related to

their operations.

These operations by the National Societies require heterogeneous practices based on the circumstances of their work: not all National Societies have the same regime requirements, nor do they have the same operational needs.

Due to their heterogeneous practices and their elevated permissions, these users contribute to the variable threat surface as users and implementers of the software, according to R003 [2]. They may have different levels of experience using the tools and skills with technology in general. Training in the software and cybersecurity best practices are an important skill set for the National Societies.

Users in this tier may be the most familiar with the national regulatory environment that governs the software. At a minimum, they are the most connected to the regime because they are implementing in the field. They may be the parties responsible for interacting with the regulatory bodies, such as the government and other NGOs. While the technical team may be responsible for implementing changes based on the regime, the National Societies are responsible for understanding their host country and need to communicate the requirements.

Beneficiaries (End Users)

The operational use case of the end users, victims of violent conflict and other disasters, is them entrusting their data to the Movement with the expectation that they get humanitarian assistance and protection, in the form of goods and services. For the RFL software, these services include video and phone calling to their families, as well as other secure messaging. They may have to use devices and technology that they are not familiar with, and provide private information that they need to keep secure. At the bottom of the hierarchy pyramid, there are more of them than any of the other users, and they have the least connection with the software producer and the regulators. They must contribute records of their assistance and protection, as well as personal details, putting them at the most risk,

and with the least permissions to access the data, likely only able to retrieve their own or their family's data [13].

The threat environment for these users is that they may be the targets of threats that compromise their safety. By using the software, they provide sensitive information that then becomes vulnerable to malicious actors. Depending on their interaction with the software, they may also introduce vulnerabilities if they do not follow best practices. In a conflict zone, such as a civil war, a host nation may be looking for the people that are using this software, and attempt to hack it to reach them. In an environmental disaster situation, criminals may try to exploit the users for financial gain.

Ultimately, the regulatory environment and its resulting regimes are designed around these end users, whether the goal is to protect the data, or to exploit it. Using the civil war example, a host nation may try to weaken protections for the users so that they can get access to the data and use it to seek out people of interest. On the other hand, a host country amidst a disaster may adhere to the best practices of the Red Cross to get their best support.

B.2.3 Regulators

The regulatory environment that the ICRC operates in is complicated, and is further complicated by its development and implementation of tailored software. According to the ICRC, "all States are bound by the four Geneva Conventions of 1949 which, in times of armed conflict, protect wounded, sick and shipwrecked members of the armed forces, prisoners of war and civilians" which extends to the data security and privacy of those people. The additional Protocols are agreed to by many nations, but not all, and add further protections for victims of international and non-international conflicts, and add more emblems beyond just the cross as identification. The Conventions and Protocols provide a legal ba-

sis for the ICRC's operations in armed conflicts and a "broad right of initiative" in various circumstances [16].

The ICRC RFL program identifies other regulations that govern their programs in their 2015 Code of Conduct on Data Protection [6]. The regulatory bodies include the Council of Europe, European Parliament, Organization for Economic Cooperation and Development (OECD), Asia-Pacific Economic Cooperation, and the Global Privacy Assembly, in addition to their own internal statutes and codes which are also legally binding. These bodies have established rules, regulations, guidance, frameworks, and other legal instruments that ICRC has agreed to adhere to [10] (RFL, 2015). Ultimately, this paints a complex landscape of both organizations and practices that guide data privacy and security.

Host countries set forth regulations that the Movement must comply with in implementing the software. There may also be non-governmental organizations and inter-governmental organizations that regulate the behavior of the Movement and its bodies. These different countries and organizations may have different, even contradictory rules, for the ICRC and the National Societies involvement in a conflict, and with their use of software. Some of these rules may be more favorable than others for meeting the needs of the beneficiaries [2].

Together, these regulators and their rules yield an emergent regime that governs the behavior of the Movement, including its software implementation. The regime is comprised of overlapping laws, rules, and regulations, as well as the current political climate, changing governments, legal history, human and capital resources, opinions towards the ICRC, or sentiments towards the beneficiaries. Because this work is often conducted in a conflict zone, there also may be contradictory requirements placed on the software producer and its users [14]. Due to these factors, an emergent regime is not easily navigable. While any regulatory body may define their rules clearly, their operational ability to enforce their rules and their methods of enforcement will vary. They may be limited by superior jurisdictions

or by human and capital resources.

Regulatory bodies also have their own familiarity with vulnerabilities that are unique to them, such as their domain or territory. They may have developed expertise in dealing with these threats, both pre-emptively and in post. Alternatively, they may be unfamiliar or unprepared, therefore exposing vulnerabilities, and unable to remedy the harms caused by attacks. For example, the Red Cross has been providing aid since its inception in the mid-nineteenth century, and the Geneva Conventions date back to WWII, and their ability to protect the data privacy of the people that are in their purview may not be as advanced as the threats that exist.

The ICRC, as part of its mission, also adheres to its own internal regulations, which include impartiality, independence, and neutrality. These directives help the organization operate in conflict zones by never giving preference to one side, thus being able to provide aid to any party in a conflict, and helping make sure that it is not attacked during its operations. Internal regulations may not always be a legitimate source of rules, however, in this case, the Movement depends on these internal controls in order to continue operations. The Movement's various bodies are somewhat independent of each other, which adds to their ability to self-regulate [2].

For a national government, ultimately, the regulators and their regimes are meant to support the political interests of the governing body. For a democracy, that means protecting the users who are their citizens and constituents, as well as the businesses critical to the economy. For an autocracy, that means protecting the interests of the ruling party. In conflict zones, the National Societies must balance the interests of their beneficiaries while complying with the requirements of stakeholders who are actively engaged in violent conflict.

B.3 Operating

The operating phase reflects the typical business and organizational processes in developing, using, and regulating the software. For the developers and the users that are responsible for the software, particularly in this case, these operations are comprised of **implementing or deploying, securing, and adhering/complying**. For regulators, operations include **regulating** and **bureaucracy**.

B.3.1 Users

Users and software producers frequently have aligned goals: deploy and implement software to support their operations, keep the software secure, and meet regulatory requirements. In this case, their goals are particularly aligned given that the users deploying the software are subsidiaries of the organization that developed it. The users in this case include the ICRC Movement partners that deploy the RFL software, and the end users that use it for its intended purpose: "prevention of family separation and disappearances and maintaining family contact, searching for missing persons, providing answers to families, restoring family links, providing support to families during the search, and supporting family reunification [13].

Deploying

In 2022, the RFL program facilitated 2.2 million phone calls, found 12,500 people, and reconnected 4,700 people with their families [18].

Securing

Users would be responsible for some amount of security, in addition to the developers of the software. Particularly the staff tasked with implementing the software, making sure that they followed the best practices established by their software producers, and general cyber security hygiene. Managers also should be tasked with ensuring their teams are adhering to best practices as well.

Adherence/Compliance

Users, particularly the field staff, would be responsible for helping to ensure they met the regime guidance and rules that governed their operations. Guidance like the Data Protection Code of Conduct was provided for deployment users.

B.3.2 Software Producers

In 2021, ICRC's day-to-day operations served millions of people through 100 delegations and missions in over 100 countries, with a staff of over 20k+ people. In terms of their RFL services, this includes millions of phone calls and thousands of reunified families (ICRC Annual Report 2022). The ICRC technical teams develop and support information technology tools for these delegations because they may not have the resources to do this themselves (Interview R003). Achieving this required the development and implementation of software. Users around the globe had different needs, and it was the duty of the ICRC as the producer of the software to meet those needs, adapting to changes, providing training, and supporting implementation as the organization pursued its mission.

Implementing

The Restoring Family Links (RFL) services that the ICRC and its National Societies provided to beneficiaries, included a suite of tools that used a case management system. This case management system was built, in part, using a commercial software called Microsoft Dynamics. The Dynamics implementation is developed, supported, and maintained centrally by the ICRC, for Movement partners to deploy for RFL operations and business/mission needs. The digital transformation effort that was rolled out to bring the various RFL implementations into a more connected and secure environment that used Microsoft Dynamics, started in 2008, with the first implementation launching in 2013, and expanding to over 70 countries since then [2].

Securing

The software producers necessarily spend some of their time securing the software from threats. This means preparing for, defending against, and preventing cyber-attacks. An interviewee (R002) familiar with the organization's security practices said that ICRC was operating at a high level to protect their data [1]. Patching new vulnerabilities, ensuring new features are properly secured, and training their clients (users that deploy the software, mainly the National Societies) on best practices.

Adherence/Compliance

Software developers would help make sure the software was capable of meeting these non-functional requirements. For these parties, adherence would mean that they are doing their best to abide by the spirit of the regime. Compliance would mean that they are merely sticking to the defined requirements. In this case, an example of adherence would be their

consummate dedication to neutrality, impartiality, and independence in implementing the software. Compliance might mean minimally following the guidelines prescribed by their host country so as not to upset them, but avoiding actions that might compromise their work when the rules are not clear.

The ICRC has a number of compliance-related artifacts available for analysis, including legal requirements, planning documents, and practical tools. For example, the National Societies that deploy the software also sign service and licensing agreements with the ICRC [2]. The November 2015 Code of Conduct on Data Protection is available as "one tool for all members of the Movement to use with regard to protecting fundamental rights and freedoms of individual, in particular the right to privacy and the protection of personal data, affected by RFL activities" [10]. This in-depth artifact includes details about topics like Lawful and Fair Processing, Rights of Data Subjects, Special provision on Data Transfers, Legal Instruments/Guidance and Doctrine. From this document, further practical artifacts have also been created, including the Data Protection Compliance Checklist, which can be used by the National Societies to "identify whether the quality of service to beneficiaries meets the minimum requirements for data protection set out in the code" as well as a Template for Data Protection Impact Assessment (DPIA). Additional documentation, including the RFL 2020-2025 Strategy and a progress report for 2012-2015 include data protection as a foundational principle for RFL deployment by Movement partners.

B.3.3 Regulators

The operations of regulators differ from that of software producers and users. They do not always get involved in day-to-day operations of parties, even if they are regulated, unless some conflict or event has already occurred. However, some agencies, particularly self-regulatory bodies, may perform audits and oversight duties in regular intervals. In their

regulatory duties, the agency may support the development of new rules, collect input on rules, and monitor reports of conflicts. They may also engage in bureaucratic activities, promoting the interests of their agency to meet their own goals.

Regulators that are stakeholders in the ICRC's software implementation come from a variety of jurisdictions, regimes, and politics. The Red Cross/Red Crescent Movement must be cognizant of the dynamics of these stakeholders and their rules in order to deliver their services. The countries where they operate have unique requirements that must be met and it would be under the purview of the National Society in the host country to ensure that they comply with those requirements [14]. This presents technical challenges to implementing the software in-country, as they need to adhere to unique regimes in each scenario. Regulators may have requirements that compromise the integrity of the ICRC data, meaning that the host country's objectives are at odds with the ICRC's mission, and putting its beneficiaries at risk.

B.4 Precursors

The net effects of the operating practices and activities of each of the stakeholders, described above, are the precursors to the cyber attack of the ICRC. These are the outputs of their operations, and the inputs to the adverse event that occurred. For users and software producers, the net effects of their practices align. The net effects of their operations are **knowledge & experience**; **business change**; **adherence & compliance**; and **unaddressed failures & weaknesses**. While net effects for user & producer stakeholders are similarly coded, the practical outputs differ. For example, both users and software producers generate knowledge and experience from their operations, but the outputs of that knowledge and experience for software producers might include software engineering artifacts that are not relevant or necessary for users. Instead, users' knowledge and experience is typified by the

deployment of the software, not its underlying codebase.

The key outputs of regulatory operations are regimes. Regimes are comprised of the jurisdictions, laws, regulations, rules, guidance, recommendations, and politics to which the users and software producers are beholden. Regulatory regimes arise from multiple levels of society, including local, national and supranational governments, and industry self-regulation. They are imbued with a range of powers, ranging from limited to forceful. Regulatory bodies can be purely observational, able to convene stakeholders, directly monitor behaviors, and enforce rules directly. These outputs are highly dependent on the context and the specific case. In this case, the regimes varied based on the host nation where the Red Cross National Societies were operating, and the Swiss government where the data was stored. The host-nations likely created a variable environment, while the operations in Switzerland were likely to be routine.

B.4.1 Users

As discussed above, there are parallels between deployment users and software producers in their actions and the results of those actions: their operations have net effects. Below are the broad net effects of their operations based on the outputs of practices and activities. These outputs and net effects were ultimately the inputs to the adverse event, a data breach.

Knowledge & Experience

Users's knowledge and experience are derived from their operations described above: deploying, securing, regulating, and complying. The culture of use of the software, whether it is accepted or rejected (or something in between), is also a result of the context and operations, and can vary across the hierarchy of users. Top-level users responsible for deployment may see the value in the software, while end users may see it as a threat.

Business Change

Users and software producers may induce changes to the software. Users may request new capabilities based on their unique scenarios. Producers may release new features to meet the needs of users that deploy the software, to anticipate future needs, or based on data collected from the users. For ICRC this means responding to the needs of National Societies including high-level and on-the-ground requirements. These changes, including to processes and software functionality, can add to the threat surface by introducing new vulnerabilities, both technical and non-technical. Software updates and changes to code in the process of day-to-day operations can result in new vulnerabilities that may be compromised by technical adversaries. Changes to workflows and business processes can lead to user errors that can be exploited.

External vendors and their processes also need to be examined to ensure that they are adhering to the rules, and following their own security practices when dealing with ICRC data.

Adherence & Compliance

There is a gap in the role of users and software producers in regulatory compliance practices. In this case, among the users, it is primarily the middle- and upper-tiers that are responsible for compliance. The end users are a particularly vulnerable class, with extremely limited resources to participate in compliance with regulations, before, during, or after a violation. The National Society staff users are responsible for complying with regulations in their host country.

In adhering and complying with these regimes, both groups of stakeholders generate artifacts that document their efforts. This would include both formal and informal compliance documentation. Respectively, standardized artifacts that can be submitted to regula-

tory bodies and other preserved records (like emails) that demonstrate their operations.

These artifacts may need to be reported to authorities regularly to demonstrate compliance. Various regimes may require them, including different levels of government, self-regulatory organizations, and internal teams.

Unaddressed Failures & Weaknesses

The summary net effect of these operations, and the other precursors, is an unaddressed failure or weakness that was exploited by an adversary. Amongst users, this would derive from inadequate training or experience, a mistake, which exposed a vulnerability to a malicious actor.

It is possible that either end users or administrators have their accounts compromised, which can then be used for cyber attacks. The compromised accounts can be used by malicious actors to exploit vulnerabilities. This could mean that a beneficiary has their information compromised, which could reveal personal information about themselves or their families. It could also mean that an administrator user is compromised, which could include access to multiple end user data or other administrative capabilities that could lead to harm.

B.4.2 Software Producers

Knowledge & Experience

The ICRC developed their software tools to meet their mission, which incorporates the broader goals of the Red Cross Movement and the specific needs of the National Societies to deliver RFL services. This means industry-specific knowledge and experience to deliver to the hierarchy of users in the Movement. In implementing this software, they have accrued artifacts including documentation, reusable code, checklists, training materials, and

more that are specific to their needs. They have also garnered implicit knowledge of the field that isn't necessarily documented; skills that are valuable but difficult to pass on to others. Ultimately, the software developers have delivered an engineered software product to their users, incorporating the functional and non-functional needs of their users, based on their knowledge and experience.

Business Change

Producers may release new features to meet the needs of users, to anticipate future needs, or based on data collected from their users. For ICRC this means responding to the needs of National Societies including high-level and on-the-ground requirements (Interview R003). These changes, including to processes and software functionality, can add to the threat surface by introducing new vulnerabilities, both technical and non-technical. Software updates and changes to code in the process of day-to-day operations can result in new vulnerabilities that may be compromised by technical adversaries. Changes to workflows and business processes can lead to user errors that can be exploited.

The RFL program used a case management system based on the software Microsoft Dynamics. Dynamics needs to be updated regularly with patches that support security. A new vulnerability was identified that required such an update by the ICRC software team.

Adherence & Compliance

In 2015, the ICRC released a reference document, *ICRC Rules on Personal Data Protection* "for protecting Personal Data, which will also enable it to remain at the forefront of international humanitarian action, even in the most challenging circumstances" [10]. The document introduces "rules intended to ensure that the ICRC can carry out its mandate under international humanitarian law (IHL) and the Statutes of the International Red

Cross and Red Crescent Movement (Statutes of the Movement) in a manner consistent with internationally recognized standards for protecting Personal Data."

As discussed earlier, the ICRC also supplies compliance artifacts like their Code of Conduct on Data protection. Their operations have been identified as best practices and likely include things like routine internal and external audits, training, making required security updates such as patches, and more. However, a vulnerability still went unpatched, which later led to their system being compromised.

The software producers at the ICRC are responsible for the challenge of providing the means, in terms of software functionality, for their staff users to comply with legal requirements. The ICRC as software producer must also comply with the other governance required of them by the regimes in which they operate, such as in Geneva where they are based [2].

Unaddressed Failures & Weaknesses

Ultimately, there was a failure that lead to the breach. It could have occurred amongst the users that deployed the software, or by the software producer. Software producers may have introduced these weaknesses during typical operations inadvertently or negligently, as well as by social or cognitive faults. Inadvertent vulnerabilities often arise from "zero day" exploits, which are utilized by hackers before anyone has the chance to protect against them. Negligence might be the cause if there is a known vulnerability, but the software company does not take the time to patch the software to protect against it. In some cases, they may not have the resources to do so.

In the ICRC case, a unique vulnerability was identified and exploited. The specialized nature of the attack is widely seen to indicate that it was a powerful actor, such as a state-sponsored group and known as an Advanced Persistent Threat (APT), that had extensive

resources to expose and exploit this vulnerability [1, 8].

B.4.3 Regulators

Regimes

The outputs of the cyber social context and operations of the regulatory bodies are the regimes that govern the users and stakeholders. These regimes are comprised of laws, rules, regulations, guidance, and recommendations.

In this case, disassembling the regimes that govern the ICRC and the broader Red Cross movement is nearly impossible. In practice, it is left up to experts, and even they may have difficulty fully interpreting and executing the full slate of requirements. It can even be that some requirements contradict each other, not only between regulatory bodies, but even within one itself. A study of the information security practices at the ICRC [14] indicates that they are affected by "loopholes in legislation," "asymmetric legislation," and legal pressure on their privileges and immunities.

The relationships between the regulators and the other stakeholders could have an impact on the impacts, recovery, and outcomes to the breach in the future.

Knowledge/Information Products

Third-party stakeholders, including government agencies, NGOs, and cybersecurity companies first detected and publicized a flaw known in the US National Vulnerability Database as CVE-2021-40539 starting on September 7, 2021 [4, 5, 8, 9]. Multiple US government bodies, along with formal partners like MITRE, detected and analyzed the threat, and made the knowledge publicly available. According to the disclosures by these organizations, the vulnerability is in a popular software called Zoho, specifically their use of additional ManageEngine password management system, and can be exploited remotely by

accessing the software's API. A patch was released to fix this vulnerability on September 6, 2021. However, any software implementations that did not employ this patch would remain vulnerable. Further information released by these regulators and third-parties indicates that the flaw was being exploited by Advanced Persistent Threats (APTs), and in particular, APT27, which is connected with Chinese state-sponsored hacking [3].

While the vulnerability was initially publicized by cybersecurity organizations in early September, and the patch was released around the same time, there were ongoing awareness campaigns by various stakeholders to help prevent incidents. The US Cybersecurity and Infrastructure Security Agency (CISA), FBI, and US Coast Guard Cyber Command, along with cybersecurity companies MITRE and Palo Alto Networks, issued and updated alerts in September and November [4, 5, 8, 9]. The German government issued an alert in January 2022 regarding the vulnerability [3, 4]. In addition to issuing advisories about this specific vulnerability, these government agencies and their partners attributed these attacks to APT27 and connected them with other major attacks which were condemned by even more governmental bodies including NATO, the EU, and the UK [7].

Overall, the scale and potential impact of the vulnerability was clearly understood as soon as it had been identified, and government agencies, as well as their partners, issued intelligence and knowledge publicly to help prevent attacks. These government agencies may not be directly responsible for regulating software producers, but their materials, products, and guidance can be used by other agencies.

B.5 Incident/Adverse Event

According to the ICRC and multiple reports, starting on November 9, 2021, the vulnerability identified as CVE-2021-40539 was exploited in the RFL systems until it was eradicated and disclosed on January 18, 2022 [4, 9, 17]. The vulnerability was in ICRC's

implementation of the Dynamics software, which supports the RFL programs.

B.5.1 Regulators

Government agencies and formal external partners (such as MITRE) had publicized a vulnerability with Zoho starting in September. However, there is no evidence that the regulators tasked with observing or enforcing cybersecurity requirements engaged with the ICRC.

The stakeholders that identified, analyzed, and disclosed the vulnerability were situated in countries and organizations with the skills and resources required to undertake such tasks. However, they may not have been closely connected enough to the ICRC software developers to get directly involved. Additionally, the users deploying the software were likely to be even further away from those stakeholders, in countries with limited cybersecurity capacity, to ensure that their software was patched based on the intelligence of the vulnerability.

B.5.2 Users

In this incident, user data was compromised. Users, the beneficiaries of the ICRC's Restoring Family Links program, put demographic and biographic data into the system, and used it to transmit messages. This information could be accessed and collected by the attacker for their own purposes.

Users would have been made aware of the incident according to the regime governing the software producer, often within a few weeks of the vulnerability being identified.

B.5.3 Producers

The ICRC implemented the software Zoho, along with its requisite chain of software tools to provide its RFL services to beneficiaries. They did not immediately update their software with the patch released on September 6, 2021, leaving them exposed to the vulnerability identified as CVE-2021-40539. This vulnerability was exploited in the ICRC's software in November 2021, around 60 days after it was first disclosed for affected software producers to address. After about 70 days of the flaw being exploited, the ICRC had detected, analyzed, contained, and eradicated the vulnerability. It is likely that they relied on the publicly available information about the breach from other stakeholders to conduct these operations. ICRC stated that "the patching process is an extensive activity for any large enterprise. Annually, we implement tens of thousands of patches across all our systems" [17].

After the incident had been eradicated, the ICRC began interacting with users and regulators to respond and recover from the event.

B.6 Impacts

The immediate impact of the incident consists of a few net effects on the different stakeholders. Users and software producers suffered injuries & harms, and may have generated some adherence & compliance documentation, such as logs as well. The regulators at this early stage of the incident are less involved, although they may have made some observations of the event.

B.6.1 Injuries & Harms

Both users and software producer suffered injuries & harms.

Users

The end users, totaling 515,000 people, who are beneficiaries of the ICRC and submitted their data to receive support, lost their confidentiality. They are a protected class of people, the survivors of violent conflict and disasters that need help. The other tiers of users, the ICRC staff, also suffered. Their data may have been compromised, and their ability to deliver assistance and protection may have diminished, either through lack of trust of their beneficiaries, or because the compromised data was used to directly subvert their efforts. For example, if the attacker was aware that some beneficiary was attempting to connect with their family, they could use this data to get access to those people and stop the connection from being made.

Developers

The ICRC, the developers of the software, also suffered from the breach. Just like the staff that implemented the software, the legitimacy of the technical team would also be called into question. Their ability to continue their operations as an organization and meeting their mission goals could have been in jeopardy. It is also possible that this breach was covered by a regulation, which could leave them open to further issues if they violated the regime's rules. However, this did not end up being the case. There also would be immediate, direct costs associated with the breach, such as incident investigation, customer notification, and crisis management. Future costs could include regulatory fines and lawsuits, as well as other internal resources to make improvements. At the time of this writing, none of these penalties have been incurred.

B.6.2 Regulators

Regulatory bodies may also have suffered some harm if their rules were found to be unsatisfactory in preventing the incident. They may also have had to expend some resources to look into the event and determine their course of action.

B.6.3 Observation

Regulators would have observed the event in the course of their duties, and as it was reported to them by other stakeholders. For example, prior to the event, regulators and other third parties issued warnings about the vulnerability that ICRC fell victim to. This failure would have been reported to the relevant regulatory bodies.

B.7 Responding & Recovering

Below are the practices and actions taken by each stakeholder following the breach. They fall into four categories of strategy: adherence & compliance; posturing; correcting; and compensating.

B.7.1 Adherence & Compliance

All stakeholders would have had to comply with any rules regarding the aftermath of the incident. In particular, the software producer that suffered the breach, may have had to notify the affected parties. However, these rules vary by jurisdiction, which included dozens of countries. It would be impossible to identify the complex regimes that governed the end users, and even the staff's rights in this case. Not only do I not have the records of the affected people, but I also cannot enumerate the rules in place that protect them between the jurisdictions where they may be protected. Regardless, it is the ICRC's adherence to the

spirit of the law that was most observable. They immediately responded by broadcasting pertinent details of the situation to the affected users, their constituents in the Movement, and the public.

It is not clear what end users would have had to do, if anything. However, if they sought compensation such as through a lawsuit, they would have to comply with rules like a statute of limitations on how long they have to respond, and what remedies are available to them.

Regulatory bodies responsible for the pertinent regimes would have to initiate their processes to observe, investigate, and determine a course of action as required by their mandate.

B.7.2 Posturing

The technology and security team at the ICRC addressed the breach publicly quickly and transparently to position themselves as acting in the best interests of their constituents, and demonstrate their efforts. Their public statements to journalists and industry publications addressed critical aspects of the breach. However, they shied away from making bold or accusatory statements, such as indicating who might have been behind the breach, other than that it was likely a state actor. This can be seen to be in line with their mandate to remain neutral. Colleagues in the humanitarian data network of the ICRC also spoke in favor of their efforts to prevent the attack, explaining that they have industry-leading data protection policies and practices [19] and this was reinforced by interview R002 [1]. The Movement also issued a new resolution which condemned these types of attacks, called on states and other humanitarian orgs to cooperate on data protection, and pushed for resources to prevent future breaches.

In this case, the affected individuals are actually largely represented by the Red Cross Movement. The Movement acts as an advocate for their beneficiaries, and made public

statements about the attack, condemning the attackers (whomever they may be) and calling for accountability. Other network advocates for people disenfranchised by conflict, such as USAID, issued similarly critical statements on the attack [19].

No regulator directly responsible for the ICRC seems to have made any public statements. The ICRC is largely governed by complex international agreements, and their efforts, as described above, seem to have forestalled any posturing by regulators. There did not seem to be any attempts to reprimand the organization such as by threatening an investigation or signaling their jurisdiction to act.

B.7.3 Correcting

Once the attack was stopped, the ICRC immediately began a long-term campaign to correct the shortcomings that led to the breach through changes to their business processes, regardless of the effectiveness of their prior prevention efforts. According to the Central Tracing Agency, "a major global effort was needed to keep the services running while these tools were offline, to rebuild secure systems and support National Societies and ICRC delegations struggling to cope with the consequences of the attack" [12]. The Movement drafted and affirmed a new resolution, CD/22/R12, *Safeguarding humanitarian data.* It called for the organizations to address security needs, commit to changes to enhance security, contribute resources where needed, create new working groups, share practices, and more. They also led a symposium on safeguarding humanitarian data, where the breach, and other topics, would be discussed [1, 11]. Additionally, ICRC developed a new Delegation for Cyberspace in Luxembourg, in partnership with CERN. This created a new experimental space for software development for the ICRC.

In this case, the Movement, which includes the broader Red Cross stakeholders, acts as the users of the software, even if they don't comprise all of the end user beneficiaries. The

resolution, described above, includes their commitment to correcting the business problems that may have led to the breach. This could include improving the physical, information, cognitive, and social dimensions of their cyber resilience [15].

The Movement is so wide, some of its bodies are also external to the software producers in the ICRC, and act as self-regulators. Their affirmation of the resolution can be seen as a self-regulatory correction, although the enforcement mechanisms are not publicly available. State or international regulators have not acted in response to the event.

B.7.4 Compensating

There is no evidence of compensation sought by the users, offered by the software producers, or mandated by regulators.

B.8 Outcomes

The Outcomes of the above strategies and practices below fall into four Net Effects: costs; transformations, remedies, and preservation. These net effects are comprised of various outputs from the response and recovery practices, and serve as inputs to the aftermath of the event.

B.8.1 Costs

The costs to the end users are somewhat indeterminate. Beneficiaries offered critical information about themselves beyond even basic definitions of personally identifiable information. Data about their families, health, location, personal history, and more were compromised, and this puts them at risk of harm from actors who want to use that data for nefarious purposes. For these passive users, those costs largely come in the form of risks of future harm. Whoever has that data now has it to use to achieve their goals.

For the deployment users, costs include training and adoption for improved processes to prevent against a future breach. The breach may have also exposed vulnerabilities with these users that could be exploited in the future as well.

For the ICRC organization that developed the software, it is likely that the largest cost was remediation of their business processes and technical implementation to prevent a similar event in the future. Given that their data privacy and security efforts have been heralded as being top-notch, the costs are likely to be a complex mix of human and capital resources. The most obvious cost is the establishment of the new delegation in Luxembourg, which required technical and legal resources. Technically, migrating their operations, physical infrastructure, and data. Legal costs include the agreement with the Luxembourg government. There does not seem to be any direct payment to beneficiaries as compensation for the breach.

Regulators may have spent some resources investigating the breach, but there is no public record to evaluate the time or money spent. However, the new Luxembourg delegation required regulators there to establish the agreement between them and the ICRC. Going forward, there will be some costs to regulating the ICRC's cyber operations which are now based in that country. There is also an analysis that the failure of the Swiss government to provide the regime that met the needs of the ICRC in their cyber operations had an indirect economic cost, because the operations were moved out of Switzerland (Fichter, Republik, 2023).

B.8.2 Transformations

It is unlikely that the end users were able to make any substantial transformation to the way that they interacted with the ICRC and its software. However, they may be disinclined to work with the organization in the future because of heightened awareness of the risks.

The technical implementation users, as documented in the Resolution, have updated their business and security practices in order to prevent future breaches. This includes better adherence and compliance with guidelines and rules that are highlighted in the *Handbook on Data Protection in Humanitarian Action*. They may have also organized with other partners to enhance their network and improve their security, such as cybersecurity companies and cybersecurity advocates.

The ICRC as software producer made business process transformations, most notably, the development of the Cybersecurity Delegation in Luxembourg, a novel initiative. It is likely that there were more internal transformations that have not been documented publicly. However, the drastic decision to move software development operations out of Switzerland cannot be understated. As discussed, the ICRC is seen to be a model for cybersecurity processes, so this output of their transformation is remarkable. The end result is a new jurisdiction under which they will operate.

Government regulators, which did not appear to act, did not establish any case law or create new regulations in direct response to the breach. However, the new jurisdiction that the ICRC will operate did result in a new agreement on regulating their data privacy and protection operations.

B.8.3 Preservation

Users

There is no way to know how many of the end user beneficiaries continued to work with the ICRC, but out of 515,000 people whose data was compromised, it is possible that there were some differences in their response. Those who stuck with the organization sought to preserve their support and services and made no change to their use. Others may have decided to preserve their future safety by disengaging with the ICRC.

Deployment teams would have sought to preserve their ability to meet their mission.

Developers

The ICRC software producers would have sought to preserve their position to deliver technology products to the Movement. In this case, they chose to sunlight the details of the breach. This included hosting a conference to discuss humanitarian data privacy and security, and were able to discuss the incident in an open, but secure environment. They made public statements to the press and through their own channels. This was all in an effort to be open about the event, and that has been seen as a positive (Interview). However, not all organizations choose to do this.

Regulators

Regulators would have sought to preserve the rules that had been set forth if they were deemed appropriate, and maintain their bureaucratic roles. In this case, Switzerland failed in that endeavor as ICRC moved its operations elsewhere.

B.9 Aftermath

This case, although very concerning, did not have any aftermath that changes the threat, regulatory, and operational environments in the broader social context going forward. Based on the model, such an aftermath would be constituted by awareness of gaps in enforcement mechanisms, new methods of cooperation, and the critical nature of the issue. While the ICRC did improve its security posture, this case did not change the data privacy laws of any of the regimes in place. There were no new methods of cooperation introduced that would change future cases, although the ICRC did hold events to discuss humanitarian data privacy after the incident. While there may have been positive outcomes, it is not a

shift in the way stakeholders come together to address data privacy and security. Lastly, and unfortunately, there did not seem to be a widespread acknowledgment of the critical nature of this issue. While the threat of humanitarian security was real, those end users had little opportunity to represent themselves to a broader population to make change. Furthermore, it is unlikely that regulators, sitting comfortably at home, could see themselves in the same shoes as the beneficiaries in conflict and disaster zones.

B.10 Case Bibliography

Bibliography

[1] Interview with participant R002, April 2024.

[2] Interview with participant R003, June 2025.

[3] Catalin Cimpanu. German government warns of apt27 activity targeting local companies. *The Record*, 2022.

[4] Catalin Cimpanu. Red cross blames hack on zoho vulnerability, suspects apt attack. *The Record*, 2022.

[5] Cybersecurity and Infrastructure Security Agency. Apt actors exploiting newly identified vulnerability. Online, 2022.

[6] Family Links Network. Code of conduct on data protection, 2015.

[7] Sergiu Gatlan. State hackers breach defense, energy, healthcare orgs worldwide. *BleepingComputer*, November 2021.

[8] Sergiu Gatlan. Red cross: State hackers breached our network using zoho bug. *BleepingComputer*, February 2022.

[9] Jonathan Greig. Red cross traces hack back to unpatched zoho vulnerability. *ZDNet*, 2022.

[10] International Committee of the Red Cross. Icrc rules on personal data protection, February 2015. Adopted by the Directorate of the ICRC on 24 February 2015, updated 10 November 2015.

[11] International Committee of the Red Cross. Symposium on cybersecurity and data protection in humanitarian action, November 2022.

[12] International Committee of the Red Cross. Towards safer digital services: The cta data breach 1 year on. Online, 2023.

[13] International Committee of the Red Cross and International Federation of Red Cross and Red Crescent Societies. Restoring family links: Strategy for the international red cross and red crescent movement 2020–2025. Technical report, ICRC and IFRC, Geneva, Switzerland, 2020.

[14] Stevens Le Blond, Alejandro Cuevas, Juan Ramon Troncoso-Pastoriza, Philipp Jovanovic, Bryan Ford, and Jean-Pierre Hubaux. On enforcing the digital immunity of a large humanitarian organization. In *2018 IEEE Symposium on Security and Privacy (SP)*, page 424–440, San Francisco, CA, May 2018. IEEE.

[15] Igor Linkov, Daniel A. Eisenberg, Kenton Plourde, Thomas P. Seager, Julia Allen, and Alex Kott. Resilience metrics for cyber systems. *Environment Systems and Decisions*, 33(4):471–476, December 2013.

[16] International Committee of the Red Cross. Our mandate and mission, December 2023.

[17] International Committee of the Red Cross. Cyber attack on icrc: What we know, June 2024.

[18] International Committee of the Red Cross. Reconnecting families: Preventing separation, searching for the missin, reuniting loved ones, 2024.

[19] William Worley. Icrc says cyberattack was 'state-like' in nature. *Devex*, February 2022.

Appendix C: Equifax Case Analysis

C.1 Introduction

Equifax is a US-based credit reporting agency (CRA), one of three in what is called the Consumer Reporting Agency System. The role of a CRA is to collect consumer data that can be used by businesses, such as employers and creditors, as well as government agencies, in their operations. There is a robust regulatory environment surrounding the CRA system, including oversight and enforcement from agencies like the SEC and FTC, as well as others. The CRA system has a very large role in American society, pulling in data on every consumer in the country and their habits and purchases, and providing them to a variety of business customers. In 2017 an attacker accessed and stole the data of 145.5 million consumers in the US, and more in Canada and the UK. There were immediate responses from all stakeholders, including regulatory action, business customer behavior, and, eventually, monetary compensation from Equifax to affected individuals. The scale of the breach, the regulatory environment in which it occurred, and the aftereffects offer an excellent case study in conflict and cooperation in cybersecurity.

In order to analyze Equifax's internal software engineering and cybersecurity behaviors leading up to and immediately following the breach for this case study, I relied on a variety of data. However, there are a handful of archival documents which are especially important to the analysis. These include the investigations by the US House of Representatives Committee on Oversight and Government Reform, the US Senate Committee

on Homeland Security and Governmental Affairs, and the US Government Accountability Office, which issued their final reports in 2018 and 2019. The reports include primary data from interviews with Equifax staff (including the CEO, CISO/CSO, CIO), auditors and forensic analysts within the federal government, staff at Mandiant (the firm that was both hired by Equifax to respond to the breach and mandated by Congress to report on Equifax's response efforts), and government agencies that were customers. These reports are valid sources for so much data because they include e.g. sworn statements from key participants in the case, who could be prosecuted for intentionally misleading the investigators. These individuals (like the former Equifax CEO or CISO) are also not likely to be willing to participate in my study, such as through interviews, so their testimony to the government must serve as primary data for the case study. The data collected in the reports are also extensive. They include valuable information like longitudinal explanations of the software engineering and cybersecurity practices at Equifax as far back as the 1970s, and more recent strategies and organizational behaviors prior to the breach. These are based on testimony from staff within the firm and from their expert vendor, Mandiant. I do not rely solely on this data, and triangulate my analysis with other sources and observations as well. This document was mainly used to analyze the internal workings of the software producer, while the behaviors of the other stakeholders rely on a broader range of sources.

C.2 Cyber Social Context

The credit reporting agency system is vast in scale. For its end users, it incorporates the data of nearly every adult living in the US, and there is no ability to opt out of it [48]. The end users, typically US consumers, are critically impacted by the data collected in their everyday lives, including housing, employment, and banking. CRAs are "woven into the fabric of the country's business establishment" [51]. Business users subscribe to services

provided by the agencies, making use of the data for their operations as a "vital aspect of the global financial system ... that fuels the economy" [17]. The credit reporting agencies that collect this information rely on their own complex software implementation to do their business. They collect data from a variety of sources including banks and lending institutions and aggregate the data to create products like credit scores which are used by their business clients. The data they store includes personally identifiable information as well as habits and behaviors that would be valuable to threat actors. These CRAs are highly regulated by multiple government agencies including the Securities and Exchange Commission (SEC), Federal Trade Commission (FTC), Consumer Financial Protection Bureau (CFPB), the courts, and state governments in US. There are additional corresponding agencies in the UK, Canada, and elsewhere. In short, the threat environment is rich with opportunity, the operational environment is considerable with regard to the monetary value of the data, and the regulatory environment is complex.

C.2.1 Software Producer

Credit reporting started as a way for businesses to get a centralized and controlled method for evaluating potential business partners for lending [32, 48]. The industry's operations have expanded to incorporate important aspects of everyday life, supporting a variety of businesses. CRAs offer a suite of products that businesses use to inform their operations based on the data collected about consumers. Equifax is one of three major credit reporting agencies in the US, along with Experian and TransUnion, and boasts credit information on 820 million consumers and 91 million businesses as of the time of the breach [48].

Operational Environment

Equifax has been a publicly traded company since 1965. It "gather[s] consumer data, analyze[s] it to create credit scores and detailed reports and then sell[s] the reports to third parties". Those third parties are businesses that are considering lending money or doing business with individual consumers. Equifax maintains an ecosystem of software to meet their business goals and to meet non-functional requirements to comply with regulations. One such application was the "Automated Consumer Interview System (ACIS), a custom-built internet-facing consumer dispute portal developed in the 1970s". Equifax built the ACIS software to comply with the Fair Credit and Reporting Act of 1970 and handle customer disputes [48].

The ACIS system was built using the Solaris operating system, developed by the "now-defunct company Sun Microsystems" [48] and relied on both open-source and proprietary closed-source software. Equifax used the popular Apache Struts software to make the ACIS system consumer-facing via the internet.

This combination of legacy software intertwined with modern software created a complex operational environment for Equifax.

Meanwhile, the company continued to grow, including a commercial growth strategy that included acquiring eighteen companies from around the world leading up to the breach.

Threat Environment

According to the House investigation, "massive amounts of data equals massive security risks." As the company grew, so too did its value to prospective threat actors who would seek to compromise their data for illicit gains. There were multiple high profile data breaches of CRAs leading up to 2017, which included Equifax as well as other companies [6].

In order to mitigate this threat, the cybersecurity teams at Equifax would need to develop a broad internal familiarity with the vulnerabilities that were unique to them. This means that the systems they developed, combined with the value of the data that they stored, warranted "best-in-class protection and cybersecurity practices" for their industry according to the House of Representatives [48]. The investigation detailed the cybersecurity leadership at Equifax, including officers with decades of technology and legal experience who had been hired between 2010 and 2013.

Regulatory Environment

In the US, credit reporting agencies like Equifax operate in a highly regulated environment, both at the federal and state levels, leading to a complex regime to which they must adhere. Federal regulations that grant oversight for CRAs include the Federal Trade Commission Act, Dodd-Frank Act, Fair Credit Reporting Act (FCRA), the Fair and Accurate Transactions Act (FACT), and the Gramm-Leach-Bliley Act, which are enforced by the Federal Trade Commission (FTC) and the Consumer Financial Protection Bureau (CFPB). Because Equifax is a publicly traded company, cybersecurity issues are also overseen by the Securities and Exchange Commission (SEC). At the state level, Equifax also needs to comply with any regulatory requirements set forth by any of 50 states [17, 48, 53]. CRAs that operate in other countries must adhere to their regimes as well as international guidelines, such as those provided by the OECD [18]. There is also a bevy of case law that factors into the cybersecurity regulatory regime, as well as other consumer protections, in various US court jurisdictions [38, 51, 53].

In 2017, Equifax was already in the FTC's crosshairs. In 2012 they were fined for knowingly violating consumer privacy laws, when they improperly sold the data of US consumers who were late on their mortgages. In addition to the fine, Equifax was also

required to comply with additional requirements set forth by the FTC [10].

Equifax also does business in the United Kingdom, and is subject to regulations there, including the independent Financial Conduct Authority (FCA) and the parliamentary Information Commissioner's Office (ICO), which regulate financial services firms and data privacy, respectively.

The regulatory environment that Equifax operates in is highly challenging. It requires compliance with a multitude of laws, necessitating formidable internal regulations as well. To meet these requirements, there are technical challenges that must be addressed, including security protocols, file integrity monitoring, and network segmentation. Ultimately, they interpret all of the laws and regulations that contribute to the regime to interpret them and apply them as they see fit.

C.2.2 Users

The users of the software created by Equifax fall into one of two use cases, passive or active. Active users are the customers of Equifax's services, purchasing data about consumers to make operational and financial decisions. The passive users are the consumers about whom Equifax collected data, typically without any affirmative agreement to do so, and without the option to prevent access to the data [48].

Operational Environment

Business customers are active users of credit agency services. "Major corporate and government contracts rather than sales to individual consumers create the company's earnings" [48]. These organizations partner with CRAs like Equifax which "serve as sources of information about consumers' use of credit as reported by those from whom users borrow" and "give businesses insight into a consumer's past behavior" [32]. Money lenders,

like banks and credit unions, that are CRA customers may also participate in a "give-to-get" scheme, where they must provide information about their existing customers in order to get information about potential customers [32]. While historically money lenders were the customers of this data, today, other companies also have access to it for heterogeneous practices. For example, to "enable marketers to better deliver the right message to the desired target audience based on consumers' likely interests and economic profiles" [16, 26]. In short, CRAs provide data about consumers to any business customer.

Business users benefit from these software services by using them to find and reach their target audiences. Not every staff member has access to this data, so there would be restricted permissions and a hierarchy of users that can use the data for business operations. Consumer users benefit from these services by getting access to products that meet their heterogeneous needs: consumer needs vary widely from individual to individual.

Business customer users also include government agencies, such as the Internal Revenue Service, which used Equifax's identity verification services [48].

Consumers are passive users of the CRA technology, automatically supplying their financial information without the option to opt out [40, 43, 48] when they spend money on "retail, travel, auto, and more" [16]. Consumers can also self-report data like their employment and income. All this data, along with other information like demographics, magazine subscriptions, charity contributions, utility payments, and more, collected from a variety of sources, are available to business customers. They are also aggregated for ease of use, including "buying behaviors, preferences, and characteristics" [20, 26, 27]. This data is compiled based on credit accounts using Social Security numbers and other identification information [23].

Threat Environment

According to the US House investigation, "having so much personal information in one place made Equifax a prime target for hackers" and CRAs were the "target[s] of multiple cyberattacks in recent years" [48]. As such, there is a broad threat of harm to users in this context.

Identity theft, which can occur when personally identifiable information (PII) is leaked can have a negative impact on consumers and their credit history. PII can be leaked by inadequate security for credit data, such as in this case, or from a variety of other intrusions. According to a report from the US Department of Justice, "in 2016, an estimated 26 million persons, or about 10% of all U.S. residents age 16 or older, reported that they had been victims of identity theft during the prior 12 months" (Harrell, 2019). These victims suffered direct monetary losses as well as other financial or legal problems, including higher interest rates on credit cards, denials on loans, utility shutoffs, and even criminal proceedings (Harrell, 2019; Anderson et al, 2008; CALPIRG, 2001; Cheney, 2003). They also experienced emotional distress (Harrell, 2019). This report, based on data from 2016 also indicates that 55% of identity theft victims spent one day or less, and an average of 4 hours, resolving financial and credit problems. By comparison, a 2000 report from the consumer advocacy groups CALPIRG and the Privacy Rights Clearinghouse, reported that it took 55% of victims an average of 44 months to resolve their cases [3]. This report also noted that the victims they sampled (n=66) indicated that Equifax was the "hardest one to get in touch with, and the one about which most negative comments were made."

The DOJ and CALPIRG identity theft reports differ widely in multiple ways. First, there is more than a 15-year difference between the data collected, in which time a lot changed with regard to data privacy and security, particularly surrounding the growth of the internet, social media, and e-commerce. Additionally, the more recent report was released

by the federal government, and the earlier by consumer advocacy groups. The DOJ report had a sample size of over 96,000 people, while the CALPIRG report had a sample size of 66. Lastly, while both artifacts used quantitative data, the CALPIRG report also included qualitative data including comments and stories about the victim's experiences. The DOJ report only included statistical information which hid the perniciousness of the identity theft and seemed to diminish the real impact: it highlighted that 55% were able to solve their problem in a day or less, but that still leaves over 10 million people that had to take more than a day to solve issues arising from the identity theft. However, the DOJ report did include a metric for emotional distress, which was unique. The interests, methodology, and context vary widely between these publications, so it is important to take this into account when analyzing secondary data about the threat environment for victims of identity theft.

Regulatory Environment

The business customer users of the CRA software do not appear frequently in the discussions of the regulatory environment. The data that they accessed may be regulated depending on what industry they are in, such as banking, but the case here is about Equifax itself, which collected, aggregated, and sold the data.

The passive consumer users, however, are highly protected. The regulations introduced in Section C.2.1, including legislation and case law going back decades, contribute to regimes that are in place specifically to safeguard consumers. The FTC and CFPB pursue data security violations, enforce consumer financial law, and enforce compliance based on the Fair Credit Recording Act, Dodd-Frank act, and Gramm-Leach-Bliley Act. Private companies are also required by state laws to disclose cybersecurity breaches to users, and possibly by the SEC to investors [48]. CRAs have also been the subject of lawsuits by consumers since their inception in the 19th century, and consumers were also punished if

they “knowingly submitted erroneous financial statements” [51].

C.2.3 Regulators

As discussed, there is a large network of bodies that contribute to the context of credit reporting agency regulation. Their environments have inputs and outputs that have changed drastically over the century and a half since the industry developed, in particular since the advent of software as a key component of CRA operations.

Regulatory Environment

The regulatory environment in the credit reporting system is very active, including the legislative and judicial branches of government in the US, and their counterparts internationally. Although software security is a more recent focus, due to the sensitive nature of the credit reporting system, protecting consumers privacy and rights while supporting businesses economic interests has long been the nexus of regulatory efforts [32, 48, 50, 51, 53]. The FCRA, enacted in 1970, was designed specifically because of the concerns arising from the modernizing credit reporting system and its consolidation of sensitive information [40, 43]. Subsequent laws like the 2003 Fair and Accurate Credit Transactions Act (FACT) include sections to prevent and correct identity theft [53]. The result is an emergent regime that governs CRA behavior, that has adapted to and been shaped by societal changes including politics, technology, law, and economy. Laws and subsequent regulations have been enacted, resulting in authority being granted to independent agencies to enforce them. Court cases stemming from disputes between parties have led to case law that also contributes to the regulation of CRAs by administrative authorities and sets precedent for future cases. The SEC also participates in regulating the cybersecurity of publicly traded companies like Equifax given the impact of risks and incidents for investors [34, 61].

Outside the US, such as in the UK and Canada, Equifax is regulated by similar laws. The Data Protection Act of 1998 defines eight data protection principles to ensure the lawful processing of data by UK entities and is enforced by the ICO. In Canada, the Personal Information Protection and Electronic Documents Act is enforced by the Privacy Commissioner.

The emergent regime, based on these complex factors, stood as the context for this case study leading to the breach, and throughout the conflict as it unfolded until its conclusion. Regulatory stakeholders acted based on the environment at the time.

Threat Environment

International regulatory stakeholders were familiar with the data security and privacy threats to CRA's data, and had established security measures going as far back as the 1980 OECD guidelines for privacy and transborder personal data flow protection [18]. In the US, the Fair Credit Reporting Act of 1970 requires CRAs to "adopt reasonable procedures ... with regard to the confidentiality" of consumer information [15, 48].

Software and information technology has become a critical component of CRA operations, and regulatory stakeholders have developed expertise on vulnerabilities, and there is a network of stakeholders that can contribute to monitoring and enforcement actions, both within and outside the government, including industry groups, third party contractors, and other government agencies.

Operational Environment

There are multiple regulatory stakeholders responsible for the credit reporting system, and they are subject to a variety of factors that can impact their operations. In particular are FTC and CFPB, independent agencies that were established by the US Congress. In

the UK, Equifax is also subject to regulation by the FCA and ICO. Each organization has mandated jurisdictions and enforcement capabilities that determine their ability to regulate the CRA subjects. They are also impacted by the interests of the parties and politicians that are in power (the CFPB for example, was created by President Obama and cut by President Trump in 2025). There are other inputs, such as the economy, and the human resources available that also impact the operational capabilities of regulators. The courts are also subject to legal precedence, jurisdiction, and the inclinations of the judges that are serving at any given time.

Regulators must take all stakeholders into account in their operations. Enforcement efforts that punish CRA companies for cybersecurity failures too strictly can harm businesses and the economy. In the short term, it could negatively impact the CRA and its clients. In the long term, it could negatively impact the community by dissuading other businesses from operations that they deem too risky. However, lax enforcement action could negatively harm individual consumers and families, and lead to future harms if companies see opportunities to circumvent regulations. Regulatory bodies also have to report to supervisors, such as Congress or a board of directors.

The US Federal Government also provides a collaborative entity that sits within the Department of Homeland Security's National Cybersecurity and Communications Integration Center (NCCIC), the United States Computer Emergency Readiness Team (US-CERT). "US-CERT has partnerships with private sector security vendors, academia, federal agencies, ISACs, state and local governments, and international organizations" to "aggregate and disseminate cybersecurity information intended to help recipients prevent and respond to cyberattacks" [58].

C.3 Operating & Precursors

The conditions that preceded the breach of Equifax include their operating activities and overarching practices, as well as those of their users and the regulators. Users relied on Equifax for their day-to-day operations, and Equifax was supposed to follow requirements set by regulators. These operations had inputs and outputs, as well as net effects, that directly led to the breach of Equifax's data. The software that Equifax struggled to maintain was actually their Automated Consumer Interview System (ACIS), a custom-built internet-facing consumer dispute portal developed in the 1970s to comply with the Fair Credit and Reporting Act to handle customer disputes. By 2017, the legacy system behind ACIS was not only outdated, but faced major maintenance and was slated to be updated. In particular, the House investigation shed light on the internal processes of the C-suite leadership and the IT management operations that affected the precursors leading up to the breach.

C.3.1 Software Producer

In this case, there are clear connections between the business operations of Equifax and the precursors that led to the breach, as well as, ultimately, to the impacts of the breach. The implementation of their software to do business required the constant and ubiquitous collection of data about US and global consumers' "most personal information" [43], using software and IT infrastructure going back decades. At the same time, they also had to secure their software to protect this sensitive data, to defend against, and prevent unauthorized intrusions. Simultaneously, they had to comply with strict regulations because of the sensitive nature of their business. The two broad areas of concern are the overarching business practices at Equifax, and the specific management of the ACIS software that was breached.

Business Model

Equifax's business model is to collect, analyze, and sell data about consumers to meet the needs of its customers. While this started as financial information that was sold to businesses for the purposes of credit, it later expanded into new lines of business, specifically, software tools for marketing a wider range of products and services. To meet those business needs, the data being collected also expanded into more types of information about consumers. Starting in the 1970s and 1980s, CRAs like Equifax "entered the database marketing business" meeting their customers' needs with capabilities like demographic segmentation and direct mail campaigns. This growth paralleled the internet revolution and inception of the information economy starting in the 1990s as collecting data about consumers became easier and easier [40]. The quantity and depth of this data made it valuable for Equifax's business, which meant it also became increasingly valuable for criminals.

Business-wide, their capacity was severely limited due to business process issues with leadership and management, restricting their ability to comply with mandated security requirements and general best practices. At the same time, their software, which had been developed in the 1970s, had become outdated and required business change. Changes required not only immediate critical updates and patches to the software, but also an eventual full system upgrade, replacing the legacy software. Neither of these were properly managed (US House, 2018; US Senate, 2019). These all led to unaddressed failures and weaknesses.

Conflicts between executive leadership also led to capacity issues. Ineffective reporting structures and inattention to cybersecurity by the CEO were identified as inputs that led to the unaddressed failures. According to the report, management "failed to establish clear lines of accountability for developing IT security policies and executing these policies" [48].

One example of the weaknesses caused by issues in their business processes was making the ACIS application compliant with the Payment Card Industry (PCI) Data Security Standard (DSS). The IT team explained that they had fallen behind in this implementa-

tion, and had they come into compliance, it would have “largely addressed” key security concerns [48].

In addition to compliance with existing regulations, Equifax also attempted to influence regulations, at one point spending $250,000 to stop a new consumer privacy act according to Senator Patrick Leahy(Senate Judiciary Hearing, 2017).

Software Management

The Congressional reports go into detail about two of the broad operational security weaknesses at Equifax: their patch management process and their certificate management process. These would have been critical in preparing for, defending against, and possibly preventing the breach altogether. Once an alert had been issued about a vulnerability in a component of their software, Apache Struts, a policy manager should have been accountable for applying and testing the patch and ensuring that it was applied properly. Their certificate management process also lacked appropriate capacity and would have been another tool to alert the team about suspicious traffic. However, the SSL certificates were not properly maintained, representing another unaddressed failure.

Specific to the legacy ACIS environment, the reports analyzed crucial capacity and security issues. For example, documentation and business artifacts regarding the legacy system were ineffective: There was no inventory of the software used in the application, and logs were not kept long enough to identify malicious activity. Capacity to maintain the antiquated software was based on the knowledge of team members that had been there since its implementation. By the time of the breach, this cadre had dwindled to “a couple” of people, according to testimony from the CIO [48]. The reports identified and analyzed multiple unaddressed technical security failures and weaknesses that existed in spite of the plans to upgrade and patch the system, such as the lack of separation between different networks, servers, and file systems, which made it easy for attackers to access more data once they had compromised the system.

C.3.2 Users

As described in the Context in Section 1, there are broadly two classes of user stakeholders for Equifax and other CRAs: business customers and consumers. The business customer users deal directly with Equifax, deploying its software to meet their business goals. The consumers are "passive" users, as their data are the subject of the business relationship between Equifax and its customers. To put it in terms of a hierarchy, the business users have a close relationship with Equifax, putting them higher up on a pyramid. Consumer users sit low on the pyramid, there are more of them, but they are further removed from the CRAs and have limited access to the software system.

Business Customers

The primary users of Equifax's software are businesses, organizations, and government agencies. In his testimony, Equifax CEO Rick Smith stated that only 10% of their business at the time was consumer business (B2C), which means around 90% of their business was with other businesses (B2B) [1]. A financial report from the credit agency Experian (a competitor of Equifax) shows that in 2024 around 16% of their business was direct-to-consumer [26]. As discussed above, these business customers deploy Equifax's software for a variety of business needs. As of 2024, Equifax identifies products for "Credit Risk, Verification, Identify & Fraud, Workforce Management, Data-driven Marketing" [26]. In 2017, their website advertised nearly 200 products and solutions for "business needs" including "Acquire more customers," "manage my workforce," "mitigate risk," "recover debt" and more [21].

According to the US House Report,

> ...lenders rely on credit reports and scores when determining whether to grant

> a loan and the corresponding interest rate. Insurance companies use the information to set policy premiums. Employers may use the information to screen prospective employees for risk of fraud. Utility and telecommunication service providers use the reports to verify the identity of customers and determine down payment requirements for new customers.
>
> Federal agencies use identity verification services ... when enrolling new applicants for federal benefits and services. The Internal Revenue Service (IRS), for example, awarded Equifax a $7.25 million contract for taxpayer identity verification and validation services after the 2017 data breach had been publicly announced.

[48].

This shows that the CRAs provide a valuable resource for businesses and government agencies. Consumer reports help businesses make informed decisions which can help them succeed and protect them from risk [32, 36, 40]. They can use modern credit reporting software to decide with whom to do business as well as identify markets to grow their business. They can also verify that the people they are doing business with are who they say they are through identity verification. Business customers also include government agencies, the largest of which were the Internal Revenue Service (IRS), Social Security Administration (SSA), and US Postal Service (USPS). Much like other business customers, these government agencies used Equifax's identity verification services [52].

Business customers not only receive data from CRAs, but also provide it to them. They must "give to get" and "have incentives to report their own experiences with borrowers so as to gain access to other creditors' data in the future" [32]. This gives them access to a "deep and granular view of consumers' lives" from a variety of sources, which is critical to their business model. As of 2017, "Equifax had credit information on 820 million consumers

and 91 million businesses" [48].

Businesses that deploy these tools come from a variety of industries, and the data that they collect about consumers from Equifax, as well as the data that they provide to Equifax is protected under the same regime that governs Equifax itself. They must secure this information because it includes protected data including PII, which is vulnerable to identity theft. For example, the FTC has compliance requirements for disposal of consumer reports to "protect the privacy of consumer information and reduce the risk of fraud and identity theft" stemming from the GLBA and FACT Act [13]. Companies that purchase consumer reports must have the capacity to protect this data: their staff must be trained on the rules, and they must provide resources to their technical teams.

Consumer Users

Consumers are the critical component of the CRA system. It is their data that the business customers pay the software producers to aggregate and analyze. It is also the protection of that data that effected the laws and regulations that govern the CRA software producers and their customers. The regimes with which the software producers must comply are designed to protect consumers, who are the citizens of the US and other countries where the companies operate. Consumers also include the government staff responsible for regulation and the employees of the CRA companies who implement the software.

Consumers need this data in their daily lives to meet needs such as housing, employment, and banking. In the interest of "future access to credit," consumers "have an incentive to avoid a default that might become known to other creditors" [36]. As such, people can regularly rely on their credit record as a resource for businesses to trust them in important transactions where there is no prior relationship, such as for mortgages, leases, loans, jobs, childcare, insurance, and more. The companies that use this data can provide other prod-

ucts and services that are valuable for consumers as well, meeting their needs by identifying prospective customers through marketing data provided by CRAs.

However, these reports can also be flawed, leading to negative impacts for consumers. Inaccurate reporting by businesses or adverse events out of the consumer's control can be recorded, affecting their future access to credit. "A lot of times bad credit is the result of bad luck" [43]. Moreover, consumer users cannot fully opt-out of this ecosystem and have little control over how this data is collected and secured, leading to the expansive "slurping up" of their "most personal information" [40, 43, 46]. To help remedy the effects of bad credit, especially when it is based on inaccurate information, there are dispute mechanisms mandated by regulators through the multitude of laws and regulations discussed previously. Protecting the interests of consumers from the harms of poor credit reporting practices has been an important impetus for the rights codified in the law.

Crucially, negative data that puts consumers at risk in the CRA system can arise from identity theft and fraud. Identity theft has indirect and direct costs for consumers. Indirectly, and especially important to this case, are the impacts on their credit reports. Direct costs are the out-of-pocket payments that victims may have to pay resulting from the identity theft. The indirect costs associated with derogatory data on their credit reports can lead to higher interest rates on credit cards, denials on loans, utility shutoffs, and even criminal proceedings [2, 3, 7, 35].

C.3.3 Regulators

As discussed in Section C.2.3., there is a complex regime that emerges from the various governmental and non-governmental bodies that regulate the credit reporting system and its stakeholders. In their regular operations, these bodies practice rulemaking, enforcement, and investigation (based on FTC Authority, 2021) with varying levels of au-

thority and power depending on their influence. There are substantial federal (national) resources that regulate the industry, including the FTC and CFPB in the US. There are also state-level practices from all 50 states and US territories, and supranational organizations as well. CRA stakeholders also participate in self-governance, which can be binding or non-binding, such as PCI-DSS and CDIA Metro 2. The outputs of all of these regulatory practices result in the net effect of the regime that governs the stakeholders. Additionally, their operational practices, such as rulemaking and influence, have outputs that determine their capacity. For example, rules, created by these agencies and other government offices, can determine how powerful a government agency is: thorough rules can make an agency strong, and fragile rules can make an agency feeble. For example, an agency that can fine violators, resulting in money paid to the regulator and its counterparts, can influence their capabilities.

The FTC is a particularly useful stakeholder for analysis because of the scale and scope of their operations. They perform many of the operations that other regulators do, although most regulators do not have the capacity to do as much as the FTC does. They cover the breadth of operations of most regulators, and while their jurisdiction may be different from other regulators, they present an excellent archetype for analysis of regulatory operations. In this case, they are important because they are an established stakeholder shaping the regulation of CRAs as well as privacy and data security more broadly.

The practice of rulemaking by regulators is ongoing and significant in the credit reporting system. New laws are made, extant ones are updated, and subsequent regulations are established based on those laws. However, changes can take time and are subject to influence from all stakeholders while they are being established. Just a few examples of major changes include the FCRA of 1970, the GLBA of 1999, the Safeguards Rule issued by the FTC in 2003, and the establishment of the CFPB by the Dodd-Frank Act of 2010 [48].

Enforcement practices by federal agencies are continuous as well: by 2018, “the FTC

has brought over 60 cases against companies for engaging in unfair or deceptive practices by failing to adequately protect consumers' personal data" [48], and over 100 cases for violations of the FCRA and almost 30 cases for violations of the GLBA [14, 48]. Civil and administrative enforcement activities like these are the FTC's "principal tool ... for unlawful behavior, and require the company to take affirmative steps to remediate this behavior. Affirmative steps may include the implementation of a comprehensive data security program or monetary redress to consumers" [48].

Another critical factor is that rules are also subject to prior decisions made by the courts. Each enforcement action can impact future enforcement activities, and the regime more broadly. Court decisions seem almost constant, occur in a variety of jurisdictions, implicate heterogenous stakeholders, and result in countless outcomes [38, 48].

Investigative practices occur before and after violations are identified, as well as after the violations have been remediated with the regulator. Investigation can occur before a violation, resulting in the identification of violations, such as the FTC's 2004 nationwide compliance sweep of financial institutions for violations of the security requirements protecting customers' sensitive personal and financial information [8]. Investigation also occurs once a violation has been reported, such as to determine whether to take further action, the scale of the violation, and the appropriate response. This process can involve third parties from other regulators or industry experts, such as auditors or forensic specialists. Following enforcement actions resulting from a violation, regulators may be required to monitor the violating party to make sure they are compliant with rules that they agreed to as a result of the enforcement actions. For example, the FTC sued financial company RealPage, Inc. in 2018 and they were, among other penalties, required to provide a yearly compliance notice to the FTC for 10 years [14, 30].

Regulators also engage in activities of influence that impact both their capacity and the emergent regime. Again, the FTC provides an excellent example within the field of con-

sumer privacy, although not directly in the CRA industry. In 2012, the FTC sued and won in landmark cases against Facebook and Google for consumer privacy violations, demonstrating their ability to pursue violators. The Google suit resulted in a $22.5 million civil penalty, an historic fine for the agency at the time [11]. The Facebook suit led to a consent order, which put penalties in place if Facebook "made misleading statements in the future about consumers' control over the privacy of their personal information." Ultimately, although it occurred after the 2017 Equifax breach, Facebook was fined $5 billion in 2019 for violating this order and resulted in a new order for oversight into their practices [9, 12]. These cases are extreme examples of the FTC as a regulator to influence other stakeholders. Although they are not in the consumer reporting field, they do signal to other software companies, as well as users and other regulatory bodies, that the FTC has the capability, including authority, funding, intelligence, and knowledge to enforce rules. Their operations also shape the regime, establishing precedence for future regulatory operations.

C.4 Incident & Impact

Attackers breached Equifax and remained undetected for 76 days starting in May 2017. The attackers used a vulnerability that was first detected by the Apache Software Foundation in February 2017 and disclosed by them publicly on March 7. NIST's National Vulnerability Database indicated that the complexity of compromising the vulnerability was low, and the potential damage was high, and US-CERT also notified companies like Equifax of the vulnerability. In late July an Equifax cybersecurity team detected suspicious behavior and began the process of containing and eradicating the vulnerability. Starting in August, Equifax began investigating the impacts of the breach and preparing for their next steps. The incident refers to the span of time between when hackers exploited the vulnerability and when Equifax was able to eradicate it. The incident compromised the data of 148

million users, exposing their protected PII to nefarious actors. The incident has multiple impacts during and after the incident on the company, its users, and on regulators.

C.4.1 Software Producer

Incident

As discussed in Section 2, Equifax's operations effected a variety of precursors that exposed a vulnerability in their software. Specifically, there were unaddressed failures and weaknesses in the legacy systems supporting their internet-facing ACIS environment, including two web servers and two application servers. These servers relied on a software module called Apache Struts, which needed to be patched after a critical vulnerability was discovered and publicized in Spring 2017. The vulnerability was identified as CVE-2017-5638, was published by the National Vulnerability Database on March 11, 2017. Companies including Equifax were informed of its existence [48]. Two months later, on May 13th, the incident began when hackers were able to exploit the exposed vulnerability. The attackers were able to query databases in the system, target valuable data, and ultimately exfiltrate it.

During the incident, the attackers were also able to "move laterally" and access other databases unrelated to ACIS where the breach began. This is because the ACIS software was not segmented to prevent such behavior. The system suffered from other flaws (SQL Injection and Direct Object Reference attacks) that allowed the attackers to not only view the data, but also add software modules to the server which were then used to retrieve the data they identified. The attack went unnoticed for an extended period because another failure, expired credentials (for SSL certificates), prohibited Equifax's IT security team from monitoring traffic in the ACIS system.

After being out of date since January 2016 (19 months), the credentials were finally

renewed and uploaded on July 29, 2017. At this point, Equifax's IT was able to inspect traffic and immediately detected suspicious behavior, analysis indicated that it consisted of "requests from an IP address originating in China" [59]. After the suspicious traffic was detected, vulnerability testing was conducted, and the SQL injection vulnerability was also identified. At this point, on July 30, the security team "decided to shut down the ACIS web portal for emergency maintenance" eradicating the vulnerabilities and effectively ending the attack [48].

The attackers had access to the compromised systems and data for a total of 76 days until the breach was identified. The data the attackers identified and retrieved (compromised) included personally identifiable information about consumers, including names, dates of birth, social security numbers, and more [48, p. 53]. This data can be used for crime, espionage, activism, or other efforts.

Impact

The most immediate impact to Equifax was the initiation of Project Sierra, which was their endeavor to respond and recover from the attack. Eventually, the attack would have direct costs of over $1.38 billion and could be over $7 billion when considering indirect costs [47]. Direct costs include a fund of $380.5 million for the damages to members of the class action lawsuit, and millions more depending on class members (users whose data was compromised) participation. Indirect costs include the human and capital resources that Equifax had to commit in order to respond to the aftereffects of the incident. After they disclosed the incident, "Equifax's stock price fell 25 percent in the first week, wiping out $6 billion in market revenue" [48, p. 44].

Another major impact was the shut down of the ACIS portal, which was for handling customer complaints. This meant that customers were unable to file their complaints until

the legacy software was fully updated or replaced.

C.4.2 Users

All in all, the attackers gained unauthorized access to the data of 148 million individual users. Critically, this was primarily PII, including names, dates of birth, social security numbers, addresses, driver's license numbers, phone numbers, email addresses, payment card numbers, and more [48]. Together, these data put individuals at risk for a variety of harms like identity theft. However, not all users suffered the same exposure. For example, unauthorized access to payment card (credit card) number and expiration date data was limited to 209,000. And email addresses, which did not include login credentials, amounted to 1.8 million. Thus, not all users suffered the same consequences of the breach. However, the name, date of birth, and social security numbers were still compromised for over 145 million people [48].

In the UK, an additional 15.2 million consumers were affected by the breach, including the sensitive data of 693,665 users [44]. In Canada, 19,000 people's data was compromised, "almost all of whom had their social insurance number, along with other accompanying identifiers, compromised" [49].

The immediate impact on business customers is less clear. Ultimately, they trade information about the consumer users with Equifax. It is possible that they may have sought other vendors to provide these services if they no longer trusted Equifax.

The harms to users, both consumers and business customers, as a result of this breach, is unknown. There is not a way to determine whether the data compromised in the Equifax breach led directly to out-of-pocket costs for victims. Eventually, however, individuals were eligible to receive up to $125 from the settlement, as well as out-of-pocket expenses. Research indicates that there was an average loss of $930 per victim of identity theft in

2018, and victims may also suffer negative impacts on their health and well-being [42].

C.4.3 Regulators

The immediate impact of this breach on regulators is limited. The government bodies responsible for supporting cybersecurity had publicized the vulnerability in their typical operations. Nongovernmental bodies that contribute to financial data protection would face their challenges later. Eventually, the executive, legislative, and judicial branches of the federal government would get involved. However, there was no immediate impact until Equifax moved on to the responding and recovering phase.

C.5 Responding & Recovering

The responding and recovering phase for this case is immense and went on for years, compounding complex action-interactions. It necessitated the involvement of stakeholders from every corner of society: millions of users, multiple government bodies, elected officials and bureaucrats, senior leadership and middle management within Equifax, and a network of experts in cybersecurity and law representing all sides. This phase began the moment Equifax eradicated the vulnerability in July 2017 and concluded in January 2024 when the deadline passed for users to make claims for damages, as ordered by the courts in the US.

The strategies and activities of this phase are detailed down to their minutiae in highly reliable documentation, particularly the US House of Representatives Committee on Oversight & Government Reform report from 2018, as well as news publications, court documents, public statements, and official communications from Equifax.

C.5.1 Software Producer

On July 30, 2017, Equifax shut down its breached ACIS system and began the process of responding to and recovering from the incident. Their first step was escalating the details about the breach known at that time to senior management in the C-suite. The following day they initiated "Project Sierra," allocating *ad hoc* resources to correct the net effects of the incident. Their correction activities quickly included forming a network with cybersecurity firm Mandiant, the FBI, and outside legal counsel [48]. The response from both the regulatory and user stakeholders was swift and had major impacts on Equifax's response & recovery efforts. They started the process of complying with regulatory requirements, specifically disclosure, preparing statements and resources for the affected users on September 7th. On September 14th, one week after the disclosure, the House of Representatives launched its investigation. Their strategies also included posturing to protect their interests when they made the incident public, such as by carefully wording the disclosure prior to its release.

In strategies of both posturing and compensation, Equifax initiated another campaign of activities, dubbed "Project Sparta." They established a website and call centers so that users could find out whether they had been affected and "facilitate enrollment in credit monitoring and identity theft protection services" (US House, pp 42, 2018). The Project Sparta team dedicated ad hoc resources including dozens of staff and was led by senior leadership. On September 7th, Equifax publicly announced the cybersecurity incident, directed consumers to the ad hoc website (equifaxsecurity2017.com), and promised one year of free services to victims of the breach as compensation. Initially, it seems as though they were not prepared for the scale of the incident: this site, as well as the call centers, were overwhelmed. Their systems were not ready to handle the influx of requests to either channel [48]. A fake website was even set up to take advantage of consumers, leading to further

confusion and harm [46].

To recover from the breach, Equifax also had to correct the issues that led to the breach in the first place. The recommendations for these changes to business processes came from their external partner Mandiant and included eleven overarching technical and process improvements. These changes began in early October. Mandiant and Equifax confirmed to regulators in August 2018 that these recommendations had been implemented [48].

Soon, Equifax also began its arduous compliance activities, specifically, reporting to regulators' investigations. Between October and December of 2017, then-Equifax CEO Richard Smith testified before three Senate Committees and two House Committees. Other senior leaders were also interviewed as part of the House committee on Government Oversight. The Government Accountability Office conducted their own investigation which included visits to Equifax offices and interviews [52]. Email communication and other business artifacts were also collected from Equifax and Mandiant as evidence in these investigations, which would have required effort to obtain. Smith's official statements and testimonies both admitted guilt and helped posture the company to protect its interests in the future. He acknowledged failures and highlighted efforts to correct them, and pushed their compensation for users that were affected. Equifax also disclosed details about the breach to the SEC in their regular filings, including the May 8, 2018 report (8-K) which detailed the scope of the breach in terms of the affected users, and the annual report (10-K) on March 1, 2018, which included information about their remediation efforts [24, 25, 48].

Compliance activities continued, and starting in 2018 Equifax was issued Consent Orders from multiple state and federal agencies including the FTC, CFPB, State of New York, State of California, and others. These required Equifax to pay fines, compensate affected users, remediate problems, and report on their compliance to these regulators.

C.5.2 Regulators

The response phase by regulators was prompt, broad, and vehement. A week after the breach was disclosed, the FTC, FBI, multiple Congressional Committees, and multiple States opened or joined investigations and called for hearings and reports. Bills targeting Equifax were even introduced to Congress. Consumer advocacy groups also chimed in, calling for compensation. That same week, Equifax CEO Richard Smith agreed to testify before Congress within a month. At this early stage, these activities supported nearly the full gamut of response strategies for regulators: posturing, correcting, and adhering. Only compensating remained, and that came later. The ongoing enforcement by regulators ultimately resulted in correction and compensation mandates by legislative, executive, and judicial bodies.

The mix of these response activities come from multiple regulatory bodies, can support multiple strategies, and vary in their effects. A statement by a legislator may be passionate, but not lead to any real change. A lawsuit from an individual could expand into a class action case. Below I will analyze regulators' activities and how they support their strategies to respond to the incident.

Posturing

Posturing activities took place especially early in the response phase following the breach. These activities could turn into further strategies but could also just remain as posturing if they were not followed up with further action. Their efforts could have ulterior motives as well, attempting to influence other situations such as elections. However, even the posturing could have an impact on the software producer and the users with respect to the incident.

The purest examples of posturing activities are statements made. Following the dis-

closure of the breach there were numerous statements made by regulatory bodies. Senator Chuck Schumer denounced Equifax in the Congressional Record, calling not only for an investigation to "the murky bottom," but also demanding five specific actions by Equifax, and calling for the resignation of the CEO and board of directors if they do not submit [54, 60]. According to news reports, the FTC spokesperson confirmed in advance that they would be investigating the breach, which is not typical [31, 60]. Senator Sherrod Brown leveraged the breach in session to promote his proposed amendment to existing legislation, stating that it would protect military servicemembers from negative impacts of the breach. He made this statement during his allotted time debating the unrelated nomination of the Deputy Secretary of Housing and Urban Development [5]. Representative Ted Lieu stated that he was drafting two bills in response to the Equifax hack [31]. According to the Congressional Record, Lieu did not introduce a bill, nor did he appear as a co-sponsor of the single bill that was introduced to the House. Clearly, these statements have nothing near the force of law, and they may not even result in further action, but they may influence behaviors by all stakeholders.

A more complex example of posturing is constructing jurisdiction. This means that regulators prepare to amend the regime that regulates the software producer, although it may not come to fruition. This amounts to posturing particularly when it is reasonable to assume that their efforts are not likely to succeed. A success would entail correction or enforcement actions that come later. However, the activity does require resources and is visible to all stakeholders, so it can have an impact even if it fails. For example, two bills were introduced to Congress within a week in response to the breach, including one in the House of Representatives and one in the Senate. The House bill was an amendment to the Fair Credit Reporting Reform Act (FCRA), introduced by Maxine Waters with 34 cosponsors, and it was referred to a Committee where it died [63]. The Senate bill, the Freedom from Equifax Exploitation Act, also an amendment to the FCRA, was introduced

by Elizabeth Warren with 11 cosponsors, it was referred to a Committee where it died [62]. Neither Waters nor Warren seemed to make any public statements about the breach, and instead focused on constructing jurisdiction through proposed legislation as a means of posturing.

The last activity that supports posturing as a strategy is forming and managing networks. Regulators can combine resources with other parties to bolster their response and recovery actions. This might include other regulatory bodies, technical experts, legal experts, advocacy groups, and more. While forming networks might be done privately, the publicly visible activities are the one that can be observed for study and have the most impact on posturing specifically as they can be observed by the other stakeholders. In this case, networks formed by regulators abound. The House Committee on Energy and Commerce submitted questions to the Apache® Software Foundation (ASF) ahead of their hearings with the Equifax CEO. ASF posted their response publicly on their blog [48, 55]. The Government Accountability Office (GAO) conducted their study into federal government customers of Equifax software at the behest of Congressional Requestors. The court's decision in the federal class action lawsuit against Equifax included Supplemental Declarations (sworn statements) from third party legal experts [47]. Even Mandiant, the firm hired by Equifax to investigate their breach, became part of the regulatory network. The US House Committee on Oversight and Government Reform (it is their report that is heavily relied upon in this analysis) relied on Mandiant not only to provide essential information during their investigation, but also confirm that Equifax had made critical changes necessary to remediate their cybersecurity failures later on[48].

Congress also postured by forming networks with experts in the field, specifically by bringing them in to testify. The Committee on Banking, Housing, and Urban Affairs brought a legal scholar, a financial technology analyst, the president of the Electronic Privacy Information Center, and cybersecurity analyst from the Congressional Research

service to testify about the Equifax breach [56, 57].

Adhering & Complying

The multiple regulatory bodies discussed so far all have their own mandates, different foundational principles that contribute to the regime that governs the stakeholders in this case. For regulators, the compliance activities that they undertake are implementing their mandate. This case, each body implemented their mandate in different ways.

Initially, regulators were passive, receiving the notification from Equifax about the breach. The regulators that received the notification formally included all 50 states per their individual breach notification requirements. Immediately thereafter, federal agencies and congressional committees initiated investigations. Additionally, the US-CERT warned consumers about possible scams arising from the breach [48].

Based on those investigations, federal agencies like the FTC filed complaints against Equifax, exercising their right, and duty, to sue companies. Additionally, law suits were filed by individuals, who also have a right to sue, and the courts implemented their mandate in hearing those cases, eventually finding in favor of the class action lawsuit. In the UK and Canada, regulators began investigations into the breach.

There does not seem to be any evidence that third parties that help regulate the consumer reporting system, such as the CDIA, took any action against Equifax for the breach.

Correcting

Regulatory agencies took many actions to correct the operations and precursors that led to the breach. These activities primarily took the form of enforcement, and each body has its own enforcement capacity and capabilities. Activities also include amending the regime to prevent similar issues from arising in the future, and to set precedent for how to respond

when they do.

In the legislature, the multitude of investigations, including hearings with the Equifax CEO is part of their enforcement capacity. They brought in the most senior leader to account for the behavior of the company. While there was new legislation introduced to amend the existing regime, no changes to the law were made.

Federal executive agencies also performed enforcement activities, including their own investigations, lawsuits, and penalties. The CFPB, for example, levied a penalty of $100 million for the violations, and State agencies also engaged in similar activities. These agencies also amended the regime in a narrow way by introducing new controls and reporting requirements for Equifax going forward so that they could monitor the correction activities by Equifax. These were meant to punish Equifax and correct their behavior so that an incident like this did not happen again (FTC, Equifax to pay $575 million, 2019). The SEC also sent a comment letter in response to the Equifax's annual filing requesting that they "expand [their] disclosure of the 2017 cybersecurity incident" to which Equifax responded with a single paragraph quoted from other filings [4, 24].

The United Kingdom also punished Equifax through two fines for compromising the data of its citizens. First in 2018, the parliamentary Information Commissioner's Office (ICO) fined them £500,000. Then, in 2023, the Financial Conduct Authority (FCA), a non-governmental regulatory body fined Equifax £11,164,400 after a series of complex calculations based on the company's income, the "seriousness of the breach" and Equifax's "mitigating and aggravating" actions during and after the breach [29, 37]. Both fines are considered punishment (correction activities, not compensation) because they do not compensate users for the harm. Instead, they are levied to force Equifax to comply in the future, and the money goes to the organizations as revenue to support their capacity.

In 2019, the Canadian Office of the Privacy Commissioner found that following the breach, Equifax had done enough to prevent a future incident, and required them to be

monitored by Canadian authorities for six years. No other penalties were imposed.

The results of these correction strategies are discussed in the Outcomes section.

Compensating

Regulators pursued compensation for the users that were negatively affected by the breach. Not all regulatory bodies have the capacity or jurisdiction to do this, so it was primarily the FTC, CFPB, state governments, and the courts that pursued payments and services to be provided by Equifax. Following the various procedures, investigations, and lawsuits by government agencies, Equifax was mandated to compensate consumers, paying money and providing services to help protect them from future harm.

The class action lawsuit filed by affected users was also upheld in federal court, which also mandated that compensation be paid. In that order, the court also required Equifax bear the costs associated with filing the lawsuit by the class, and the cost of administering the payouts [22].

C.5.3 Users

Users began their response and recovery phase once the breach was disclosed by Equifax. They were first able to collect compensation and correct business problems through the services provided by the Equifax breach website, finding out if their data had been compromised and signing up for credit monitoring and identity theft protection services. Later, users were also able to collect compensation from the FTC settlement and class action lawsuits.

Users, as well as advocacy groups representing them, began posturing through making statements and forming networks. An example of these efforts are the public comments submitted through Regulations.gov, a portal for citizens to reach out to federal agencies

like the FTC and CFPB. Starting after the breach disclosure, through the end of 2018, at least 46 comments were submitted referencing the breach. These comments have the dual impact of acting as public statements as well as attempting to form a network with the regulators, by contributing to their enforcement activities. As recently as 2024, requests were being made by individuals for the CFPB to regulate the credit reporting industry due to the 2017 breach through the Regulations.gov website.

User advocacy groups like the Electronic Frontier Foundation (EFF) and the US Public Interest Research Group (US PIRG) also made statements on behalf of consumers, advocating for compensation and corrections to the law, as well as criticizing regulatory actions as ineffective [19, 41].

In 2018 a 559-page class action lawsuit was also filed against Equifax by 96 individuals (class representatives) and 13 lawyers, for 99 counts under state and federal law, in the US District Court for the Northern District of Georgia. Given the importance of this litigation, in response, Equifax made a concerted effort to protect their business interests through appeals, statements, objections, and overall attempts to construct the jurisdiction of the case in their favor. They also formed a network of supporters to help object to the lawsuit, including *amicus curiae* briefs and even objections from affected individuals, although they may not have all been from actual affected individuals [39]. The plaintiffs won the case, adding to the regime that regulated Equifax. To comply with the regime, the court ordered Equifax to pay compensation of at least "$380,500,000 into a Consumer Restitution Fund," including cash payments, credit monitoring services, restoration services, and all fees related to administering the fund. This amounted to about $125 per person who who filed a claim [22]. This settlement process ended in January 2024 following the close of the deadline for extended claims.

Other corrections by individual users to resolve their business and software problems would have been for them to use competitor credit reporting tools and services to replace

those provided by Equifax. However, there are a few caveats to this. First, individual users (consumers) are unable to extricate themselves from the credit reporting industry, or Equifax's software, as discussed in the Context section. Second, if they chose not to use Equifax's credit monitoring and identity theft services, provided for free as compensation, then they would likely incur costs to use a competitor's services. Using a competitor's services may have been an option for some users, so as not to further rely on Equifax. However, for others it may have been a burden, requiring them to find, subscribe, and pay for those services.

Business customers of Equifax responded as well. The best examples of these responses available are from the government agencies, like the IRS, SSA, and USPS that used Equifax's services. They are major customers of Equifax and have resources that many customers would not have, but are still useful examples of activities that support the response strategy of correcting. According to the GAO, which reported on these responses, these customers identified affected individuals, performed independent assessments of Equifax security controls, modified contracts, communicated with the public and affected individuals, made changes to "identity-proofing procedures," and there is an example of a canceled short-term contract with the IRS [52].

I conducted a thorough search of publicly available information about similar activities by financial institutions and other business customers of Equifax, but found no data.

C.6 Outcomes

C.6.1 Software Producer

Costs

The cost estimates from At-Bay and eRiskHub for the 2017 Equifax data breach range from $660 million to $868m. These estimates include, *inter alia*, between $236m and $400m in fines, $88m for a call center, and $98m for credit monitoring services.

The lawsuits by individuals (and their class action), the FTC, state agencies, and others, culminated in a final settlement of a minimum of $380.5 million paid to consumers, and up to $505.5 million depending on the result of the claims made. Additionally, Equifax paid $175m to 48 states, the District of Columbia and Puerto Rico, and another $100 million fine to the CFPB [22, 28]. There were additional fines in the UK totaling over $14m dollars as well (based on conversions from xe.com for 2018-2024 and the fines totaling £11,664,400). Assuming the entire US settlement was paid to consumers, this reaches nearly $795m in direct costs just for compensation and penalties.

The consent order from the class action suit also indicates the costs of remediation. Equifax agreed to "spend a minimum of $1 billion for data security and related technology over five years" [47]. In 2020, Equifax stated that the incident cost them nearly $2 billion at that point [45].

Equifax stock price also went down following the announcement of the breach. The breach was publicized by Equifax on September 7, 2017, with a closing share price of $142.72. A week later, on September 14, the price had tumbled to $96.66, losing as much as 30% of its value [64] and wiping out potentially $6 billion in market revenue [48].

Transformations

There were manifold transformations that were outcomes of Equifax's response and recovery actions. Because of the high profile of this case, these changes were made public as part of the investigations and reported to regulators as required by enforcement actions. While some changes at the highest levels are made public for large companies like Equifax, the mid-level changes are not usually available for analysis. In this case, we can see that executive and middle-management personnel were fired or changed roles, new security processes were implemented, processes that had wavered were bolstered, new networks were formed with external experts, software was upgraded, among other things, according to the US House investigation [48].

Preservation

Equifax was able to preserve certain interests despite the breach. For example, they are still in business, this event didn't cause them to fail. Similarly, while their business customers may have conducted some investigations, like the IRS and SSA did, those customers continued to use Equifax's software in some capacity [52].

C.6.2 Regulators

The response & recovery actions of regulators from multiple jurisdictions resulted in multiple outcomes, setting the stage for years of future work.

Remedies

Regulators, including courts, agencies, and legislators effected a few remedies. First, the courts supported the claims of both the individuals' and the government agencies, re-

sulting in a settlement fund to be paid directly to harmed individuals, and fines paid to regulatory bodies. Second, the courts supported ongoing enforcement actions, specifically monitoring Equifax's data security practices going forward [47].

Additionally, regulators (FTC, CFPB, ICO, FCA) also fined Equifax for violating the law, resulting in revenue for their agencies to conduct their operations.

Costs

The regulatory response was vast, tapping into the capacity of a variety of regulatory stakeholders. Human resources were dedicated by lawyers, technologists, bureaucrats, judges, elected officials, etc., inside and outside the government. Their efforts would have incurred further costs including things like travel and materials. Agencies that levied fines against Equifax may have been able to recover some of these costs.

Transformations

Despite the scale of this case, there do not seem to be many transformations to the regime that preceded the incident. Regulatory bodies from across the spectrum followed their existing mandate and operated well within their jurisdictions. National and state agencies pursued investigative and enforcement actions in accordance with prior incidents. Elected officials investigated and created public documentation due to the sensitive nature of the data for consumers. So, there were no new enforcement approaches to speak of. The courts ruled in favor of the plaintiffs, but the decision was not seen as radical, although the monetary damages were substantial. As such, the case law was transformed only insofar as it added another example of continuity.

The only transformation to the regime was specific to Equifax, in that there were a new set of rules specific to them, such as reporting requirements, business process changes, and

monetary compensation.

Preservation

Regulators preserved much through their response and recovery actions. As described in Section 4.2, they pursued the offending software producer very visibly in a variety of ways. The net effects of these actions are that their interests, as well as those of the other stakeholders, were largely preserved.

Regulators were able to follow best practices given their capacity and deliver results that can be seen as favorable to their stakeholders. For example, elected officials were able to hold public hearings to hold Equifax accountable for their failure, which is validating for their voters. Enforcement agencies were able to sue, and eventually won a substantial settlement which they publicized widely, demonstrating their ability to achieve their mandate. Individuals were also able to sue (with representation) and also won in court, giving consumers a judicial victory. Equifax, while it incurred significant costs, was still able to operate going forward, much the same as it had done before, showing that while regulatory enforcement can be harsh, it can also be fair.

In this case, regulators were able to show that the regime was working and that its summative components should be preserved.

C.6.3 Users

Remedies

Users were compensated via a settlement fund, following the class action lawsuit by individuals, and the lawsuit brought by the FTC, CFPB, and state governments. The settlement included a minimum of $380.5 million payment by Equifax into a Consumer Restitution fund, which would pay cash to Settlement Class Members (victims of the breach) for

Out-of-Pocket Losses, Time Spent, and Credit Monitoring Services, among other things. This fund also included payment to the lawyers that represented the case, which amounted to close to $80 million, over 20% of the fund. There was also an additional $125 million for Out-of-Pocket losses, if the initial fund was used up. Typical payments were up to $125 for affected individuals [22].

Individual users were also able to take advantage of identity theft protection services provided by Equifax for both compensation and preventative measures against future harm.

Business customers, specifically the IRS, SSA, and USPS, following their investigation required Equifax to remediate a few issues. First, they were required to address some "lower-level technical concerns." Additionally, the IRS and SSA modified contracts to require them in case of future breaches, as they were not notified separately from the public announcement [52]. It is possible that other large clients of Equifax were able to negotiate similar remedies, but smaller businesses would be unlikely to be able to customize their agreements without sufficient leverage.

Costs

For consumer users, who were passive users of Equifax's software, the costs of recovering from the breach are complex, but limited. Some users may have invested resources (time, money) to protect themselves from possible identity theft resulting from the breach. They may have trained themselves on data privacy and security or purchased new software to protect themselves from future harms. However, it does not seem like this was a common course of action. Even in 2023, as much as 50% of US adults indicate that they have not used or heard of identity theft protection software, and an additional 17% planned to use it in the future. Furthermore, in terms of how much adults would be willing to pay for ID protection, 44% of people said that they would not pay anything, and 30% said they would

pay less than $15 per month. Only 11% of respondents indicated that they would pay more than $15, while the remainder said that they had never heard of it [33].

Ultimately, users that were able to receive compensation stemming from the settlement still paid the lawyers that represented them around $80 million dollars in the aggregate for the right to be remedied financially.

Business customers may have also spent money to respond and recover from the incident. The federal agency customers launched their own investigations, requiring time and money. Including, for example, visiting the offices of Equifax in Georgia. Other business customers may have privately sought other vendors for the services that Equifax provided.

Transformations

In response to the breach, it is not likely that many consumer users made any noticeable changes to their business, security, or use processes. However, new networks may have emerged, such as those people that participated in the litigation, and advocacy groups that may have seen growth in interest in their cause because of the publicity of the breach.

Business customers may have addressed security concerns like the government agencies did, conducting their own investigations and introducing new processes for future cybersecurity incidents with their vendors.

Preservation

Among users, both business and consumer, there is a strong indication that there was little or no change as a result of the recovery and response phase. The operations that preceded the incident appear more likely to be preserved than changed.

C.7 Aftermath

As discussed in Section C.6, while the scope of this case was immense, there were no substantive changes to the future contexts of similar cases. The principal outcomes were mostly preservation of the context and operations that preceded the incident. The transformations that occurred were predominantly narrow in scope, limited to almost exclusively to Equifax. In this case, there were no enforcement gaps identified, as demonstrated by the immediate and robust response by regulators and users, without any major hurdles. Consumer PII was already heavily protected by existing regulations. Nor were there new methods of cooperation for addressing data privacy and security. Lastly, there was no perception of the critical nature of the data that was compromised. Despite the historic number of affected users, the breached consumer data itself did not attract any substantive changes to stakeholder behaviors going forward. The general plight of consumers and privacy violations seemed to give way to apathy, as users felt there was little they could do, and that breaches like this were a common occurrence.

C.8 Case Bibliography

Bibliography

[1] Senate judiciary committee hearing on equifax data breach.

[2] Keith B. Anderson, Erik Durbin, and Michael A. Salinger. Identity theft. *Journal of Economic Perspectives*, 22, 2008.

[3] Janine Benner. Nowhere to turn: Victims speak out on identity theft. *CALPIRG Privacy Rights Clearinghouse*, 2000.

[4] Mark W. Berger. Comment letter: Form 10-k for fiscal year ended december 31, 2017. File No. 001-06605.

[5] Sherrod Brown. Data Breaches in Credit Reporting Agencies. Congressional Record, September 2017. 115th Congress, 1st Session. Accessed via source file Brown - Congressional Record Equifax Data Breach 9.14.17.pdf.

[6] Electronic Privacy Information Center. Equifax data breach.

[7] Julia S. Cheney. Identity theft: A pernicious and costly fraud. *Payment Cards Center Federal Reserve Bank of Philadelphia*, 2003.

[8] Federal Trade Commission. Ftc enforces gramm-leach-bliley act's safeguards rule against mortgage companies.

[9] Federal Trade Commission. Ftc imposes $5 billion penalty and sweeping new privacy restrictions on facebook.

[10] Federal Trade Commission. Ftc settlements require equifax to forfeit money made by allegedly improperly selling information about millions of consumers who were late on their mortgages.

[11] Federal Trade Commission. Google will pay $22.5 million to settle ftc charges it misrepresented privacy assurances to users of apple's safari internet browser.

[12] Federal Trade Commission. What the ftc facebook settlement means for consumers.

[13] Federal Trade Commission. Disposing of consumer report information? rule tells how, 2005.

[14] Federal Trade Commission. Federal trade commission 2018 privacy and data security update, 2019.

[15] U.S. Congress. Permissible purposes of consumer reports. 15 U.S. Code § 1681b, 2012.

[16] Oracle Corporation. Oracle data cloud data directory, 2021. Retrieved from Oracle service provider.

[17] Luke Cuomo, Alex Fredman, and Noah Goldstein. Regulating credit reporting agencies: Responding to the equifax crisis.

[18] Rafael del Villar, Alejandro Diaz de Leon, and Johanna Gil Hubert. *Regulation of Personal Data Protection and of Credit Reporting Firms: A Comparison of Selected Countries in Latin America, the United States, and the European Union*, chapter 11, pages 397–431. MIT Press, 2003.

[19] Electronic Frontier Foundation. Equifax Data Breach Update: Backsliding. EFF Deeplinks Blog, November 2019. Accessed via source file EFF - Equifax Data Breach Update_ Backsliding 2019.pdf.

[20] Equifax. Equifax business. Equifax lines of business as they displayed on the website in October 2024.

[21] Equifax. Equifax business.

[22] Equifax. Equifax data breach settlement.

[23] Equifax. What is a credit bureau?, 2022.

[24] Inc. Equifax. Comment letter response: Form 10-k for the fiscal year ended december 31, 2017. File No. 001-06605.

[25] Inc. Equifax. Form 8-k.

[26] Experian. Understand and reach your audience with consumer insights.

[27] Experian. *consumerview*^{SM}: Marketing data that connects brands with fans, 2021.

[28] Federal Trade Commission. Equifax to Pay $575 Million as Part of Settlement with FTC, CFPB, and States Related to 2017 Data Breach. Press Release, July 2019. Accessed via source file FTC - Equifax to Pay $575 Million as Part of Settlement.pdf.

[29] Financial Conduct Authority. Financial watchdog fines Equifax Ltd £11 million for role in one of the largest cyber security breaches in history. Press Release, October 2023.

[30] U.S. District Court for Northern District of Texas. Federal trade commission v. realpage, inc, 2018.

[31] Brian Fung and Hamza Shaban. The ftc is investigating the equifax breach. here's why that's a big deal.: It's rare for the ftc to disclose an ongoing probe.

[32] Mark Furletti. An overview and history of credit reporting, 2002.

[33] Emily Goodwin. Many Consumers Aren't Convinced to Pay for Identity Theft Protection. CivicScience, January 2023. Accessed via source file Goodwin - Many Consumers Aren't Convinced to Pay for Identity Theft Protection.pdf.

[34] Megan Gordon and Daniel Silver. The equifax hack, sec data breach, and issuer disclosure obligations.

[35] Erika Harrell. Victims of identity theft, 2016, 2019.

[36] Robert M. Hunt. What's in the file? the economics and law of consumer credit bureaus. *Business Review*, 2002.

[37] Information Commissioner's Office. Monetary Penalty Notice: Equifax Ltd. Data Protection Act 1998 Supervisory Powers Notice, September 2018. Accessed via source file ICO - Equifax Penalty UK (2018).pdf.

[38] Vincent R. Johnson. Credit monitoring damages in cybersecurity tort litigation. *George Mason Law Review*, 19, 2011.

[39] Robert Klonoff. Supplemental declaration of professor robert klonoff in equifax inc. customer data security breach litigation.

[40] John Lauer. *Creditworthy: A History of Consumer Surveillance and Financial Identity in America*. Columbia University Press, 2017.

[41] Mike Litt and Ethan Lutz. Equifax Breach: One Year Later: How to Protect Yourself Against ID Theft and Hold Equifax Accountable. Report, U.S. PIRG Education Fund, September 2018. Accessed via source file US PIRG - FinalReport4Sept18_Equifax.pdf.

[42] Cooper A. Maher and Brittany E. Hayes. Nonfinancial consequences of identity theft revisited: Examining the association of out-of-pocket losses with physical or emotional distress and behavioral health. *Criminal Justice and Behavior*, 51(3):459–481, March 2024.

[43] Kenny Malone and Robert Smith. Bad credit bureau. Podcast.

[44] John McCrank. Equifax says 15.2 million UK records exposed in cyber breach. Reuters, October 2017. Accessed via source file McCrank (Reuters) - Equifax says 15.2 million UK records exposed.pdf.

[45] Mark Meltzer. Equifax says data breach has cost it nearly $2 billion so far. Atlanta

Business Chronicle, February 2020. Accessed via source file Equifax says data breach has cost it nearly $2 billion so far - Atlanta Business Chronicle.pdf.

[46] Office of Elizabeth Warren. Bad credit: Uncovering equifax's failure to protect americans' personal information, 2018.

[47] U.S. District Court Northern District of Georgia. Amended order granting final approval of settlement. 1:17-md-02800-TWT, 2020.

[48] U.S. House of Representatives Committee on Oversight and Government Reform. The equifax data breach.

[49] Office of the Privacy Commissioner of Canada. PIPEDA Findings #2019-001: Investigation into Equifax Inc. and Equifax Canada Co.'s compliance with PIPEDA in light of the 2017 breach of personal information. Investigation Finding 2019-001, Office of the Privacy Commissioner of Canada, April 2019.

[50] Kieron O'hara and Wendy Hall. Four internets. *Communications of the ACM*, 63(3):28–30, 2020.

[51] Rowena Olegario. Credit reporting agencies: A historical perspective. In Margaret J. Miller, editor, *Credit Reporting Systems and the International Economy*, chapter 3, pages 115–159. MIT Press, 2003.

[52] GAO Data Protection. Actions taken by equifax and federal agencies in response to the 2017 breach.

[53] David D. Schlein and James D. Phillips. Holding credit reporting agencies accountable: How the financial crisis may be contributing to improving accuracy in credit reporting. *Loyola Consumer Law Review*, 24, 2012.

[54] Charles E. Schumer. Equifax Data Breach. Congressional Record, September 2017. 115th Congress, 1st Session. Accessed via source file Schumer - Equifax Data Breach 9.14.17.pdf.

[55] The Apache Software Foundation. Response From The Apache Software Foundation To Questions From US House Committee On Energy And Commerce Regarding Equifax Data Breach. The Apache Software Foundation Blog, October 2017.

[56] U.S. Senate Committee on Banking, Housing, and Urban Affairs. Consumer Data Security and the Credit Bureaus. S. Hrg. 115-132, October 2017. 115th Congress, 1st Session. Available at https://www.govinfo.gov/app/details/CHRG-115shrg28249/CHRG-115shrg28249.

[57] U.S. Senate Committee on Banking, Housing, and Urban Affairs. Examining the Fintech Landscape. S. Hrg. 115-95, September 2017. 115th Congress, 1st Session. Available at https://www.govinfo.gov/app/details/CHRG-115shrg27749/CHRG-115shrg27749.

[58] Committee on Homeland Security U.S. Senate Permanent Subcommittee on Investigations and Governmental Affairs. How equifax neglected cybersecurity and suffered a devastating data breach.

[59] USAspending.gov. Federal awards: Advanced search results for identity theft guard solutions, inc., 2025. Source file: Federal Awards _ Advanced Search _ USAspending.pdf.

[60] Dustin Volz and Susan Heavey. Ftc probes equifax, top democrat likens it to enron.

[61] Tawei Wang, Ju-Chun Yen, and Kyunghee Yoon. Responses to sec comment letters on

cybersecurity disclosures: An exploratory study. *International Journal of Accounting Information Systems*, 2022.

[62] Elizabeth Warren. S. 1816 – Freedom from Equifax Exploitation Act. U.S. Senate, September 2017. 115th Congress, 1st Session. 163 Cong. Rec. S5743. Accessed via source file Warren - 115 S. 1816 Bill Profile Report.pdf.

[63] Maxine Waters. H.R. 3755 – Comprehensive Consumer Credit Reporting Reform Act of 2017. U.S. House of Representatives, September 2017. 115th Congress, 1st Session. 163 Cong. Rec. H7382. Accessed via source file Waters - 115 H.R. 3755 Bill Profile Report.pdf.

[64] Yahoo Finance. Equifax Inc. Stock Performance September 2017. Data Table/Chart, September 2017. Accessed via source file Equifax Inc Stocks Feb 2024 - Yahoo.pdf.

Appendix D: CatalanGate Case Analysis

D.1 Introduction

In 2022, a political scandal erupted when reports detailed the hacking of prominent people from Catalonia, specifically through their use of the popular mobile/instant messaging software WhatsApp. Catalonia is currently an autonomous region within Spain, and, in conflict with the interests of the Spanish government, has sought independence throughout modern history. The people affected by the hack include elected officials, political leaders, and activists that were involved in the Catalan independence movement, as well as people associated with them, all of whom were users of WhatsApp. Much of the hacking occurred around the time of the independence referendum in 2017. The most in-depth report of the breach of Catalan citizens [51] was published by Citizen Lab, a prominent research laboratory at the University of Toronto that studies issues in cyberspace. They detail targeted hacking, alleged to be primarily organized by the Spanish government. The investigators dubbed the incident "CatalanGate," using a popular portmanteau of the 1972 Nixon Watergate scandal, to describe what they declared to be a surveillance and hacking campaign by the government of Spain against their perceived Catalan political opponents.

The Citizen Lab report was released following a broader journalistic investigation called the Pegasus Project, a collaboration between multiple organizations, that revealed the breadth of surveillance hacks in Europe and beyond. However, even within just the CatalanGate breaches, the scandal continued in multiple venues, including the news, courts, and per-

sonal opinions worldwide. The conflict implicated a variety of stakeholders, across multiple jurisdictions, in a changing environment. The affected users were Catalan people, who are citizens of Spain, and protected by the recently applied (as of 2018) General Data Protection Regulation of the supranational European Union, and rights protected by the UN. The software producer is WhatsApp, an American company with massive reach in Europe, purchased by Facebook in 2014, and now part of the parent conglomerate Meta. Responses to the scandal include multilevel EU enforcement activities and US court decisions in 2025.

The CatalanGate scandal, as described by the Citizen Lab report, is actually an agglomeration of multiple cybersecurity incidents that occurred primarily between 2017 and 2020. This report [51] is an instrumental source of information about the case, and a crucial foundation for further analysis and action by many stakeholders. An earlier investigation, The Pegasus Project also shed light on the broader issue of spyware starting in 2021 (Amnesty International, 2022). Additionally, after the discovery of these incidents, the European Parliament conducted a series of investigations which, crucially, yielded a Report created by Rapporteur Sophie in 't Veld, which was formally adopted by the EU [28]. I rely on these reports and investigations heavily for my case analysis, as they include data that I would not be able to replicate, such as interviews with the affected users, technical details about the breaches, and legal analysis. However, I do not need to reproduce their findings and instead can extend their analysis with additional data from before and, especially, after the incidents.

D.2 Cyber Social Context

The cyber social context overarches the environments in which the stakeholders of the case operate and sets the stage for the incident and its aftermath. Per the model, the stakeholders are the users, software producer, and regulators. Each of them has a regulatory,

threat, and operational environment. In this case, the users were public figures involved in the Catalan government and civil society, as well as some "off-centre" victims, people that are simply related to those people, like family members, all of whom were using the mobile app WhatsApp [51]. The software producer is WhatsApp, a popular mobile messaging application. Stakeholder regulators include the Government of Catalonia, the Government of Spain, the European Union, and the United States government.

D.2.1 Users

WhatsApp was acquired by Facebook (now Meta) in 2014. At the time, WhatsApp boasted 465 million monthly active users and Facebook itself had 1.2 billion users. By the end of 2017, WhatsApp had over 1.5 billion users and in February 2020 they reached 2 billion (Richter, 2020). For years, WhatsApp was clearly the choice for mobile messaging users worldwide, both before and after it was acquired by social media monolith Facebook. Due to its prevalence, it naturally included everyday users that were of interest to prospective political opponents that sought their private information.

In this case, general WhatsApp users fall into two crucial categories. First, they are EU data subjects, as citizens of Spain, a member state of the EU. Second, they are affiliated with the Catalan government, which has a history of conflict within Spain.

Additionally, the users that were ultimately compromised in the case also fall into the category of "high risk" targets, including journalists and independence movement activists who are often the subjects of government surveillance.

Operational Environment

Between 2014 and 2017, WhatsApp was one of the most popular, if not the most popular, mobile chat and messaging applications in the world, adding "roughly 25 million new

active users each month, or 833,000 active users per day" [42]. As of 2024, WhatsApp is the most popular social media platform in Spain [9]. For everyday messaging between people, it is clear that WhatsApp was the preference for many people, including in Spain. However, as strictly free, consumer users, WhatsApp users fall far down in a hierarchy of operations with the company, and have no direct relationship with the developers.

In the Citizen Lab report, they describe the use of Android devices compared to Apple iOS devices. This is a commonplace discussion between users of chat applications, and for this case study is irrelevant. At the end of the day, WhatsApp was incredibly popular and, retrospectively, we can see that its use resulted in a cybersecurity incident.

Targeted Users

The Catalangate report concludes that 63 people were targeted with spyware, and 51 were infected and their data compromised. Of those, 47 were targeted with the Pegasus spyware that exploited a vulnerability in WhatsApp, and 18 of those were confirmed to have been conducted by the Spanish government. Confirmed infections include Members of European Parliament (MEPs), civil society figures, Members of Catalan Parliament, and all Catalan Presidents since 2010, as well as individuals who had personal relationships with those people [28, 51].

Outside of Spain and Catalunya, there were documented cases of more than 1400 WhatsApp users being targeted with the Pegasus spyware (Amnesty, 2025).

Advocacy

A rather large and active network of advocacy organizations exists to support data privacy and security as they pertain to human rights, democracy, and media/journalism. Organizations like Citizen Lab, Electronic Frontier Foundation, Access Now, and Amnesty International investigate and report on cybersecurity issues, including threats to civil society and democratic institutions. They also attempt to influence regulations.

One example is a 2018 report from Citizen Lab about Pegasus, prior to the discovery of

the Catalangate breaches. This report provides technical documentation about the software including IP addresses and domain names associated with the malware, as well as some of the actors using it around the world [37]. Artifacts like this one can be reported to authorities for further investigation and action.

Regulatory Environment

WhatsApp users in Spain, and in Europe more broadly, fell under the regime jurisdiction of the European Union's General Data Protection Regulation (GDPR) as of May 25, 2018. It has been described as a possible basis for a "gold standard" for global data privacy, and includes a number of protections for users that require action by businesses, and mandates for governments [49]. In particular, it protects the personal data of EU consumers, based on the premise that "all natural persons have a fundamental right to the protection of personal data" including right to be forgotten, right to object, right to rectification, right of portability, right of access, and right to be notified [49]. Additionally, they give EU data subjects the right to collectively complain against violators, similar to US-based class action lawsuits. EU data subjects are also protected from "personal-data record-keeping systems whose very existence is secret." These protections apply to users of foreign businesses that offer goods or services in the EU, not just companies based there.

However, there are some restrictions to the GDPR protections. For example, the "Right to be Forgotten" is a protection that allows data subjects to have information deleted after a certain period, the right to have a "clean slate," and the right to access and clear outdated information. However, this right does not preclude legal obligations which require data processing by law, the exercise of freedom of expression, for archiving purposes, and more [49]. More importantly, the GDPR protections are limited in matters of national security, see Section D.2.1 for more details.

Threat Environment

WhatsApp & Technical Threats

Due to the scale of its user base, WhatsApp is a prized target for cyberattacks. In a 2023 incident, the phone numbers of WhatsApp users were allegedly made available for sale, including nearly 11 million people in Spain [32].

By 2019, the vulnerabilities exploited in the Catalangate scandal were known to WhatsApp and its then-parent company Facebook. In this case, the vulnerability was known to a company called NSO Group, who sold the exploit to customers for profit. Roughly 1,400 users were targeted through the WhatsApp exploit known as CVE-2019-3568, including 47 in the Catalangate scandal [51]. WhatsApp and Facebook sued NSO Group in US Federal Court in 2019 (Penney & Schneier, 2022), ultimately leading to a win for Meta in 2025.

Political Threat Surface & Surveillance

According to Citizen Lab, there have been multiple recent cases of possibly illegal surveillance activities by Spanish authorities, including purchases of spyware between 2001 and 2020. In particular, a 2017 referendum on Catalan independence seems to have been the impetus for the data breaches between 2017 and 2020 (Railton et al, 2022). The users targeted in this case (Section D.2.1) were high value/high risk targets for the attackers [2].

As potential victims of surveillance for security or political reasons, these users are at increased risk. According to a vice-president at NSO in an interview with The New Yorker, in order to create products that are valuable to government customers for surveillance, they are "looking for a silver bullet, a simple exploit that can cover as much mobile devices around the world" [22].

Prior examples of Spanish users targeted by spyware include the Spanish authorities authorized breaches in anti-drug efforts, combating terrorism, and fighting corruption [28].

D.2.2 Regulators

In this case, the clear regulatory stakeholders are the agencies and courts of the European Union that are responsible for data protection under the GDPR. This primarily includes the institutions of the EU, such as the European Parliament, European Commission (EC), and the Court of Justice (CJEU) headquartered in Brussels. The case also implicates the governments of Spain, where the conflict primarily took place, Ireland, where WhatsApp maintained its European headquarters at the time, and the US, where WhatsApp was primarily based. The case takes place between 2017 and 2020, which was also a period of transition for regulators in Europe with the implementation of GDPR in May 2018, and subsequent interpretations of the new law by legislators and jurists.

The Spanish government, in addition to being one of the responsible regulators for the incident, is also confirmed to be the perpetrators of at least some of the hacks, specifically the National Intelligence Service (CNI) and the Ministry of Defense. The agencies responsible for the hacks used legal procedure to justify them, both before and after the incidents, which add to the complexity of the rules that need to be analyzed.

Regulatory Environment

Background The European regime, particularly under the EU, "highly prizes the protection of personal information" [45], and sees privacy as "a key democratic value … [and] favours precautionary measures" to protect EU citizens' data "held or processed anywhere in the world" [40]. This regime did not begin with the establishment of GDPR and is based on long legal histories from its member states. Immediately preceding GDPR was the 1995 Data Protection Directive, which was quite strong in its protection of EU citizens, and bolstered by the 2009 Treaty of Lisbon [40, 45]. However, the EU was induced to expand the protection of EU data subjects through GDPR due to key societal changes: First was the

general growth of the internet over the prior two decades and the development of monolithic companies like Google and Facebook; second was a 2015 CJEU decision, known as Schrems I, against Facebook regarding the transfer of EU citizens data to the US in light of the leaks from Edward Snowden; and third was a case against Google Spain regarding the right to be forgotten [6, 14, 17, 40]. The net effects of these conflicts were to alter existing regulations or initiate new ones, such as GDPR and special agreements with the US, such as a data transfer agreement called Privacy Shield. However, they did not provide compensation for the complaining parties.

The series of action and enforcement in the Schrems cases demonstrates the prioritization of user protections by the EU and its institutions. Additionally, it connects Spain specifically as a member state that participated directly in the emergent regime governing data privacy and security. However, they are *not* examples of precedence for collective action against companies for data breaches.

Surveillance and Spyware in Europe This case includes the use of surveillance by national security regimes, which is also regulated in the European Union, including by the CJEU and the European Court of Human Rights (ECtHR) [21]. The interests of national security and individual rights need to be balanced in cases like this, and use of spyware for "political purposes, targeting critics and opponents of the parties in power" can be considered abuse of the rights to use spyware by states [28].

Spain Although Spain is a Member State of the EU, it also maintains its sovereignty and has its own regimes in place. Even the authority of the EU can be precluded from interference in certain situations, specifically on national security [28].

The 2023 Report on the Catalangate and broader Pegasus, written by Sophie in 't Veld, and adopted by the European Parliament provides useful information about the structure of

the Spanish regime on user protections for data privacy. The report explains

> The right to privacy is protected under Article 18 of the Spanish Constitution of 1978, including the right to secrecy of communication, and in particular guarantees 'postal, telegraphic and telephone communications' ... The constitution also provides for further exceptions to those rights in Part I Section 55 by stating that some rights can be suspended subject to the 'participation of the courts and proper parliamentary control' if it has been agreed to declare a state of emergency or siege under the terms provided for in the Constitution or in the case of individuals under investigation for activities relating to armed groups or terrorist organisations. Furthermore, Article 55 includes democratic safeguards to ensure that 'unjustified use or misuse' of those powers will give rise to criminal liability.

[28]

In short, the privacy of Spanish citizens is protected, but the emergent regime may be altered by state security interests if they need to violate those protections. There are a number of legislative and judicial decisions that inform the ability of the government to suspend those protections, including both Spanish and European laws. They require specific authorization and oversight by various government bodies. Broadly, the authorization to suspend protections are based on four principles: "firstly, specialisation (that the surveillance is related to a specific crime); secondly, adequacy (outlining duration, objective and the subjective scope); thirdly, proportionality (strength of available evidence, severity of the case and result sought), and finally exceptional nature and necessity (there are no other measures available and without it, the investigation will be interfered with)" [28, 36]. It is worth noting that the Spanish Data Protection Agency has no power over the National Intelligence Service (CNI) [25].

Other International Regulators As a regulatory stakeholder in this case, the UN's primary contribution to the regime in this case is related to human rights, such as through the Office of the High Commissioner on Human Rights (OHCHR). Other international agreements can also have an impact on the context. Prior to the Catalangate case, there were few salient examples of international regulation by the UN or other regimes regarding spyware.

Operational Environment

The EU and its institutions were empowered to protect user privacy and data security, as were its member states. However, it is possible that the interests of member states like Spain were at odds with EU laws, particularly in the realm of surveillance.

The European Parliament has the authority to conduct investigations into matters of data security and privacy with regard to its member states and their citizens. Despite the landscape of regulatory enforcement against major tech companies, the EU's approach to spyware has been described as a "wild west of spyware" as it lacks rules on licensing, export laws, who can use it, and how it is used [48]. It seems as though there is a conundrum, where EU lawmakers like to have enforcement methods against big tech companies, especially those based in the US, but are reluctant to regulate spyware, where their own national security interests may be at risk.

In Spain, the primary operational context for regulators in this case deals mainly with the Catalan independence movement, against which the Spanish government has aggressively fought. There was a tense political environment, and economic concerns regarding the possibility of secession, including the arrest of a former president of Catalonia, and sometimes violent repression [26].

In general, there was a challenging hierarchy between potential targets of spyware and the regulators responsible for the regime. Regulators in this case were not closely tied to

the targeted users by either the Spanish or European regimes.

Threat Environment

Broad regulatory attention to the threat of spyware arose in 2021 in an investigation called The Pegasus Project, led by journalists and civil society organizations like Amnesty International [4]. This investigation largely highlighted regulators' limited familiarity with the threat environment and implored them to act. As will be described later, the regime also protected the use of spyware threats by government actors for national security purposes.

D.2.3 Software Producer

As described in Section D.2.1, WhatsApp was, and continues to be, the most popular mobile/instant messaging application in the world. Its growth, as measured by users, was insurmountable by competitors, which is likely what provoked Facebook to buy it in 2014 for $19 billion, reaching 2 billion users in 2020 [9]. Facebook, at that point, was already in the crosshairs of EU regulators [6, 13], and this acquisition could implicate WhatsApp in any future interest or action against Facebook. Ultimately, it meant that any regulatory engagement with WhatsApp would necessarily incriminate Facebook.

Regulatory Environment

As discussed in D.2.2, software producer Facebook, Inc was the subject of consequential regulatory action in Europe. Founded in 2004, by 2014 the company had become a monolithic operator in cyberspace, controlling a substantial amount of internet users on mobile and desktop devices worldwide. In 2015 and 2020, they lost two cases in the CJEU (both of which were initiated by privacy activist Max Schrems) that were instrumental in setting precedence and establishing regulations for software producers that had users pro-

tected by the EU. The 2015 Schrems I decision was instrumental in driving the passing of GDPR, and Schrems II in 2020 instigated important interpretations of the new regulations [6, 14, 35, 40, 45, 53].

In short, Facebook was not simply the subject of regulatory action, they were an archetype of software producers upon which European regulators established their laws.

Operational Environment

As described above, WhatsApp was huge at the time of the data breaches. It was continuously growing, regularly adding new features and security updates to maintain its commercial viability [5, 30, 54]. While Facebook and its subsidiaries like WhatsApp provide a variety of features for their users, they are not known for working closely with them, as they provide free services that are funded primarily by advertising. Unlike software as a service platforms where users contract directly with the company, WhatsApp users would be less likely to cooperate directly with the company itself.

Threat Environment

Messaging apps are technically challenging for software producers to secure, according to the Electronic Frontier Foundation (EFF). In 2018 they created four publications about the variable threat surface, concluding that "there is no single correct way to balance security features, usability, and the countless other variables that go into making a high-quality, secure communications tool" [10]. For example, they mention that more popular messaging software can be more secure because it is less suspicious (compared to using software designed specifically for secure messaging that could readily be identified for cyber attacks), and larger companies have more resources (i.e. internal familiarity) to maintain the application in the face of a complex threat environment [44]. With that in mind, the EFF

staff that created the publications said that they would “reluctantly” recommend average users use WhatsApp for these reasons [23]. On the flip side, and adding to the complexity, an earlier 2017 EFF report about government access to user data gave WhatsApp a 2-star rating out of 5, indicating that they may not adequately protect users from government intrusion [10]. This rating includes assessments of both their interpretation of legal regimes and internal regulations about protecting data.

In general, the scale of the WhatsApp userbase may have made it a more secure option for the average user, but it created a huge threat surface for surveillance and spyware activity by security agencies.

D.3 Operating & Precursors

D.3.1 Users

The users targeted included civil society representatives, lawyers, journalists, and elected officials that were directly or indirectly part of the pro-Catalan independence movement. They also include people who were simply affiliated with those figures, described as “by-catch” and “relational or ‘off-centre’ ” targets (possibly even people mistakenly targeted because they shared the same name) [28, 51]. Due to the ubiquitous use of WhatsApp, they were presumably using the app for both their personal and official/business purposes, creating potentially valuable data to attackers in either case, and providing a vector for nefarious use of their mobile phones for surveillance. The users were targeted across a long timeline, but in particular before and after key events like the 2017 independence referendum, and other political events such as elections and political appointments [28, 51].

The Surveilled and their Software

The targeted users in this case were using the software WhatsApp to communicate with other people on their mobile devices, just like any other user. However, these users were seen as significant, and their use of the app created data that was desirable to would-be attackers. We do not know whether or how much of that data was actually valuable to an attacker; it is possible that users secured critical information with hygiene practices, like discussing sensitive information on more protected platforms such as encrypted email or other internal messaging systems. For example, two of the targets were software developers that worked on security-focused technology, and their devices were not compromised. Furthermore, the breaches they suffered could have offered up more than just text messages within the app: the spyware is likely to have exposed them to additional surveillance by compromising the sensors on their mobile phones, like cameras, microphones, and GPS antennas.

Even with operations that include rigorous prevention practices, and strict adherence to security rules, these users were still at serious risk because of the level of interest by the attackers, who could use complex methods like zero-click attacks that target zero-day vulnerabilities [33, 38, 50, 51]. The targeted users worked for a variety of organizations and even government agencies, and those organizations may have had adept defense and prevention security practices. They could have been secured through their IT departments across the various software that they used for work. However, for individuals targeted for surveillance, a more powerful attack outside of those applications, one focused on unaddressed failures not supported by their employers, was the larger threat, and the vector was the nearly ubiquitous messaging app WhatsApp.

People that are considered high risk for surveillance and spyware technology, like those in this case, are able to receive training and technical support from advocacy organizations

like Citizen Lab, Amnesty International, and Access Now. However, those resources are limited and are by no means a guarantee of safety [2] and we do not know whether any of the targeted users took advantage of these opportunities.

Precipitating Changes

In many instances, the attacks occurred around the time of important events for the users involved. Basically, in the course of their operations, there were changes in their business that made their data valuable to potential attackers. The most prominent change was the 1 October 2017 referendum on Catalan independence, which had an enormous impact on Spanish and global society. The referendum passed, with 92% voting yes, but was declared unconstitutional by Spain. It also resulted in later events that were of interest to hackers like the Spanish intelligence agencies. Because WhatsApp was already deployed on their phones, they could be targeted nearly at-will by hackers with the right resource, the Pegasus spyware.

The October 2017 referendum was a sea change in Spain, with potential impacts on the fundamental nature of the country, including its economy, politics, geography, population, institutions, etc. It should come as no surprise that the Spanish government were acutely interested in the movement, and their intelligence agencies would increase their focus on the key actors. One such actor was Jordi Sanchez, the president of the pro-independence Catalan National Assembly (ANC). Among the known breaches Sanchez was one of the earliest, and was hacked multiple times between May and October 2017 [51].

Immediately following the referendum, multiple activists promoting independence were imprisoned for their involvement, and some were freed in 2021, after over three years in prison. During their imprisonment, their legal teams and colleagues were attacked via Pegasus at critical times of change, including nearing their court cases and during discussions

of how to fill a parliamentary seat left open, after it was decided one politician could not serve while imprisoned [28, 51].

D.3.2 Regulators

While European regulators were working on implementing GDPR to protect data privacy and security, they did not directly address spyware. Meanwhile, Spanish authorities were pursuing court orders to legally hack phones of targeted individuals.

European Regime

There are overlaps between the laws of the EU and the laws of its Member States when it comes to national security, intelligence, and law enforcement. As such, the regime that governs the actions of Spain using spyware on its citizens in this case, such as its rules, enforcement, and capacity, is very ambiguous. According to the PEGA Committee Report, "all Member States use spyware in one way or another, some legitimate, some illegitimate" and at least 14 EU countries purchased the Pegasus spyware [28]. According to the Treaty of the European Union, Member States have exclusive rights over their national security. However, the CJEU and the ECtHR also have case law that attempts to balance fundamental rights with national security considerations. In short "the lack of clarity as to how national security is defined and the excessively broad interpretation of its scope by the national authorities pose a challenge in understanding the justification for the use of spyware," [28]. This indicates ambiguity for the capacity of regulators, and the rights of users and software producers.

The Surveillance Regime: Spanish Authorities

In this section, I will investigate the regulatory operations of the Spanish authorities. What makes this case, and this section, interesting is that Spanish authorities are also the attackers that executed the breaches. However, I will not be scrutinizing the full anatomy of the attacks even though they were carried out by partners of the regulatory bodies. The focus will be on how the Spanish government implemented the regime, not the attacks themselves.

The CNI is an agency created by parliament in 2002 as a part of the Ministry of Defense. It "achieves its missions by collecting information in Spain and overseas and acts under the supervision and control of the executive, legislative and judicial powers" (Veld, 2023). Additionally, the CNI must be authorized by the Spanish Judiciary in advance, such as through a court order, "to adopt measures that may affect the inviolability of the home, and the secrecy of communications" [25, 28]. Furthermore, the Spanish Ombudsman also has full access to documents to investigate actions by the CNI after they have occurred, but has limited enforcement powers [25, 28].

As described in Section D.2.11, privacy rights for Spanish citizens are protected by the constitution, but there are exemptions to those rights. These exemptions are within the capacity of the CNI to exploit, given their authority, funding, and the rules made to govern their actions. In particular, the CNI is tasked with preventing threats to the "independence and integrity of the state," [28] which could easily be interpreted to encompass the Catalan independence movement. The CNI and other authorities implemented their regime to be able to conduct spyware operations where they saw fit, such as by getting judicial authorization in advance (Tomás, 2022).

D.3.3 Software Producer

When WhatsApp was acquired by Facebook in 2014 for $19 billion, it became part of one of the largest software companies in the world. By 2020, it claimed over 2 billion monthly users (Richter, 2020; WhatsApp, 2020). However, its popularity with users meant it also became a high value target for hackers.

WhatsApp's drastic business changes included user growth and acquisition, as well as updated features, which would mean expanding capacity to maintain and secure the software. They implemented prominent new features including file uploads (Angela, Online-Convert.com, 2017), voice and video calling (WhatsApp, 2016), and end-to-end encryption (Koum & Acton, 2016). These features met the needs of their users by adding more communication and security capabilities, and were completed by a "small engineering organization" of about 57 people (Reed, 2016). This small organization approach also entailed a small technical footprint which helped them "reduce the number of things that could break" meaning that they had adequate capacity despite their minimal size (Reed, 2016). However, some of these features could also increase the threat surface for users, requiring additional security measures.

WhatsApp took data privacy and security seriously, even when they were criticized for partnering with Facebook, which itself had been criticized for privacy concerns. Co-founder Jan Koum detailed his commitment to "private communication" due to his upbringing in the USSR, asserting that "respect for your privacy is coded into our DNA" and that partnering with Facebook would not "compromise the vision" (Koum, WhatsApp, 2014). WhatsApp did undertake a multi-year "effort to reinforce the security of its products" and was able to coordinate with Facebook security capacity as well (Farrow, 2022). Security patches prior to 2020 included at least 13 patches for known vulnerabilities from the NIST National Vulnerability Database (WhatsApp Security Advisories Archive, accessed 2025),

mostly from 2018 and 2019. In 2020, they patched an additional 15 known vulnerabilities (WhatsApp Security Advisories 2020 Updates, accessed 2025). Included in those patches was CVE-2019-3568, which was the unaddressed failure exploited by the Pegasus spyware, but not before it was exploited.

In its growth, and in the changing regulatory landscape, WhatsApp complied with regulatory requirements when they were defined. The most prominent example is the introduction of GDPR, which forced WhatsApp to create new Terms of Service and Privacy Policy documentation, as well as a business entity in Europe in 2018. The new business, WhatsApp Ireland Limited only serves users in the European Economic Area and the European Union, and is the data controller responsible for their services, per EU law (WhatsApp, Updating Our Terms, 2018; WhatsApp Privacy Policy, 2018).

D.4 Incident & Impacts

Between 2017 and 2020, around 1400 WhatsApp users in 45 countries were targeted for the vulnerability eventually identified as CVE-2019-3568, which was compromised using the Pegasus spyware technology. Of those, 47 were Catalan people directly or indirectly connected to the independence movement and alleged to be infected with the spyware [51], 18 of whom were confirmed by the attackers themselves, the Spanish National Intelligence Service [29] (Veld, Report, 2023).

D.4.1 Users

The users, Catalan civil society and political figures discussed in Section 2.1.1, suffered unauthorized access of their data, including turning their devices into sensors which could be used for surreptitious surveillance. The scale of the breach for each user included text messages, emails, WhatsApp messages, contact details, call records, location, microphone

and camera (Khandelwal, 2019). It is unclear exactly what this data would be used for by the attacker, and any impacts beyond the violation of their private information. As reported by many investigators, the Spanish authorities were behind the attacks and likely used it to stymy or prevent Catalan independence efforts, including arresting multiple people associated with the cause. Some of the attacks coincided with court cases, and thus the compromised data could have been used to inform legal strategy, although that cannot be verified.

Investigators describe the impacts of the Pegasus spyware as human rights violations "including monitoring, blackmailing, smear campaigns, intimidation and harassment" with secondary impacts on "data protection and privacy, freedom of expression, freedom of the press, freedom of association, redress mechanisms, legal remedy and fair trial, and democratic processes and institutions" [28].

D.4.2 Regulators

Regulator interest began in earnest following this breach, although the software behind it was known previously. The PEGA Committee would later adopt the following definition of spyware based on the Catalangate and other breaches:

> any product with digital elements that is specifically designed to exploit vulnerabilities in other products with digital elements and enables the covert surveillance of natural or legal persons by monitoring, extracting, collecting or analysing data from such products or from the natural or legal persons using such products, in particular by secretly recording conversations or otherwise using the microphone of a terminal device, filming natural persons, machines or their surroundings, copying messages, taking photographs, tracking browsing activities, tracking geolocation, collecting other sensor data or tracking activities

> across multiple terminals, without the natural or legal person concerned being specifically informed and having given their explicit specific consent.

They go on to describe the complexity of regulating and investigating spyware compared to wiretapping: "Contrary to conventional wiretapping, which only allows for the real-time monitoring of communications, spyware can provide full, retroactive access to files and messages created in the past, passwords, and metadata about past communications" [28].

During the incident, the US Department of Justice was able to observe the incident, as they were alerted to the breach by WhatsApp before they even patched it [22].

D.4.3 Software Producer

WhatsApp and Facebook first detected the threat posed by Pegasus in May 2019 and quickly determined that it was an active exploit, affecting users as they were analyzing it. Initially, they decided not to block the attackers in order to get more time to analyze the vulnerability and its impact on users. This allowed them to trace the data, which ultimately led them to identify NSO, the creator of Pegasus, as the culprit. At this point, they were ready to update the software to patch the vulnerability, but before doing so, they alerted the Department of Justice. After implementing the update, they continued to monitor the behavior of the attackers, and also notified users that had been targeted [22].

D.5 Responding, Recovering, and Remediating

Following the publicization of the data breaches in Catalunya, multiple widescale efforts by a variety of stakeholders began, including a broad campaign of disclosure by user advocacy groups, regulatory investigation and enforcement, international litigation, political posturing and public outcry.

D.5.1 Users

Targeted users may have first become aware of the breaches in 2019 when they were notified by WhatsApp of the vulnerability (Farrow, 2022). The incidents were then made public in an article in The Guardian in July 2020, as well as through the efforts of the Pegasus Project, and subsequently investigated by Citizen Lab, resulting in their 2022 report, which revealed the full extent of the breaches [4, 34, 51].

The immediate response to the breaches can clearly be seen as posturing: the targeted users made statements to journalists about the breaches and networked with activist organizations like Citizen Lab and Amnesty International. Those organizations also made public statements about Pegasus and related spyware.

Because many of the users were government officials, they were ardently involved in correction, compensation, and adherence behaviors at the national and international levels. At the national level, they pursued their protections under Spanish laws regarding the use of spyware, and filed as many as nine complaints in court. In adhering to their rights under the regime, they sought an ex post investigation into the breaches through the independent Spanish Ombudsman's office, which oversees the use of surveillance technology by government authorities [15]. Additionally, in May 2025, two criminal complaints, leveraging different jurisdictions, against the Spanish CNI were announced. One by former regional president Artur Más and another by five plaintiffs, represented by an organization called Sentinel Alliance [48]. This litigation can be seen as correcting and/or compensating behavior, depending on the details of the complaint. At the European level, affected users and other civil society groups participated in the European Parliament's Pegasus Committee hearings and investigation in order to amend the regime to improve protections for potential victims of spyware [28].

D.5.2 Regulators

European regulators had shown interest in the Pegasus spyware prior to the Citizen Lab report, but within weeks of its release, official investigations were launched. Spanish regulators also responded to the incident, particularly in response to the public outcry and political action of the supranational European Union. Most of the responses seeking compensation or other remedies have been targeted at the perpetrators of the attack, not WhatsApp, which failed to prevent it.

European Regulators

Adhering to their mandate, the European regulatory regime responded to the data breaches of European citizens in Catalunya as a result of the Pegasus spyware. The European Parliament was alerted to the breaches, and as part of their enforcement authority, established a Committee of Inquiry to investigate, known as the PEGA Committee. The investigation included data breaches resulting from the use of Pegasus spyware in Catalunya and Spain as well as more than a dozen European countries [28].

There were multiple steps in the regulatory response process, including submitting legislation and eventually creating the PEGA Committee, which issued reports based on their investigation, culminating in a final one formally adopted by the European Parliament. Investigative artifacts like the PEGA Committee Study, *The impact of Pegasus on fundamental rights and democratic processes,* served as posturing statements from the EU that highlighted the negative impact of spyware on democracy and individual rights [50]. The final PEGA Committee report was adopted by Parliament on May 8, 2023. Later, in June, the Parliament also made recommendations to the European Council and the Commission, as well as to Spain specifically (and other countries) on what further actions to take to correct the harms from the use of spyware [18].

The adopted PEGA Committee Report concluded that "Spain has an independent justice system with sufficient safeguards" but that there was room for improvement [28]. Furthermore, the Parliament declared that "the regulatory framework in Spain is in line with the requirements set by the Treaties" but that "some reforms" are needed such as "real and meaningful legal remedy" for people who have been targeted by spyware [18]. They called on Spain to undertake six corrective and enforcement actions, including investigation into the alleged cases of spyware use by the CNI, sharing judicial authorization materials with the victims, ensuring the victims have legal remedy for compensation, amending the legal framework of the CNI, and inviting Europol to contribute to the investigations [18]. The stances by the Special Rapporteur and the European Parliament show the difference between complying with regulations and adhering to them: both documents describe Spain's regime as adequate, merely complying with the rules, but they also say that they could advance their protections of their citizens by adhering more closely to the spirit of the regime.

The PEGA Committee and subsequent Parliamentary texts called more broadly for a variety of actions to amend the regime governing the use of spyware, including legislation and action from the executive branch of the EU, the European Commission. The areas they specify for action include better implementation and enforcement of existing legislation, international cooperation to protect citizens, strengthening the capacity of telecom providers, bringing in Europol for more action, creating new entities to support research and development, and more [18].

Since the 2023 actions in Parliament, the main response behaviors have been plenary debates in Parliament and statements from MEPs, particularly as further news about the use of spyware in Europe is released [12, 31, 43]. In early 2025, the rapporteur responsible for the PEGA Committee Report and Dutch MEP until 2024, Sophie in't Veld, made a public statement saying that legally-binding action needed to be taken by the EU to transform the regime that governs the use of spyware. The debates are simple compliance with legislative

procedure, follow up discussions after the initial investigation. For example, key members of the European Commission and Council did not attend the 2024 plenary debate which had spyware and the PEGA Committee on the agenda [43]. The public statements can be seen as posturing to drive future action.

It is also worth noting that these responses have primarily been focused on amendments to the regime that governs "illegal" use of spyware. While Spain was largely found to be operating within the law, other Member States were excoriated for illegal or anti-democratic behaviors [12, 18, 28, 31, 43]

A countervailing voice came from MEP Jordi Cañas Pérez and an academic who published a report that called into question the validity of the data collected by The Citizen Lab and the PEGA Committee in Spain and Catalunya. In this report, they contribute to the Spanish authorities' stance that the surveillance was conducted legally and with legitimate national security interests in mind, in full adherence with the law. They also state that much of the data about the potential "victims" of the surveillance was not able to be validated, and therefore could not be relied on as evidence of nefarious behavior [41]. This report, in particular the statement from the MEP included, serves to posture the regulatory response against the claims of the users that were surveilled, and in favor of the existing regime, encouraging no corrective behavior. Additionally, it shows a network formed with the MEP and an academic researcher to assist in that posturing behavior at the international level.

Spanish Regulators

Key responses from Spanish national authorities came from the CNI itself and the primary Ombudsperson's office, known as the Defensor del Pueblo, an independent authority with investigative powers. According to a news article, the director of the CNI Paz Es-

teban, reported that they spied on "eighteen pro-independence leaders and people in their circles" with prior judicial authorization [52]. This leaves a difference of nearly 50 people compared to the report from Citizen Lab (including users that were targeted with software other than Pegasus). The Ombudsman, in compliance with their mandate, investigated and made a limited statement. In it, he declared that the CNI "[acted in accordance with the Constitution and the law in the cases examined]" [15]. In terms of correcting or enforcing, this could be considered no correction, maintaining the status quo of the regime and providing no compensation for the victims. The response does not even include mention of WhatsApp or Meta, the software producers. Together, these responses construct an *ex post* jurisdiction, that supports the *ex ante* operations, and the extant regime, that permitted the use of the spyware for national security interests.

In the judiciary system, new court cases have arisen in 2025, opening another door to correction of the regime, or compensation for the victims. As of September, one case filed by victims against the Civil Guard and the CNI, as well as the creators of the spyware, NSO Group, has progressed in a court in Barcelona. However, a previous case in the national courts was dismissed [7, 48]. Spanish judicial authorities also attempted to investigate the spyware technology by sending a letter to Israeli authorities, where the NSO Group is headquartered, however, there was no response [47].

In 2023, a report was released challenging the investigation by the Citizen Lab. This report, written by an academic researcher in cooperation with a Spanish MEP is an example of posturing in favor of the regime that governed the use of the spyware, and supporting the regulators' compliance behaviors. The report challenges the "methodological and ethical issues" of the Citizen Lab investigation, including the research design, field work, and findings. Among the 22 issues, the report claims that the claims of spying specifically by the lawyers representing the targeted users were used to try to upend their court cases, and that much of the monitoring was generally legal because many of the affected users were in-

carcerated. The report ties the Catalan independence movement with Russian involvement, which, by extension, implicates national security. The author included a statement from Spanish MEP Jordi Cañas Pérez that outlined his concerns which he also communicated to the PEGA Committee [41].

Other International Regulators

There were some responses from international regulatory stakeholders following the publicization of Catalangate and similar incidents. The UN High Commissioner for Human Rights made a public statement calling for countries not to violate human rights, but also stated that surveillance measures can "be justified in narrowly defined circumstances, with a legitimate goal" [8].

In 2023, a joint statement by a network of 11 countries was issued stating their commitment to "counter the proliferation and misuse of commercial spyware" and an additional six countries added their names to it in 2024 (Herpig & Paulus, 2024; UK Foreign, Commonwealth & Development Office, 2024). Following this, in 2024, the UK and France began a new initiative calling for regime amendments governing commercial spyware, called the Pall Mall Process, but nothing beyond statements and creating networks has occurred [27].

D.5.3 Software Producer

WhatsApp took a variety of actions following the incident, primarily directed at the attackers. First, while remediating the vulnerability, WhatsApp tried to obfuscate the effects of the patch to try and collect data about the attackers, in hopes they didn't notice that the update affected their exploit. This could help the software team correct their security business processes to pre-emptively stop future attacks from attackers, and also provide data artifacts for other response, remediation, and recovery actions. Additionally, the WhatsApp

security team adhered to disclosure requirements and notified users that had been targeted by the attack as well as the US Department of Justice [22].

Next, WhatsApp/Meta filed a lawsuit against NSO Group in US federal court in October, 2019 barely 6 months after the vulnerability was discovered [39]. This complaint was a good example of posturing, as it gave WhatsApp and Meta the ability to make public statements, begin constructing jurisdiction in a novel way, and protect their interests. The case would prove to be novel, as it became the first "victory against the development and use of illegal spyware" (Meta, 2025). This was also a compensation activity to get money from the attacker, and a correcting activity to try and prevent future attacks by setting legal precedence in future court cases. The US District Court of the District of Northern California subsequently ordered the NSO Group to stop using Pegasus to attack users of WhatsApp [24].

In this court case, Amnesty International, a global human rights advocacy organization that also works on privacy issues, along with Access Now and other privacy advocacy organizations, joined the network of supporters for WhatsApp when they filed an amicus curiae brief that highlighted the human rights concerns with the Pegasus spyware [3]. As a note, it is rare that a user privacy advocacy group would side with a software producer like Meta, as they typically attempt to improve privacy protections for users by such large companies. While they have connected on issues like content moderation and freedom of speech issues, this collaboration between privacy advocates and big tech companies does seem to represent a more impactful interaction, according to an expert on the topic [2].

D.6 Outcomes

The outcomes for all stakeholders are still playing out five years after the breach was initially discovered. In courts, legislatures, and the media, the costs, transformations, and

remedies are still being assessed. However, thus far, the regime has been preserved.

D.6.1 Users

The targeted users in this case are still seeking meaningful remedies. The Spanish authorities, specifically the Ombudsman, ruled that the data breach was lawful. This has meant that, thus far, there has been no compensation and no transformations to their protections, nor direct prevention from future harms. While there have been lawsuits filed, some have been dismissed and some are still in progress, but no compensation or transformations have come from these cases yet either. However, the broad public outcry about the use of spyware in Spain and elsewhere, especially in Europe, could lead to some transformations as advocates work together with targeted users to shame prospective perpetrators, specifically government actors.

The costs for these users could include things like a loss of privacy, impacts on their careers, or the need to adopt new processes to protect themselves. More broadly, it could also have a chilling effect on their involvement in civil and democratic action.

The day following the formal adoption of the PEGA Committee Report, a user advocacy organization called European Digital Rights (EDRi) plainly stated their opinion on the outcome in a report entitled "PEGA Committee does not go all the way on spyware regulation" [16]. The EDRi response is clearly critical of the result and actively seeks to transform the regulatory regime to improve user protections. First, the result is that there is a "conditional moratorium" on the use of spyware by Member States, requiring them to investigate and resolve spyware abuse cases, align national legal frameworks with international law standards, involve Europol in investigations, and repeal certain export licenses. EDRi claims that there would not be any enforcement action based on these rules, but that some of the concepts could lay the groundwork for future legislation [16]. This critique

was mirrored by another user advocacy organization, Amnesty International in a brief public statement the same day [4].

D.6.2 Software Producers

Meta and WhatsApp have been aggressive in their response, recovery, and remediation activities. The results have been largely favorable for them. In 2025, their lawsuit against NSO Group netted them over $4 million in compensation in US courts, and a permanent injunction on the use of Pegasus against WhatsApp users [24]. The decision highlighted that NSO Group violated the terms of service they would have agreed to when accessing WhatsApp [11]. This outcome can be seen as a transformation in favor of other software producers as it sets precedent to protect them from future abuses of their technology when vulnerabilities are exploited for spyware and profit by third parties.

This case also brought privacy advocates into a cooperative network with software producers to fight a shared threat, which is not typical, and could have a lasting impact on the way these two stakeholder groups collaborate [2].

D.6.3 Regulators

In this case the regulators in Spain are also essentially the enforcers of the regime that enabled the attack to occur, making it a confusing situation to describe. In the European Parliament, regulators are limited in their ability to influence the national politics of Member States. In the US, courts awarded WhatsApp with damages, setting a new precedent for future cases.

Spanish Regulators

As a result of their enforcement actions, namely testifying before the legislature and investigating through the ombudsman's office, Spanish regulatory authorities predominantly preserved their power to use spyware in the future. They found that their actions did not violate any rules and therefore took no action. There was no compensation or remedy for the affected individuals, although only eighteen cases were investigated fully [46, 52] (Pujol, 2022; Tomás, 2022).

However, the courts have decided to hear at least one of the lawsuits against the entities that used the Pegasus spyware as of September 2025 [7].

European Regulators

The adopted PEGA Committee Report and the Recommendation of 15 June 2023 are not legally binding remedies, but they are both enforcement actions in their own right, documenting facts and proposals in the legal record.

Amnesty International and EDRi both responded to the PEGA Committee Report by saying that recommendations did not go far enough [4, 16]. In general, these responses describe the transformation in the regulations surrounding the use of spyware in Europe due to this event as modest, and that they are largely a preservation of the existing approach, including weakly enforced rules and strong deference to Member States in their handling of national security matters. On the other side, the report that criticized the Citizen Lab findings, which includes a signed statement from a Spanish MEP, seems to support preservation of the regime, declaring that the surveillance was legitimate [41].

There has only been limited action dealing directly with the investigations that concluded in 2023. There have been debates in Parliament and public statements from MEPs, which are not seen to be productive (see Section 4.2.1) [12, 29, 31, 43]. However, there

have been some attempts at legislative changes that have impacts on the legal uses of spyware.

However, two regulations in particular have had an impact on the regime, to prevent future spyware threats, although spyware is not their only focus: the Cyber Resilience Act (CRA) and Media Freedom Act (EMFA), both passed in 2024. The CRA sets cybersecurity requirements for hardware and software available in the EU to help ensure they are more secure, including from threats such as spyware [20]. The EMFA adds protections for the media and journalists, including prohibiting the use of spyware against them, and requiring Member States to designate an independent authority to handle complaints. Once, again, however, there are limitations for national security and "serious crimes" such as terrorism [19].

Other International Regulators

In 2024, France and the United Kingdom proposed a new regime for "Tackling the Proliferation and Irresponsible Use of Commercial Cyber Intrusion Capabilities" called the Pall Mall Process. The initiative focuses primarily on commercially available cyber-surveillance software like Pegasus. It boasts a multistakeholder network including multiple national governments, industry, and civil society [1].

However, according to a report from The Lawfare Institute in cooperation with the Brookings Institution, the process may be limited in its impact because it does not address the role that governments play in the proliferation and irresponsible use of spyware. They state that "governments are fueling the commercial cyber intrusion capabilities ecosystem with millions of taxpayer dollars every year" effectively driving the spyware software economy. Additionally, they argue that the Pall Mall Process does not directly address the capacity of governments to create their own spyware [27]. A follow up conference was

held in April 2025, but it does not appear that any transformations have resulted thus far.

In US courts, the Meta lawsuit against NSO Group took six years, but the end result was a landmark court decision that ordered NSO Group to "permanently cease targeting WhatsApp users" [24].

D.7 Aftermath

In cases where there has been a substantive change to the context of future similar cases, there is an observable pattern of response behaviors and outcomes. In the CatalanGate case, where there has been variety of impacts for software producers, regulators, and users, there is a clear aftermath that will shape the future. This case highlighted gaps in enforcement mechanisms for regulators, new methods of cooperation between stakeholders, and the perception of critical characteristics that set it apart from others.

D.7.1 Enforcement Gaps

In this case, although there was a large regulatory effort by the EU, enforcement actions against WhatsApp or the hackers for the data breach were nonexistent. This was a rare turn of events because large social media companies like Meta were regularly the subjects of EU action, and the GDPR regime was established in part to control Meta's privacy practices. The difference was that the data breach was perpetrated by EU member nations for purported national security reasons. In essence, regulators did not see WhatsApp's failure to prevent these breaches as their fault as software producers, and that violations for national security purposes were not adequately regulated. Additionally, opportunities for the affected users in Spain to seek redress were also limited, and thus far no claims have been granted in Spanish or international courts. The ultimate response was to introduce multiple new approaches to regulation, including the Pall Mall Process, European Media Freedom

Act, and the Cyber Resilience Act, all of which introduce new mechanisms to protect data privacy and security, and enforce violations even in situations of national security. Additionally, WhatsApp was able to successfully sue the company that provided the spyware, NSO Group, in US courts in a precedent-setting decision. This court decision marked the first time a software producer was able to sue a company for distributing commercial hacking tools. This marks a shift in the regulatory environment for all stakeholders through new regulations being put in place. As well as for the operational environment, particularly for users, who have new resources to protect their data.

D.7.2 New Methods of Cooperation

In the CatalanGate case, one component of the enforcement was WhatsApps lawsuit against the commercially available hacking tools that led to the breach of their users' data. This lawsuit included a rare and novel cooperation between privacy advocates, who typically represent users, and the software producer. In this case, privacy advocates like Access Now contributed to an amicus curiae brief which was submitted to support WhatsApp in their lawsuit. While there are a number of factors that go into a judge's final decision, and we cannot evaluate the weight of this document, it represents a new method of cooperation that stood out in regulatory enforcement efforts. This has an impact on the regulatory environment as it alters the context going forward for all stakeholders.

D.7.3 Critical Characteristics

In the case, some of the targets were politicians and journalists, which seemed to resonate with regulatory stakeholders, who realized that they were also at risk. The result was that regulators were more actively involved in finding new enforcement methods, journalists were outspoken, and advocacy groups advocating for data security protections for both

groups were also very active.

D.8 Case Bibliography

Bibliography

[1] The pall mall process: Tackling the proliferation and irresponsible use of commercial cyber intrusion capabilities, February 2024. Conference Declaration, Lancaster House, London.

[2] Interview with participant c004, November 2025.

[3] Access Now et al. Brief of amici curiae access now, amnesty international, committee to protect journalists, internet freedom foundation, paradigm initiative, privacy international, red en defensa de los derechos digitales, and reporters without borders in support of appellees, December 2020. Case No. 20-16408, United States Court of Appeals for the Ninth Circuit (WhatsApp Inc. v. NSO Group Technologies Ltd.).

[4] Amnesty International. Eu: 'greater steps' needed to protect rights after eu parliament suggests regulating spyware. *Amnesty International News*, May 2023. Response to the final recommendations and report by the European Parliament's PEGA committee.

[5] Angela. Whatsapp supports all kinds of file formats now, 2017.

[6] Sebastian Anthony. Europe's highest court strikes down safe harbor data sharing between eu, us. *Ars Technica*, October 2015. Ruling will likely force Facebook, Twitter, Google to keep EU data in the EU.

[7] ARA. A judge is investigating the civil guard for the first time for spying with pegasus. *ARA*, September 2025.

[8] Michelle Bachelet. Use of spyware to surveil journalists and human rights defenders. Office of the High Commissioner for Human Rights (OHCHR), July 2021. Statement by UN High Commissioner for Human Rights.

[9] Tiago Bianchi. Favorite social media platforms among internet users in spain as of 3rd quarter 2024. *Statista*, May 2025. Survey time period: Q3 2024.

[10] Nate Cardozo, Andrew Crocker, Jennifer Lynch, Kurt Opsahl, and Rainey Reitman. Who has your back? 2017: Protecting your data from government requests. Technical report, Electronic Frontier Foundation, 2017.

[11] Carly Page. Whatsapp scores historic victory against nso group. *TechCrunch*, 2024.

[12] Center for Democracy and Technology Europe. Eu tech policy brief: July 2025, July 2025.

[13] Court of Justice of the European Union. Judgment of the court (grand chamber) of 6 october 2015. maximillian schrems v data protection commissioner, 2015. Case C-362/14.

[14] Kate Cox. Us-eu privacy shield data sharing agreement struck down by court. *Ars Technica*, July 2020. Ruling holds that US surveillance practices and EU privacy law do not mesh well.

[15] Defensor del Pueblo. Escrito a la secretaria de estado-directora del cni, May 2022. Conclusions regarding the ex officio investigation into the CNI's use of Pegasus.

[16] EDRi. Pega committee does not go all the way on spyware regulation. *European Digital Rights (EDRi)*, 2023.

[17] Electronic Privacy Information Center. Max schrems i amicus brief (standard contractual clauses), 2016.

[18] European Parliament. European parliament recommendation of 15 june 2023 to the council and the commission following the investigation of alleged contraventions and maladministration in the application of union law in relation to the use of pegasus and equivalent surveillance spyware, June 2023. P9˙TA(2023)0244.

[19] European Parliament. Regulation (eu) 2024/1083, 2024.

[20] European Parliament. Regulation (eu) 2024/2847, 2024.

[21] European Parliamentary Research Service. Investigation of the use of pegasus and equivalent surveillance spyware, June 2023. At a Glance Plenary - June 2023.

[22] Ronan Farrow. How democracies spy on their citizens. *The New Yorker*, April 2022.

[23] Gennie Gebhart and Alexis Hancock. Why we can't give you a recommendation, 2025.

[24] Dan Goodin. Nso permanently barred from targeting whatsapp users. *Ars Technica*, October 2025.

[25] Cristina J. Gortázar, Nuria Lores, and María José Castaño. National intelligence authorities and surveillance in the eu: Fundamental rights safeguards and remedies - legal update (spain). Technical report, European Union Agency for Fundamental Rights (FRA), 2016.

[26] Jon Henley. Eu still unmoved by spain's standoff with catalan separatists. *The Guardian*, March 2018. European leaders maintain their position that independence drive is strictly a matter for Madrid.

[27] Sven Herpig and Julia Paulus. The pall mall process on cyber intrusion capabilities, 2024.

[28] Sophia in 't Veld. Report of the investigation of alleged contraventions and maladministration in the application of union law in relation to the use of pegasus and equivalent surveillance spyware. Technical Report A9-0189/2023, European Parliament, Committee of Inquiry to investigate the use of Pegasus and equivalent surveillance spyware, May 2023.

[29] Sophie in 't Veld. An inquiry on spyware in the eu revealed abuses by member states. *Digital Frontlines*, 2025.

[30] Jan Koum and Brian Acton. end-to-end encryption, April 2016.

[31] Connor Jones. Eu funds are flowing into spyware companies, and politicians are demanding answers. *The Register*, October 2025. Experts say Commission is 'fanning the flames' of the continent's own Watergate.

[32] Jurgita Lapienytė. Whatsapp data leaked: 500 million user records for sale online. *Cybernews*, 2022.

[33] Swati Khandelwal. Hackers used whatsapp 0-day flaw to secretly install spyware on phones. *The Hacker News*, 2019.

[34] Stephanie Kirchgaessner and Sam Jones. Phone of top catalan politician 'targeted by government-grade spyware'. *The Guardian*, July 2020.

[35] Christopher Kuner. Reality and illusion in eu data transfer regulation post schrems. *German Law Journal*, 18(4):881–918, 2017.

[36] Mariusz Maciejewski, Martina Schonard, Quentin Liger, and Mirja Gutheil. Briefing for the pega committee mission to spain. Technical report, European Parliament, Policy Department for Citizens' Rights and Constitutional Affairs, March 2023.

[37] Bill Marczak, John Scott-Railton, Sarah McKune, Bahr Abdul Razzak, and Ron Deibert. Hide and seek: Tracking nso group's pegasus spyware to operations in 45 countries. Technical Report 113, The Citizen Lab, Munk School of Global Affairs and Public Policy, University of Toronto, September 2018.

[38] Ottavio Marzocchi and Martina Mazzini. Pegasus and surveillance spyware. Technical report, European Parliament, Policy Department for Citizens' Rights and Constitutional Affairs, May 2022.

[39] Meta. Winning the fight against spyware merchant nso, 2025.

[40] Kieron O'hara and Wendy Hall. Four internets. *Communications of the ACM*, 63(3):28–30, 2020.

[41] José Javier Olivas Osuna. The pegasus spyware scandal: A critical review of citizen lab's "catalangate" report. Technical report, UNED, 2023.

[42] Parmy Olson. Whatsapp hits 600 million active users, founder says. *Forbes*, 2014.

[43] C. Perez. Eu council and eu commission must urgently address issues by pega committee. *Center for Democracy and Technology*, 2024.

[44] E. Portnoy. Building a secure messenger. *Electronic Frontier Foundation*, 2025.

[45] Robert C. Post. Data privacy and dignitary privacy: Google spain, the right to be forgotten, and the construction of the public sphere. *Duke Law Journal*, 67:981–1072, 2018.

[46] Reuters. Spain ombudsman to probe alleged cyber spying of catalan figures. *Reuters*, April 2022.

[47] Reuters. Spain's high court shelves israeli spyware probe. *Reuters*, 2023.

[48] Antoaneta Roussi. Catalonia reignites its court fight with spain over spyware. *POLITICO*, August 2024.

[49] Michael L. Rustad and Thomas H. Koenig. Towards a global data privacy standard. *Florida Law Review*, 71(2):365–454, 2019.

[50] Giovanni Sartor and Andrea Loreggia. The impact of pegasus on fundamental rights and democratic processes. Technical report, European Parliament, Policy Department for Citizens' Rights and Constitutional Affairs, January 2023.

[51] John Scott-Railton, Elies Campo, Bill Marczak, Bahr Abdul Razzak, Siena Anstis, Gözde Böcü, Salvatore Solimano, and Ron Deibert. Catalangate: Extensive mercenary spyware operation against catalans using pegasus and candiru. Technical Report 155, The Citizen Lab, Munk School of Global Affairs and Public Policy, University of Toronto, April 2022.

[52] Nicolas Tomás. Spain's cni admits spying on aragonès and on puigdemont's circle, with court approval. *El Nacional*, May 2022.

[53] Maria Tzanou. Schrems i and schrems ii: Assessing the case for the extraterritoriality of eu fundamental rights. In Federico Fabbrini, Edoardo Celeste, and John Quinn, editors, *Data Protection Beyond Borders: Transatlantic Perspectives on Extraterritoriality and Sovereignty*. Hart Publishing, 2021.

[54] WhatsApp. Whatsapp video calling, November 2016. WhatsApp Blog announcement

regarding the rollout of video calling across Android, iPhone, and Windows Phone devices.

Appendix E: OPM Case Analysis

E.1 Introduction

The United States Office of Personnel Management (OPM) "serves as the chief human resources agency and personnel policy manager for the federal government" [51]. Between 2014 and 2015, the OPM suffered from a series of cybersecurity failures that amounted to one of the largest data leaks in US government history. The vulnerability exploits compromised sensitive data for government employees, including information that could be threatening to national security. The exfiltrated data contained personally identifiable information (PII) from over 21 million government employees, including personnel files, detailed information from background security investigations required for security clearances, and biometric fingerprint data. As a government agency, the OPM is highly regulated, particularly by the Federal Information Security Modernization Act (FISMA), and the data it was responsible for was also highly protected.

"Background investigations conducted on these individuals are designed to identify the type of information that could be used to coerce an individual to betray their country" [19]. Ergo, the compromised data could be used to coerce an individual to betray the United States.

The OPM suffered two breaches that compromised the data as a result of multiple, ongoing failures to secure vulnerabilities. Starting in 2005, the OPM "assumed responsibility for the processing and storage of federal background investigation" and had to clear a back-

log of investigations that had impacts on their resources for years to come [19]. In 2013, leadership changed, including a new Director in May and a new CIO (Chief Information Officer) in December. In March 2014 a "significant data breach at the agency" occurred, and despite efforts from the OPM, federal authorities, and outside cybersecurity companies, vulnerabilities were exploited until May 2015. The breaches in 2014 were identified, but security teams were unable to identify the full extent of the exploits, which led to them persisting through 2015, resulting in a second overall data breach. In response to the incidents there was comprehensive regulatory enforcement, including by the US House of Representatives and federal agencies, as well as a successful class action lawsuit against OPM and its software vendor, KeyPoint. OPM provided credit data monitoring for affected victims and reformed their cybersecurity efforts as a result of the incident.

This case is extremely valuable to investigate because of its scale, the involvement of regulators, and, especially, the cyclical nature of the incidents themselves. This case is comprised of two separate but related incidents, each with their own precursors and outcomes. Following the first incident, there were dedicated response, recovery, and remediation efforts. However, they were inadequate, and a second breach occurred, resulting in further actions and outcomes. The precursors to each incident are important factors, and there is effectively double the amount of data to analyze before and after the incidents. Afterwards, the consequences shaped data security and privacy, particularly in the federal government, as we know it today.

These vulnerabilities and failures, as well as their outcomes, are detailed in a 241-page report from the 7 September 2016 US House Oversight and Government Reform Committee, *The OPM Data Breach: How the Government Jeopardized Our National Security for More than a Generation* led by Representative Jason Chaffetz. This report is valuable for its forensic detail, and it is referenced heavily in this analysis. There are other artifacts used for analysis, and the report does not document all of the events pertinent to the case.

However, it includes details that are not found elsewhere, clarifies key information, and has reliable data such as testimony from individuals involved in the incidents, and results from investigations by the House of Representatives and other government agencies.

E.2 Cyber Social Context

The cyber social context comprises the environments for the stakeholders before a cybersecurity incident. In this case, the software producer, the Office of Personnel Management (OPM) implemented technology to manage employment data for end users including government employees, and deployment users such as other government agencies. As a government agency, and due to the protected nature of the data, the OPM is regulated by a wide-ranging regime, including oversight by Congress. User data included PII and sensitive background investigation information as well, and end users are represented by organizations like labor unions, as well as privacy advocates.

E.2.1 Software Producer

The software producer in this case is the OPM, a federal agency that supports other federal agencies' human resources needs. Their role includes managing employment data for millions of people, mainly government employees, including background checks for security clearance. This is highly sensitive data, and of keen interest to threat actors. The OPM, as well as other federal agencies, had been under threat from attacks for many years prior to the incidents that began in 2014. Their oversight comes from a variety of rules enforced by internal and external regulators within the federal government.

Operational Environment

According to the Government Accountability Office, in 2017, the OPM was the

> central human resources agency for the federal government, overseeing all policy to support federal agencies' human resources departments—from classification and qualifications systems to pay, leave, and benefit policies. In addition, the agency provides investigative products and services for more than 100 federal agencies to use as the bases for suitability for employment and security clearance determinations ... It also provides more than 95 percent of the government's background investigations, conducting approximately 2.2 million investigations a year. The agency had a fiscal year 2016 discretionary budget authority of about $245 million and around 5,300 full-time equivalent employees.

[55]

The product for background investigation was known as the Personnel Investigations Processing System (PIPS), which at the time included "approximately 15 million records of investigations conducted by and for OPM, the Federal Bureau of Investigations, the US Department of State, the US Secret service, and other customer agencies" [19]. Starting in 2004, this service fell under OPM's Federal Investigative Services (FIS) division after it was moved from the Department of Defense through an act of Congress. This was a significant increase in scale of their mission as an agency, although it fell within their typical operations. To manage this, OPM worked with a variety of contractors, including KeyPoint (which was later absorbed by a company known as Peraton) and US Investigations Services, LLC (USIS), both of which also performed background investigations. USIS was formerly an office of OPM but was privatized in 1996 [17]. They also relied on cybersecurity technology from vendors and other federal agencies, such as US-CERT, to maintain the data security of their products.

The transition of the background investigation services led to a backlog of applications

which took years to clear. By 2008, audits began to indicate that the OPM was suffering from weaknesses that could compromise their security [19]. In particular, the supervision of these operations fell under both the OPM Director and the Office of the CIO (OCIO), which includes both a CIO and a CISO at the helm. In 2009 there were leadership changes, including a new Director. However, there was an 18-month period where a permanent Senior Agency Information Security Official went unfilled. Audits from the Inspector General continued to highlight deficiencies in the cybersecurity operations of the agency, including PIPS, in 2010, 2012, and 2013 [19]. In 2013, both a new Director, Katherine Archuleta, and CIO, Donna Seymour, were installed just months prior to the first incident. Archuleta discussed addressing cybersecurity issues in her Senate confirmation hearing, including modernizing IT [19].

As described in the next section, this era of cybersecurity operations for federal technology producers was typified by "playing catchup" according to a subject matter expert [3]. New best practices, requirements, and technologies were being put in place, and OPM in particular was dealing with antiquated systems that needed to be secured.

Regulatory Environment

The OPM is governed by a variety of regulators both internal and external, mandated by a handful of laws and rules. Internally, their most important stakeholder is probably the Inspector General, who at the time was Patrick McFarland, who had held the position for 26 years before resigning in 2016. The IG as an internal watchdog was codified in law in the Inspector General Act of 1978 to "provide a means for keeping the head of the establishment and the Congress fully and currently informed about problems and deficiencies" in federal agencies and is responsible "not to any individual, but to the public interest" [1, 19]. It was his audits and memoranda that since 2009 had announced issues with cybersecurity

at the agency. The Office of the Inspector General (OIG) is tasked with supporting law enforcement authority and investigation, is meant to be an integral part of incident response, and has oversight for contractors and procurement, according to OPM's own internal rules [19]. At OPM there is also a Management Review Board, which includes the CISO, Deputy CISO and other leaders, that supports managing information security risks [55].

Externally, the regime under which the OPM operates, specifically regarding its security, is most closely tied to the Federal Information Security Modernization Acts of 2014 and 2002 (FISMA). This law "is intended to provide a comprehensive framework for ensuring the effectiveness of information security controls over information resources that support federal operations and assets" [55]. It includes requirements for agency leaders regarding security protections, as well as agency-wide cybersecurity programs. It is the law that requires agencies to comply with NIST standards, and authorizes a central security incident center, the DHS US-CERT [55]. FISMA audits within OPM are conducted by the OIG, and are required at least every year for overall security controls, and at least every three years for systems in operation in order to be authorized to operate (ATO). Additionally, the Federal Information Technology Acquisition Reform Act has implications for security, and uses a "scorecard to assess agencies' implementation of this law" [19].

As a federal agency, OPM is also subject to oversight from Congress, including the Committee on Oversight and Government Reform, which in 2016 was chaired by Representative Jason Chaffetz. There are also multiple examples of guidance and directives from other responsible agencies, such as the Office of Management and Budget (OMB).

Employees of the federal government also have protections that OPM must comply with, such as those established by unions. There are a variety of unions that represent government employees, including the American Federation of Government Employees (AFGE) and the National Treasury Employees Union (NTEU) among others. In recent years, unions have started to include data privacy and security as part of their portfolio

of protections for their members, which also benefits other non-union employees as well when employers implement those protections.

Threat Environment

Since at least 2005, federal agencies have been under threat from Advanced Persistent Threat (APT) attacks, which focus on high-value targets and physical systems. This includes agencies that hold sensitive employee information, as well as their contractors. OPM itself was breached in 2012 when a database was compromised and user IDs and passwords were stolen. By the time of the breaches in 2014, "[t]he threat of APTs was well-known throughout the federal government and OPM was a prime target given the sensitive information it held on current and former federal employees and contractors" [19]. Between 2009 and 2014, the number of cybersecurity incidents at federal agencies involving PII more than doubled, reaching 27,624, among over 67,000 total incidents reported in 2014, according to the US-CERT [54]. The cybersecurity vulnerabilities at OPM were also well documented in audits for years.

In fact, OPM contractor USIS encountered a sophisticated breach in 2013 that was similar to what OPM would later experience [19, 38]. USIS at this time was a company providing background investigations services for OPM, but it was previously an office within the agency before being privatized in 1996.

The PIPS system used to handle background investigation itself stored information gathered from the SF-86 form, described as "some of the government's most valuable PII" as it requires disclosure of "intimate and potentially embarrassing aspects of a person's life" [19].

In general, OPM should have been very familiar with the threats they faced, and many of their security staff and contractors were. However, their capacity to implement the required

practices were documented as lacking.

E.2.2 Regulators

There is a network of regulators that support the regime in this case. Federal agencies, the legislature, internal regulators, and third-party organizations all contribute to the rule-making process, and the enforcement of those rules. They have a wide range of experience, but many are highly focused on cybersecurity because of the sensitivity of the data at the OPM.

Regulatory Environment

In 2005, there were two major initiatives that kicked off years of regulatory action and a growing regime that governed federal software security. One was the US-CERT Technical Cyber Security Alert that put all agencies on watch. The other was the Homeland Security Presidential Directive 12: Policy for a Common Identification Standard for Federal Employees and Contractors (HSPD-12), which set years of cybersecurity action in motion. In 2002, Congress passed FISMA and updated it in 2014. FISMA required agencies to manage their own systems and authorized other agencies to support broader cybersecurity functions [16, 19, 54, 54].

Courts also offer important safeguards for victims of data breaches. In an Amicus Curiae brief filed during the class action lawsuit following the breach, EPIC, a privacy advocacy organization, highlighted cases like *NASA v. Nelson* in 2011, which supported the right to privacy regarding employment records collected by the government following a data breach [13].

Operational Environment

The network of regulators is strongest at the federal level, as many agencies worked together to establish and enforce a regime of cybersecurity regulations. Agencies like the Department of Homeland Security and its US-CERT, the Office of Management and Budget, Government Accountability Office, as well as Congress, and the President were all active in cybersecurity operations for federal software and IT systems. There was near constant activity in supporting cybersecurity efforts beginning around 2005, when the threat of APTs became clear.

Much of the operational activity, and authorization to do so, had been at the hands of two agencies, OMB and DHS at this time. The OMB, for example, issued multiple rounds of guidance and directives, including support for implementation of HSPD-12 [19, 54]. Additionally, FISMA authorized OMB to oversee and monitor agency implementation of security requirements, provide operational and technical assistance, as well as enforcement. In 2014, FISMA was updated to authorize DHS to support OMB in their efforts [16, 54].

Given the seriousness of threats and severity of incidents, it seems that enforcement of cybersecurity requirements was not effective enough in the years leading up to the OPM breach. The OMB Annual FISMA report in 2013 showed agencies' heterogeneous levels of compliance with the law, and while OPM seems to report that they were making progress in cybersecurity compliance, the results do not seem to support their self-assessments [8]. Across all of these reports, year to year, the overarching theme is that there is always more to do to secure federal software systems, regardless of the measures in place. Even in 2020, a GAO report was released, titled "Federal Agencies and OMB Need to Continue to Improve Management and Cybersecurity" [18].

Threat Environment

The threat environment for regulators specifically refers to their familiarity with the threats that they are responsible for mitigating through regulations. In this case, regardless of operational capability or capacity, it is clear that these agencies were intensely familiar with the vulnerabilities that needed to be addressed by their constituent software producers. Each agency had an immense repository of knowledge and support mechanism to address threats from APTs starting at least in 2005. DHS with support from US-CERT and OMB with technical capacity from NIST showed clear knowledge of the issues at hand. However, they may have lacked some capacity to enforce compliance to meet the increasing threat from APTs.

E.2.3 Users

In this case the users are comprised of two categories, the government agency deployment users of OPM's personnel systems (especially PIPS), and the employee end users whose data was managed in those systems. Deployment users were largely regulated under the same regime as OPM with regard to cybersecurity and protection of employee PII. End user personnel, whose PII was compromised in the breach, would also have regime protections, engaged with the software, and had advocacy organizations helping represent them during situations like these data breaches.

Regulatory Environment

Information about personnel is protected as PII, and employers, including the federal government, are required to keep it secure. OPM carried information not only about their own employees, but at other agencies as well. Data including Social Security numbers,

residency and education history, employment history, information about immediate family and other personal and business acquaintances, criminal and financial history, job assignments, performance ratings, training information, and fingerprints, were all required to be secured by OPM, but were later compromised [19, 54].

Deployment users of the OPM software are likely to be required to use OPM's services and products as government agencies, and probably were protected from any adverse behaviors by OPM for which they could not be held accountable.

Threat Environment

The scale and sensitivity of the data about these employees made this a very risky threat environment. This high value data, in a centralized system, is a clear target, and had been sought after on many occasions by APTs [38]. End users had no way of advancing their security protections through the OPM software, so their familiarity was largely irrelevant. Deployment users also were not responsible for any critical actions to improve security in their use of the OPM software, other than following standard procedures.

Operational Environment

The heterogeneous practices of the deployment users, that is the various ways in which they need the OPM software, increased the variety of data being stored by OPM, and increased its value. For example, when OPM took over the background investigation data through its PIPS software, this increased the level of risk. Agencies that relied on OPM to manage its biometric fingerprint information also increased the value of the data. Not all agencies used the software for the same purposes, but overall every agency used the system for a variety of purposes related to personnel management.

End users include government personnel and job applicants who would have used the

OPM software for HR purposes, in particular, background checks. These end users would have entered various data such as tax, healthcare, and retirement information on a regular basis. Additionally, those completing background security checks would have used the software directly to answer questions and submit supporting documentation that would have been required for their roles.

Advocacy groups were active in attempting to protect employee data at this time, including privacy organizations like EPIC, as well as unions like AFGE and NTEU. These civil society groups were available to support personnel that were affected by incidents like the OPM data breach.

Ultimately all the data that was at risk at the OPM was furnished by its users because they were required to use OPM's software to perform their duties and meet their needs as government employees.

E.3 Operating & Precursors

Analysis of the operating behaviors and precursor states of the stakeholders in this incident are weighted heavily towards the software producer and regulators. The investigation by Chaffetz et al (the House Oversight Committee) provides detailed information about the actions preceding the incident, and regulatory participation at this stage was also very involved. While users were going about their normal business, the OPM and its regulators were in constant motion, including some friction, which presaged the massive data breach that occurred.

This case is also distinguished by its dual incidents, which offers two stages of antecedent factors, those that led up to the first breach, and the responses to it, which then become the operations and precursors that led to the second breach. While they were thoroughly connected, they do appear to be two individual incidents to analyze. This is

valuable for several reasons, but mainly because it clearly illustrates examples of behaviors that failed to address key issues after a breach and immediately resulted in another.

E.3.1 Software Producer

OPM went through a variety of changes in the decade leading up to the breach, including taking over the responsibility for managing security clearances for government employees following the Intelligence Reform and Terrorism Prevention Act of 2004 (IRTPA). This legislation, partly a response to the attacks of 9/11, sought to address a backlog of security clearances necessary for government personnel and contractors [19, 25]. This added thousands of staff to OPM's office, and further needs to process clearances more quickly drastically altered the business processes at OPM. During this time, cybersecurity failures began to appear, with multiple documents detailing the specifics.

Human Resources in the Federal Government

The Office of Personnel Management was created as part of the Civil Service Reform Act of 1978 to "oversee federal workforce management." They were preceded by the Civil Service Commission which was created in 1883 [52]. OPM's duties include programs typical of any HR department, including retirement, healthcare, diversity and inclusion, and supporting hiring and employee management practices. In addition, it has some unique responsibilities, including the on-and-off-again processing of security clearances and background investigations, or Personnel Security Investigations (PSI) [4, 44, 47].

The management of PSIs at OPM has a confusing timeline. From the 1970s, the task was split between the Department of Defense and the OPM. In 1996, the office of the OPM that handled PSI was spun off into a private company called US Investigative Services (USIS). Throughout all this time, the PSI function was chronically delayed, underfunded,

and understaffed. According to Clearance Jobs, a private job board, delays in processing clearances cost the government $920 million per year in lost productivity [4]. By 2004, the backlog for contractors had reached over 188,000, and the average processing time was 375 days [19, 25].

In 2004, Congress passed the IRTPA which required under Title III that all PSIs be consolidated into one agency, the OPM, both to improve performance for processing and for security reasons. This resulted in migrating the DoD's Defense Security Service, including their 1,850 employees, to OPM's Federal Investigative Services division (FIS). At the time, OPM had about 3,000 employees, 170 of whom worked on PSIs, including managing external contractors (such as USIS) that supported processing clearances [26]. To meet the needs of the government, the goal was to reduce processing times to within 60 days and potentially expand OPM's staff to over 7,500 by 2009 [19, 25]. Following these changes in operations, they may have met their business needs, by 2012 they reduced the average initial investigation to 36 days, and raised the workforce headcount to over 9,000 people internally and externally [25]. However, criticism about their approach exploded when two events, the leaks from Edward Snowden and a shooting attack at the Navy Yard, led to concerns that the government may have "heedlessly prized speed over quality [25]. Crucially, the focus on processing times may have given way to capacity issues in complying with cybersecurity best practices.

According to the House Oversight Committee's report, starting in 2005, the Office of the Inspector General began identifying security weaknesses that were included in reports to Congress. This persisted under three directors until the breaches, Linda Springer, John Berry, and Katherine Archuleta. At Berry's confirmation hearing, Congress asked specifically about managing the PSI caseload, but did not ask about information security, although he did testify later about the need to upgrade security practices shortly thereafter [19]. During this time, the OIG's reports indicated issues with cybersecurity leadership, including

unfilled positions for key roles, issues with the authority of the OCIO to "manage security matters effectively," and security officers that had limited experience in information security, as well as a lack of "fully documented information security policies and procedures," all of which threatened the capacity of OPM to secure its implementation of services [19]. By the end of FY2013, concerns about OPM's internal compliance, capacity, security, as well as their budget, had been thoroughly documented. At this point, a FISMA audit by the IG revealed a more specific threat to the PIPS software, which supported the PSI function, including its interfaces with other software applications. The report explicitly referred to security controls that were never tested. [19].

This FISMA audit was released just as the new Director, Katherine Archuleta, and the new CIO, Donna Seymour, were being onboarded in 2013. They immediately announced that in their first few months, they would release a "Strategic Information Technology Plan" as a key artifact to improve security and compliance operations. They released this plan on time in March 2014, at which point they discovered the first data breach. Seymour testified before Congress in June 2014 about the plan, but, crucially, did not mention the data breach [19].

While budget limitations were highlighted and are likely a factor in the ability to enhance cybersecurity, the 2012-2014 Congressional Budget Requests (CBJ) from the office of the CIO did not vary widely. For 2014 (released in April 2013) the CIO request was just over $51m, for 2013 (released in 2012) was $53.3m, and for 2012 (released in 2011) it was $52.3m [40–42]. Starting with the CBJ report for 2016, after the first incident had been mitigated, and while the second one was underway, the CIO request seems to have increased to $77m [46]. It is important to note that these requests may not account for all of the OCIO's budget authority. Regardless, the House Oversight report indicates that data from the OMB shows that OPM consistently spent less than other agencies on cybersecurity, and affirms that the 2016 budget request was "too little, too late" [19].

Unaddressed Failures and Weaknesses Part 1

Courtesy of the House Oversight Committee investigation, and other artifacts included therein, we have thorough details of the specifics of the unaddressed failures and weaknesses at OPM that preceded the breach, including technical, management, leadership, and compliance breakdowns. The report titles one of the sections on these shortcomings "OPM Failed to Prioritize the Security of Key Data and Systems" [19].

The investigation, including details from US-CERT, the OIG, and other experts, concluded that OPM had not appropriately implemented multifactor authentication, encrypt critical data, properly authorize 11 of their 21 systems, or implement access-control capabilities, among other issues, all of which were required for regulatory compliance and data security best practices [19].

Multifactor authentication would have best been implemented with Personal Identity Verification (PIV) through cards for staff to access software and data. However, an OMB report in 2015 reported that OPM was one of the "weakest" in implementing such a system, with only one percent of staff required to use them [19]. These failures included the ability for a hacker to pose as an employee for contractor KeyPoint, which was the first step in exploiting the vulnerabilities within OPM's network in the second breach, despite efforts to secure their systems following the first breach [19].

The authorization of their systems is a requirement that should result in a Security Assessment and Authorization, or ATO, to operate their IT systems and help prevent security breaches. In particular, among the systems without proper ATOs were PIPS, the Enterprise Server Infrastructure, and the Local Area Network/Wide Area Network (LAN/WAN), all of which were critical weaknesses that led to the data breach being so extensive [19]. The PIPS system "is a mainframe application on the OPM environment that stores the background investigation information provided by employees and prospective employees on

forms SF-86, SF-85, and SF85P" [19].

Unaddressed Failures and Weaknesses Part 2

A new phase of operations began after the activities and outcomes resulting from the first breach, which was eradicated 27 May 2014. The correcting activities and transformations (discussed in later sections) included working with a new network of vendors and procuring new software to support security. These can be considered cyclical inputs back into operations activities like implementing and securing, resulting in precursors such as business change and capacity, as well as unaddressed failures and weaknesses.

Note: If you prefer to follow along chronologically, skip this section, and return after you have completed Section 3, Incident and Impacts, and Section 4, Recovery and Outcomes.

The procurement of new security software starting in June 2014, such as those by a company called Cylance, were met with "bureaucratic hurdles" and led to OPM purchasing a product that could detect, but not prevent, malicious behavior, despite that feature being readily available. Disagreements between different technical teams went unaddressed, leading to the procurement decision. Additionally, there were compliance issues with their ability to purchase the software to improve their capacity: Cylance did not have the correct approval through FedRAMP to supply federal agencies. However, this did not stop OPM from purchasing the limited version of their software, only the more advanced version. They claimed that although they had already broken the rules, they did not want to continue breaking them by making the additional purchase [19].

Eventually, once the upgraded tools were implemented around April 2015, including Cylance, as well as CyTech and Websense, all indicated that a second "severe attack" was underway. At this point, OPM was working with a network of "interagency partners,

government contractors, and private sector incident responders" to manage the incident. It is during the analysis of the second breach that OPM and these partners discovered that compromised login credentials from PSI contractor KeyPoint (Peraton) were the culprit for the installation of a sophisticated set of malware.

Compliance Behaviors

Particularly following the second breach, but also in response to the first, OPM's compliance behaviors regularly conflicted with the expectations of their OIG. The OIG described four situations where the OCIO did not "cooperate fully" which indicates a weak adherence to regulations prior to the breaches. The House report includes these four examples as reported by the OIG in a memorandum of concern to the new Director, Beth Cobert, in July 2015: failure to appropriately notify the IG of the April 2015 intrusion detection, failure to notify the OIG of the loss of background investigation data in a timely manner, failure to notify the OIG about the 2014 incident, and meetings with federal law enforcement agencies (which included multiple accusations of interference by the OCIO in the OIG's required participation with such meetings) [30].

As this case is cyclical, these compliance behaviors, and others, will be detailed again in the RRR section. This is because while they were in part Operations and Precursors to the second breach, they also demonstrate a pattern of weak compliance after the breaches.

E.3.2 Regulators

As discussed, the involvement of regulators both internal and external in the cybersecurity of OPM was quite thorough. Data from a variety of artifacts including scholarship and government documents detail a variety of rulemaking and enforcement actions that resulted in a comprehensive regime governing OPM and a strong capacity to respond to

issues. However, it seems that some of the capacity to respond with action was limited, as although regulators were able to identify the issues, they persisted, and adequate changes were not made to prevent the data breaches.

My analysis has already included mentions of a variety of legislation and case law that is pertinent to this case, and there are even more. Federal regulators created new agencies, mandated structural changes to existing agencies, created guidance, supplied support resources, and more all in the name of improving cybersecurity for the federal government and national security. Suffice it to say, this demonstrates a very active rulemaking environment, and strict regimes, particularly with the regulators that are externally responsible for OPM. However, the enforcement capabilities of the regulators may have been lacking in ways that could have prevented the OPM breaches. Federal authorities at this time did not have as strict methods for compelling agencies to comply as they did with conducting oversight and rulemaking.

Internally at the OPM, the OIG, whose responsibilities extend beyond just investigating cybersecurity issues, requested budgets of $25m - $26m for fiscal years 2013 – 2015, a meaningful amount of money to carry out their duties [41–43]. As required by law, the OIG submitted both its Semiannual Reports and annual FISMA audits, which were included and cited extensively in the House Oversight investigation. Again, we see active internal regulatory operations and strict regimes. The OIG also began active observation and documentation of OPM's compliance behaviors following the first data breach, which resulted in some formal reprimands later on, including a memorandum of concern regarding the CIO on 22 July 2015.

Courts were also very active in deciding on protections for privacy violations like those suffered by the OPM data breach. Cases like TransUnion v. LLC v. Sergio L. Ramirez and NASA v. Nelson, despite their heterogeneous outcomes, all demonstrated the growing importance of privacy litigation [13, 15, 24].

E.3.3 Users

The users affected by the data breach include over 22 million people who suffered unauthorized access to and theft of their data. A portion of these people include users whose especially sensitive security background clearance data was affected. As current, former, and prospective government employees, these users submitted their information to the OPM system so that their employers could rely on OPM as the central human resources agency for federal employers.

The number of users participating in the PSI system was so large that the demand for budget and staff to address it was a constant struggle [25]. This change in operational needs both for the employers that deployed the software, and the end users submitting their data, is what helped drive the shift to consolidating PSI processing to one software provider.

The capacity of these users to protect their privacy and secure their data was limited, and was primarily, if not entirely, under the control of OPM. In fact, compared to other industries that manage data on general consumers, the federal government has a strong national security interest in securing this data, as demonstrated by the strict regime they have in place.

However, privacy advocacy for employees does exist in civil society, outside of the federal employment network. This advocacy helps enhance the capacity of government employees as software users to protect their privacy. In particular, privacy advocacy groups and unions have the resources to help ensure these users can pursue compensation for harms, primarily through litigation. While not all employees are members of unions, class action lawsuits can still provide for other people who might have been affected by privacy breaches. While these groups can also help support security hygiene best practices, in this case, those efforts would have done nothing to improve security because the data breach was not influenced by the security behaviors of the employees themselves, only those of

the software producer. However, their ongoing efforts, particularly in privacy litigation, is a key element of users' capacity to help ensure that data privacy and security regulation continues to be active.

E.4 Incident and Impacts

The anatomy of the data breach and its immediate impacts are, per usual, detailed very thoroughly in the House Oversight Committee report, based on detailed documentation, testimony, and expert input from actors involved in the data breach. This is comprehensive information that would be difficult to find elsewhere in this case, and impossible to find in similar data breach cases, especially those in the private sector. In general, it would be impractical to find such a level of detail for research purposes.

E.4.1 The First Breach: 2014

On March 14, 2014, OPM was notified by US-CERT that data had been exfiltrated from OPM systems. This would have kicked off first a detection & analysis phase, followed by a containment, eradication, and recovery phase, based on the NIST Incident Response Life Cycle, which is the cybersecurity guidance document for federal agencies [29].

Within a week of detection, OPM, DHS, FBI, and NSA cybersecurity teams began to document and address the issue, and by March 25 they had made a " 'full determination on the who and what' of the data breach, to know where the hackers are 'going, what they are seeing,' and most importantly 'what [the hackers] are interested in" [19]. As they observed that the attacker was interested in the PIPS system, the outside cybersecurity teams also became aware that OPM had severely limited security measures, including their ability to secure that system. These security limitations included the use of a legacy mainframe and lack of use of PIV/multifactor access controls. The incident also indicated that OPM may

not have been able to observe other behaviors by the attackers, and US-CERT reported that attackers had access since 2012. Other exfiltrated documents also included details (manuals) about OPM's software which would help hackers to gain and maintain access for nefarious purposes.

Once they had fully analyzed the "tactics, techniques, and procedures" of the attacker, they were ready to begin eradicating and remediating in a process they called "Big Bang," which also included outside security firm Mandiant [19]. This phase concluded on May 27, 2014.

In June, following the eradication of the threat, US-CERT issued an Incident Report with recommendations based on their observations throughout the process. US-CERT's involvement, as well as that of other cybersecurity teams, is not simply part of the cybersecurity capability of the software producer, they also have a regulatory responsibility, as demonstrated by the use of their documentation in the Oversight Committee's investigation.

E.4.2 The Second Breach: 2015

While the first breach unfolded, attackers set the stage for another breach a year later, infiltrating a part of the OPM system that could not be monitored adequately. In fact, details from cybersecurity exports indicate that the attacks were "likely connected, possibly coordinated" [19]. In the first breaches, the data stolen included overviews of various systems and the people who had access to those systems, which would have been useful for future attacks, and "could explain the speed with which the 2015 attacker was able to establish access, orient themselves, escalate network authorities, and penetrate the most highly sensitive data repositories on OPM's network" [19]. Ultimately, following the attempted remediation of the first breach, attackers were still able to exploit vulnerabilities, and continued exfiltrating through spring 2015. They were discovered on April 15 and the incident

was disclosed in June and July, 2015.

The second breaches were largely discovered as OPM began the expansive corrections to their security situation after the first breach. Upgrades to their cybersecurity software began to indicate new malicious behavior. When they received a product demo from a potential contractor, the software immediately indicated a swathe of vulnerabilities actively being exploited. Between April 15 and April 25, software updates improved their ability to identify and analyze the threats, detecting incredibly dangerous tools like Trojan viruses. They were able to quarantine the exploits on April 24. After this, they realized that since June 23, 2014, attackers had unauthorized access to the OPM mainframe, which included background investigation data. Files were exfiltrated in part through access to outside servers, with surreptitious names like "opmsecurity.org" and "opm-learning.org" to hide their behaviors.

From April to August 2015, OPM worked to collect forensic information about the attacks, which suffered some setbacks, while the disclosure of the breaches reached national news.

E.5 Response, Remediation, and Recovery

Following the first breach, there was a massive undertaking to recover and remediate the insecure systems. Regulators became involved heavily at this point, including Congressional testimony from OPM leadership. Following the second breach, similar efforts were made, as well as major changes to leadership, and new legislation to again split the PSI system between OPM and another new agency.

E.5.1 Software Producer

Following the incidents of spring 2014, OPM began activities to correct their "very insecure, insecurely architected network" based partly on US-CERT's recommendations [19]. To help address this, OPM contracted with a handful of outside companies to enhance their security measures. However, US-CERT's observations also described concerns with leadership that led to the security issues, not just technical problems. Meanwhile, their efforts were later shown to fall short, as a second breach was imminent. Additionally, OPM leadership's reporting to Congress regarding the incidents also added to their problems.

Follow-up to the second breach was more severe, including compensation for affected users, formal complaints about leadership, leadership changes, and ultimately establishing entirely new federal agencies to manage the software systems. In fact, to the extent that the OPM data breach is well-known, it is primarily the second breach that the public is familiar with.

Security Through Procurement

In June 2014, CIO Donna Seymour began a new project with an outside company to improve OPM's software, focused on four phases: securing the legacy IT environment, creating a new data center and IT architecture, migrating all legacy IT to the new architecture, and decommissioning legacy hardware and systems. As part of this process, they pursued additional contracts to expand their capabilities, including with Cylance and CyTech, as well as updates to other services with vendors like Websense. The House Oversight report includes intricate details about this process, including internal documents and even some colorful language used by the vendors that is expected in difficult situations like this, but normally impossible to get hold of.

The involvement of these outside companies was rife with issues as they began to grap-

ple with the situation at OPM. In 2014 OPM purchased a tool from Cylance called V, a detection tool. However, due to "internal bureaucratic hurdles" (see Section E.3.1) they did not purchase the additional software package called Protect, which would have helped prevent malicious activity, not just detect threats once they are already in place [19]. OPM's security teams also upgraded their existing product, Websense. It was upon implementing these two tools, in April 2015, that they became aware of the second breach.

Problematic Posturing and Concerning Compliance

As part of their regulatory compliance requirements, OPM's leadership regularly reported to Congress, among other reporting duties. In June 2014, CIO Donna Seymour testified before Congress about the Strategic Information Technology Plan developed with Director Archuleta over the first few months of her tenure. However, Seymour at this juncture did not bring up the data breach and remediation efforts that had occurred just weeks before. In a later testimony, they also misled Congress about the nature of the data that had been stolen [19]. The House Oversight Committee also documented "five incorrect and/or misleading statements to Congress" regarding the data breaches and the security state of OPM.

Later, when information about some of the security operations with the contractor CyTech were published in The Wall Street Journal, there was also some dispute about the nature of CyTech's involvement, which OPM seemed to try to diminish. OPM's effort to deny CyTech's involvement went as far as testimony to Congress in which both Archuleta and Seymour denied the involvement of the company in the detection of the second breach, which appears to be objectively false [19].

Of note are the OIG's required Semiannual Reports to Congress for April 1 2014 – September 30, 2014 (during the first breach) and October 1, 2014 – March 31, 2015 (im-

mediately prior to detection of the second breach). The first report stated that they "did not detect any instance of non-compliance with regards to the major categories of FISMA requirements reviewed" and in the second report, they noted some opportunities for improvement, specifically for OPM to seek active Authorizations (ATOs) (OPM OIG, 2014; OPM OIG, 2015). In addition to the OIG's Semiannual Reports to Congress, the agency is also required to prepare a "Management Response" for that reporting period. In the same reporting periods (Apr – Sep, 2014; Oct 2014 – Mar 2015), the Management Responses did not mention the data breaches [45, 48].

Only in the April 1, 2015 – September 30, 2015 Management Report by OPM, following detection of the second breach, were the breaches mentioned. In the next report (through March 31, 2016), it was also omitted [49, 50]. The OIG Semiannual Report continued to address the breach and cybersecurity concerns in later reports [32]. This corresponds with the House investigation and the testimony given by IG McFarland, in which he stated that the OCIO "failed to provide timely notification concerning the breach" in 2014, and that he was actually notified by another agency [19]. He also testified that his notifications for the 2015 breach were accidental [19]. In short: OPM was lackluster at best in required disclosures about their data breaches.

It seems worth noting that the first 2014 Management Response report was the earliest report available via the OPM website, but also coincided with the breach, fortunately for my data collection. However, the OIG Semiannual Reports go back to 2000.

The posturing maneuvers here, to deflect some of the issues, are in some ways typical of software producers that suffer a breach. However, when it comes to Congressional testimony, and reporting to the OIG, it would seem that OPM were being noncompliant with their governing rules.

Following these Posturing and reporting incidents, it appears that OPM was able to get increased resources to meet cybersecurity requirements. According to interviewee O005,

they eventually "made the case" for how they were understaffed and underfunded, and convinced congress and the Obama administration to increase resources for them and other agencies [3]. This coincided with the broader campaign to improve federal cybersecurity, such as the 30-Day Sprint, described later.

"Failure to Cooperate"

What fits into my model under Compliance Behaviors following an incident, may not be strictly legal terms per se. Instead, such behaviors were officially documented as a "failure to cooperate fully" and "incorrect or misleading statements" by the OCIO [19]. The House report includes four examples of this as reported by the OIG in a memorandum of concern to the new Director, Beth Cobert, in July 2015 : failure to appropriately notify the IG of the April 2015 intrusion detection, failure to notify the OIG of the loss of background investigation data in a timely manner, failure to notify the OIG about the 2014 incident, and meetings with federal law enforcement agencies (which included multiple accusations of interference by the OCIO in the OIG's required participation with such meetings). These were discussed briefly in the Operating & Precursors section, but I will include more details now.

The first compliance concern was in response to the first breach. The OIG's Special Agent in Charge (SAC) testified in Congress that the OCIO did not notify the IG of the first breach in a timely manner and that it was not "in keeping with OPM policy and rules governing notification to the OIG." The SAC also testified that they only learned of the detection of the 2015 breach by accident when they ran into a colleague in a "chance encounter." In a similar situation, the SAC also testified that they only learned about the loss of background data in another "right place at the right time situation" (Special Agent Testimony in [19]).

Lastly, the IG, Patrick McFarland, and the SAC both stated that OPM's OCIO violated the terms of the Inspector General Act by preventing the OIG from participating in law enforcement support for incident response. In 2014 when the OIG was trying to investigate a breach of OPM contractor KeyPoint, the OCIO delayed the investigation for over three months. Then, in 2015 when the FBI and US-CERT were working on response measures, OPM Director Archuleta tried to delay and/or prevent the OIG from participating, as required by law [19].

Compensating

The OPM provided voluntary compensation for victims through identity theft monitoring. Following a successful class action lawsuit, they were also required to pay up to $63 million in damages to affected individuals.

Credit monitoring services have been provided by companies that suffered data breaches both voluntarily and by court order [21]. In August 2015, OPM worked with the Defense Department to award a contract to ID Experts (later called IDX) to provide credit monitoring, identity monitoring, and identity restoration services to individuals affected by the breaches [22]. Those services lasted for 10 years and are scheduled to close to new enrollments for the OPM breach in 2026, although the government also uses IDX to handle identity theft monitoring for other government breach victims, costing the government tens of millions of dollars per year [27]. IDX reported in 2019 that it had enrolled millions into its system, responded to millions of calls, and issued "over a hundred million routine credit and identity monitoring alerts" [20].

Additionally, OPM was required to pay up to $63 million as the result of a settlement agreement following a lawsuit on behalf of the victims [5, 23]. However, due to the terms of the settlement, only about 7% of the total fund was claimed, around $4.8 million. This

money was distributed to over 5,000 individuals, among the 22 million total victims and 27,000 who filed claims. While victims could claim up to $10,000 for harms directly attributable to the breach, proving those harms can be difficult, which may explain the low expenditure compared to the settlement total sum. In early 2025, the case was closed and the remaining balance returned to the Treasury Department [23].

E.5.2 Regulators

Regulatory actions were heavy-handed in this case. Multiple agencies took impactful actions and cooperated closely with each other to respond. The courts were also involved following class action litigation that required appeals before deciding in favor of the plaintiffs.

Federal Executive & Legislative Regulatory Response

Regulators had been involved in the incident through cybersecurity partners like US-CERT, as well as internal bodies like the OIG. However, involvement soon expanded to Congress and the GAO following the first and second breaches. Ultimately the House Oversight and Government Reform Committee, chaired by Jason Chaffetz, launched a full investigation including multiple hearings, and released a scathing report. The Committee report included important data that would have been nearly impossible to obtain otherwise such as previously redacted information, testimony from key individuals, unreleased internal documents, and email messages.

The OPM Office of the Inspector General was heavily involved in compliance efforts following the breaches, although, as discussed earlier, they were also thwarted at times by OPM staff. They conducted extensive investigations and enforcement efforts as part of their mandated duties and supported corrective measures by OPM like implementing new

security policies and procuring additional resources.

The GAO also conducted investigations and issued reports with information critical to understanding the regulatory compliance behaviors of OPM before and after the breach. The GAO released a 2015 Testimony to the House of Representatives Committee on Homeland Security about OPM's data breach and broader concerns with government cybersecurity, and a 2017 Report about OPM's improvements following the 2014 and 2015 breaches [54, 55]. The 2017 report is titled "OPM Has Improved Controls, but Further Efforts Are Needed" and discusses multiple remediation behaviors that needed to be completed, and/or were not handled properly. The report states that OPM had 19 recommendations from US-CERT to improve their cybersecurity practices, but at that point had only completed 11. The GAO concluded that OPM had not "consistently updated milestones for outstanding US-CERT recommendations or complied with its own plan for conducting periodic control assessments" and "key security controls on selected contractor-operated systems have not always been comprehensively tested" [55].

The Senate Financial Services and General Government Subcommittee also held a hearing on data security at OPM on June 23, 2015, which included testimony from Director Archuleta, Assistant IG Michael Esser, and an expert witness in the cybersecurity field [39].

On June 12, 2015, the Obama Administration announced a "30-Day Cybersecurity Sprint" along with OMB and DHS, a whole-of-government effort to "further protect Federal information and assets and improve the resilience of Federal networks" [35, 37]. The sprint involved pushing federal agencies like OPM to correct shortcomings and introduce monitoring methods, which they would then report to OMB and DHS at the end of the 30 days for evaluation. The recommendations for correcting activities included "dramatically accelerating implementation of multi-factor authentication" including PIV cards, "tightening practices for privileged users," and "patching critical vulnerabilities without delay"

[37]. These recommendations match verbatim some of the failures detailed in the OPM data breach case, and the effort was directly linked [14]. Following the sprint, both the status and progress of agencies' actions were assessed and resulted in recommendations documented in a 2015 memorandum from the OMB, as well as a $1.4 billion proposed budget increase to improve cybersecurity [14, 31, 35].

Eventually, these investigations required regulators like the OIG and House of Representatives to posture themselves against OPM for their failures through critical statements. And, ultimately, they moved beyond posturing into punishment enforcement actions, including calls for the Director and CIO to resign [10] and the IG's memorandum of concern to that effect [19]. Director Archuleta resigned in July 2015 and was replaced by former OMB Director Beth Cobert as Acting Director. During Cobert's tenure, calls continued for CIO Donna Seymour to resign, and she eventually retired just before the House Oversight Committee hearing in February 2016 [9].

Judicial Involvement

The court decisions following the lawsuit brought by unions representing the victims of the breach were important, in part because the plaintiffs received a settlement, but also because the initial complaint was dismissed, then overturned.

Initially, the lawsuit filed by the NTEU and AFGE unions representing victims of the breach entered the U.S. District Court for the District of Columbia. However, there are issues in data privacy breach litigation around the country regarding what is called Article III standing. Article III is a legal rule that determines whether a plaintiff has standing to sue in court, based on three elements: they have suffered an "injury in fact"; the injury is fairly traceable to the challenged action of the defendant; and it is likely, not merely speculative, that the injury will be redressed by a favorable decision. This rule has been

identified as a key factor in data privacy litigation and is a determining factor in the success of plaintiffs in such cases, although it presents a "tricky conundrum" [2, 15, 24]. This case was no different, except that it was initially dismissed for lack of Article III standing but was granted on appeal in the US Court of Appeals for the District of Columbia Circuit. This led to the $63 million settlement agreement between the plaintiffs and OPM. This reversal is not necessarily consistent with decisions in other cases, so while it does not definitively amend the current regime, it could have implications for future litigation.

E.5.3 Users

Users primarily got involved following the second breach, mainly through representation from the NTEU and AFGE unions, and support from a privacy advocate, the Electronic Privacy Information Center (EPIC). The most prominent action was their class action suit against OPM and their vendor, KeyPoint (now known part of Peraton). But they were also involved in supporting compensation through credit monitoring at OPM's expense by submitting testimony to the Senate's hearing on OPM [5, 28] .

The plaintiffs, along with the NTEU and AFGE sued OPM and Peraton in the DC District Court. First, the case was dismissed, but that decision was later reversed on appeal. In support of that appeal, EPIC and the US Chamber of Commerce provided input through amicus curiae briefs in favor of the plaintiffs, and advocating for improved data security [11, 13]. Eventually, they won up to $63 million, of which about $4.8 million was eventually claimed.

Interestingly, there were two quantitative studies of the emotions of people affected by the OPM data breach using Twitter (now X) as its data source. The authors published first in 2017 then again in 2022 using a slightly different approach, both times focusing on aggregate emotional responses to the data breach over time. Both papers described feelings

of anger, anxiety, and sadness [6, 7]. The more recent paper added context, and categorized concepts from the tweets to include "lack of agency and control in data breach responses," "decrease of citizen trust in secure digital operations," and "lack of security governance" among others [7].

E.6 Outcomes

The consequences, including a wide variety of Response, Recovery, and Remediation Behaviors after these incidents included some drastic and widespread Outcomes. Major changes to the PSI process include the introduction of a new agency, the NBIS. Furthermore, new cyber enforcement capacity was introduced, including new agencies and regulations. Leadership changes at OPM include a new Director and a new OCIO. Improvements for users are less clear, but, as has been shown, the security requirements for federal agencies to protect such data were already in place, and it was largely a series of compliance failures that led to the breach.

E.6.1 Software Producer

The outcomes from the RRR behaviors led to important transformations and a variety of costs. Between the first and second breaches, their compliance behaviors and security behaviors were partly preserved, but that changed drastically after the second breach, as the visibility and implications of their failures grew in scope, scale, and publicity. Ultimately, the scandal caused by the breaches led to the high-profile resignations of both the Director and the CIO within a year of the second breach.

According to USA Spending.gov, OPM has awarded over $725 million to Identity Theft Guard Solutions, Inc. (known as IDX and ID Experts) for credit monitoring and identity theft protection services since 2016 [53]. They also paid victims $4.8 million as part of the

lawsuit settlement.

In 2014, the OCIO total discretionary resources were $51 million, including $7.6 million for salaries and expenses. In 2023, the OCIO total discretionary resources were $107 million, including $44.9 million for salaries and expenses. The cost of doing business for the OCIO has roughly doubled. However, this includes non-security-related work, but it does show an increase in investment. Additionally, the OPM no longer handles all of the same software, as the background investigation work moved to the Defense Counterintelligence and Security Agency (DCSA) in 2019. In 2023, the DCSA OCIO budget was $59.5 million [12]. It would seem that the DCSA is doing more with less money for data security, but that is not exactly clear, as the overall budget for OPM is around $427 million and DCSA is close to $1 billion.

It is difficult to understate the scope of the changes that OPM was required to make over years to improve their software security. This included 19 critical recommendations from DHS including documentation, personnel changes, technical improvements, technology upgrades, continuous monitoring, overseeing contractor-operated systems, and more [55]. These were incredibly stringent requirements that required a high level of diligence to complete and were supervised closely by regulators.

E.6.2 Regulators

Outcomes for regulators were varied, they largely preserved their role as enforcers and responsible authorities, but introduced new mechanisms for enforcing regulations, as well as some new rules. They forced their constituent software producers to improve their software security across the board as well. The costs to do all this work would certainly be substantial, both in terms of money and human resources. Billions of dollars and uncountable hours spent.

Executive & Legislative

Through the aggressive enforcement of regulations, it is clear that legislative and executive agencies, as well as the House of Representatives, preserved their mandate to continue to enforce regulations by software producing agencies. The GAO and House Oversight Committee were diligent in investigating and bringing OPM into compliance after the breaches, and remediating the security issues that had befallen them. The GAO enforcement also continued to demonstrate the effectiveness of the network between their partners in the DHS, like US-CERT, as well as resources from NIST, and OMB. They supported the OMB in its ability to enforce FISMA regulations, and, later, supported the development of recommendations stemming from the Cybersecurity Sprint.

According to the interview with O005, the shifts in agency responsibility also included more power for regulators to enforce cybersecurity standards and practices, particularly under the authority of the Cybersecurity and Infrastructure Security Agency (CISA), such as through their Continuous Diagnostics and Mitigation Program [3]. The subject explained that while cybersecurity efforts had been ramping up, CISA now had better authority to enforce these practices. These new, more powerful enforcement mechanisms include the Binding Operational Directives and Emergency Operational Directives [3].

Executive responses went even further, either directly or indirectly connected to the OPM breach. On 4 June 2015, the Director of National Intelligence, James Clapper, openly attributed the attacks to China, when placing blame was a rare move [33]. His comments, surprisingly, also showed that he was impressed with the magnitude of the attack. Around the same time, Secretary of State John Kerry proposed introducing a “code of conduct” for state behaviors in cyberspace (BBC, 2015). Additionally, In April 2015, President Obama signed an Executive Order to give the Department of the Treasury the ability to sanction hackers for threats to national security [33]. While no sanctions were imposed for the OPM

breach, the authority has been exercised in other cases.

Judicial

As discussed earlier, the lawsuit brought by the victims was initially dismissed, then overturned in circuit court. While this result is comprised of multiple judicial decisions that require legal theory beyond the scope of this research to understand fully, there are some observable outcomes to note. First, a lawyer writing for The Lawfare Blog, states that while "No two data breach incidents are entirely alike, and given the fact-intensive nature of the standing inquiry, it's difficult to draw decisive conclusions from any single decision ... the majority's opinion suggests that the courtroom doors may be open for plaintiffs ... Without further guidance from the Supreme Court, the D.C. Circuit's approach is likely to influence both litigants and judges in the inevitable lawsuits to come" [36]. This indicates a possible transformation to judicial enforcement in data privacy and security litigation. A somewhat contrasting opinion is that while this may not open a door for other successful lawsuits, at the very least it preserves the complexity in deciding such cases as it "did not help clarify how lower courts should evaluate whether data breach plaintiffs have standing in the future" [2].

Another interesting component, on which I cannot ascribe any legal theory, was in the dissenting opinion to overturn the initial decision, a judge said that identity theft was not likely to occur because of the nature of the hack, which was for espionage [2].

E.6.3 Users

The outcomes for users were limited, although ideally future harms against users will be mitigated from similar attacks. Regardless, those that were affected, particularly government personnel whose background investigation data was compromised, will be at risk

for years to come. Especially anyone who is actively involved in national security for the US.

Compensation was limited, although some individuals were able to collect compensation for direct harms, and those that may have suffered the most economically should have been able to recover the most money thanks to the court settlement, $700 for certain claims, and up to $10,000 for direct costs. That being said, the settlement was almost a lost cause when the case was initially dismissed. Credit monitoring protections could have helped as well, although that is also a cost to the users that now needed to adopt it. Additionally, as noted by a judge, likely the primary reason for the attack was likely not identity theft, but espionage.

Deployment users that relied on the OPM FIS system migrated to the replacement National Background Investigation Services, managed by the DCSA starting in 2019. This too would have had some costs associated with it, but it is unlikely that the existing system with OPM would have remained the same for much longer, and even the NBIS system has been upgraded in that time, as any software would and should, to meet the needs of its users and producers.

E.7 Aftermath

The OPM case had wide-reaching implications for the federal government and US cybersecurity efforts, including in industry. Going forward, the regulatory, threat, and operational environment for stakeholders was substantively altered. This is observable due to the response behaviors by all stakeholders, and their outcomes. This aftermath was driven by new awareness of gaps in enforcement mechanisms, new methods of cooperation to address data privacy and security, and the perception of the critical nature of the incident.

E.7.1

E.7.2 Gaps in Enforcement Mechanisms

In the OPM case, the precursors to the 2014 and 2015 breaches included multiple years of findings by external and internal regulators of failures to comply with cybersecurity regulations. While cybersecurity efforts by the US government, including regulations for federal agencies, had been ramping up for years before, following the OPM breach, there were massive efforts to close gaps in regulations from both the executive and legislative branches. This includes The Computer Information Sharing Act of 2015 and updates to FISMA in late 2014. These acts introduce new enforcement mechanisms for federal agencies, such as Binding Operational Directives and Emergency Orders, which are issued by CISA and "They serve as powerful instruments for standardizing the approach to information security, driving the government to be more responsive and vigilant" as they are enshrined in law [34]. This results in changes to the operational and regulatory environment for regulators and software producers, who have new regimes to comply with.

E.7.3 New Methods of Cooperation

In the OPM case, the legislation that passed soon after the disclosure of the breach, particularly the Computer Information Sharing Act of 2015, established new methods of cooperation to support regulatory enforcement. This act improves the ability of federal agencies to collect and share information about cybersecurity threats to better respond to them by providing an avenue for private companies to submit cybersecurity information. Furthermore, following the breach, the role of CISA to support cooperation between federal agencies continued to increase, including the introduction of more enforcement capabilities, and taking over the oversight role from OMB. This has implications for the threat en-

vironment, particularly the regulators' and software producers' familiarity with the threats. As well as the operational environment, improving capacity for software producers to secure their systems.

E.7.4 Critical Characteristics

In this case, the response from federal agency leaders appeared to be a realization that they could not simply rely on the technical teams, and that they would have to lead with cybersecurity in mind or face national security consequences, if not their own jobs. The data that was compromised could have national security implications at a very high level, and future incidents could also face the same threats.

E.8 Case Bibliography

Bibliography

[1] Inspector general act of 1978. Pub. L. No. 95-452, 92 Stat. 1101, 1978. Codified as amended at 5 U.S.C. app.

[2] In re U.S. Office of Personnel Management Data Security Breach Litigation. *Harvard Law Review*, 133(3):1095–1102, January 2020. Recent Case.

[3] Interview with participant o005, 2026.

[4] The brief history of the security clearance process. ClearanceJobs, n.d. Source file: The Brief History of the Security Clearance Process.pdf.

[5] American Federation of Government Employees. Statement for the record regarding opm information technology spending and data security, June 2015. Source file: afge-data-breach-testimony-6-23-15.pdf.

[6] Eric Bachura, Rohit Valecha, Rui Chen, and H. Raghav Rao. Data breaches and the individual: An exploratory study of the opm hack. In *ICIS 2017 Proceedings*, 2017. Source file: Data Breaches and the Individual_ An Exploratory Study of the OPM.pdf.

[7] Eric Bachura, Rohit Valecha, Rui Chen, and H. Raghav Rao. The opm data breach: An investigation of shared emotional reactions on twitter. *MIS Quarterly*, 46(2):881–910, 2022. Source file: OPM Data Breach Investigation of Shared Emotional Reactions on Twitter.pdf.

[8] Beth Cobert. Fiscal year 2013 annual report to congress: Federal information security management act. Technical report, Office of Management and Budget, May 2014. Source file: fy_2013_fisma_report_05.01.2014.pdf.

[9] Aaron Boyd. Opm cio seymour resigns days before oversight hearing. *Federal Times*, February 2016. Source file: Boyd - OPM CIO Seymour resigns days before Oversight hearing.pdf.

[10] Jedidiah Bracy. 21.5 million breached in second opm hack; director resigns. *IAPP*, 2015. Source file: Bracy - 21.5 Million Breached In Second OPM Hack; Director Resigns _ IAPP.pdf.

[11] Chamber of Commerce of the United States of America. Brief of amicus curiae the chamber of commerce of the united states of america, 2018. Source file: US Chamber Amicus Brief.pdf.

[12] Defense Counterintelligence and Security Agency. Dcsa op-5. Technical report, Department of Defense, 2024.

[13] Electronic Privacy Information Center. Brief of amicus curiae electronic privacy information center (epic) in support of appellants, May 2018. Source file: in-re-opm-EPIC-amicus.pdf.

[14] Federal CIO Council. State of federal it report: Cybersecurity. Technical report, CIO Council, 2017. Source file: 02.05.cybersecurity.pdf.

[15] Ellis Fenske, Christopher W Brown, and Jeff Kosseff. Courting consensus: How class action lawsuits shape data privacy rights and obligations in the us. In *Proceedings of the 23rd Workshop on Privacy in the Electronic Society*, pages 172–185, 2023.

[16] Zachary Figueroa. Time to rethink cybersecurity reform: The opm data breach and the case for centralized cybersecurity infrastructure. *Catholic University Journal of Law and Technology*, 24(2):433–467, 2016. Source file: Figueroa - Time to Rethink Cybersecurity Reform.pdf.

[17] Amruta Gayathri. Usis that vetted snowden under investigation overlooked snowden resume discrepancies. *International Business Times*, 2013. Source file: USIS That Vetted Snowden Under Investigation Overlooked Snowden Resume Discrepancies _ IBTimes.pdf.

[18] Carol C. Harris. Information technology: Agencies need to address shortcomings in modernizing legacy systems. Technical Report GAO-20-691T, U.S. Government Accountability Office, 2020. Source file: GAO - Harris 2020.pdf.

[19] House Committee on Oversight and Government Reform. The opm data breach: How the government jeopardized our national security for more than

a generation. Technical report, U.S. House of Representatives, September 2016. Source file: The-OPM-Data-Breach-How-the-Government-Jeopardized-Our-National-Security-for-More-than-a-Generation.pdf.

[20] Identity Theft Guard Solutions, Inc. U.s. office of personnel management awards id experts identity protection services contract. *IDX Knowledge Knowledge Center*, 2019.

[21] Vincent R. Johnson. Credit monitoring damages in cybersecurity tort litigation. *George Mason Law Review*, 19, 2011.

[22] Eric Katz. Government awards $133m contract to protect 21.5m victims of opm hack. *Government Executive*, September 2015. Source file: Government Awards $133M Contract to Protect 21.5M Victims of OPM Hack - Management - Government Executive.pdf.

[23] Eric Katz. Feds claims just 7% of available funds from opm breach settlement, remainder returns to treasury. *Government Executive*, January 2025. Source file: Feds claims just 7% of available funds from OPM breach settlement, remainder returns to Treasury - Pay & Benefits - Government Executive.pdf.

[24] Jeff Kosseff, Chris Brown, Ellis Fenske, and Don Needham. Not easily dismissed: The growing importance of data breach litigation in cybersecurity. *Boston University Journal of Science & Technology Law*, 30:189–222, 2024.

[25] Rebecca LaFlure. How congress screwed up america's security clearance system. *Foreign Policy*, October 2013. Source file: How Congress Screwed Up America's Security Clearance System – Foreign Policy.pdf.

[26] David McGlinchey. Opm set to absorb defense security clearance agency. *Government Executive*, 2004.

[27] Jason Miller. Opm bringing protections for data breach victims to an end. *Federal News Network*, October 2025.

[28] National Treasury Employees Union. Opm renews contract for protecting data breach victims. *NETU Blog*, 2025.

[29] Alex Nelson, Sanjay Rekhi, Murugiah Souppaya, and Karen Scarfone. Incident response recommendations and considerations for cybersecurity risk management: A csf 2.0 community profile. Technical Report NIST Special Publication (SP) 800-61r3, National Institute of Standards and Technology, Gaithersburg, MD, April 2025.

[30] U.S. House of Representatives Committee on Oversight and Government Reform. The equifax data breach.

[31] Office of Management and Budget. Memorandum m-16-04: Cybersecurity strategy and implementation plan (csip) for the federal civilian government. Technical report, Executive Office of the President, October 2015. Source file: OMB CSIP - GOVPUB-PREX2-PURL-gpo114663.pdf.

[32] Office of the Inspector General. Semiannual report to congress: October 1, 2015 – march 31, 2016. Technical report, U.S. Office of Personnel Management, 2016.

[33] Damian Paletta. U.s. intelligence chief james clapper suggests china is suspect in cyber hack. *Wall Street Journal*, June 2015. Source file: WSJ James Clapper.pdf.

[34] Kat Samiljan. Binding operational directives guide federal agencies through maze of cybersecurity. *Government Technology Insider*, January 2024.

[35] Tony Scott. Strengthening and enhancing cybersecurity for the 21st century. CIO.gov, 2015.

[36] Benjamin Sobel. Recent decision: D.c. circuit rules that opm breach victims have standing to sue. *Lawfare*, 2023. Source file: Sobel - Recent Decision_ D.C. Circuit Rules That OPM Breach Victims Have Standing to Sue _ Lawfare.pdf.

[37] The White House. Fact sheet: Enhancing and strengthening the federal government's cybersecurity, 2016. Source file: FACT SHEET_ Enhancing and Strengthening the Federal Government's Cybersecurity _ whitehouse.gov.pdf.

[38] ThreatConnect Research Team. Opm breach analysis: Update. Technical report, ThreatConnect, June 2015. Source file: OPM Breach Analysis_ Update _ ThreatConnect.pdf.

[39] United States Senate Committee on Appropriations. Hearing on opm information technology spending and data security, June 2015. Source file: Hearing _ Hearings _ United States Senate Committee on Appropriations.pdf.

[40] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2013. Technical report, U.S. Office of Personnel Management, 2011.

[41] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2013. Technical report, U.S. Office of Personnel Management, 2012.

[42] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2014. Technical report, U.S. Office of Personnel Management, 2013. Source file: opm_fy_2014_cbj_final_v4__pickens___4-09-13__-_to_print_v2__1_.pdf.

[43] U.S. Office of Personnel Management. Congressional budget justification fiscal year

2015. Technical report, U.S. Office of Personnel Management, 2014. Source file: opm_fy_2015_cbj__master__3_09_14_855pm_final.pdf.

[44] U.S. Office of Personnel Management. Fy 2013 annual performance report. Technical report, U.S. Office of Personnel Management, 2014. Source file: 2013-annual-performance-report.pdf.

[45] U.S. Office of Personnel Management. Semiannual report response: October 2014. Technical report, Merit System Accountability and Compliance, 2014. Source file: sar-response-oct-2014.pdf.

[46] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2016. Technical report, U.S. Office of Personnel Management, 2015. Source file: congressional-budget-justification-fy2016.pdf.

[47] U.S. Office of Personnel Management. Fy 2014 annual performance report. Technical report, U.S. Office of Personnel Management, 2015. Source file: opm_2014_apr_v15_508.pdf.

[48] U.S. Office of Personnel Management. Semiannual report response: April 2015. Technical report, Merit System Accountability and Compliance, 2015. Source file: sar-response-april-2015.pdf.

[49] U.S. Office of Personnel Management. Semiannual report response: October 2015. Technical report, Merit System Accountability and Compliance, 2015. Source file: sar-response-oct-2014.pdf.

[50] U.S. Office of Personnel Management. Semiannual report response: April 2016. Technical report, Merit System Accountability and Compliance, 2016.

[51] U.S. Office of Personnel Management. About us, n.d. Source file: About Us - OPM.pdf.

[52] U.S. Office of Personnel Management. Mission & history, n.d. Source file: Mission & History.pdf.

[53] USAspending.gov. Federal awards: Advanced search results for identity theft guard solutions, inc., 2025. Source file: Federal Awards _ Advanced Search _ USAspending.pdf.

[54] Gregory C. Wilshusen. Cybersecurity: Actions needed to address challenges facing federal systems. Technical Report GAO-15-725T, U.S. Government Accountability Office, 2015. Source file: gao-15-725t.pdf.

[55] Gregory C. Wilshusen and Nabajyoti Barkakati. Information security: Opm has improved controls, but further efforts are needed. Technical Report GAO-17-614, U.S. Government Accountability Office, 2017. Source file: gao-17-614.pdf.

Appendix F: Model Concept Definitions

F.1 Definition Format

Phase (Behavior or State)

-Stakeholder (Regulator, User, Software Producer)

–Variable (Net effect category of activities)

—Value scale (e.g. Risky-Stable, Low-High, Lenient-Strict, etc.)

F.2 Cyber Social Context

The context is the state that exists between software producers, regulators, and users in trying to achieve data privacy and security goals. The concept is based on the grounded theory concept of context, which bounds the case being studied, and represents the zone where the possible (or inevitable) conflict occurs between the triad of users, software producers, and regulators. For the purposes of this research, this space is limited to social conflict with regard to data security & privacy and software engineering.

After a dispute is settled, it may change the global context for future disputes, such as through case law, new regulations, changes to behavior, etc. This is why we can consider the context node a "start/finish line," as a conflict has a starting context, and may eventually

have an impact on that context.

The context is comprised of three environments for each stakeholder: regulatory, threat, and operational. These environments are interrelated but have different inputs, outputs, dimensions, and meanings for each stakeholder. The overall context sets the stage for the conditions, actions-interactions, and consequences throughout the case being analyzed.

F.2.1 Environments overview

Regulatory Environment

The regulatory environments refer to the relationships between each stakeholder and the regimes that are in place. This might include norms, case law, statutory law, internal regulations, legal history (such as path dependence), and other regulatory factors. Because there is no objective way to document and measure all these influences for any given case, the result is a regime that is emergent, arising from the vicissitudes of these inputs. The regulatory environment is comprised of the various rules and regulations across the jurisdictions where users & producers that operate collectively form a regime that the stakeholders operate under.

Threat Environment

The threat environment describes the different risks, levels of risk, and potential harms for the stakeholders, as well as their familiarity with them.

Operational Environment

The operational environment for stakeholders describes the overall functions that they perform, and is largely the practical basis for their relationships, setting the stage for how

they will interact with each other. Whereas the regulatory environments are more abstract, the operational environments explain the context for the actions that each stakeholder can take in preventing, addressing, and responding to threats and violations, as well as the setting for their software operations.

F.2.2 User Environments

Regulatory

For users, the inputs and outputs of the regulatory environment are primarily related to their data privacy and security regime protections. Their data and privacy are safeguarded by a regime that establishes their rights and privileges. These rights could protect users based on attributes innate to their person, such as their citizenship, age, or employment, or it could be based on the data being stored, such as medical or financial information. Users are afforded privileges to act based on their protections as well, they may or may not be able to file lawsuits, negotiate directly with companies, or seek specific safeguards for their data.

Value scale: Weak – Strong

The dimension for the user regulatory context evaluates the strength of the protections that the regime provides.

Threat

The threat environment for users is comprised of the harms they can suffer due to data privacy and security breaches, and the value of their data. Because users can include both end-users and technical deployment users, their familiarity with vulnerabilities can also be a factor in the threat environment. The ability of some users to support cybersecurity can help reduce threats. On the flip side, because some software supports a wide range of users

and use cases, that heterogeneity can add to a variable threat surface, which increases risk.

Value scale: Risky – Stable

The threat context dimension for users describes how risky the environment is, largely based on the value of the information about them and, to a lesser degree, how users contribute to vulnerabilities that could be exploited by a would-be attacker.

Operational

The user operational environment refers to their practices when using the software in the case. This includes the heterogeneous practices and different use cases that various users have when deploying the software. It also includes the hierarchy of users, such as end-users that have little or no control over the software, the technical users that deploy the software (including security measures) in different ways, and management users that are responsible for procuring or overseeing deployment and may work closely with the software producer.

Value scale: Challenging – Simple

This dimension describes the complexity of deploying the software with respect to its security capabilities. While it might be easy for users to install a mobile messaging app, they may not be able to work with the software producer to improve their security.

F.2.3 Software Producer Environments

Regulatory

For software producers, the regulatory environment describes how they interpret the emergent regime of regulations. The regime is supposed to dictate how they are supposed to protect the data they collect, store, and transfer about their users. However, the regime is complex, as it arises from so many sources, including laws, internal policies, industry

self-regulation, and more, that can be difficult to understand and implement. So software producers must make decisions about how to approach them based on their understanding and risk of enforcement. Furthermore, software producers' ability to comply with the regime is also impacted by technical and operational challenges. Complying with the cybersecurity regime should not be so burdensome that it negatively impacts their ability to survive.

Value scale: Lenient – Strict

The software producer regulatory environment dimensions describe how strict the environment is in driving their compliance.

Threat

The threat environment for software producers includes their "internal" familiarity with vulnerabilities, and their ability to control for a variable threat surface. Software producer familiarity with vulnerabilities is described as "internal" because there may be threats intrinsic to their specific industry or technical infrastructure to which they need to be particularly attuned. For example, dealing with student data or financial information. The threat surface is considered variable due to any heterogeneity in the ways that users operate their software, as well as the changing tactics that malicious actors may use, each of which may require ongoing enhancement of security measures.

Value scale: Risky – Stable

The dimension for the software producer threat environment describes the level of risk to their systems and data, particularly how dangerous their industry is, and how difficult it is to defend against attacks.

Operational

The operational environment for software producers describes the commercial or mission-driven (for non-commercial entities) aspects of their software implementation, including the security. This includes the relationship with their users, such as meeting user needs and requirements to ensure that they can continue to stay in business.

Value scale: Challenging – Simple

The dimension describes the complexity of the software producer's operations in meeting the needs of their customers and complying with security requirements.

F.2.4 Regulator Environments

Regulatory

The regulatory environment for regulators themselves is mainly comprised of the emergent regime that they create, and the mandates that they have to operate. The inputs to the regime are their mandate, including the laws that give them power, and the resources they have to do their work as regulators. The outputs are the components of the regime that they are responsible for, including the user protections they are tasked with ensuring, and their relationships with the software producers that interact with users.

Value scale: Lenient – Strict The regulator regulatory environment dimension describes how strict they are in enforcing the regime, in some ways a measure of how powerful regulators are.

Threat

The regulator threat environment is primarily based on their familiarity with vulnerabilities in the areas they regulate. This is essentially their expertise. If they are unfamiliar,

they may expose threats. If they are intimately familiar, they may be better able to protect against threats with effective regulation. Industry regulators, for example, might be very familiar with the threats to their constituents, or they might be focused on supporting businesses, not enforcing security requirements. **Value scale:** Unfamiliar – Familiar The regulator threat context measures the level of familiarity that regulators have with the cybersecurity that they are regulating.

Operational

The operational context for regulators describes their capabilities as enforcers, as well as the atmosphere for data privacy and security regulation. Their operational context also pertains to their flexibility in preventing regulatory violations and reinforcing compliance, while also supporting business growth and operations. Furthermore, the regulator's operational context includes the hierarchy or distribution of regulatory entities, such as different courts and lawmakers. Because the entities responsible can vary so widely, the context here is highly variable, and has a major impact on data privacy and security conflicts. For example, in Europe, EU regulators are more concerned with protecting users from corporate privacy invasion, while in the US, federal regulators are more supportive of business growth, limiting privacy regulation. However, in both cases, lower-level governments, countries in Europe and states in the US, may have different approaches to regulation and laws.

Value scale: Weak – Strong The regulator's operational context is measured by its strength in developing and enforcing cybersecurity regulations.

F.3 Operating Behaviors

The operating behaviors are the real-world actions taken by the stakeholders preceding the conflict that occurs as a result of a data breach. This phase is the first that establishes

the conditions described by GT, and these behaviors yield a precursor state. The operating behaviors follow logically from the context, and describe the various activities taken by stakeholders, which are categorized into a limited set of net effects. Net effects comprise the goals and organizational processes that each stakeholder has in interacting with each other, whether that means using software, creating software, or regulating software.

For users and software producers, the operating behaviors are deploying or implementing, securing, influencing, and adhering/complying. For regulators, they are rulemaking, enforcing, and influencing. Because the operating behaviors are all action-oriented, they can all be evaluated by how active the stakeholder is in that behavior, either active or passive.

These can be considered contingencies in grounded theory, as they describe the actions arising from the context, but do not include a relationship between the variables.

F.3.1 User Net Effects

There are a variety of users that we must account for in studying data breach cases at the systems level. Different users have different responsibilities when it comes to deploying and securing software. Additionally, users are often represented by advocacy groups that can help them protect their data. Regulatory compliance also often mandates that all users take certain actions, not just those responsible for the technical aspects, and it is the leadership that may bear the brunt of any enforcement.

Deploying

Users deploy software to meet their needs, whether that is for business or personal use. This includes a variety of ICTs that are implemented by software producers, which are built to support the users' needs. Deploying activities include: using software, doing business,

changing software.

There are a variety of types of users that deploy software, with varying responsibilities. These people could broadly be described as end-users, technical users, and management users. End-users are those we most frequently think of as software users, they are the typical day-to-day people that need to use software to get something done, whether that is manage their finances, do their job, or connect with acquaintances. End-users can even be "passive" in their deployment of software, such as when they are unable to opt-out of a system, and their data is still being collected. Technical deployment users are those responsible for setting up software and its security, particularly in business settings. They may support end-users and make decisions about how the software should be deployed, and they may be responsible for security operations. These users could have some relationship with the software producer and can even have an impact on the software itself, by asking for new features. Management-level users may be less technically involved, but often have a relationship with the software producer, including negotiating contracts or setting requirements for their deployment. The result of these users is a hierarchy, where those closer to the top (technical and management users) have a closer relationship with the software producer, and those at the bottom (end-users) have little or no relationship with them. We can describe this hierarchy in terms of "power distance" the bottom and the top, and that power can have an impact on the relationship with the software producer. In consumer software, there is often a high power distance, as end-users cannot readily get access to the software producer. But in business software, the management users for a large customer might have a low power distance, negotiating contracts and even setting security requirements for a software producer they work with.

Value scale: Passive – Active

The passive-active dimension describes users deployment across the broad circumstances of their involvement with the software. This could mean they had an active con-

nection with the software deployment, or had no ability to influence the capabilities of the software, for example. This can vary widely between the different types of users within a particular case, in addition to the scenario being studied.

Securing

Users also secure their software, although the approaches and effects can vary widely. In enterprise settings, this is often handled by dedicated technical and cybersecurity teams. Enterprise end-users are also often required to follow some security best practices, such as setting strong passwords. Consumer end-users may also try to secure their data, although they may not have the same resources as an organization.

Securing activities for technical users include preparing for, defending against, and preventing software vulnerabilities. This includes a multitude of best practices and required configuration. There are a variety of frameworks, tools, guidance, as well as additional software and companies that support software securing activities, and they can all fall into the securing net effect category.

Securing activities for end-users is often described as "hygiene" including the basic, daily, routine activities needed to keep data secure, such as setting strong passwords, avoiding scams, and protecting devices from unauthorized access.

Value scale: Passive – Active

The securing activities of users are measured by how passive and active they would have been in addressing their security needs. The options and requirements for securing vary widely by situation and software.

Influence

Users can also be involved in influencing the protections of their data privacy and security. This is frequently managed by civil society groups that specialize in organizing people and advocating for their rights. These organization could represent groups of users based on a special status, such as employees or minors, based on unique vulnerabilities, such as consumer financial data, or just be focused on data privacy and security generally.

These groups, and their constituents, often participate in influence activities through lobbying for legislation, as well as through litigation to impact case law. Additionally, these groups sometimes set up self-regulatory regimes to improve protections in particular industries.

Value scale: Passive – Active

Users can be passive or active in advocating for their protections, some fields have very active advocacy organizations representing them.

Complying

Users, mainly technical and management users in enterprise settings, have to comply with regimes when they deploy software. Depending on their use case, there may be rules that they have to follow for data security and privacy, such as for their end-users and other data that they store. Users deploying the same software in different contexts can even need to follow different regimes. Complying activities include following guidance and rules and creating artifacts and documentation on an ongoing basis. These behaviors can be monitored and evaluated through audits and supported with training. Users can also attempt to go above the minimum compliance by adhering to the spirit of the law, not merely complying with the letter of the law.

Value scale: Passive – Active

Compliance activities can be evaluated for how active or passive users are in their activities. Passive compliance in an enterprise might be demonstrated by poor performance evaluations in audits. Consumer end-user compliance are probably likely to be considered "neither passive nor active" but they could be measured through the activities of advocacy organizations.

F.3.2 Software Producer Net Effects

The behaviors and net effects of software producers are very similar to those of users. They undertake many of the same behaviors. This makes sense because the relationship between users and software companies are often close, and their goals are frequently aligned. However, a software producer's actual activities may not be in line with those of their users in practice, affected by cost-saving measures, changing circumstances, or poor performance that compromises their technology, and ultimately the data of their users.

Implementing

Software producers implement software, often through a process known as the software development lifecycle (SDLC): analyze requirements, design, implement/develop, test, deploy, and maintain. This is true for standalone applications, software ecosystems, web applications, internal IT systems, and other software that is produced to meet the needs of users. This implementation typically involves engineering a large chain of software modules that are put together to create a software product, in collaboration with other teams such as human resources, marketing, account managers, and more. Software producers consider the needs of their users, industry trends, and other factors when designing, developing, and maintaining products. Software producer implementing activities include meeting and anticipating the needs of their users, growing through new lines of business

and features, managing relationships and accounts with users, managing resources and financial stability, and overall just doing business. As these things change, so to does the software engineering, which can have an impact on the product and its security.

Value scale: Passive – Active

A software producer's implementation can be measured by how active or passive it is. A company that is growing, offering new features and products, or is merging with other companies would be considered active.

Securing

Software producers secure their software much in the same way that they implement it. There is, for example, an approach called the secure software development lifecycle (S-SDLC), which adds steps like risk assessment, threat modeling, security testing, and assessment into the software engineering process. The exact framework can vary based on the organization, but many of the activities are similar. These practices are interrelated with implementing activities but they are distinct because they are responsible for mitigating security threats.

The general activities could include preparing, defending, and preventing, much like the users that deploy the software. Additionally, the software producer will likely update and patch software as new vulnerabilities are discovered and replace legacy software as new technology is released and new features become available. This is especially true for cloud software, which is near ubiquitous in today's landscape, and allows software producers to more continuously release updates to their products.

Value scale: Passive – Active

Securing behaviors by software producers can be described by how active or passive they are in securing their software. Observing this can be difficult for businesses whose

operations are not often publicly disclosed, and often only come to light after an incident has occurred.

Influence

Software producers also may seek to influence regimes by advocating security requirements that are amenable to their operations. In many, if not most cases, businesses want fewer requirements to reduce costs. Mission-driven organizations might support more strict requirements, which could be introduced through self-regulatory entities or internal policies.

Value scale: Passive – Active

Influence behaviors by software producers can be passive or active. An active company might support organizations or regulators that meet their goals through donations or other involvement. They may also have their own lobbying offices to attempt to influence regulations.

Complying

Software producers comply with the emergent regimes and regulations in a variety of ways. They may set up their own internal policies, create technical procedures, create artifacts and documentation, meet non-functional requirements, etc. The governing regime depends on their industry, jurisdiction, size, features, users, and many more factors, making compliance behavior a complex process.

Value scale: Passive – Active

A software producer's compliance behavior can be evaluated based on how active their compliance activities are. Some producers may have more compliance requirements than others, including in areas like reporting and documentation, but others may prefer to take a

more active approach regardless of outside influence.

F.3.3 Regulator Net Effects

The net effects of regulator activities are highly dependent on the type of regulator being studied, and the scenario they are operating in. The jurisdictions, capabilities, and their efforts are all heavily context dependent, and they often set the precedence for how impactful a regime might be in a dispute. The two most prominent net effects of their activities are rulemaking and enforcement, although they also participate in influence behaviors that are important to distinguish.

Rulemaking

Regulators are the primary actor responsible for creating rules, regulations, and laws that contribute to a regime. Rulemaking is a set of activities undertaken by a variety of regulators, in a variety of ways, with a variety of potential impacts. The rules that govern and protect software producers and users have grown significantly in recent years but are also based on historical precedence. Broadly speaking, rulemaking by regulators involves case law established in courts, statutory law created by legislators, self-regulatory programs created by stakeholder constituents, and other policy development, all of which includes various levels of input from software producers and users themselves. Statutory laws in particular result in a complex array of binding and nonbinding standards and guidance for some industries. The rulemaking process also contributes to the other behaviors of regulators, including enforcement, as their capacity and capabilities are often defined by the established rules. However, the rules themselves are often a necessary but not sufficient foundation for how, when, and why regulators are able to act in their enforcement roles. As such, rules are regularly updated, both by direct action, and through the behaviors of the

regulators, which can set precedent for future action.

Value scale: Passive – Active

Rulemaking can be passive or active, and this varies by regulator and scenario, even within the same case. There are active and inactive courts, legislatures, industry groups, standards organizations, and more.

Enforcement

Enforcement activities by regulators are part of the antecedent conditions to a dispute because the actions themselves, not just the rules, contribute to the regime. Enforcement can be considered any activity to obtain compliance for the regime. Enforcement actions demonstrate to stakeholders how they should interpret the regime for a few reasons. First, sometimes laws are not perfectly defined when they go into force, so enforcement can show how regulators expect the rule to be followed. Second, the ability of a regulator to act is also a consideration when interpreting the regime; a weak enforcer may beget less strict adherence, and vice versa. Third, enforcement action can also fundamentally impact a law, such as through a major court decision. Antecedent regulatory enforcement action need not be a major legal shift, either. A routine contract dispute between a user and a software producer could result in a low-level policy change to security requirements for both parties.

Another major component of enforcement action is investigation. One may consider investigation as another behavior altogether, but as it supports the broad net effect of fostering compliance, it is grouped as an enforcement activity. Investigation efforts include monitoring audits and other compliance documentation, and is often a routine procedure for highly regulated software producers and their users. It can also involve cooperation with third party experts.

Value scale: Passive – Active

Enforcement activities by regulators can be described as active or passive, and different regulators can be involved at different levels in a given case.

Influence

Influence behaviors by regulators can promote their own interests, as well as signal important information to stakeholders, and shape the regime. Influence activities indirectly support rulemaking and enforcement, and are comprised of different activities. The net effect of influence arises from regulators making public statements, collaborating with other regulatory bodies to create guidance and other support resources, and, in the case of self-regulatory bodies, advocating for particular rules.

Value scale: Passive – Active

Regulator influence activities can be passive or active, this often coincides with other behaviors, but is not always the same, as it takes into account some of the nonbinding aspects of regulator behavior.

F.4 Precursor Conditions

The precursors comprise the state that stakeholders find themselves in as conditions to a dispute. The precursor state is the outcome of the operating behaviors, and in some ways are an abstract description and in others are a more concrete explanation of the antecedent conditions. Ultimately, they describe the state of affairs that are exploited by malicious actors and which will be under scrutiny after the data breach. There is not a direct timeline from operating to precursors and stakeholders may cycle between these two phases, for example, business change (a precursor state) may result from deployment activities (operating), which could affect their capacity (precursor).

F.4.1 Users

Capacity

User capacity is defined primarily by their ability to deploy and secure software. Some of this is also related to their advocacy or activism capacity, which can impact their security. In an enterprise setting, the deployment users land on a spectrum of effectiveness, ranging from very capable of deploying and securing the software based on their needs, to ineffective, particularly regarding security. In advocacy, an effective civil society advocating for the rights of a particular group of users can help increase their security by influencing other stakeholders to make improvements. The capacity of users includes a variety of inputs and outputs including the deployed software, culture of use and security, training and education, human and monetary resources, and the overall effectiveness of users' efforts.

Value scale: Low – High

Capacity is measured based on whether it is low or high, where high capacity includes users that have a robust capacity to not only deploy software, but also secure it, in a variety of ways.

Business Change

Users frequently have changing needs for their software, resulting in changes to their deployment, which can lead to changes in the threat surface. Users may also request that the software producer make changes to the capabilities to the software, which may result in updates that also introduce new threats, if the producer makes those updates. Users' changing needs are part of the impetus for software enhancements, so it is important to make note of how users are involved in that process. When users make changes to their software they need to manage this change, which can be an involved process that includes

deployment and securing activities. Inputs and outputs to business change include new scenarios and needs, and change management.

Value scale: Low – High

Business change can be low or high, where high business change could include drastic or constant changes to the users' needs resulting in changes to the software, which could impact security.

Compliance

The state of compliance is a logical result of compliance operations. Users can be in various states of compliance depending on their operations, and depending on the level of regulation required of them.

Compliance inputs and outputs include artifacts and documentation, reporting to authorities, and software/organizational practices.

Value scale: Low – High

User compliance can be evaluated as low or high, with low compliance meaning they do not follow required rules such as reporting, setting appropriate permissions, or securing their data. High compliance could be considered "adherence" wherein they strive to meet the spirit of the rules, not simply meet the letter of the law.

Unaddressed Failures & Weaknesses

The result of operations, and the current state of users includes unaddressed failures and weaknesses that can contribute to insecurity for them, and possibly for the software that they use. Improper deployment, low compliance, and poor security activities can lead to threats that can be exploited by malicious actors. As a state, this can also be distinguished from capacity, change, and compliance, because failures may arise regardless

of those states: a well-resourced organization that is compliant and has not made major changes to their deployment can still suffer a data breach.

Value scale: Risky – Stable

The unaddressed failures and weaknesses can be rated as risky or stable, but may not be observable until after an incident. However, a user organization that has sufficient resources may considered stable, since they have a lower risk, whereas an insecure organization may be more risky.

F.4.2 Software Producers

Capacity

The capacity state for software producers is ultimately a descriptor of the entire organization and represents the bulk of what they actually do. This is a reductive and lean term that can sum up the means of the software producer as a whole for the purposes of gauging their abilities as it relates to software engineering and cybersecurity The inputs and outputs of software producer capacity include the engineered software, business artifacts, leadership and management, knowledge and experience, and their overall accountability.

Value scale: Low – High

A software producer's capacity can be evaluated simply as low or high. This, again, seems reductive, but the objective criteria can be identified before and after a data breach. A low capacity organization may not have enough engineers or enough resources dedicated to security. They may have limited capital to run the business effectively. A high capacity software producer might be known for its robust engineering and security teams, its strong revenue, and its effective leadership.

Business Change

Business change in software producers is likely a near-constant state, given the changing needs of users, the growth imperative for a business, changes to personnel, new regulations and laws, and evolving threats to security, among many, many other factors. Change is good and necessary, but it can also lead to volatility that introduces new threats.

Inputs and outputs of business change include software updates and legacy systems, organizational changes, and change management.

Value scale: Low – High

Business change can be evaluated as low or high, with some attention to whether the business changes can be related to a later data breach. A high change software producer might be overhauling legacy systems or be merging with another organization, it might be introducing new capabilities for its software, or adopting other technology that could introduce new threats.

Compliance

The state of compliance for a software producer can depend on both its behaviors and the level of regulation in its field. Many software producers, such as consumer software, operate in areas with very low regulatory requirements. However, others work in industries that have strict regulatory practices, both for the producer and for its users and customers. Much of cybersecurity compliance is related to improving security for users, so inadequate compliance could be tantamount to insecure software. Inputs and outputs of compliance include artifacts, business practices, reporting to regulators, and adapting to rule changes.

Value scale: Lenient – Strict

Software producer compliance can be considered lenient or strict, depending on how closely they follow the regulations that govern them. Lenient compliance would include

failure to document or conduct audits, not following guidance from regulators, or other generally disregarding required activities.

Unaddressed Failures and Weaknesses

In major data breaches, the state of unaddressed failures and weaknesses in a software producer is the typical culprit. As a result of other factors in a software organization like changes to technology, people, and threats, there will eventually be vulnerabilities that can be exploited. When those vulnerabilities result in exploits that expose protected user data, the conditions for a conflict are met. As with users, the state of unaddressed failures and weaknesses for software producers are related to other states, but is distinct.

Inputs and outputs to unaddressed vulnerabilities and weaknesses include software changes, new exploits (from malicious actors), operational failures, negligence, and insufficient resources.

Value scale: Risky – Stable

Unaddressed failures and weaknesses can be measured for riskiness, which is connected to how able a software producer is to mitigate such risks, as well as the scale of the vulnerability itself. An insufficiently resourced software producer, whether through negligence or other factors, may have more risky vulnerabilities. A more stable evaluation would mean that a software producer has a better grasp of vulnerabilities.

F.4.3 Regulators

There are two straightforward states that describe regulators as conditions for a data breach that concerns them: regimes and capacity.

Regimes

The regime state is the critical, yet abstract descriptor for the emergent combination of laws, rules, regulations, court decisions, guidance, standards, recommendations, policies, and precedence that governs cybersecurity for all the stakeholders in a given scenario. The operating activities that feed into this construct include the behaviors of the regulators, as well as the other stakeholders. The regimes also inform the compliance behaviors and states of the software producers and users as well. While it is expedient to group the entire regime into a single construct, in reality there are also multiple jurisdictions and actors that are responsible for enforcement. This results in both overlapping and competing requirements that can be difficult to disambiguate. In analyzing a regime it is important to isolate the different entities and their roles relevant to the case being studied. National and subnational governments, upper and lower courts, different types of agencies, and enforcement capabilities all factor into the regime state.

Inputs and outputs to the regime include laws, rules, regulations, court decisions, guidance, standards, recommendations, policies, and precedence.

Value scale: Lenient – Strict

An overarching description of the regime can be described as lenient or strict, based on how detailed the rules are, and how aggressively it is enforced.

Capacity

The regulator capacity describes their overall ability to develop and maintain the regime as a result of their activities, including rulemaking and enforcement. This can vary widely by the regulatory actor being analyzed, even within the same case. Different regulatory stakeholders can play different roles and may also have different capacities, depending on their resources and the rules they are tasked with enforcing.

Inputs and outputs to regulator capacity include funding, bureaucracy and authority, identification and analysis of vulnerabilities, involvement of third-parties, intelligence and knowledge.

Value scale: Weak – Strong

Regulator capacity can be described by how weak or strong it is, including at a high level and regarding specific entities. A strong regulator capacity would include visible and regular enforcement that demonstrates to stakeholders that they need to be in compliance to avoid punishment.

F.5 Adverse Event/Incident

The Adverse Event or Incident is the first step of the action-interaction phase, and represents the behaviors undertaken by the stakeholders as the incident unfolds. The incidents being studied are data breaches caused by malicious actors exploiting a vulnerability and gaining unauthorized access to user data through software producer systems. Activities are almost entirely limited to the software producer during the incident itself, although users are directly affected, and regulators are implicated.

The Incident is an inflection point in the case, wherein a data privacy or security breach occurs to a Software Producer, compromising the data of the Users, and incorporating Regulators as responsible authorities. The antecedent conditions include the behaviors and states of the different stakeholders. After the event, the stakeholders respond with their own actions, resulting in consequences that have an effect on each other, as well as future similar events. But it is the adverse event that draws the parties into a conflict for observation.

F.5.1 Users

Unauthorized Access of Data

The net effect to the user of a cybersecurity incident is the unauthorized access of their data. They are likely to be unaware as the event occurs, and will find out through disclosure (typically mandated) from the software producer. There is very little activity for the users at this moment, and there is no way to evaluate their role as passive subjects of the breach.

Injuries & Harms

These are the actual injuries and harms done to users. However, they may not be protected, identified, or result in any action. They are just the objective realities, including the number of people affected, the scale of the impact, and the usability of the software. Users may suffer immediate harms, such as loss of access to a particular system, or the theft of their protected data. There are also knock-on effects of the incident, for example, if the compromised data is used in further crimes like identity theft.

F.5.2 Software Producer

The software producer handles the brunt of the activities connected with the breach. While the incident is largely seen as something that happens to them, they are also active in stopping the attack, which is a multistage effort. Additionally, the scale and impact of the event is determined by the antecedent conditions in earlier phases of the model.

Vulnerability Exploited

The first net effect of the attack is that a vulnerability is exploited, although this does not amount to much of an action taken by the software producer, instead it is undertaken

by a third-party attacker. Regardless, the activity of exploiting a vulnerability needs to be included in the action-interaction phase. This is a necessary but not sufficient component of the incident that leads to a broader conflict.

At this stage, there is no evaluation of the vulnerability exploitation, it is purely an adverse event that occurs.

Unauthorized Access to Data

The second net effect of the incident is that there is unauthorized access to data. Without this key effect, the incident is not likely to result in a broader conflict with regulators and users. At this point there is no evaluation of the unauthorized access, it is simply an activity that the software producer has suffered, the results will be analyzed in later stages.

Ending the Incident

Detecting is the first set of activities activity that is undertaken by the software producer. Prior to detecting the incident, the software producer cannot move to further steps to address the breach. Detecting aligns with other cybersecurity frameworks, which describe the activities as "detection and analysis" (NIST) or "identification" (SANS). The intricacies of these activities are important for the software producer, and for deeper investigation, but are initially generalized into a broad net effect for analysis purposes.

Eradicating activities are the logical next step after a breach is detected. Once again, the net effect is made up of activities well-known to cybersecurity practitioners, "containment and eradication" (NIST, SANS). Security teams will take a variety of measures to eradicate the vulnerability and the exploit, tailored to the situation. At this point, we are not analyzing or evaluating this behavior, but it is a necessary action that begins the conclusion of the breach.

These steps are adjacent to the Correcting efforts in the Response phase, but because activities like detection and eradication occur while the incident is ongoing, they are included during the adverse event as well.

Injuries & Harms

Software producers are also harmed as a result of the attack, their systems have been compromised and they may suffer as a result. Even the most secure businesses are at risk of breaches, and there are direct and indirect costs associated with being attacked. However, their behaviors before the breach have a major impact on the injuries or harms they suffer. Direct costs include the resources necessary to stop the attack as it is ongoing, which can be exacerbated by poor security practices. Indirect costs might include damage to their brand.

F.5.3 Regulators

As with users, regulators do not play a major role during the incident itself. Instead, they abstractly become responsible for potential violations that may have led to the breach, and the occurrence of the exploit, implicates or associates them, for lack of a better term, as responsible authorities. Their actions as the authorities depend on a variety of factors described in the antecedent conditions, as well as the behaviors of the other stakeholders after the incident.

Potentially Associated

The net effect of a data breach for a regulator is that they become associated with the breach because of the regime. At this point, it is only in the abstract that they are somehow connected to the breach, but they may become involved later, and this originates with the regime.

Observations

Regulators may observe the incident as it is occurring, or immediately after it is resolved by the Software Producer. They may observe the incident in action if the software producer has a close relationships with the regulator, for example if there is already monitoring in place, or if the software producer proactively reaches out to authorities. While regulators are not always involved as the incident occurs, in highly regulated industries, they are often made aware very quickly after the incident has been resolved.

F.6 Response, Remediation, and Recovery Action-Interactions

The behaviors that the stakeholders take in response to the incident occur in a phase called response, remediation, and recovery (RRR). The options they have are predicated on the operating and precursors before the incident, as well as the nature of the incident itself. The range of possible actions, and what actually occur, vary widely and have very different results. There are examples of conflict and cooperation in this phase, and patterns emerge that can change the context for future, similar incidents, or ensure that things stay the same.

The categories of behaviors (the net effects) taken by all stakeholders in the RRR phase are all the same: posturing, compensating, correcting, and complying. The net effects are organized to share the same terms for each stakeholder, showing that they pursue a similar set of goals, although they can have different consequences. Each individual net effect can support response, remediation, and/or recovery efforts, which is why the entire phase uses those three terms, but there is no single net effect that uses any one of them. This is a very active phase, with many intertwining actions, and overlapping efforts.

This cohesive approach holds true when the goals between stakeholders are mutually beneficial, and when they are at odds with each other. The matching categories demonstrate

the way that goals between stakeholders can be aligned following a data breach. However, even when interests are opposing, stakeholders are still seeking different goals within the same categories of activities. For example, while all three stakeholders might go to court, the way they get there, and their intentions for doing so, are not usually the same.

These activities are what grounded theory describes as covariances, as these are the actions and interactions that vary together between the stakeholders, sometimes causally. Stakeholders' actions cycle back and forth as the conflict unfolds, and their behaviors are determined not just by the antecedent conditions, but also by the behaviors of the other stakeholders.

F.6.1 User Behaviors

Users affected by a data breach being investigated can vary in population, capacity, protections, jurisdiction, and other factors. Their efforts to respond, recovery, and remediate as a result of the incident are impacted by all of these variables.

Posturing

Posturing behavior by users is comprised of many activities, but primarily it involves forming networks with experts that can represent their interests, and making public statements, often with the help of those experts. The affected users can be heterogeneous populations joined together purely through their use of the same software and because of the breach, or they can be somewhat more cohesive units that have some connections with each other. If they are a diffuse population, they are at greater disadvantage, but even more cohesive groups are likely to be in a weaker position than the software producer or regulator. This is what makes posturing an important behavior, as it helps raise awareness of their situation, both with other affected users and with decision makers within regulatory bodies

and software producers.

Value scale: Passive – Active

Posturing behavior can be passive or active in their posturing behaviors. Active behaviors include broad public statements and connecting closely with experts for support, especially lawyers who can promote their legal efforts.

Compensating

The user compensating behavior includes many complex efforts to get money or other reparation for the harms caused by the data breach. The obvious activity that they might undertake would be to file a lawsuit, however, that is a complicated process, and within data security and privacy, it is especially complex. This legal recourse is much the purview of lawyers and legal theory, and between regimes those processes vary. So, the efforts undertaken by users and their lawyers are abstracted. The net effect of compensating is comprised of constructing a jurisdiction under which legal claims can be filed, and leveraging that jurisdiction through a formal legal process, such as filing a lawsuit, with the ultimate goal of collecting compensation.

Value scale: Passive – Active

The compensating efforts of users fall into the passive and active spectrum. Active users are those that connect with lawyers, potentially filing multiple lawsuits to seek compensation. Passive actors may not attempt to collect compensation whatsoever.

Correcting

The incident can result in negative impacts to the operations of the software, such as temporary or permanent loss of access. Users use the software for a reason, so when this occurs, they also attempt to correct the issue so that they can continue to meet their needs.

This could include resolving the software problems with the producer or replacing the software altogether. Users also may try to correct the regime for its shortcomings in the case that it was not effective at preventing the breach. While the software company is more focused on correcting cybersecurity issues, users have a slightly different set of activities they need to consider to address the consequences of the data breach.

Value scale: Passive – Active

Users can be active or passive in their attempts to correct the issues arising from the data breach. Active users may try to seek enforcement actions to change laws or induce producer compliance through punishment, they may terminate contracts (in which case they may need to be active to replace the software). Passive users may not have a choice in getting the software producer to change, nor have the ability to choose another technology.

Complying

Some behaviors by users are required by the regime in place, so complying is a net effect of their efforts to follow the rules that govern them. This is especially true with business users that have contracts in place, which may force them to take some action such as investigating the incident or setting up monitoring going forward. The key detail here is that compliance activities continue after a breach, and do not only occur before.

Value scale: Passive – Active

Users may be required to take some action as a result of a breach, but the extent that they take it can vary. A business customer may choose to be passive in addressing the terms of the contract with the software producer simply out of ease, so they do not have to conduct investigations and potentially find new software. Active users may use the regime to pursue their rights to the fullest extent possible.

F.6.2 Software Producer Behaviors

Software producers are the stakeholders that, based on antecedent behaviors and conditions, suffered a data breach. Their response, remediation, and recovery activities include resolving the technical aspects, disclosing to the other stakeholders, protecting their business/organizational interests, and attempting to mitigate costs while complying with any required actions.

Posturing

Software producers that have suffered a data breach have a lot of explaining to do. In highly regulated environments in particular, they have required disclosures both to users and regulators, and may have to submit to further investigations. Additionally, they may engage in public affairs campaigns to protect their interests and shape the discussion about what occurred. These behaviors could mean that they are very open, both as required and more broadly, however it can also mean that they conceal information that they think might have negative consequences for them. In shaping the discourse with regulators, particularly in courts, it is not enough to make statements, and posturing behaviors may require legal steps that do not contribute to other activities (such as correcting or compensating) but instead serve to protect their interests.

Posturing behaviors are not typically handled by the software producer alone, and they frequently get the support of other professionals to support their efforts. These networks include public relations teams, law firms, and industry advocacy groups.

Value scale: Passive – Active

Software producers can be active in posturing by making broad appeals to the other stakeholders, as well as to the general public. They can also be active in concealing information, for example sealing court documents or actively avoiding inquiry from journalists

or nonbinding regulations.

Compensating

Following a breach, software companies often compensate their affected users, this typically comes in the form of credit monitoring services and cash payments resulting from court decisions or settlements. They may also offer cost reductions or rebates to their users and customers. Software companies will occasionally pre-emptively offer credit monitoring services, which might be seen as a way to help mitigate user concerns, coinciding with posturing behaviors. Court ordered compensation often includes a minimum payout for harms caused by the data breach, as well as additional money for victims that can prove they suffered directly as a result of the breach, such as through identity theft. Software producers will typically attempt to minimize the costs associated with compensation as much as possible in court by leveraging the jurisdiction or legal approach that best protects them. They may also seek compensation from the hackers themselves by suing them in court to recover costs, if they are identified and there is a jurisdiction that can support this.

Another area of compensation for which there is little or no data, is insurance payouts for data breaches. While cyber insurance is common among private companies, and insurance companies openly promote it, there is no publicly available data about the compensation that a software receives from their insurance coverage to help them recover.

Value scale: Unfavorable – Favorable

The compensating actions that a software producer take can be seen to be unfavorable or favorable, largely based on the costs associated with the compensation. Higher payouts would be unfavorable to the software producer.

Correcting

Correcting behaviors include the internal actions that software producers take to remediate the vulnerabilities that caused the breach, including technical issues and business processes, such as detection and eradication These activities include dedicating ad hoc resources and working with external networks of professionals to resolve issues. These measures also extend beyond just addressing the vulnerabilities and business processes, as they may have periods of time where their software is compromised, and they need to provide temporary solutions. They may also need to correct their public image after the breach. Furthermore, software producers may pursue regime change to correct for prospective future threats. This could include lobbying for new litigation or suing attackers in court. This could coincide with seeking compensation through lawsuits, but may also result in correcting the regime. In general, correcting activities reflect a broader set of behaviors beyond just cybersecurity-specific remediation.

Value scale: Passive – Active

The level of activity for correcting can be passive or active. Major campaigns to address the cybersecurity issues, including leadership changes, new investments, attempts to change the regime, would all be examples of active behavior.

Complying

Many of the actions taken by software producers following an incident are required by a regime. These mandated behaviors are often, but not always, associated with other activities in this phase. The most common of these is disclosure, both to regulators and affected users, but they may also be required to compensate users for the breach, go through additional investigations by regulators, or commit to new cybersecurity measures.

It is important to distinguish this set of activities for two reasons, first to clarify which

other activities were voluntary, and second to be able to evaluate how closely they followed the rules. In legal terms, there are the concepts of the "spirit" and "letter" of the law, meaning to follow what the law intended, or merely interpreting the words that are written. Similarly, in healthcare, there are the concepts of "compliance" and "adherence" wherein a patient either follows the rules set by a physician, or they actively pursue behavior change. These concepts can describe the way that software producers (as well as other stakeholders) pursue compliance activities, whether they take the minimum action, or attempt to go above and beyond what they are required to do.

Value scale: Passive – Active

A software producer's complying activities can be passive or active, which reflects how much effort they put into meeting required activities after a breach. A passive effort could include minor violations of the requirements, such as disclosure after the mandated window, refusing to participate in investigations, negotiating existing contract terms in their own favor, or attempting to shirk their responsibilities in other ways.

F.6.3 Regulator Behaviors

Regulators' involvement following a data breach is based on their role in the governing regime, and the ways that they may be connected through the actions of the other stakeholders. Their involvement can take time, sometimes years, before they act. Their behaviors can help or harm users and/or software producers or simply have no impact. Because regulators can include different entities that may be implicated in different ways, their behaviors and the consequences can vary. They may also need to cooperate to take certain actions.

Posturing

Like the other stakeholders, regulators make public statements about data breaches to signal their intentions and help shape the actions of the stakeholders involved. They may also engage a broader network of experts, for example cybersecurity firms and other regulators, to inform their decisions. When those partnerships are announced publicly it can demonstrate the interest and compounded resources being put into regulatory activities. Additionally, they may use their role in government to posture by threatening legal action, whether or not they go through with it.

Value scale: Passive – Active

Regulators can be passive or active in their posturing behaviors. Active examples include bold public statements, threatening legal action, collaborating with industry experts, and subpoenaing software producer leadership.

Compensating

Compensating actions by regulators typically involves mandating that the software producer pay damages to users and/or fines to regulators. Regulators have also supported compensation for the software producer, paid by the hacker if the software producer can prove their own damages, although this is rare in data privacy breaches.

Value scale: Passive – Active

Regulators may be passive in compensating behaviors if they do not fine companies, nor support victims claims in court. They would be active if they levy major fines and support large payouts for victims, which can also include cooperation between different regulators to implement.

Correcting/Enforcing

The correcting behaviors of regulators can also be described as enforcement, given that enforcement is meant to correct behavior to bring a stakeholder into compliance with a law or regime. Enforcement actions vary based on the situation and by the regulator. It can involve investigations, filing lawsuits, mandating action, and other punishments. It can also mean correcting the regime to improve outcomes in the future, such as through clarifying rules, creating new rules, setting precedent through judicial decisions, or passing new laws. The overlap of regime correcting with enforcement is particularly observable in court decisions, which build on the case law precedent for future cases while enforcing the regime for the parties in court.

Regulators also do not always act in isolation, and they may need to rely on other entities to conduct enforcement activities. This plays out in many ways, but there are a few relevant examples. When a government regulator pursues action against a software producer, they may file complaint in court, relying on the input of judges, not simply making a demand. Some regulatory agencies may share authority with other agencies in enforcement actions. These conditions are also related to the complying behaviors of regulators.

Value scale: Passive – Active

Regulators can be active or passive in their correcting and enforcing behaviors. It is very clear when a regulator is active as they will take formidable actions such as filing lawsuits and visibly punishing stakeholders for their actions. However, they may be passive and decide not to pursue any action.

Complying

Regulators also have to comply with the regime in place, they cannot act outside of the law. However, the level to which they comply with their mandate is also important to ob-

serve. For example, if a regulator has the authority to pursue some enforcement action, but they do not, then they are not adhering closely to their mandate. In essence, the complying behaviors by regulators are the bounds that they have to pursue regulatory action.

Additionally, regulators may be required to cooperate with other regulatory bodies to take actions. Normative or legal requirements may force them to incorporate other regulators in their activities. For example, regulatory agencies can conduct some enforcement operations independently, but may have to go to court for other actions, such as certain fines.

Value scale: Passive – Active

Much like enforcement, regulator complying activities would be passive if they decide to take little action compared to what they have the power to do. Active complying behaviors would be, for example, "prosecuting to the fullest extent of the law" and making use of all the powers they have available to them.

F.7 Outcomes/Consequences

The outcomes and consequences are the practical results of the behaviors in the previous phase. Similar to the RRR phase, the possible outcomes are organized into a set of categories that are the same for each stakeholder: costs, transformations, preservation, and remedies. While the individual outcomes within these categories vary for each stakeholder, the categories themselves remain the same, and can represent both the aligned and disparate outcomes for the stakeholders. For example, in determining remedies, the stakeholders might negotiate together (such as in a court settlement) to get the best remedies for themselves, while reducing their own costs.

The consequences are typically focused within the given case they are describing, but those with a larger scope can result in broader changes to the context going forward, which

is described in the next phase.

The outcomes have a rich covariance with each other, and with the previous phase. It is difficult to disambiguate many of the outcomes, both for each stakeholder and between stakeholders. For example, costs and remedies are connected, but may not vary directly, as higher costs could mean better remedies, but not necessarily. These correlations and causations have important implications for observing the relationship between the parties, including their cooperation and conflict.

From a theoretical standpoint, by including the same categories for each stakeholder, even when there was little or no data in some cases, it left the door open for future cases to introduce that data. By creating interconnected categories in advance, it was feasible to assume that future cases could fill in those gaps, instead of limiting the model to what had only been observed.

F.7.1 Users

Outcomes for users are a result of their ability to advocate for their interests in the RRR phase, as well as the protections afforded them by the regime in place. Users are typically facing an asymmetric power imbalance with the software producer and rely on rights-based approaches to resolving the conflict, which means involvement from regulators. They must have the capacity to leverage their rights as part of the regime, but the regime must also have the pathways in place for them to pursue their goals.

Costs

The ultimate costs for users are wide-ranging, including finding new software solutions, securing new contracts, injuries from data theft, investment of resources in credit monitoring, adopting new practices, emotional/psychological harms, and direct monetary

costs related to any actions they may have needed to take. Even in favorable outcomes where users won cash settlements, they must also pay the lawyers to represent them.

Value scale: Unfavorable – Favorable

While costs can be relatively low or high for users, they are better described as favorable or unfavorable. While they may have had to make some investments, such as in lawyers or training, that still may be a more favorable outcome if they are kept low and are connected to better remedies.

Transformations

Users may see transformations in the form of new processes, new networks with advocacy groups, and even new protections from the regime. These transformations can be somewhat localized to the case, but they can also introduce broader impacts to users in future privacy disputes.

Value scale: Weak – Strong

Users may see weak or strong transformations resulting from the responses by themselves and the other stakeholders. Weak or strong transformations are not good or bad, they just describe how impactful the changes are on them going forward. Weak transformations can mean that they do not need to take any action, nor do they need any new protections. It can also mean that they did not get any meaningful changes to their status. Strong transformations could mean that they had to implement new, possibly costly, processes. It can also mean that they received new protections or developed new relationships with advocates to be utilized in the future.

Remedies

Remedies for users typically include some compensation for the data breach, or benefits from additional data privacy and security protections in the future. This is closely related to costs and is also impacted by compensating behaviors in the previous phase, but these factors do not always determine the remedies. Big spending on seeking remedies, such as through lawsuits, does not guarantee that they will get a cash settlement. Additional protections are a remedy, but do not counteract the harm that has already been done. Users that must rely on the same software that was breached may benefit from the new security measures, but for victims of the breach, it only helps make sure they are not harmed again.

In addition to payments, users also often receive credit monitoring services to make it easier to determine whether their data has been used for criminal activity like identity theft. Using these services also has a cost associated with it, namely in the time it takes to set it up, learn to use it, and continue to monitor it.

Value scale: Unfavorable – Favorable

Much like costs, the remedies can be favorable or unfavorable. Favorable remedies include sizable cash payments with additional funds for harms directly caused by the breach, as well as free credit monitoring services. An unfavorable outcome in the remedies category would mean that users did not receive any compensation, although they almost always benefit from additional security measures.

Preservation

For all stakeholders, preservation describes the degree to which things stayed the same, for better or for worse, following the breach and the response, remediation, and recovery efforts. This category is closely related to transformations, but it is important to distinguish the things that did not change and observe their importance. For users, preservation

includes continuing to use the pertinent software, maintaining business relationships with the software producer, a lack of changes to their regime protections, and no shift in their options for future RRR efforts.

Value scale: Weak – Strong

Strong preservation means that things stayed very much the same. If users stick with the software, it could mean that the users saw the incident as an anomaly, or that they simply had no other option. If the regime protections stay the same, it could mean that the regime was adequate in addressing the needs of the victims, or that the incident was not impactful enough to warrant a change. If the preservation was weak, then users might have migrated to other software, or achieved new protections.

F.7.2 Software Producers

The outcomes for software producers are complex, emerging from the conditions of the regulatory context and their operations before the breach, as well as their response efforts after the breach.

Costs

The costs to software producers represent the highest monetary figures in direct costs, arising necessarily from the remediation efforts to enhance their cybersecurity, and possibly from compensation paid to users and fines paid to regulators. Additionally, they may suffer indirect costs such as negative impacts on their perception by customers which could affect their business. Multiple cybersecurity companies provide free calculators to estimate the costs of a data breach, all of which reckon tens of millions of dollars for breaches impacting hundreds of thousands of users.

These costs are not always available for observation, so it is difficult to assess the direct

costs associated with remediation. The general consensus is that it is cheaper to prevent a breach than it is to recover from one. However, large companies may be able to balance the cost of incidents with a preemptive investment in cybersecurity. This makes it unclear to an outside observer how impactful the costs are to a large company following a data breach.

Value scale: Unfavorable – Favorable

There are likely no "favorable" costs for companies that suffer major data breaches, although smaller ones might be lest costly. The favorability of the costs improves when users do not recover damages from the incident, and/or when regulators do not levy fines. However, major deficiencies can still require massive investments even when there are not additional payments to users or regulators.

Transformations

Software producers will necessarily undergo some internal transformations to improve their cybersecurity stance after a major breach. This is most likely to include changes to business processes and technology. It may also involve more substantial changes to human resources such as firing leadership or other staff, as well as hiring new staff and bringing on external cybersecurity contractors. These can be supplemented by new compliance measures, either voluntarily or mandated by regulators.

Software producers may also seek regime change to improve their protections in the future. The most common way this plays out is in courts. When they respond to lawsuits from regulators or users, they argue that they should not have to pay compensation or fines, which is primarily a cost-reduction effort. However, if they win this argument, they are setting precedent for future cases that could help protect them, and others, from having to pay. It is also possible for software producers to pursue regime changes that can improve their outcomes for the future. This could include harsher penalties for hackers, or new

security requirements for other companies, particularly related software producers, which can improve broader cybersecurity capacity.

It is important to note that within private companies it can be difficult to observe internal transformations to cybersecurity, such as technical or human resources changes.

Value scale: Weak – Strong

Transformations for software producers can be weak or strong, depending on their voluntary efforts and actions mandated by regulators. Strong transformation includes firing senior leaders, pursuing strategic litigation, and major technical improvements. Weak transformation might include limited improvements to technology, and no major shifts in their approach to managing data privacy and security.

Remedies

Remedies for software producers include the new prevention measures that are put in place, as well as compensation. Prevention measures are related to transformations but include more of the concrete results of the remediation efforts arising from the breach. For example, installing a patch would not really qualify as a transformation if that is the only change to the security measures. Additionally, compensation occurs if the software producer can get external benefits from the breach, such as an insurance claim, or damages from the attacker through a lawsuit.

The limited examples of prevention as remedies hardly show up in the data, as the scale of the breaches resulted in major transformations which are more prevalent. Additionally, compensation for the breaches is rare to find for two reasons. First, because insurance claims are not publicized whatsoever. Second, because getting resources from external resources because of a breach is rare. Lawsuits by software producers against attackers for data privacy breaches are not common but are one example of such external support. While

other data theft has been successfully litigated, the exposure of PII has not been a common claim in courts by software companies. Another source is from funding partners which could increase resources for cybersecurity.

Value scale: Unfavorable – Favorable

While the remedies for software producers are rare, they are not always unfavorable. A novel approach through litigation to get damages from attackers was successful. And an organization that is funded from external sources can make the case that they did not receive adequate resources to support necessary cybersecurity, so without drawing on their existing budget, they were able to address their needs.

Preservation

For all stakeholders, preservation includes data that shows where no changes occurred after the breach and RRR efforts. For software producers, this includes their continuing operations (e.g. staying in business), their customers continuing to do business with them, or limited changes to their internal business processes.

Software producers do not want to cease existing because they suffered a data breach. Users and regulators often feel the same way. For regulators, putting companies out of business is bad for the economy, and over-enforcing regulations does not encourage compliance, it dissuades organizations from disclosing incidents, which only adds to insecurity. For users, while breaches are not ideal, changing software can also be a challenge, incurring new costs, and even adding to insecurity. As such, preservation for the software producer, not just transformation, has important implications.

Value scale: Low – High

Preservation tends to be on the higher end, as software producers are not typically radically changed due to a data breach. They continue to operate and work with their

users. However, they may lose customers or shift their software services to other entities to alleviate concerns or improve operations.

F.7.3 Regulators

Consequences for regulators include impacts on the regime, costs associated with enforcement activities, and enforcement results that affect the other stakeholders. Because regulators are described in such broad terms, including legislators, judges, internal actors, and third-party organizations, the consequences of their activities are broad and differ based on their role.

Costs

Conducting enforcement activities including investigation and litigation incurs costs to regulators. Human and budgetary resources must be dedicated, although they are not easily discernable. The salaries of the staff, for example, are built into the overhead of the organization, and reviewing the itemized reimbursements for travel or materials for a particular case, although they would theoretically be publicly available, is not really feasible. For judicial systems, which have a backlog of cases, hearing cases also costs money and time, for which they typically charge fees, although that may not cover the full cost of the work. Regardless, the scale of an investigation can still be observed from the scope of the actions taken, and a rough understanding of costs can be discerned. This is reflected in the value scale.

Value scale: Low – High

The cost scale for regulators is low to high, unlike those of the users and software producers, which are evaluated for favorability. This is based on the lack of readily available quantitative data, although it could be collected for more accuracy. It is also indicative of

the goals of regulators, which are to enforce compliance. That being said, they certainly want to keep their budget in check, and pursuing fines can mean they get revenue. The costs to regulators, when evaluated based on the scope of their efforts, is also an indicator of their interest in the case. Therefore, high costs would mean extensive investigation, thorough litigation, voluminous reporting, cooperation with a larger network, and other highly visible activities. Low costs would be indicated by a lack of statements, limited or no investigation, and likely, no enforcement actions

Remedies

The remedies consequences of regulators are the results of their enforcement actions. Regulatory enforcement in data privacy and security is generally meant to bring software producers into compliance and protect users from harm. As such, their remedies are strongly connected to, if not directly responsible for, the outcomes for users and software producers. These remedies most prominently include the decisions of judges and independent actions of regulatory authorities. They also include policy decisions by internal regulators and third-party industry regulators.

The most salient example is the result of a class action lawsuit filed by the victims of a data breach against the software producer, wherein the final decision is issued by a judge, who is acting as a regulator. In this courtroom drama, the regulator's remedies appear to emerge as the culminating consequence of all the antecedent conditions and covariance actions of the stakeholders: who wins and who loses, who is right and who is wrong, who pays and who gets paid, who gets punished and what for. However, this is only one component of the aggregate consequences of the entire case, albeit a crucial one. Additionally, a judge's decision may support some claims, and not others, and can have complex results. Furthermore, this is not how the remedies are determined in all cases. Independent actions

by regulators, or simply internal policy changes may be the extent of regulatory remedies. While the regulator's involvement and ultimate decision is often broadly impactful, it is still important to situate that outcome among the other consequences, and even the actions that led to them.

Value scale: Weak – Strong

The enforcement remedies of regulators can be considered weak or strong based on how they exhort compliance and remunerate victims. Strong remedies include meaningful fines, mandating aggressive cybersecurity measures, compensation for victims, regime changes, ongoing monitoring, and involving a broader network of experts to support enforcement.

Transformations

Regulators can introduce transformations, particularly to the regimes that govern software producers and protect users, as a result of their actions following a data breach. These transformations can arise from judge's rulings and case law, new regulations created to respond to a threat, enforcement actions that signal their interpretation of an existing law, new guidance on existing laws, new approaches to enforcing the law, and more. These transformations can shape the way that software producers and users act and interact going forward.

Transformations can signal that the existing regime, and its regulators, were not effective for enforcing compliance. So, while transformations might improve the regime, it might also have negative consequences for regulators who are unable to perform their duties.

Value scale: Low – High

Transformation by regulators can be low or high, depending on how much the regime is changed by their action. High transformation would include new laws or regulations, new

authorities for handling compliance, or new precedent set by case law. Low transformation would mean that the regime stayed the same, and stakeholders would largely behave as they had before.

Preservation

Regulators may preserve the regime, as well as their authority, when responding to data breaches. They may have already established best practices and effective regulations that allowed them to regulate effectively. They may also want to demonstrate that they are the bureaucratic entity that should remain in charge of these incidents, so they may avoid transformations to preserve their position.

Value scale: Low – High

Preservation can be low or high for regulators, regardless of the covariant transformations. Regulators can preserve their authority while changing the regime, and they can also fine-tune specific rules. High preservation would be demonstrated by an overall continuation of the existing regime and the regulators in authority. Low preservation would include new regulators introduced and/or comprehensive new laws.

F.7.4 Aftermath

The Aftermath describes the impacts on the global Context going forward, affecting future, similar cases. Not all cases have such drastic consequences for future situations. However, important cases can change the threat, regulatory, and operational environment for all stakeholders in observable ways. This was observed through three connected factors: gaps in enforcement mechanisms, new methods of cooperation, and the perception of the critical nature of the issue. These characteristics differ from the other elements because they do not have a value scale, and are the culmination of the preceding behaviors and their

outcomes.

Gaps in Enforcement

Following some incidents, there was occasionally alignment between the stakeholders that the existing regime was not effective. This ineffectiveness was perceived by the stakeholders for example, in enforcement, security protections, or remedies. This resulted in efforts to close this gap through new regulations, capacity, or other resources.

New Methods of Cooperation

In cases that changed the context for future, similar incidents, there were also observable examples of cooperation that were not seen in the other cases where no such shifts occurred. This cooperation manifested in different ways, but included partnerships between privacy advocates and software producers and new networks of regulatory bodies.

Perception of Critical Nature

The final, very qualitative and difficult to measure, factor in the aftermath impacts to future contexts is the sentiment of the stakeholders about the issues in the cases. Stakeholders in all cases may have varying levels of concern, the affected users are often more likely to be upset, for example, than the regulators or software producers. However, in these cases, there seemed to be a shared notion that the privacy that was violated was somehow unique compared to other breaches, and something needed to be changed. This included the data of minors and students, journalists, politicians, and government employees.

Appendix G: Full Model

Full model broken into two pages for visibility.

Context				Conditions			
Stakeholder		**Cyber Social Context** (State)		**Operating** (Behavior)		**Precursors** (State)	
		Environment	*Inputs/Outputs*	*Net Effects*	*Activities*	*Net Effects*	*Inputs/Outputs*
Users	End Users	Regulatory	Regime (Norms): Regime Protections (Legal History incl. case law, legislation, rules, path dependence)	Deploying	Doing Business Using Software Changing User Hierarchy Creating desirable data	Capacity	Implemented Software Culture of Use Spectrum of effectiveness Training & education Human & Capital Resources
	Deployment Users	Threat	External familiarity with vulnerabilities Variable threat surface Target value Harm	Securing	Preparing, Defending, Preventing Hygiene	Business Change	New Scenarios & Needs Change management
	Management/ Leadership Users	Operational	Heterogeneous practices Hierarchy, permissions, and use cases Civil society, advocacy groups	Influence	Lobbying & Advocating Enforcing requirements Suing	Compliance	Artifacts Business/Use Practices Reporting to authorities
				Complying	Following guidance & rules Creating artifacts & documentation	Unaddressed Weaknesses	
Software Producer	Engineers/ Developers	Regulatory	Regime (interpreted and applied) Legal Challenges Internal regulations Technical challenges Regime Support (business growth)	Implementing	Doing Business Account Management Meeting needs Anticipating needs Growth/New Lines of Biz Interpreting user data	Capacity	Engineered Software Business Artifacts Leadership & Mgmt Knowledge & Experience Accountability
	Leadership	Threat	Internal familiarity with vulnerabilities Controlling for variable threat surface	Securing	Preparing, Defending, Preventing Updating & patching Replacing legacy software	Business Change	Software updates Legacy systems Org changes Change mgmt
	Field Staff	Operational	Cooperating with user (client) requirements Commercial viability Mission compliance	Influence	Lobbying & Advocating Self-regulating	Compliance	Artifacts Business Practices Reporting to Authorities Adapting to rule changes
				Complying	Setting, documenting, and implementing policy, guidance & rules Non-functional requirements	Unaddressed Weaknesses	Software Changes New exploits Operational Failures Negligence Insufficient resources
Regulators	National/ International Governments	Regulatory	Regime (Emergent) Mandate (Legal History incl. case law, legislation, rules, path dependence) Societal change (gov, tech, econ, law) User protections Business growth	Rulemaking	Collecting input Creating standards and protections Creating laws Creating regulations Creating agencies Updating rules	Regimes	Laws, Rules, Regulations, Case Law, Guidance, Standards, and Recommendations Precedence
	State/ Lower Governments	Threat	Familiarity with vulnerabilities (expertise)	Enforcement	Legal Administrative Civil Criminal Contractual Regime implementation Investigating Audting	Capacity	NGO/Third-Party Partners Vulnerability Identification & Analysis Intelligence & knowledge Authority Bureaucracy Funding
	Nongovernmental/ Third-Party Bodies	Operational	Flexibility to support growth and prevent regulatory violations Enforcement methods Political interests/climate Economic interests/situation Hierarchy/Distribution	Influence	Promoting interests of agency Shaping Signaling Advocacy		

Action-Interaction				Consequence			
Incident/Adverse Event		**Responding, Recovering, and Remediating** (Behavior)		**Outcomes** (State)		**Aftermath** (Behavior)	
Net Effects	*Activities*	*Net Effects*	*Activities*	*Net Effects*	*Inputs/Outputs*	*Factors*	*Influenced Environment*
Unauthorized Access of Data	Vulnerability exploited Dispute logged	Posturing	Making Statements Forming networks	Costs	New software solutions New contracts Future risks Adopting & training to remediate ineffective processes Direct Costs		Threat
Injuries & Harms	Scale of Impact Class of User Software Usability	Compensating	Constructing Jurisdiction Leveraging Jurisdiction Collecting Compensation	Transformations	Business & security processes Use processes Emergent Networks		Regulatory
		Correcting	Resolving Business/Software problems Replacing Software Resuming Capacity	Remedies	Compensation Prevention		Operational
		Complying	Following rules, agreements arising from the incident	Preservation	No Change		
Vulnerability exploited Unauthorized Access to Data	Vulnerability Exploited Data Compromised (verb)	Posturing	Making Statements Concealing Info Protecting interests Forming & Managing Networks Constructing Jurisdiction Apologizing	Costs	Remediation Compensation Business costs (indirect) Penalties		Threat
Ending the Incident	[NIST] Detection & Analysis [SANS] Identification	Compensating	Offering Compensation Complying with Compensation Leveraging Jurisdiction Seeking compensation for breach	Transformations	Business processes Adherence & Compliance New jurisdiction New Software	Enforcement Gaps	Regulatory
	[NIST/SANS] Containment, Eradication	Correcting	Remediation (restoring software, stopping attack) Changing Business Processes Dedicating ad hoc resources Forming Networks	Preservation	No Change	New Methods of Cooperation Critical Characteristics	Operational
Injuries & Harms		Complying	Disclosure & Reporting (incl. artifacts) Complying with Regime	Remedies			
Potentially Associated	Incident Observed Regime implicates regulator as a stakeholder	Posturing	Making Statements Forming & Managing Networks & cooperation Signaling Constructing Jurisdiction	Costs	Budget Human Resources Indirect economic costs		Threat
Observations		Compensating	Pursuing Compensation Mandating Compensation Leveraging Jurisdiction	Remedies	Enforcement actions Forming & managing networks Supporting claims		Regulatory
		Correcting/ Enforcing	Enforcing No response (status quo) No correction Amending regime Punishing	Transformations	Case Law Enforcement approaches Changes to jurisdiction/regime		Operational
		Complying	Implement mandate Investigating Debating/meeting in session	Preservation	Case Law No Action Best practices		

Appendix H: Model-Case Matrix

The Case-Model Matrix is comprised all the states, behaviors, and their values, for each case. This is also known as a "predictor-outcome-consequence matrix" [205]. This data was used to compare and contrast the different behaviors and outcomes within and between cases reviewed in the findings in Section 5.3. The original file was created in both Excel and Airtable for easier manipulation, and included color coding for ease of use. The full file is a CSV available online at `https://github.com/elliotmtg/regulate-recover-repeat`.

Appendix I: Interview Protocol

I.1 Software Data Privacy & Security Security Conflict Semi-Structured Interview Questions

Background

1. What is your current/most recent job title?
2. What is your experience with, what have you read, or what do you know about the selected case?
    a. Or: What was your most recent project/case that related to conflicts between software companies, users, and regulators?
3. What role did you have in this case?

Lead-up to dispute

4. In terms of your experience with the case/topic/actor, what was the issue that led to this conflict?
5. What were the software producer's decisions that led up to the problem?
6. If you had been there, what would you have done?

7. What were the software producer's decisions after the problem became an issue? (What did they do after the problem arose?)

8. What were the regulations that were applicable?

9. Were regulations being followed correctly?

10. Have regulatory bodies identified or prioritized this conflict or issue in the past in this industry?

11. What was the user's interaction with the issue? Was there an immediate impact? Were they aware of the problem?

12. What were the users doing, or not doing, that may have contributed to the conflict?

Dispute Management

13. How did the software producer manage the conflict?

14. What were some of the choices that the company had in this situation?

15. How did the users attempt to resolve the conflict?

16. What did the regulatory body (court, agency, etc.) do to manage the conflict?

17. At what point did other stakeholder actors get involved? What was the timeline?

18. What tactics or strategies did they use to get an outcome that was beneficial for them?

19. Did they use any strategies that were mutually beneficial for all stakeholders?

Post-dispute

20. What was the resulting enforcement action, settlement, or agreement?

21. What was the impact of the issue on the users? Software producers? Regulatory bodies?

22. How did each actor respond to the outcome?

23. What else could each actor have done after the issue occurred that may have led to a different outcome?

24. Was there a longer-term impact of the outcome on the topic/actor/field?

Perceptions of cyber conflict

25. What are approaches to regulation that can protect users without making it more difficult for software producers to do business/achieve strategic goals?

26. Are companies like the one in this case doing enough to secure data?

27. Should users feel confident that their data and privacy are secure, and that if there are issues, then they will get their needs taken care of?

28. Are there examples of collaboration or cooperation that support software security that you are familiar with?

Bibliography

[1] At bay cost estimate. At Bay Cyber Risk Calculator. Cyber Risk Calculators document.

[2] The cybersecurity capacity maturity model for nations (cmm). https://gcscc.web.ox.ac.uk/the-cmm. Accessed: 2023-04-06.

[3] Mission, team, and story - the algorithmic justice league. https://www.ajl.org/about.

[4] Senate judiciary committee hearing on equifax data breach.

[5] Inspector general act of 1978. Pub. L. No. 95-452, 92 Stat. 1101, 1978. Codified as amended at 5 U.S.C. app.

[6] The logical framework. Technical report, USAID, 2012.

[7] In re U.S. Office of Personnel Management Data Security Breach Litigation. *Harvard Law Review*, 133(3):1095–1102, January 2020. Recent Case.

[8] Policy statement of the federal trade commission on education technology and the children's online privacy protection act. Technical report, Federal Trade Commission, May 2022.

[9] Interview with participant f001, October 2023.

[10] Interview with participant R002, April 2024.

[11] The pall mall process: Tackling the proliferation and irresponsible use of commercial cyber intrusion capabilities, February 2024. Conference Declaration, Lancaster House, London.

[12] Interview with participant c004, November 2025.

[13] Interview with participant R003, June 2025.

[14] Interview with participant o005, 2026.

[15] The brief history of the security clearance process. ClearanceJobs, n.d. Source file: The Brief History of the Security Clearance Process.pdf.

[16] Access Now et al. Brief of amici curiae access now, amnesty international, committee to protect journalists, internet freedom foundation, paradigm initiative, privacy international, red en defensa de los derechos digitales, and reporters without borders in support of appellees, December 2020. Case No. 20-16408, United States Court of Appeals for the Ninth Circuit (WhatsApp Inc. v. NSO Group Technologies Ltd.).

[17] Alessandro Acquisti, Laura Brandimarte, and George Loewenstein. Privacy and human behavior in the age of information. *Science*, 347(6221):509–514, 2015.

[18] Ioannis Agrafiotis, Jason RC Nurse, Michael Goldsmith, Sadie Creese, and David Upton. A taxonomy of cyber-harms: Defining the impacts of cyber-attacks and understanding how they propagate. *Journal of Cybersecurity*, 4(1):tyy006, 2018.

[19] Najd Alfawzan, Markus Christen, Giovanni Spitale, and Nikola Biller-Andorno. Privacy, data sharing, and data security policies of women's mhealth apps: Scoping review and content analysis. *JMIR mHealth and uHealth*, 10(5):e33735, 2022.

[20] American Federation of Government Employees. Statement for the record regarding opm information technology spending and data security, June 2015. Source file: afge-data-breach-testimony-6-23-15.pdf.

[21] Amnesty International. Eu: 'greater steps' needed to protect rights after eu parliament suggests regulating spyware. *Amnesty International News*, May 2023. Response to the final recommendations and report by the European Parliament's PEGA committee.

[22] Keith B. Anderson, Erik Durbin, and Michael A. Salinger. Identity theft. *Journal of Economic Perspectives*, 22, 2008.

[23] Angela. Whatsapp supports all kinds of file formats now, 2017.

[24] Sebastian Anthony. Europe's highest court strikes down safe harbor data sharing between eu, us. *Ars Technica*, October 2015. Ruling will likely force Facebook, Twitter, Google to keep EU data in the EU.

[25] ARA. A judge is investigating the civil guard for the first time for spying with pegasus. *ARA*, September 2025.

[26] Susan G. Archambault. Student privacy in the digital age. *Brigham Young University Education and Law Journal*, 2021(1):1–49, 2021.

[27] Laurence Ashworth and Clinton Free. Marketing dataveillance and digital privacy: Using theories of justice to understand consumers' online privacy concerns. *Journal of business ethics*, 67:107–123, 2006.

[28] Brooke Auxier, Lee Rainie, Monica Anderson, Andrew Perrin, Madhu Kumar, and Erica Turner. Americans and privacy: Concerned, confused and feeling lack of control over their personal information. *Pew Research Center*, 2019.

[29] Michelle Bachelet. Use of spyware to surveil journalists and human rights defenders. Office of the High Commissioner for Human Rights (OHCHR), July 2021. Statement by UN High Commissioner for Human Rights.

[30] Eric Bachura, Rohit Valecha, Rui Chen, and H. Raghav Rao. Data breaches and the individual: An exploratory study of the opm hack. In *ICIS 2017 Proceedings*, 2017. Source file: Data Breaches and the Individual_ An Exploratory Study of the OPM.pdf.

[31] Eric Bachura, Rohit Valecha, Rui Chen, and H. Raghav Rao. The opm data breach: An investigation of shared emotional reactions on twitter. *MIS Quarterly*, 46(2):881–910, 2022. Source file: OPM Data Breach Investigation of Shared Emotional Reactions on Twitter.pdf.

[32] Steven Bellman, Eric J Johnson, Stephen J Kobrin, and Gerald L Lohse. International differences in information privacy concerns: A global survey of consumers. *The Information Society*, 20(5):313–324, 2004.

[33] Janine Benner. Nowhere to turn: Victims speak out on identity theft. *CALPIRG Privacy Rights Clearinghouse*, 2000.

[34] Mark W. Berger. Comment letter: Form 10-k for fiscal year ended december 31, 2017. File No. 001-06605.

[35] Beth Cobert. Fiscal year 2013 annual report to congress: Federal information security management act. Technical report, Office of Management and Budget, May 2014. Source file: fy_2013_fisma_report_05.01.2014.pdf.

[36] Tiago Bianchi. Favorite social media platforms among internet users in spain as of 3rd quarter 2024. *Statista*, May 2025. Survey time period: Q3 2024.

[37] Raymond Bierens, Bram Klievink, and Jan van Den Berg. A social cyber contract theory model for understanding national cyber strategies. In *Electronic Government: 16th IFIP WG 8.5 International Conference, EGOV 2017, St. Petersburg, Russia, September 4-7, 2017, Proceedings 16*, pages 166–176. Springer, 2017.

[38] Michael Böcher. A theoretical framework for explaining the choice of instruments in environmental policy. *Forest Policy and Economics*, 16:14–22, 2012.

[39] Barry W Boehm and Philip N. Papaccio. Understanding and controlling software costs. *IEEE transactions on software engineering*, 14(10):1462–1477, 1988.

[40] Lisa Bowleg. The problem with the phrase women and minorities: intersectionality—an important theoretical framework for public health. *American journal of public health*, 102(7):1267–1273, 2012.

[41] Aaron Boyd. Opm cio seymour resigns days before oversight hearing. *Federal Times*, February 2016. Source file: Boyd - OPM CIO Seymour resigns days before Oversight hearing.pdf.

[42] Jedidiah Bracy. 21.5 million breached in second opm hack; director resigns. *IAPP*, 2015. Source file: Bracy - 21.5 Million Breached In Second OPM Hack; Director Resigns _ IAPP.pdf.

[43] Ian Brown and Christopher T Marsden. *Regulating code: Good governance and better regulation in the information age*. MIT Press, 2013.

[44] Sherrod Brown. Data Breaches in Credit Reporting Agencies. Congressional Record, September 2017. 115th Congress, 1st Session. Accessed via source file Brown - Congressional Record Equifax Data Breach 9.14.17.pdf.

[45] Nate Cardozo, Andrew Crocker, Jennifer Lynch, Kurt Opsahl, and Rainey Reitman. Who has your back? 2017: Protecting your data from government requests. Technical report, Electronic Frontier Foundation, 2017.

[46] Carly Page. Whatsapp scores historic victory against nso group. *TechCrunch*, 2024.

[47] Ann Cavoukian. Privacy by design. *Office of the Information and Privacy Commissioner*, 2009.

[48] Electronic Privacy Information Center. Equifax data breach.

[49] Center for Democracy and Technology Europe. Eu tech policy brief: July 2025, July 2025.

[50] Chamber of Commerce of the United States of America. Brief of amicus curiae the chamber of commerce of the united states of america, 2018. Source file: US Chamber Amicus Brief.pdf.

[51] Kathy Charmaz. *Constructing grounded theory*. sage, 2014.

[52] Julia S. Cheney. Identity theft: A pernicious and costly fraud. *Payment Cards Center Federal Reserve Bank of Philadelphia*, 2003.

[53] Mitchell Chris. *The Structure of International Conflict*. Macmillan, London, 1981.

[54] Catalin Cimpanu. German government warns of apt27 activity targeting local companies. *The Record*, 2022.

[55] Catalin Cimpanu. Red cross blames hack on zoho vulnerability, suspects apt attack. *The Record*, 2022.

[56] Richard Alan Clarke and Robert K Knake. *The fifth domain: Defending our country, our companies, and ourselves in the age of cyber threats*. Penguin Press, 2019.

[57] Jason A Colquitt, Donald E Conlon, Michael J Wesson, Christopher OLH Porter, and K Yee Ng. Justice at the millennium: a meta-analytic review of 25 years of organizational justice research. *Journal of applied psychology*, 86(3):425, 2001.

[58] Federal Trade Commission. Ftc enforces gramm-leach-bliley act's safeguards rule against mortgage companies.

[59] Federal Trade Commission. Ftc imposes $5 billion penalty and sweeping new privacy restrictions on facebook.

[60] Federal Trade Commission. Ftc settlements require equifax to forfeit money made by allegedly improperly selling information about millions of consumers who were late on their mortgages.

[61] Federal Trade Commission. Google will pay $22.5 million to settle ftc charges it misrepresented privacy assurances to users of apple's safari internet browser.

[62] Federal Trade Commission. What the ftc facebook settlement means for consumers.

[63] Federal Trade Commission. Disposing of consumer report information? rule tells how, 2005.

[64] Federal Trade Commission. Federal trade commission 2018 privacy and data security update, 2019.

[65] U.S. Congress. Permissible purposes of consumer reports. 15 U.S. Code § 1681b, 2012.

[66] Sam Cook. Us schools leaked 32 million records in 2,691 data breaches. *Comparitech*, April 2023.

[67] Oracle Corporation. Oracle data cloud data directory, 2021. Retrieved from Oracle service provider.

[68] Lewis A Coser. *The functions of social conflict*, volume 9. Routledge, 1998.

[69] Court of Justice of the European Union. Judgment of the court (grand chamber) of 6 october 2015. maximillian schrems v data protection commissioner, 2015. Case C-362/14.

[70] Kate Cox. Us-eu privacy shield data sharing agreement struck down by court. *Ars Technica*, July 2020. Ruling holds that US surveillance practices and EU privacy law do not mesh well.

[71] Sadie Creese, William H Dutton, Patricia Esteve-Gonzalez, and Ruth Shillair. Cybersecurity capacity-building: cross-national benefits and international divides. *Journal of Cyber Policy*, 6(2):214–235, 2021.

[72] Fabio Cristiano, Xymena Kurowska, Tim Stevens, Louise Marie Hurel, Noran Shafik Fouad, Myriam Dunn Cavelty, Dennis Broeders, Tobias Liebetrau, and James Shires. Cybersecurity and the politics of knowledge production: towards a reflexive practice. *Journal of Cyber Policy*, 8(3):331–364, 2023.

[73] Crunchbase. Illuminate education - crunchbase company profile, 2025.

[74] Mary J Culnan and Robert J Bies. Consumer privacy: Balancing economic and justice considerations. *Journal of social issues*, 59(2):323–342, 2003.

[75] Luke Cuomo, Alex Fredman, and Noah Goldstein. Regulating credit reporting agencies: Responding to the equifax crisis.

[76] Cybersecurity and Infrastructure Security Agency. Apt actors exploiting newly identified vulnerability. Online, 2022.

[77] Lynn M. Daggett. Ferpa in the twenty-first century: Failure to effectively regulate privacy for all students. *Catholic University Law Review*, 58(1):59–114, 2008.

[78] Defense Counterintelligence and Security Agency. Dcsa op-5. Technical report, Department of Defense, 2024.

[79] Defensor del Pueblo. Escrito a la secretaria de estado-directora del cni, May 2022. Conclusions regarding the ex officio investigation into the CNI's use of Pegasus.

[80] Peter DeGrace and Leslie Hulet Stahl. *Wicked problems, righteous solutions*. Yourdon Press, 1990.

[81] Rafael del Villar, Alejandro Diaz de Leon, and Johanna Gil Hubert. *Regulation of Personal Data Protection and of Credit Reporting Firms: A Comparison of Selected Countries in Latin America, the United States, and the European Union*, chapter 11, pages 397–431. MIT Press, 2003.

[82] Mina Deng, Kim Wuyts, Riccardo Scandariato, Bart Preneel, and Wouter Joosen. A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements. *Requirements Engineering*, 16(1):3–32, 2011.

[83] William H Dutton, Sadie Creese, Ruth Shillair, and Maria Bada. Cybersecurity capacity: does it matter? *Journal of Information Policy*, 9:280–306, 2019.

[84] EDRi. Pega committee does not go all the way on spyware regulation. *European Digital Rights (EDRi)*, 2023.

[85] Kathleen M Eisenhardt. Building theories from case study research. *Academy of management review*, 14(4):532–550, 1989.

[86] Electronic Frontier Foundation. Equifax Data Breach Update: Backsliding. EFF Deeplinks Blog, November 2019. Accessed via source file EFF - Equifax Data Breach Update_ Backsliding 2019.pdf.

[87] Electronic Privacy Information Center. Max schrems i amicus brief (standard contractual clauses), 2016.

[88] Electronic Privacy Information Center. Brief of amicus curiae electronic privacy information center (epic) in support of appellants, May 2018. Source file: in-re-opm-EPIC-amicus.pdf.

[89] Michael Elsen-Rooney. Nyc schools ban online gradebook following security breach. *New York Daily News*, June 2022.

[90] Equifax. Equifax business. Equifax lines of business as they displayed on the website in October 2024.

[91] Equifax. Equifax business.

[92] Equifax. Equifax data breach settlement.

[93] Equifax. What is a credit bureau?, 2022.

[94] Inc. Equifax. Comment letter response: Form 10-k for the fiscal year ended december 31, 2017. File No. 001-06605.

[95] Inc. Equifax. Form 8-k.

[96] European Parliament. European parliament recommendation of 15 june 2023 to the council and the commission following the investigation of alleged contraventions and maladministration in the application of union law in relation to the use of pegasus and equivalent surveillance spyware, June 2023. P9˙TA(2023)0244.

[97] European Parliament. Regulation (eu) 2024/1083, 2024.

[98] European Parliament. Regulation (eu) 2024/2847, 2024.

[99] European Parliament and Council of the European Union. Regulation (EU) 2016/679 of the European Parliament and of the Council.

[100] European Parliamentary Research Service. Investigation of the use of pegasus and equivalent surveillance spyware, June 2023. At a Glance Plenary - June 2023.

[101] Experian. Understand and reach your audience with consumer insights.

[102] Experian. *consumerview*^{SM}: Marketing data that connects brands with fans, 2021.

[103] Family Links Network. Code of conduct on data protection, 2015.

[104] Ronan Farrow. How democracies spy on their citizens. *The New Yorker*, April 2022.

[105] Jody Feder. The family educational rights and privacy act (ferpa): A legal overview. Technical report, Congressional Research Service, November 2013.

[106] Federal CIO Council. State of federal it report: Cybersecurity. Technical report, CIO Council, 2017. Source file: 02.05.cybersecurity.pdf.

[107] Federal Trade Commission. Equifax to Pay $575 Million as Part of Settlement with FTC, CFPB, and States Related to 2017 Data Breach. Press Release, July 2019. Accessed via source file FTC - Equifax to Pay $575 Million as Part of Settlement.pdf.

[108] Federal Trade Commission. Is your kid using education technology?, 2022.

[109] Ellis Fenske, Christopher W Brown, and Jeff Kosseff. Courting consensus: How class action lawsuits shape data privacy rights and obligations in the us. In *Proceedings of the 23rd Workshop on Privacy in the Electronic Society*, pages 172–185, 2023.

[110] Zachary Figueroa. Time to rethink cybersecurity reform: The opm data breach and the case for centralized cybersecurity infrastructure. *Catholic University Journal of Law and Technology*, 24(2):433–467, 2016. Source file: Figueroa - Time to Rethink Cybersecurity Reform.pdf.

[111] Financial Conduct Authority. Financial watchdog fines Equifax Ltd £11 million for role in one of the largest cyber security breaches in history. Press Release, October 2023.

[112] Simon Fisher, Jawed Ludin, Dekha Ibrahim Abdi, Richard Smith, Steve Williams, and Sue Williams. *Working with conflict: Skills and strategies for action*. Zed books, 2011.

[113] U.S. District Court for Northern District of Texas. Federal trade commission v. realpage, inc, 2018.

[114] Anderson Frailey. The effects of privacy regulation on the supply of stolen data. 2025.

[115] R Edward Freeman. *Strategic management: A stakeholder approach*. Cambridge university press, 2010.

[116] Brian Fung and Hamza Shaban. The ftc is investigating the equifax breach. here's why that's a big deal.: It's rare for the ftc to disclose an ongoing probe.

[117] Mark Furletti. An overview and history of credit reporting, 2002.

[118] Future of Privacy Forum. Student privacy pledge bolsters legal requirements, September 2020.

[119] Simson Garfinkel and Heather Richter Lipford. Usable security: History, themes, and challenges. *Synthesis Lectures on Information Security, Privacy, and Trust*, 5(2):1–124, 2014.

[120] Sergiu Gatlan. State hackers breach defense, energy, healthcare orgs worldwide. *BleepingComputer*, November 2021.

[121] Sergiu Gatlan. Red cross: State hackers breached our network using zoho bug. *BleepingComputer*, February 2022.

[122] Amruta Gayathri. Usis that vetted snowden under investigation overlooked snowden resume discrepancies. *International Business Times*, 2013. Source file: USIS That Vetted Snowden Under Investigation Overlooked Snowden Resume Discrepancies _ IBTimes.pdf.

[123] Gennie Gebhart and Alexis Hancock. Why we can't give you a recommendation, 2025.

[124] Robert Gellman. Fair information practices: A basic history. *Available at SSRN*, 2415020, 2017.

[125] Dan Goodin. Nso permanently barred from targeting whatsapp users. *Ars Technica*, October 2025.

[126] Emily Goodwin. Many Consumers Aren't Convinced to Pay for Identity Theft Protection. CivicScience, January 2023. Accessed via source file Goodwin - Many Consumers Aren't Convinced to Pay for Identity Theft Protection.pdf.

[127] Megan Gordon and Daniel Silver. The equifax hack, sec data breach, and issuer disclosure obligations.

[128] Cristina J. Gortázar, Nuria Lores, and María José Castaño. National intelligence authorities and surveillance in the eu: Fundamental rights safeguards and remedies - legal update (spain). Technical report, European Union Agency for Fundamental Rights (FRA), 2016.

[129] Jonathan Greig. Nyc officials call for investigation after data of 820,000 students compromised in hack. *The Record*, March 2022.

[130] Jonathan Greig. Nyc school platform outage complicating covid-19 tracing efforts. *ZDNet*, January 2022.

[131] Jonathan Greig. Red cross traces hack back to unpatched zoho vulnerability. *ZDNet*, 2022.

[132] António Guterres. Roadmap for digital cooperation. *United Nations. June*, 2020.

[133] Foad Hamidi, Kellie Poneres, Aaron Massey, and Amy Hurst. Who should have access to my pointing data? privacy tradeoffs of adaptive assistive technologies. In *Proceedings of the 20th international acm sigaccess conference on computers and accessibility*, pages 203–216, 2018.

[134] Geir K Hanssen. A longitudinal case study of an emerging software ecosystem: Implications for practice and theory. *Journal of Systems and Software*, 85(7):1455–1466, 2012.

[135] Erika Harrell. Victims of identity theft, 2016, 2019.

[136] Carol C. Harris. Information technology: Agencies need to address shortcomings in modernizing legacy systems. Technical Report GAO-20-691T, U.S. Government Accountability Office, 2020. Source file: GAO - Harris 2020.pdf.

[137] Ayako A Hasegawa, Daisuke Inoue, and Mitsuaki Akiyama. How {WEIRD} is usable privacy and security research? In *33rd USENIX Security Symposium (USENIX Security 24)*, pages 3241–3258, 2024.

[138] Jon Henley. Eu still unmoved by spain's standoff with catalan separatists. *The Guardian*, March 2018. European leaders maintain their position that independence drive is strictly a matter for Madrid.

[139] Sven Herpig and Julia Paulus. The pall mall process on cyber intrusion capabilities, 2024.

[140] Richard Hill. The internet, its governance, and the multi-stakeholder model. *Info*, 16(2):16–46, 2014.

[141] Rashina Hoda. Socio-Technical Grounded Theory for Software Engineering. *IEEE Transactions on Software Engineering*, 48(10):3808–3832, October 2022.

[142] House Committee on Oversight and Government Reform. The opm data breach: How the government jeopardized our national security for more than a generation. Technical report, U.S. House of Representatives, September 2016. Source file: The-OPM-Data-Breach-How-the-Government-Jeopardized-Our-National-Security-for-More-than-a-Generation.pdf.

[143] Jennifer Yang Hui. Social media and the 2019 indonesian elections. *Southeast Asian Affairs*, pages 155–172, 2020.

[144] Robert M. Hunt. What's in the file? the economics and law of consumer credit bureaus. *Business Review*, 2002.

[145] Identity Theft Guard Solutions, Inc. U.s. office of personnel management awards id experts identity protection services contract. *IDX Knowledge Knowledge Center*, 2019.

[146] Illuminate Education. Log in - illuminate education, 2025. Webpage.

[147] Illuminate Education. Our story, 2025. Webpage.

[148] Sophia in 't Veld. Report of the investigation of alleged contraventions and maladministration in the application of union law in relation to the use of pegasus and equivalent surveillance spyware. Technical Report A9-0189/2023, European Parliament, Committee of Inquiry to investigate the use of Pegasus and equivalent surveillance spyware, May 2023.

[149] Sophie in 't Veld. An inquiry on spyware in the eu revealed abuses by member states. *Digital Frontlines*, 2025.

[150] Information Commissioner's Office. Monetary Penalty Notice: Equifax Ltd. Data Protection Act 1998 Supervisory Powers Notice, September 2018. Accessed via source file ICO - Equifax Penalty UK (2018).pdf.

[151] Chris Inglis and Harry Krejsa. Thee cyber social contract: How to rebuild trust in a digital world. *Foreign Affairs*, 2022.

[152] International Committee of the Red Cross. Assessing restoring family links needs: Handbook for national societies and the icrc, 2010.

[153] International Committee of the Red Cross. Icrc rules on personal data protection, February 2015. Adopted by the Directorate of the ICRC on 24 February 2015, updated 10 November 2015.

[154] International Committee of the Red Cross. Symposium on cybersecurity and data protection in humanitarian action, November 2022.

[155] International Committee of the Red Cross. Towards safer digital services: The cta data breach 1 year on. Online, 2023.

[156] International Committee of the Red Cross and International Federation of Red Cross and Red Crescent Societies. Restoring family links: Strategy for the international red cross and red crescent movement 2020–2025. Technical report, ICRC and IFRC, Geneva, Switzerland, 2020.

[157] Jan Koum and Brian Acton. end-to-end encryption, April 2016.

[158] Karen A Jehn. A qualitative analysis of conflict types and dimensions in organizational groups. *Administrative science quarterly*, pages 530–557, 1997.

[159] Vincent R. Johnson. Credit monitoring damages in cybersecurity tort litigation. *George Mason Law Review*, 19, 2011.

[160] Connor Jones. Eu funds are flowing into spyware companies, and politicians are demanding answers. *The Register*, October 2025. Experts say Commission is 'fanning the flames' of the continent's own Watergate.

[161] Jurgita Lapienytė. Whatsapp data leaked: 500 million user records for sale online. *Cybernews*, 2022.

[162] Kaplan Fox & Kilsheimer LLP and Kantrowitz, Goldhamer & Graifman, P.C. Consolidated class action complaint. United States District Court, Central District of California, October 2022.

[163] Eric Katz. Government awards $133m contract to protect 21.5m victims of opm hack. *Government Executive*, September 2015. Source file: Government Awards $133M Contract to Protect 21.5M Victims of OPM Hack - Management - Government Executive.pdf.

[164] Eric Katz. Feds claims just 7% of available funds from opm breach settlement, remainder returns to treasury. *Government Executive*, January 2025. Source file: Feds claims just 7% of available funds from OPM breach settlement, remainder returns to Treasury - Pay & Benefits - Government Executive.pdf.

[165] Mark Keierleber. Ftc targets ed tech companies that 'illegally surveil children'. *The 74*, 2022.

[166] Lucas Kello. *The virtual weapon and international order*. Yale University Press, 2017.

[167] Méabh Kenny and Robert Fourie. Contrasting classic, straussian, and constructivist grounded theory: Methodological and philosophical conflicts. *The Qualitative Report*, 20(8):1270–1289, 2015.

[168] Swati Khandelwal. Hackers used whatsapp 0-day flaw to secretly install spyware on phones. *The Hacker News*, 2019.

[169] Young Mie Kim, Jordan Hsu, David Neiman, Colin Kou, Levi Bankston, Soo Yun Kim, Richard Heinrich, Robyn Baragwanath, and Garvesh Raskutti. The stealth media? groups and targets behind divisive issue campaigns on facebook. *Political Communication*, 35(4):515–541, 2018.

[170] Stephanie Kirchgaessner and Sam Jones. Phone of top catalan politician 'targeted by government-grade spyware'. *The Guardian*, July 2020.

[171] Anastasiya Kisil. Class action complaint. United States District Court, Central District of California.

[172] Robert Klonoff. Supplemental declaration of professor robert klonoff in equifax inc. customer data security breach litigation.

[173] ERIKS KLOTINS, VESELKA BOEVA, KRZYSZTOF WNUK, and MICHAEL UNTERKALMSTEINER. A collaborative method for identification and selection of data sources in market-driven requirements engineering. 2019.

[174] M Audrey Korsgaard, Sophia Soyoung Jeong, Douglas M Mahony, and Adrian H Pitariu. A multilevel view of intragroup conflict. *Journal of management*, 34(6):1222–1252, 2008.

[175] Jeff Kosseff, Chris Brown, Ellis Fenske, and Don Needham. Not easily dismissed: The growing importance of data breach litigation in cybersecurity. *Boston University Journal of Science & Technology Law*, 30:189–222, 2024.

[176] Christopher Kuner. Reality and illusion in eu data transfer regulation post schrems. *German Law Journal*, 18(4):881–918, 2017.

[177] Kristal Kuykendall. Renaissance acquires illuminate education. *THE Journal*, August 2022.

[178] Alex LaCasse. Us consortium of privacy regulators discuss enforcement priorities, collaboration. *IAPP*, October 2025.

[179] Rebecca LaFlure. How congress screwed up america's security clearance system. *Foreign Policy*, October 2013. Source file: How Congress Screwed Up America's Security Clearance System – Foreign Policy.pdf.

[180] Stefan Laube and Rainer Böhme. The economics of mandatory security breach reporting to authorities. *Journal of Cybersecurity*, 2(1):29–41, December 2016.

[181] John Lauer. *Creditworthy: A History of Consumer Surveillance and Financial Identity in America*. Columbia University Press, 2017.

[182] Stevens Le Blond, Alejandro Cuevas, Juan Ramon Troncoso-Pastoriza, Philipp Jovanovic, Bryan Ford, and Jean-Pierre Hubaux. On enforcing the digital immunity of a large humanitarian organization. In *2018 IEEE Symposium on Security and Privacy (SP)*, page 424–440, San Francisco, CA, May 2018. IEEE.

[183] Doug Levin. The state of k-12 cybersecurity: Year in review, 2022. Presentation to NPE.

[184] Igor Linkov, Daniel A. Eisenberg, Kenton Plourde, Thomas P. Seager, Julia Allen, and Alex Kott. Resilience metrics for cyber systems. *Environment Systems and Decisions*, 33(4):471–476, December 2013.

[185] Mike Litt and Ethan Lutz. Equifax Breach: One Year Later: How to Protect Yourself Against ID Theft and Hold Equifax Accountable. Report, U.S. PIRG Education Fund, September 2018. Accessed via source file US PIRG - FinalReport4Sept18_Equifax.pdf.

[186] LLR Partners. Io education. Portfolio Companies Profile.

[187] Anne L Lytle, Jeanne M Brett, and Debra L Shapiro. The strategic use of interests, rights, and power to resolve disputes. *Negotiation Journal*, 15(1):31–51, 1999.

[188] Mariusz Maciejewski, Martina Schonard, Quentin Liger, and Mirja Gutheil. Briefing for the pega committee mission to spain. Technical report, European Parliament, Policy Department for Citizens' Rights and Constitutional Affairs, March 2023.

[189] Cooper A. Maher and Brittany E. Hayes. Nonfinancial consequences of identity theft revisited: Examining the association of out-of-pocket losses with physical or emotional distress and behavioral health. *Criminal Justice and Behavior*, 51(3):459–481, March 2024.

[190] Kenny Malone and Robert Smith. Bad credit bureau. Podcast.

[191] Konstantinos Manikas. Revisiting software ecosystems research: A longitudinal literature study. *Journal of Systems and Software*, 117:84–103, 2016.

[192] Bill Marczak, John Scott-Railton, Sarah McKune, Bahr Abdul Razzak, and Ron Deibert. Hide and seek: Tracking nso group's pegasus spyware to operations in 45 countries. Technical Report 113, The Citizen Lab, Munk School of Global Affairs and Public Policy, University of Toronto, September 2018.

[193] Christopher T Marsden. Beyond europe: The internet, regulation, and multistakeholder governance—representing the consumer interest? *Journal of Consumer Policy*, 31(1):115–132, 2008.

[194] Kelly D Martin and Patrick E Murphy. The role of data privacy in marketing. *Journal of the Academy of Marketing Science*, 45:135–155, 2017.

[195] Vivian B. Martin. Using Popular and Academic Literature as Data for Formal Grounded Theory. In *The SAGE Handbook of Current Developments in Grounded Theory*, pages 222–243. Sage Publications, Ltd, Thousand Oaks, CA, 2019.

[196] Ottavio Marzocchi and Martina Mazzini. Pegasus and surveillance spyware. Technical report, European Parliament, Policy Department for Citizens' Rights and Constitutional Affairs, May 2022.

[197] John McCrank. Equifax says 15.2 million UK records exposed in cyber breach. Reuters, October 2017. Accessed via source file McCrank (Reuters) - Equifax says 15.2 million UK records exposed.pdf.

[198] Thomas K McCraw. Regulation in america. *Business History Review*, 49(2):159–183, 1975.

[199] David McGlinchey. Opm set to absorb defense security clearance agency. *Government Executive*, 2004.

[200] Gary McGraw. Software security. *IEEE Security & Privacy*, 2(2):80–83, 2004.

[201] Mark Meltzer. Equifax says data breach has cost it nearly $2 billion so far. Atlanta Business Chronicle, February 2020. Accessed via source file Equifax says data breach has cost it nearly $2 billion so far - Atlanta Business Chronicle.pdf.

[202] Anna Merod. Class action data breach lawsuit against illuminate dismissed. *K-12 Dive*, 2023.

[203] Anna Merod. Illuminate education reaches settlement with ftc over 2021 data breach. *K-12 Dive*, January 2025.

[204] Meta. Winning the fight against spyware merchant nso, 2025.

[205] Matthew B Miles, A Michael Huberman, and Johnny Saldaña. *Qualitative data analysis a methods sourcebook*. Thousand Oaks, Califorinia SAGE Publications, Inc., 2014.

[206] Jason Miller. Opm bringing protections for data breach victims to an end. *Federal News Network*, October 2025.

[207] George R Milne and Mary Ellen Gordon. Direct mail privacy-efficiency trade-offs within an implied social contract framework. *Journal of Public Policy & Marketing*, 12(2):206–215, 1993.

[208] Ronald K Mitchell, Bradley R Agle, and Donna J Wood. Toward a theory of stakeholder identification and salience: Defining the principle of who and what really counts. *Academy of management review*, 22(4):853–886, 1997.

[209] Nabil M Mohammed, Mahmood Niazi, Mohammad Alshayeb, and Sajjad Mahmood. Exploring software security approaches in software development lifecycle: A systematic mapping study. *Computer Standards & Interfaces*, 50:107–115, 2017.

[210] National Treasury Employees Union. Opm renews contract for protecting data breach victims. *NETU Blog*, 2025.

[211] Alex Nelson, Sanjay Rekhi, Murugiah Souppaya, and Karen Scarfone. Incident response recommendations and considerations for cybersecurity risk management: A csf 2.0 community profile. Technical Report NIST Special Publication (SP) 800-61r3, National Institute of Standards and Technology, Gaithersburg, MD, April 2025.

[212] NetDiligence. Netdiligence mini data breach cost calculator.

[213] New York City Department of Education. Data privacy and security policies, 2025.

[214] Joseph S Nye et al. *The regime complex for managing global cyber activities*, volume 1. Belfer Center for Science and International Affairs, John F. Kennedy School, 2014.

[215] Marie Caroline Oetzel and Sarah Spiekermann. A systematic methodology for privacy impact assessments: a design science approach. *European Journal of Information Systems*, 23(2):126–150, 2014.

[216] Office of Elizabeth Warren. Bad credit: Uncovering equifax's failure to protect americans' personal information, 2018.

[217] U.S. District Court Northern District of Georgia. Amended order granting final approval of settlement. 1:17-md-02800-TWT, 2020.

[218] U.S. House of Representatives Committee on Oversight and Government Reform. The equifax data breach.

[219] Office of the Press Secretary. Presidential policy directive. Technical report, The White House, 2013.

[220] International Committee of the Red Cross. Our mandate and mission, December 2023.

[221] International Committee of the Red Cross. Cyber attack on icrc: What we know, June 2024.

[222] International Committee of the Red Cross. Reconnecting families: Preventing separation, searching for the missin, reuniting loved ones, 2024.

[223] Office of Management and Budget. Memorandum m-16-04: Cybersecurity strategy and implementation plan (csip) for the federal civilian government. Technical report, Executive Office of the President, October 2015. Source file: OMB CSIP - GOVPUB-PREX2-PURL-gpo114663.pdf.

[224] Office of the Inspector General. Semiannual report to congress: October 1, 2015 – march 31, 2016. Technical report, U.S. Office of Personnel Management, 2016.

[225] Office of the Privacy Commissioner of Canada. PIPEDA Findings #2019-001: Investigation into Equifax Inc. and Equifax Canada Co.'s compliance with PIPEDA in light of the 2017 breach of personal information. Investigation Finding 2019-001, Office of the Privacy Commissioner of Canada, April 2019.

[226] Kieron O'hara and Wendy Hall. Four internets. *Communications of the ACM*, 63(3):28–30, 2020.

[227] Rowena Olegario. Credit reporting agencies: A historical perspective. In Margaret J. Miller, editor, *Credit Reporting Systems and the International Economy*, chapter 3, pages 115–159. MIT Press, 2003.

[228] José Javier Olivas Osuna. The pegasus spyware scandal: A critical review of citizen lab's "catalangate" report. Technical report, UNED, 2023.

[229] Parmy Olson. Whatsapp hits 600 million active users, founder says. *Forbes*, 2014.

[230] Cathy O'neil. *Weapons of math destruction: How big data increases inequality and threatens democracy*. Crown, 2017.

[231] Paul N Otto and Annie I Antón. Addressing legal requirements in requirements engineering. In *15th IEEE international requirements engineering conference (RE 2007)*, pages 5–14. IEEE, 2007.

[232] Leysia Palen and Paul Dourish. Unpacking" privacy" for a networked world. In *Proceedings of the SIGCHI conference on Human factors in computing systems*, pages 129–136, 2003.

[233] Damian Paletta. U.s. intelligence chief james clapper suggests china is suspect in cyber hack. *Wall Street Journal*, June 2015. Source file: WSJ James Clapper.pdf.

[234] C. Perez. Eu council and eu commission must urgently address issues by pega committee. *Center for Democracy and Technology*, 2024.

[235] Jennifer Pinsof. Reproductive justice and digital rights: 2022 in review. *Electronic Frontier Foundation*, 2022.

[236] E. Portnoy. Building a secure messenger. *Electronic Frontier Foundation*, 2025.

[237] Robert C. Post. Data privacy and dignitary privacy: Google spain, the right to be forgotten, and the construction of the public sphere. *Duke Law Journal*, 67:981–1072, 2018.

[238] Institute Project Management. *A Guide to the Project Management Body of Knowledge (PMBOK® Guide) – Seventh Edition and The Standard for Project Management (ENGLISH).*, volume Seventh edition of *PMBOK® Guide*. Project Management Institute, 2021.

[239] GAO Data Protection. Actions taken by equifax and federal agencies in response to the 2017 breach.

[240] Dean G Pruitt and Sung Hee Kim. *Social conflict: Escalation, stalemate, and settlement*. Mcgraw-Hill Book Company, 2004.

[241] Reuters. Spain ombudsman to probe alleged cyber spying of catalan figures. *Reuters*, April 2022.

[242] Reuters. Spain's high court shelves israeli spyware probe. *Reuters*, 2023.

[243] William N Robinson. Integrating multiple specifications using domain goals. *ACM SIGSOFT Software Engineering Notes*, 14(3):219–226, 1989.

[244] Antoaneta Roussi. Catalonia reignites its court fight with spain over spyware. *POLITICO*, August 2024.

[245] Per Runeson and Martin Höst. Guidelines for conducting and reporting case study research in software engineering. *Empirical software engineering*, 14:131–164, 2009.

[246] Andrew L Russell. *Open standards and the digital age*. Cambridge University Press, 2014.

[247] Michael L. Rustad and Thomas H. Koenig. Towards a global data privacy standard. *Florida Law Review*, 71(2):365–454, 2019.

[248] Kat Samiljan. Binding operational directives guide federal agencies through maze of cybersecurity. *Government Technology Insider*, January 2024.

[249] Spyridon Samonas and David Coss. The cia strikes back: Redefining confidentiality, integrity and availability in security. *Journal of Information System Security*, 10(3), 2014.

[250] Giovanni Sartor and Andrea Loreggia. The impact of pegasus on fundamental rights and democratic processes. Technical report, European Parliament, Policy Department for Citizens' Rights and Constitutional Affairs, January 2023.

[251] David D. Schlein and James D. Phillips. Holding credit reporting agencies accountable: How the financial crisis may be contributing to improving accuracy in credit reporting. *Loyola Consumer Law Review*, 24, 2012.

[252] Charles E. Schumer. Equifax Data Breach. Congressional Record, September 2017. 115th Congress, 1st Session. Accessed via source file Schumer - Equifax Data Breach 9.14.17.pdf.

[253] Paul Schwartz and Edward Janger. Notification of data security breaches. *Michigan Law Review*, 105(5):913–984, 2007.

[254] Tony Scott. Strengthening and enhancing cybersecurity for the 21st century. CIO.gov, 2015.

[255] John Scott-Railton, Elies Campo, Bill Marczak, Bahr Abdul Razzak, Siena Anstis, Gözde Böcü, Salvatore Solimano, and Ron Deibert. Catalangate: Extensive mercenary spyware operation against catalans using pegasus and candiru. Technical Report 155, The Citizen Lab, Munk School of Global Affairs and Public Policy, University of Toronto, April 2022.

[256] Carolyn B. Seaman, Rashina Hoda, and Robert Feldt. Qualitative Research Methods in Software Engineering: Past, Present, and Future. *IEEE Transactions on Software Engineering*, 51(3):783–788, March 2025.

[257] Jason Seawright and John Gerring. Case selection techniques in case study research: A menu of qualitative and quantitative options. *Political research quarterly*, 61(2):294–308, 2008.

[258] Elaine M Sedenberg and Deirdre K Mulligan. Public health as a model for cybersecurity information sharing. *Berkeley Tech. LJ*, 30:1687, 2015.

[259] James Shires. Enacting expertise: Ritual and risk in cybersecurity. *Politics and Governance*, 6(2):31–40, 2018.

[260] Natasha Singer. A cyberattack illuminates the shaky state of student privacy. *The New York Times*, July 2022.

[261] Diana S. Skowronski. Coppa and educational technologies: The need for additional online privacy protections for students. *Georgia State University Law Review*, 38, 2022.

[262] Benjamin Sobel. Recent decision: D.c. circuit rules that opm breach victims have standing to sue. *Lawfare*, 2023. Source file: Sobel - Recent Decision_ D.C. Circuit Rules That OPM Breach Victims Have Standing to Sue _ Lawfare.pdf.

[263] Daniel J Solove. A taxonomy of privacy. *University of Pennsylvania Law Review*, pages 477–564, 2006.

[264] Klaas-Jan Stol, Paul Ralph, and Brian Fitzgerald. Grounded theory in software engineering research: a critical review and guidelines. In *Proceedings of the 38th International conference on software engineering*, pages 120–131, 2016.

[265] Anselm Strauss and Juliet Corbin. *Basics of qualitative research*. Sage publications, 1990.

[266] Emily Tate Sullivan. Illuminate education's buying spree comes at a price, including layoffs. *EdSurge*, July 2019.

[267] Elliot Talbert-Goldstein. Integrative question for the doctoral comprehensive examination, 2022.

[268] Elliot Talbert-Goldstein, Yaxing Yao, and Carolyn Seaman. The role of the user in privacy regulation. Manuscript submitted for publication, 2026.

[269] National Telecommunications and Information Administration. Sbom at a glance. *NTIA Multistakeholder Process on Software Component Transparency*, 2021.

[270] The Apache Software Foundation. Response From The Apache Software Foundation To Questions From US House Committee On Energy And Commerce Regarding Equifax Data Breach. The Apache Software Foundation Blog, October 2017.

[271] The White House. Fact sheet: Enhancing and strengthening the federal government's cybersecurity, 2016. Source file: FACT SHEET_ Enhancing and Strengthening the Federal Government's Cybersecurity _ whitehouse.gov.pdf.

[272] ThreatConnect Research Team. Opm breach analysis: Update. Technical report, ThreatConnect, June 2015. Source file: OPM Breach Analysis_ Update _ ThreatConnect.pdf.

[273] Elizabeth J Tisdell, Sharan B Merriam, and Heather L Stuckey-Peyrot. *Qualitative research: A guide to design and implementation*. Jossey-Bass, 4th edition edition, 2016.

[274] Nicolas Tomás. Spain's cni admits spying on aragonès and on puigdemont's circle, with court approval. *El Nacional*, May 2022.

[275] Troutman Pepper Locke. Key takeaways from $5.1m settlement with education technology company. *Regulatory Oversight*, 2026.

[276] Maria Tzanou. Schrems i and schrems ii: Assessing the case for the extraterritoriality of eu fundamental rights. In Federico Fabbrini, Edoardo Celeste, and John Quinn, editors, *Data Protection Beyond Borders: Transatlantic Perspectives on Extraterritoriality and Sovereignty*. Hart Publishing, 2021.

[277] Central District of California United States District Court. Order regarding motion to dismiss (excerpt). Case No. 8:22-cv-1164.

[278] United States Senate Committee on Appropriations. Hearing on opm information technology spending and data security, June 2015. Source file: Hearing _ Hearings _ United States Senate Committee on Appropriations.pdf.

[279] William L Ury, Jeanne M Brett, and Stephen B Goldberg. Designing an effective dispute resolution system. *Negotiation Journal*, 4(4):413–431, 1988.

[280] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2013. Technical report, U.S. Office of Personnel Management, 2011.

[281] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2013. Technical report, U.S. Office of Personnel Management, 2012.

[282] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2014. Technical report, U.S. Office of Personnel Management, 2013. Source file: opm_fy_2014_cbj_final_v4__pickens___4-09-13__-_to_print_v2__1_.pdf.

[283] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2015. Technical report, U.S. Office of Personnel Management, 2014. Source file: opm_fy_2015_cbj__master__3_09_14_855pm_final.pdf.

[284] U.S. Office of Personnel Management. Fy 2013 annual performance report. Technical report, U.S. Office of Personnel Management, 2014. Source file: 2013-annual-performance-report.pdf.

[285] U.S. Office of Personnel Management. Semiannual report response: October 2014. Technical report, Merit System Accountability and Compliance, 2014. Source file: sar-response-oct-2014.pdf.

[286] U.S. Office of Personnel Management. Congressional budget justification fiscal year 2016. Technical report, U.S. Office of Personnel Management, 2015. Source file: congressional-budget-justification-fy2016.pdf.

[287] U.S. Office of Personnel Management. Fy 2014 annual performance report. Technical report, U.S. Office of Personnel Management, 2015. Source file: opm_2014_apr_v15_508.pdf.

[288] U.S. Office of Personnel Management. Semiannual report response: April 2015. Technical report, Merit System Accountability and Compliance, 2015. Source file: sar-response-april-2015.pdf.

[289] U.S. Office of Personnel Management. Semiannual report response: October 2015. Technical report, Merit System Accountability and Compliance, 2015. Source file: sar-response-oct-2014.pdf.

[290] U.S. Office of Personnel Management. Semiannual report response: April 2016. Technical report, Merit System Accountability and Compliance, 2016.

[291] U.S. Office of Personnel Management. About us, n.d. Source file: About Us - OPM.pdf.

[292] U.S. Office of Personnel Management. Mission & history, n.d. Source file: Mission & History.pdf.

[293] U.S. Senate Committee on Banking, Housing, and Urban Affairs. Consumer Data Security and the Credit Bureaus. S. Hrg. 115-132, October 2017. 115th Congress, 1st Session. Available at https://www.govinfo.gov/app/details/CHRG-115shrg28249/CHRG-115shrg28249.

[294] U.S. Senate Committee on Banking, Housing, and Urban Affairs. Examining the Fintech Landscape. S. Hrg. 115-95, September 2017. 115th Congress, 1st Session. Available at https://www.govinfo.gov/app/details/CHRG-115shrg27749/CHRG-115shrg27749.

[295] Committee on Homeland Security U.S. Senate Permanent Subcommittee on Investigations and Governmental Affairs. How equifax neglected cybersecurity and suffered a devastating data breach.

[296] USAspending.gov. Federal awards: Advanced search results for identity theft guard solutions, inc., 2025. Source file: Federal Awards _ Advanced Search _ USAspending.pdf.

[297] Axel Van Lamsweerde, Robert Darimont, and Emmanuel Letier. Managing conflicts in goal-driven requirements engineering. *IEEE transactions on Software engineering*, 24(11):908–926, 1998.

[298] Jai Vijayan. Baltimore reportedly had no data backup process for many systems, 2019.

[299] Emily A Vogels. 56% of americans support more regulation of major technology companies. *Pew Research Center*, 20, 2021.

[300] Dustin Volz and Susan Heavey. Ftc probes equifax, top democrat likens it to enron.

[301] Srdjan Vucetic. Genealogy as a research tool in international relations. *Review of International Studies*, 37(3):1295–1312, 2011.

[302] Tawei Wang, Ju-Chun Yen, and Kyunghee Yoon. Responses to sec comment letters on cybersecurity disclosures: An exploratory study. *International Journal of Accounting Information Systems*, 2022.

[303] Elizabeth Warren. S. 1816 – Freedom from Equifax Exploitation Act. U.S. Senate, September 2017. 115th Congress, 1st Session. 163 Cong. Rec. S5743. Accessed via source file Warren - 115 S. 1816 Bill Profile Report.pdf.

[304] Maxine Waters. H.R. 3755 – Comprehensive Consumer Credit Reporting Reform Act of 2017. U.S. House of Representatives, September 2017. 115th Congress, 1st Session. 163 Cong. Rec. H7382. Accessed via source file Waters - 115 H.R. 3755 Bill Profile Report.pdf.

[305] Daphne C Watkins. *Secondary data in mixed methods research*. SAGE Publications, 2022.

[306] Max Weber. Politics as a vocation. 1918. *From Max Weber: Essays in Sociology*, 1992.

[307] WhatsApp. Whatsapp video calling, November 2016. WhatsApp Blog announcement regarding the rollout of video calling across Android, iPhone, and Windows Phone devices.

[308] Andrew Whiting. Constructing cybersecurity. In *Constructing cybersecurity*, pages 126–49. Manchester University Press, 2020.

[309] Richard A Williams. Conflict propagation within large technology and software engineering programmes: A multi-partner enterprise system implementation as case study. *IEEE Access*, 7, 2019.

[310] Gregory C. Wilshusen. Cybersecurity: Actions needed to address challenges facing federal systems. Technical Report GAO-15-725T, U.S. Government Accountability Office, 2015. Source file: gao-15-725t.pdf.

[311] Gregory C. Wilshusen and Nabajyoti Barkakati. Information security: Opm has improved controls, but further efforts are needed. Technical Report GAO-17-614, U.S. Government Accountability Office, 2017. Source file: gao-17-614.pdf.

[312] William Worley. Icrc says cyberattack was 'state-like' in nature. *Devex*, February 2022.

[313] Yuxi Wu, W Keith Edwards, and Sauvik Das. "a reasonable thing to ask for": Towards a unified voice in privacy collective action. In *Proceedings of the 2022 CHI Conference on Human Factors in Computing Systems*, pages 1–17, 2022.

[314] Yahoo Finance. Equifax Inc. Stock Performance September 2017. Data Table/Chart, September 2017. Accessed via source file Equifax Inc Stocks Feb 2024 - Yahoo.pdf.

[315] Robert K Yin. *Case study methods.* American Psychological Association, 2012.

[316] Laney Zhang. A guide to chinese legal research: Who makes what?, 2014.